GHUNCHAS HEALTHCARE AI

Microsoft Purview & Defender Implementation Playbook

Document Version: 1.0
Classification: Public / Client-Facing
Author: Ghunchas Healthcare AI Security Engineering Team

1. Executive Summary

In the era of generative AI and cloud-scale data, protecting sensitive healthcare information (PHI) is no longer just a compliance checkbox—it is a foundational business requirement. Organizations face a dual threat: the rapid adoption of AI tools (like Microsoft 365 Copilot) which can accelerate data exposure, and the increasingly strict evidentiary requirements of HIPAA and HITRUST auditors.

At Ghunchas Healthcare AI, we do not rely on theoretical frameworks or manual spreadsheets. As a Microsoft AI Cloud Partner, we deploy the native Microsoft Security ecosystem to automate discovery, enforce zero-trust access, and generate defensible audit evidence.

This Playbook outlines the exact, hands-on methodology Ghunchas uses to architect, configure, and validate Microsoft Purview and Defender for our clients. It is a reflection of the controls we have built and tested in our own live lab environment, proving that our solutions are not just designed—they are operational.

2. The Ghunchas Implementation Philosophy

Our methodology follows the Microsoft Security Development Lifecycle (SDL) adapted for data security. We follow a strict, six-phase deployment model:

1. **Assess & Discover:** Identify where sensitive data lives.
2. **Classify & Label:** Apply automated sensitivity controls.
3. **Protect:** Enforce Data Loss Prevention (DLP) across email, devices, and AI.
4. **Govern:** Establish retention, audit, and eDiscovery frameworks.
5. **Secure AI:** Implement DSPM for AI to monitor and control Copilot interactions.
6. **Transfer Knowledge:** Train the client's team to maintain a defensible posture.

3. How to Read This Playbook

This document is structured as a technical configuration guide and an operational proof-of-concept. For every phase of the deployment, Ghunchas provides:

- **The Business Value:** Why this specific control matters for HIPAA/HITRUST.
- **The Microsoft Tool:** The exact Purview or Defender solution used.
- **The Ghunchas Lab Proof:** Screenshots and real-world evidence from our testing environment, demonstrating that the configuration works exactly as intended.
- **The Configuration Standard:** The step-by-step logic our engineers follow to deploy the control securely.

PHASE 1: DATA MAP & UNIFIED CATALOG

Objective: Establish the foundation of data governance by mapping the Ghunchas healthcare estate (Azure, Fabric, and Odoo) into logical business domains, assigning data ownership, and enabling automated scanning.

1.1 The Business Value (Why We Do This)

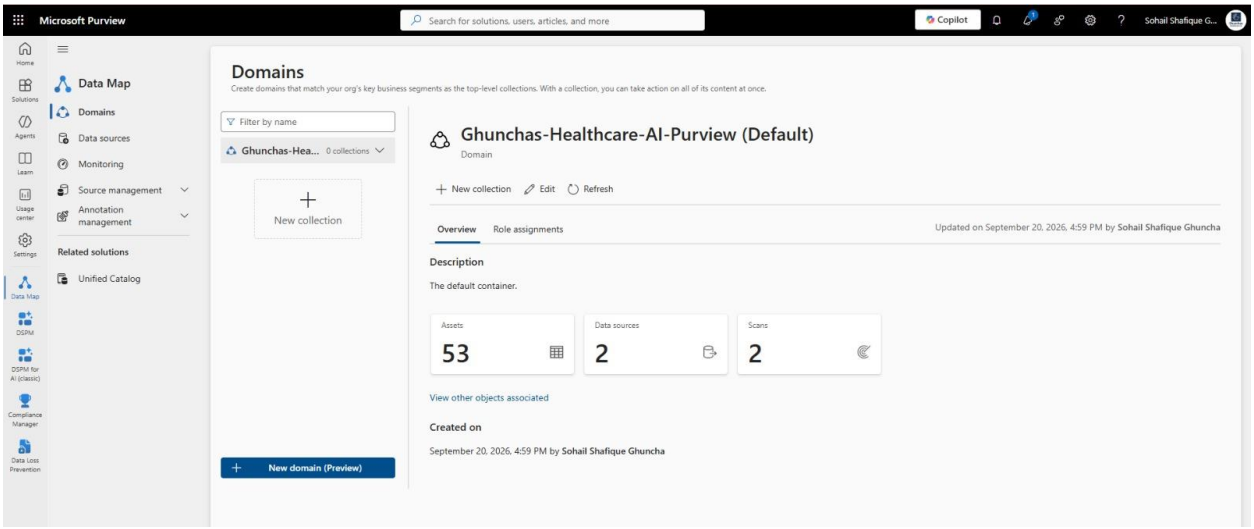
You cannot protect what you cannot see. Before applying DLP or Sensitivity Labels, Ghunchas engineers build a centralized Data Map. For healthcare clients, this means moving away from scattered, unclassified databases and creating a single source of truth that maps exactly where PHI and clinical AI data live, who owns it, and how it flows.

1.2 The Ghunchas Configuration Standard

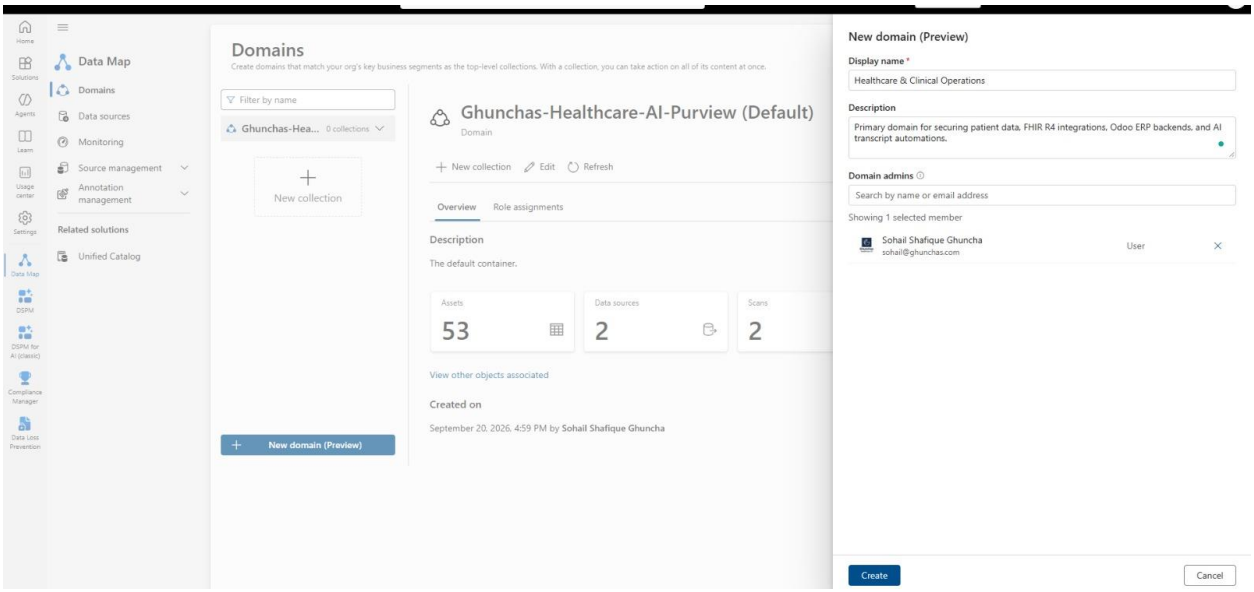
We structure the Data Map using **Business Domains** and **Collections**, ensuring that technical assets align with the client's organizational structure.

Step 1: Domain Architecture
We create top-level Domains based on the client's business operations. For Ghunchas, we established the *Healthcare & Clinical Operations* domain, which acts as the primary container for securing patient data, FHIR R4 integrations, and AI transcriptions.

- 📸 **Screenshot Placement 1:** Use the image showing the Domain overview with the description *"Primary domain for securing patient data, FHIR R4 integrations, Odoo ERP backends..."* (Image 8).



- 📸 **Screenshot Placement 2:** Use the image showing the right-hand panel creating the *"Healthcare & Clinical Operations"* domain and assigning Domain Admins (Image 9).

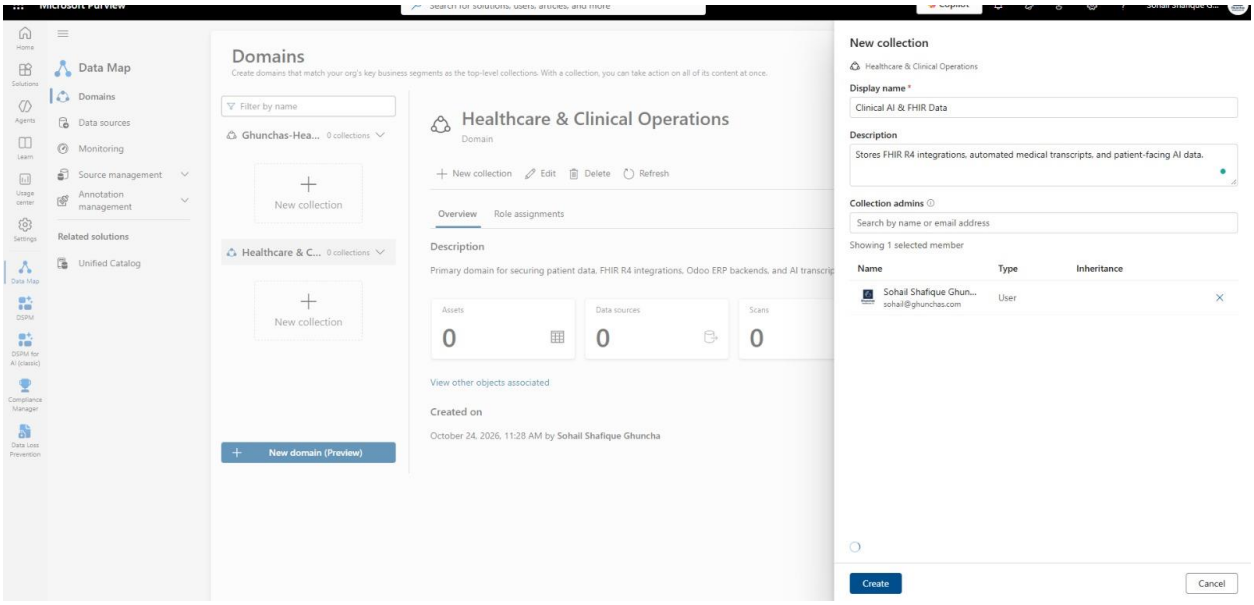


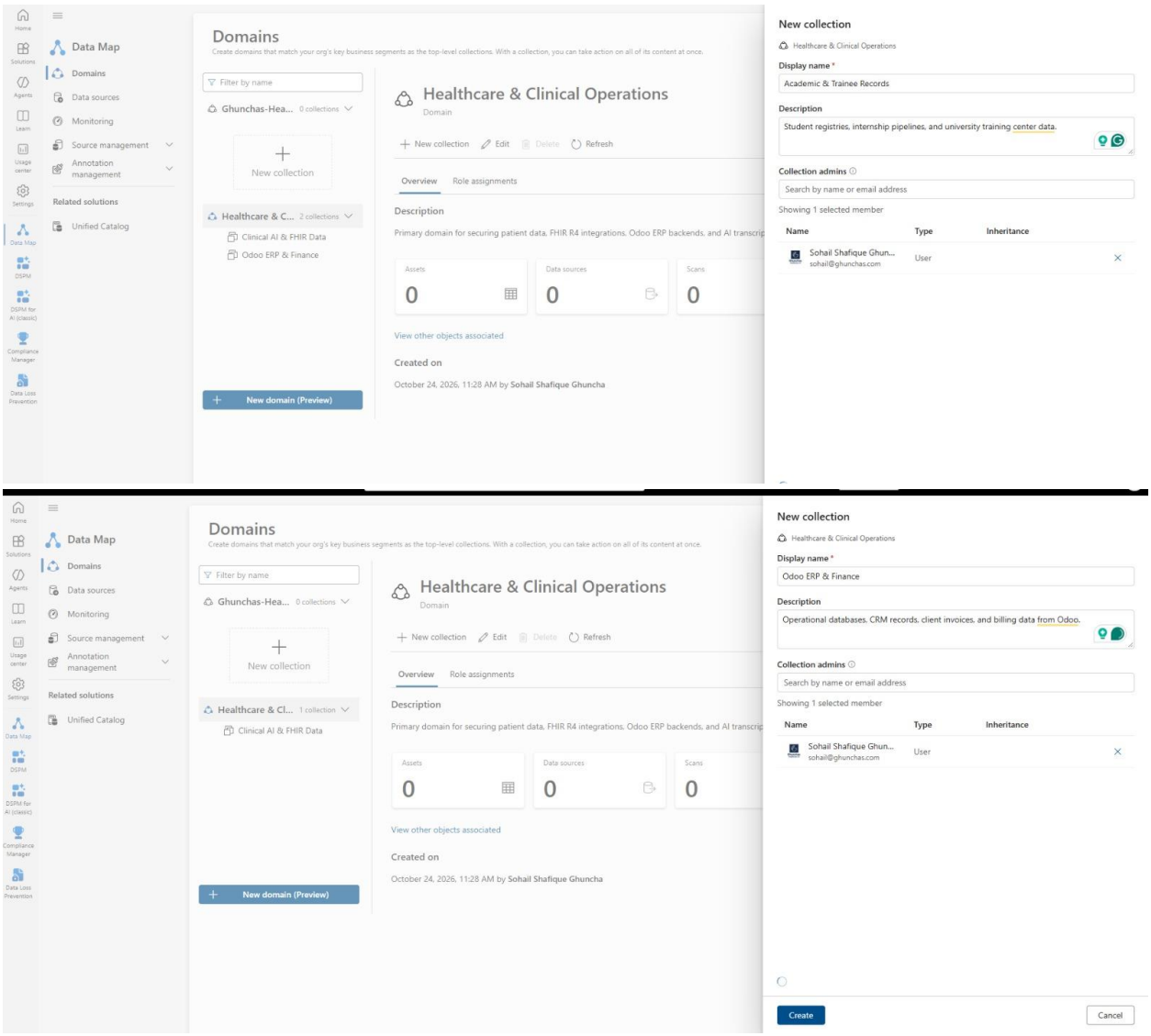
Step 2: Creating Collections (Sub-Domains)

Within the main Domain, we create distinct Collections to segment data types. This is critical for HITRUST compliance, as it allows us to apply different access controls to clinical data versus financial data.

We create specific collections for:

- **Clinical AI & FHIR Data:** For automated medical transcripts and patient-facing AI.
- **Odoo ERP & Finance:** For operational databases, CRM records, and billing data.
- **Academic & Trainee Records:** For internship pipelines and university training data.

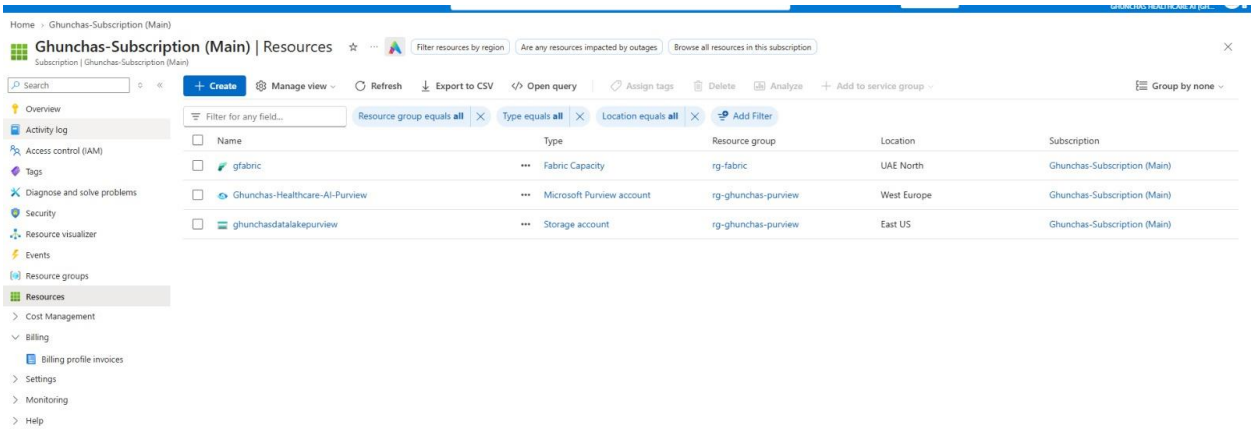




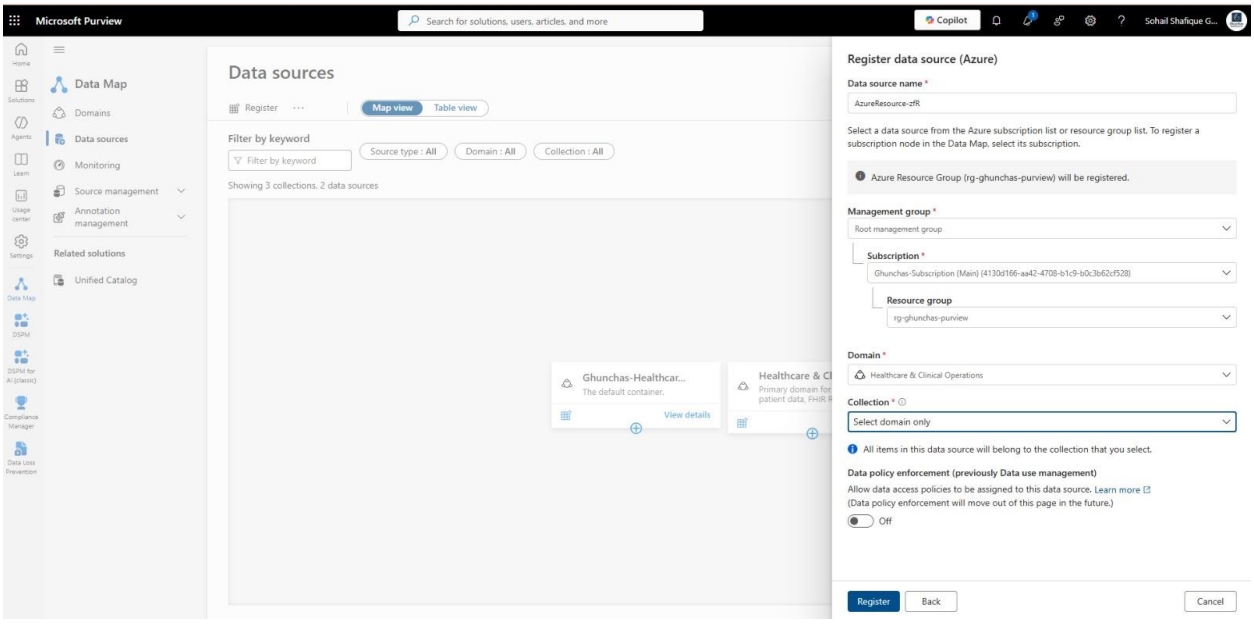
Step 3: Registering Data Sources (Azure & Fabric)

We connect the Microsoft Purview account directly to the client's Azure subscriptions and Microsoft Fabric workspaces. We map the specific Resource Groups (e.g., `rg-ghunchas-purview`) so the scanner knows exactly where to look.

- 📸 **Screenshot Placement 4:** Use the Azure portal screenshot showing the Purview resource and the Fabric capacity (Image 10).



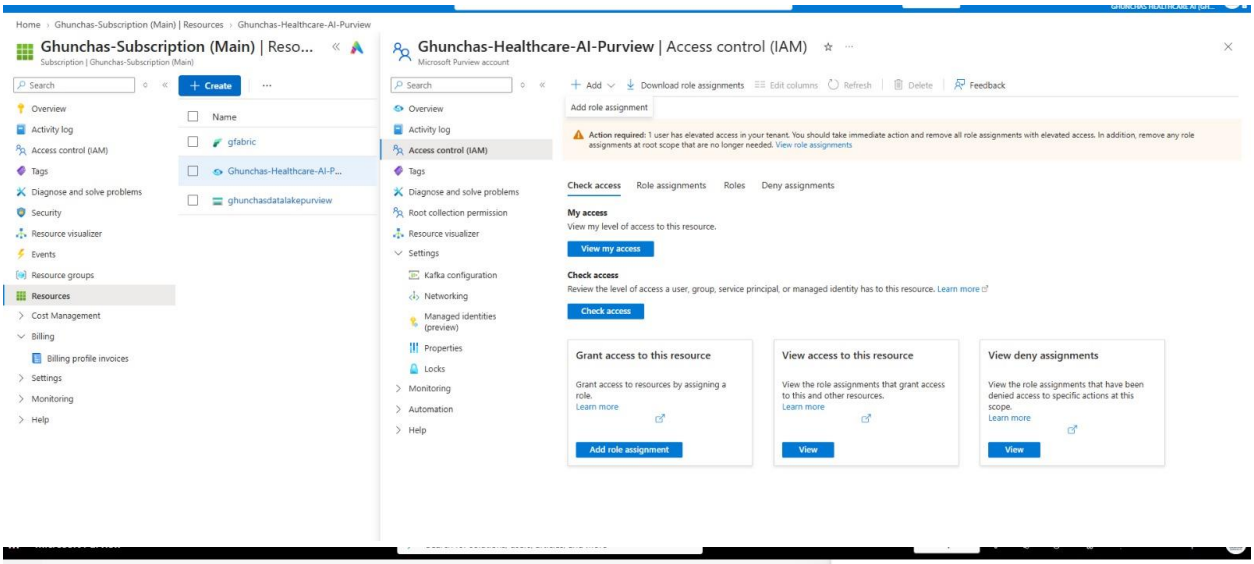
- 📸 **Screenshot Placement 5:** Use the Purview Data Map screen where we are registering the *"AzureResource-zfR"* data source and mapping it to the Resource Group (Image 6).

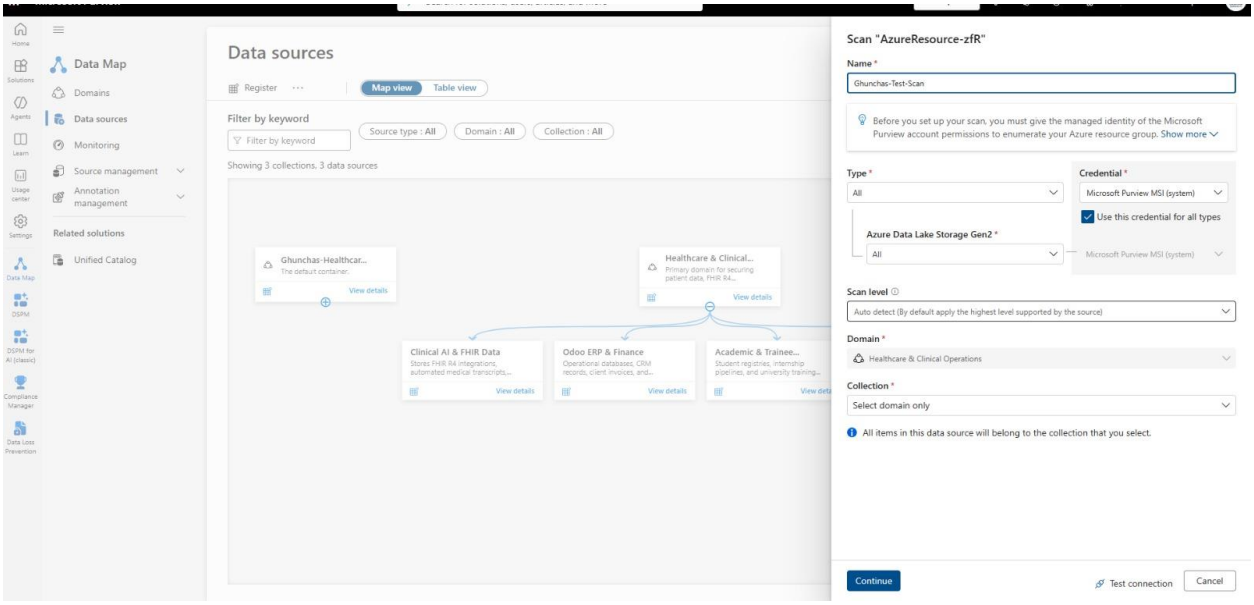


Step 4: Configuring the Automated Scan

We do not rely on manual tagging. We configure the Microsoft Purview Managed Identity (MSI) to automatically scan the Azure Data Lake Storage Gen2 and Fabric environments. The scan level is set to "Auto detect" to ensure we capture all metadata and schema data without disrupting performance.

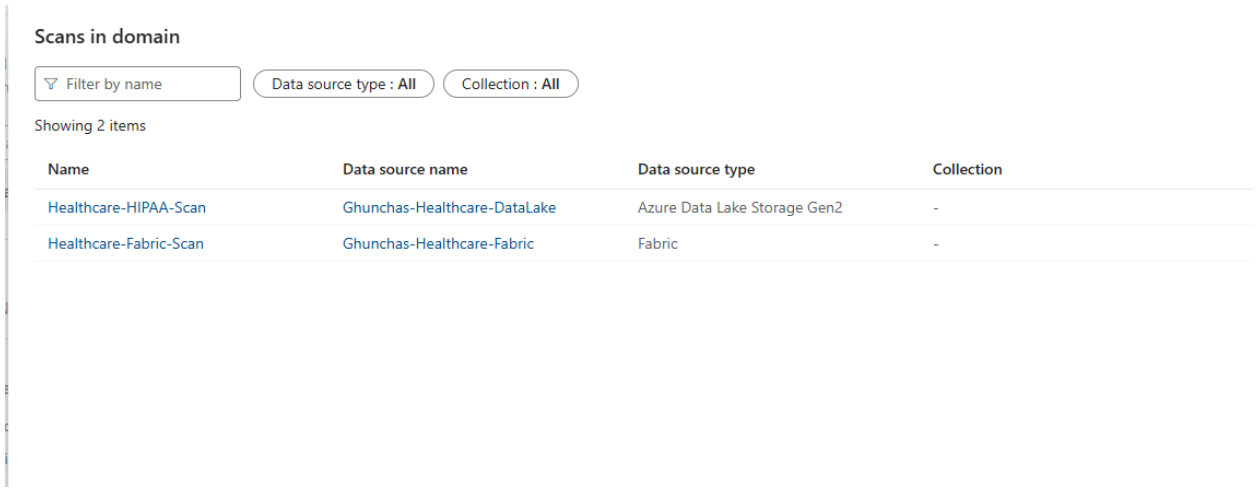
- 📸 **Screenshot Placement 6:** Use the image showing the Scan configuration panel with the MSI credential and "Auto detect" scan level (Image 3 or Image 7).





Step 5: The Result – The Visual Data Map

Once the scan completes, the Data Map renders a visual representation of the client's entire data estate. This becomes the "boardroom slide" we show to the CEO.



PHASE 2: UNIFIED CATALOG & BUSINESS GLOSSARY

Objective: Translate the technical assets found in the Data Map into business language. This ensures that auditors, data scientists, and clinicians all speak the same language (e.g., defining exactly what "PHI" or "Inpatient" means).

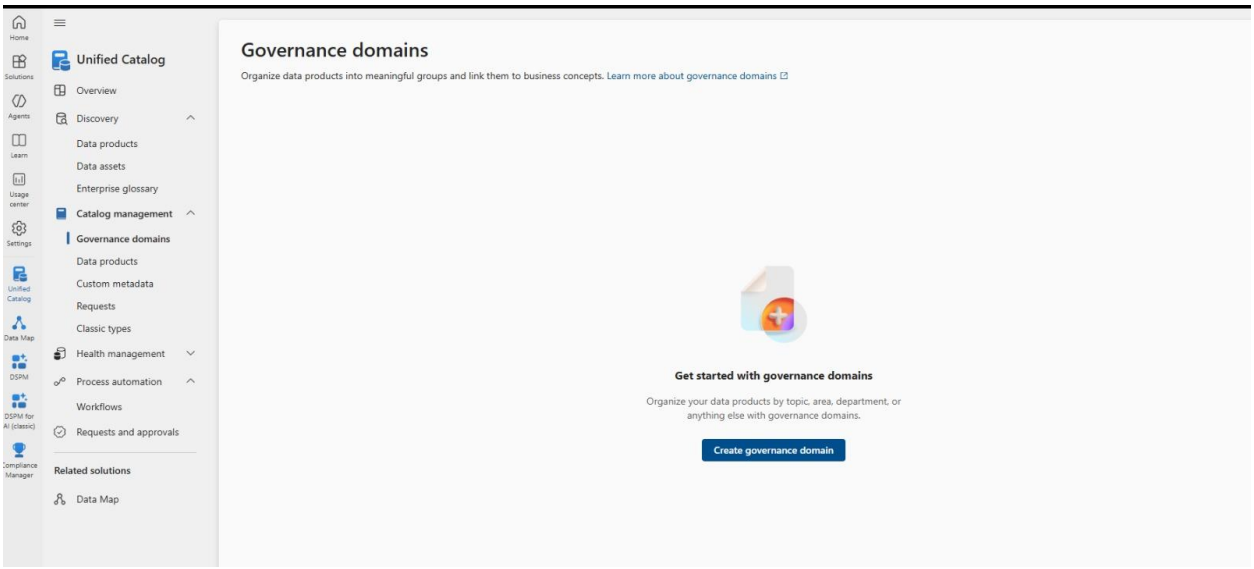
2.1 The Business Value (Why We Do This)

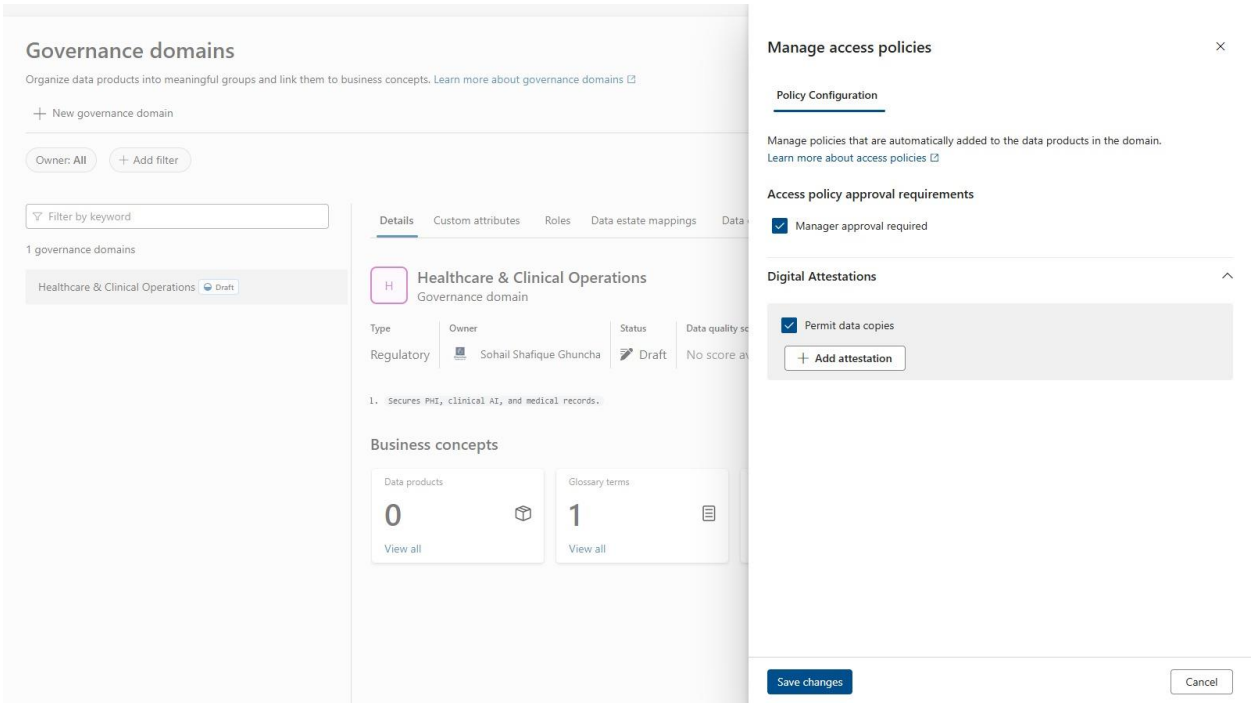
In healthcare, data silos create risk. If the billing team defines "Patient" differently than the clinical team, HITRUST audits and AI training models will fail. Ghunchas establishes a **Unified Catalog** where every critical data element (CDE) is linked to a business glossary term, assigned to an owner, and tracked against measurable Objectives and Key Results (OKRs).

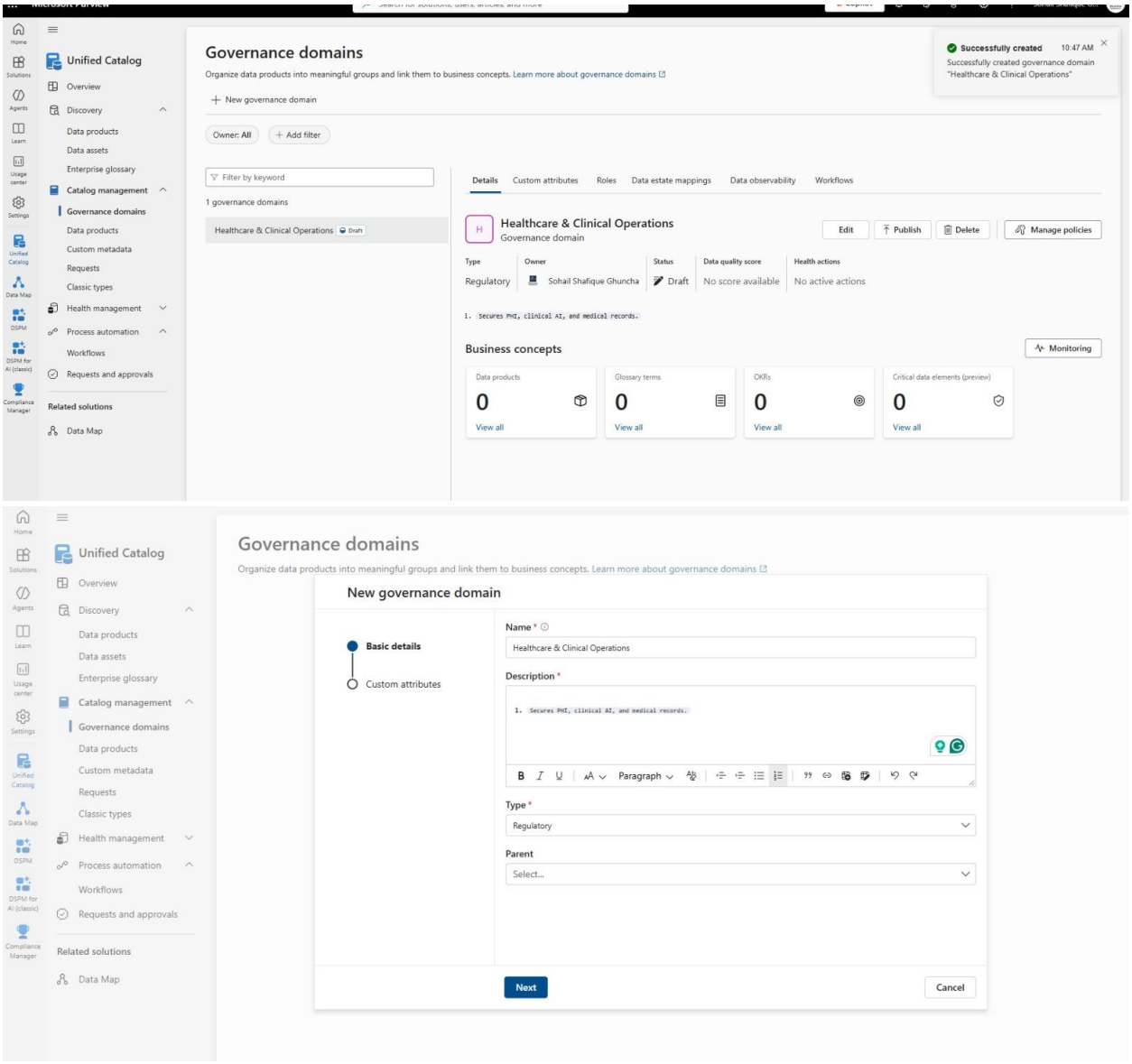
2.2 The Ghunchas Configuration Standard

Step 1: Establishing Governance Domains
We create specific Governance Domains in the Unified Catalog to map to the client's organizational structure.

- 📸 **Screenshot:** `Governance domain overview` (or `new governance domain created`)


Unified Catalog
Overview
Discovery
Data products
Data assets
Enterprise glossary
Catalog management
Governance domains
Data products
Custom metadata
Requests
Classic types
Health management
Process automation
Workflows
Requests and approvals
Related solutions
Data Map
Governance domains
Organize data products into meaningful groups and link them to business concepts. Learn more about governance domains
Get started with governance domains
Organize your data products by topic, area, department, or anything else with governance domains.
Create governance domain


Governance domains
Organize data products into meaningful groups and link them to business concepts. Learn more about governance domains
New governance domain
Owner: All
Add filter
Filter by keyword
1 governance domains
Healthcare & Clinical Operations Draft
Details
Custom attributes
Roles
Data estate mappings
Healthcare & Clinical Operations
Governance domain
Type
Regulatory
Owner
Sohail Shafique Ghuncha
Status
Draft
1. Secures PHI, clinical AI, and medical records.
Business concepts
Data products
0
View all
Glossary terms
1
View all
Manage access policies
Policy Configuration
Manage policies that are automatically added to the data products in the domain.
Learn more about access policies
Access policy approval requirements
Manager approval required
Digital Attestations
Permit data copies
Add attestation
Save changes
Cancel

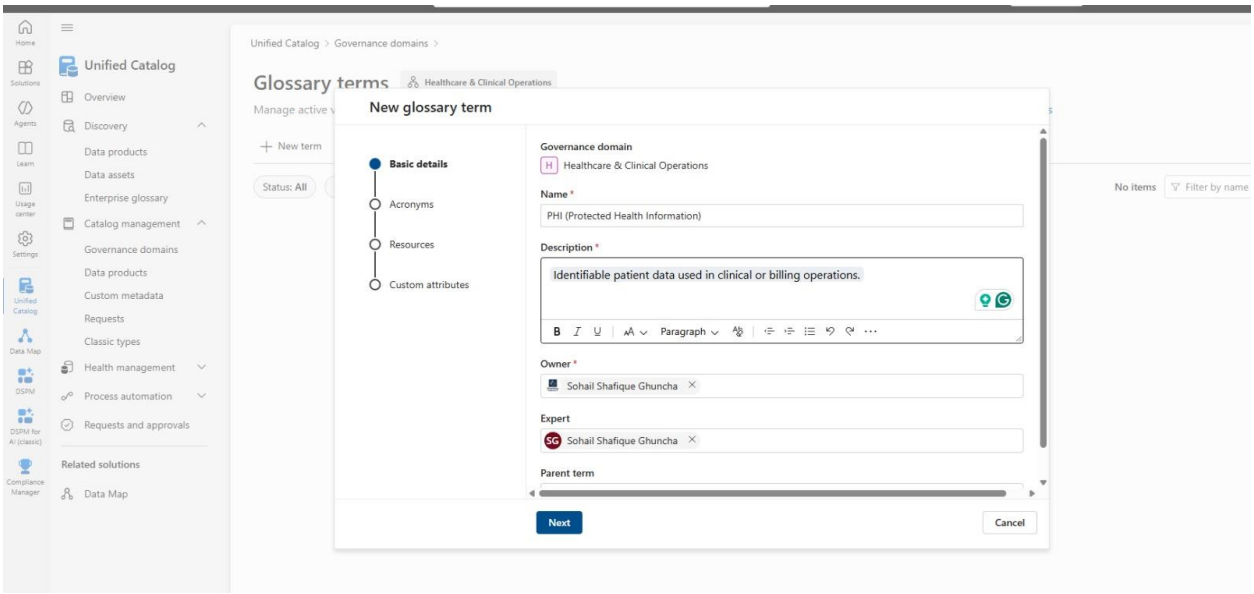


- *Caption:* "Figure 2.1: Creating the 'Healthcare & Clinical Operations' governance domain, assigning ownership and aligning it to Regulatory compliance."

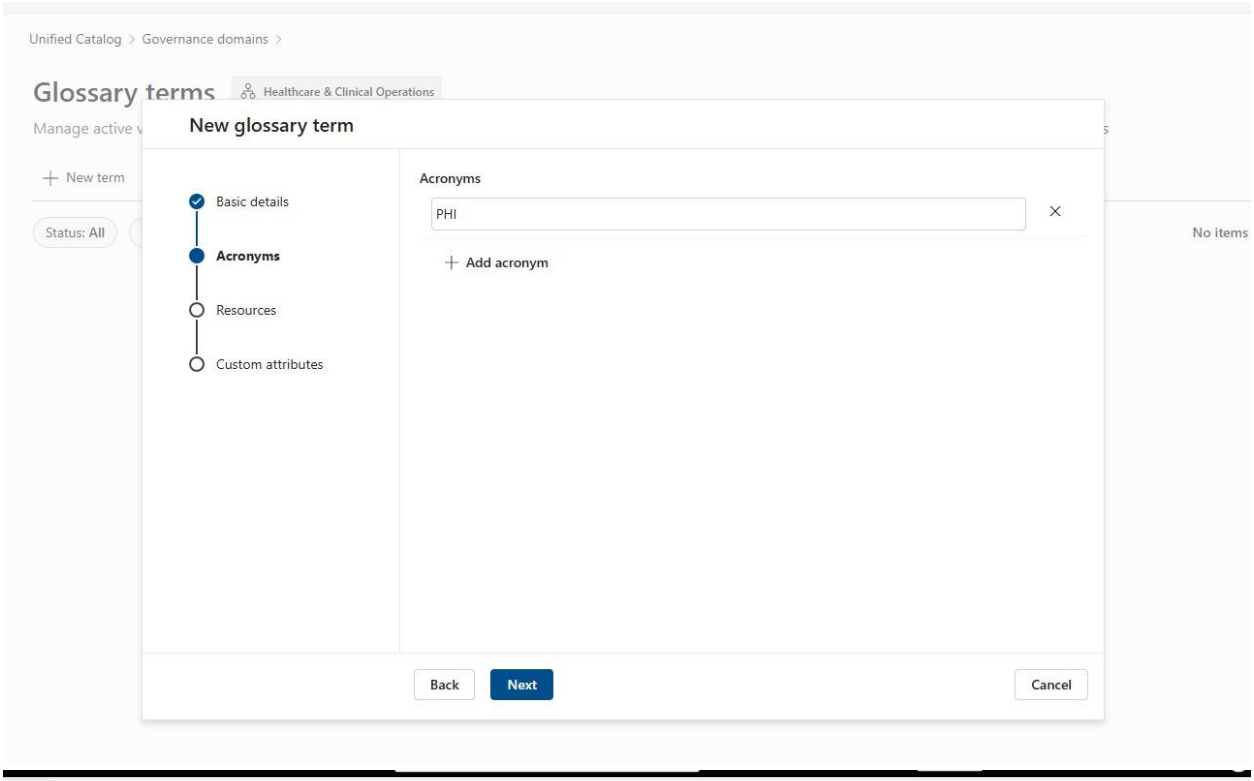
Step 2: Building the Business Glossary

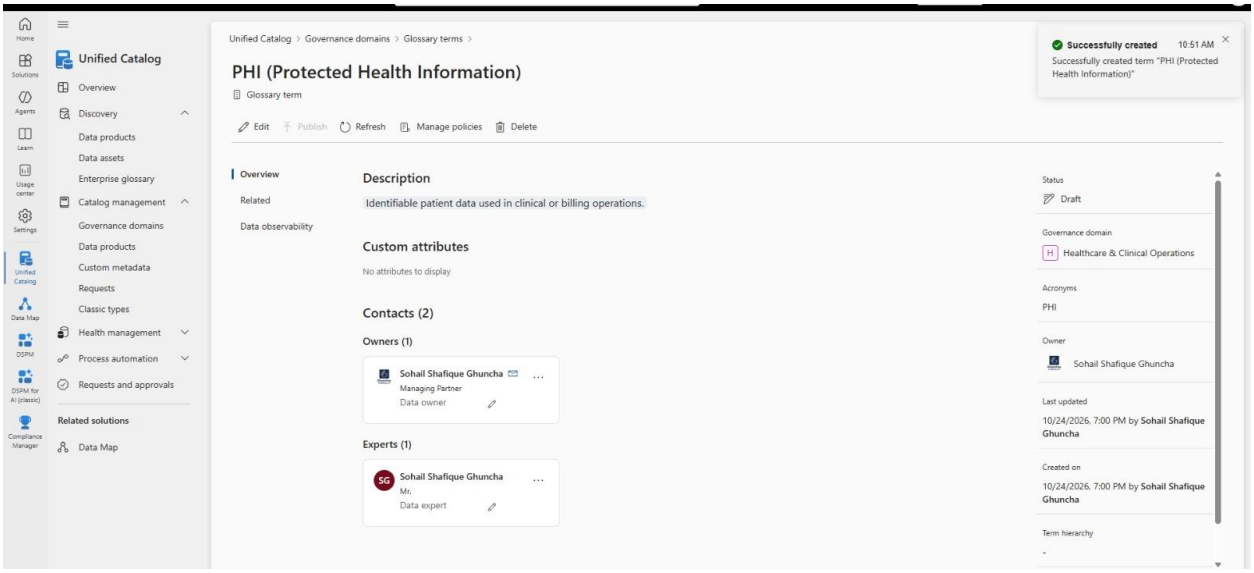
We define the exact business terms used by the organization. This prevents ambiguity. We create hierarchical terms (e.g., a "Patient" can be an "Inpatient" or an "Outpatient").

- 📸 **Screenshot:** `new glossary term created` (or `new glossary term`)

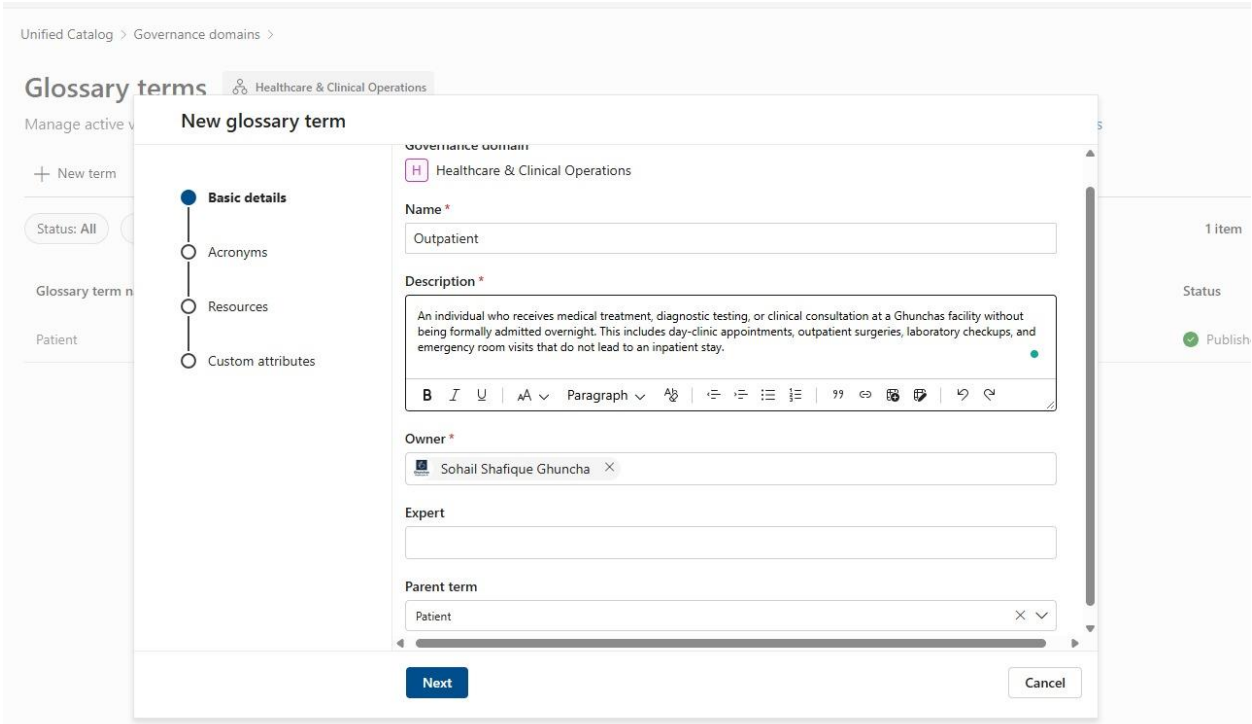


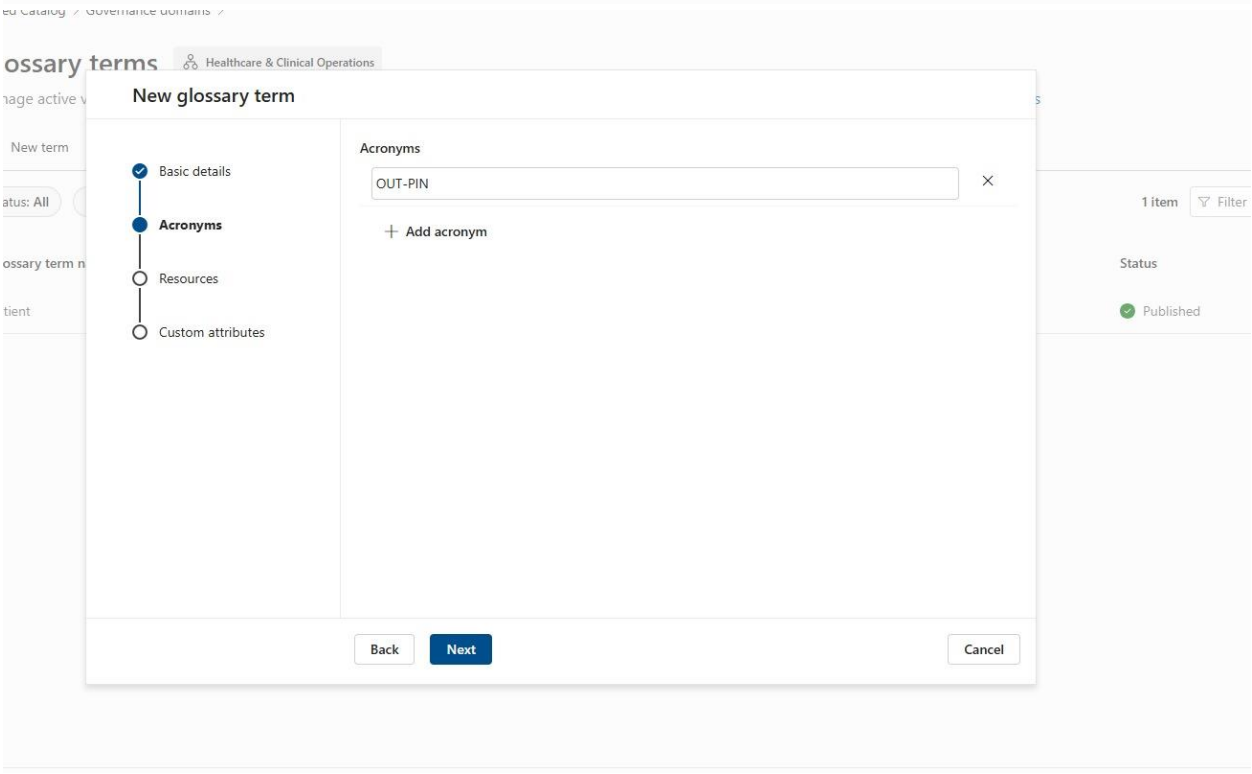
- *Caption:* "Figure 2.2: Defining core clinical terms within the Enterprise Glossary."

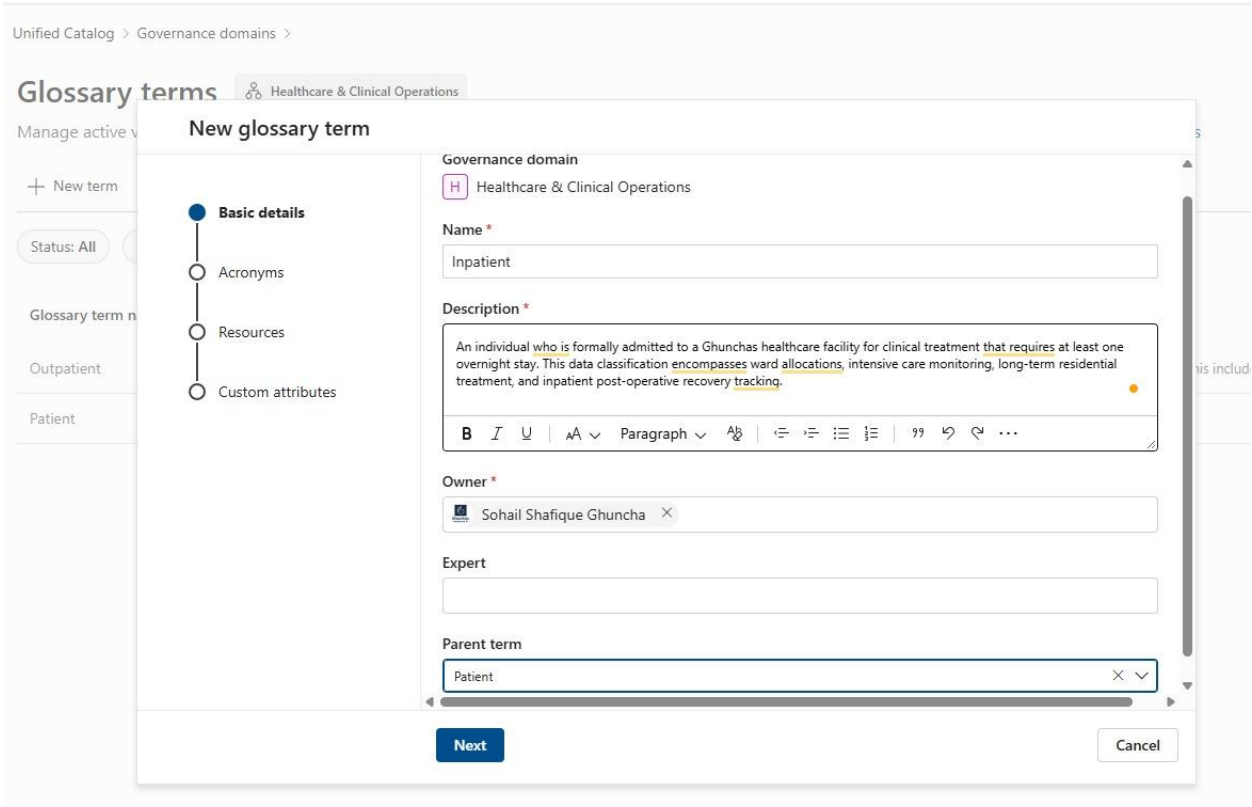


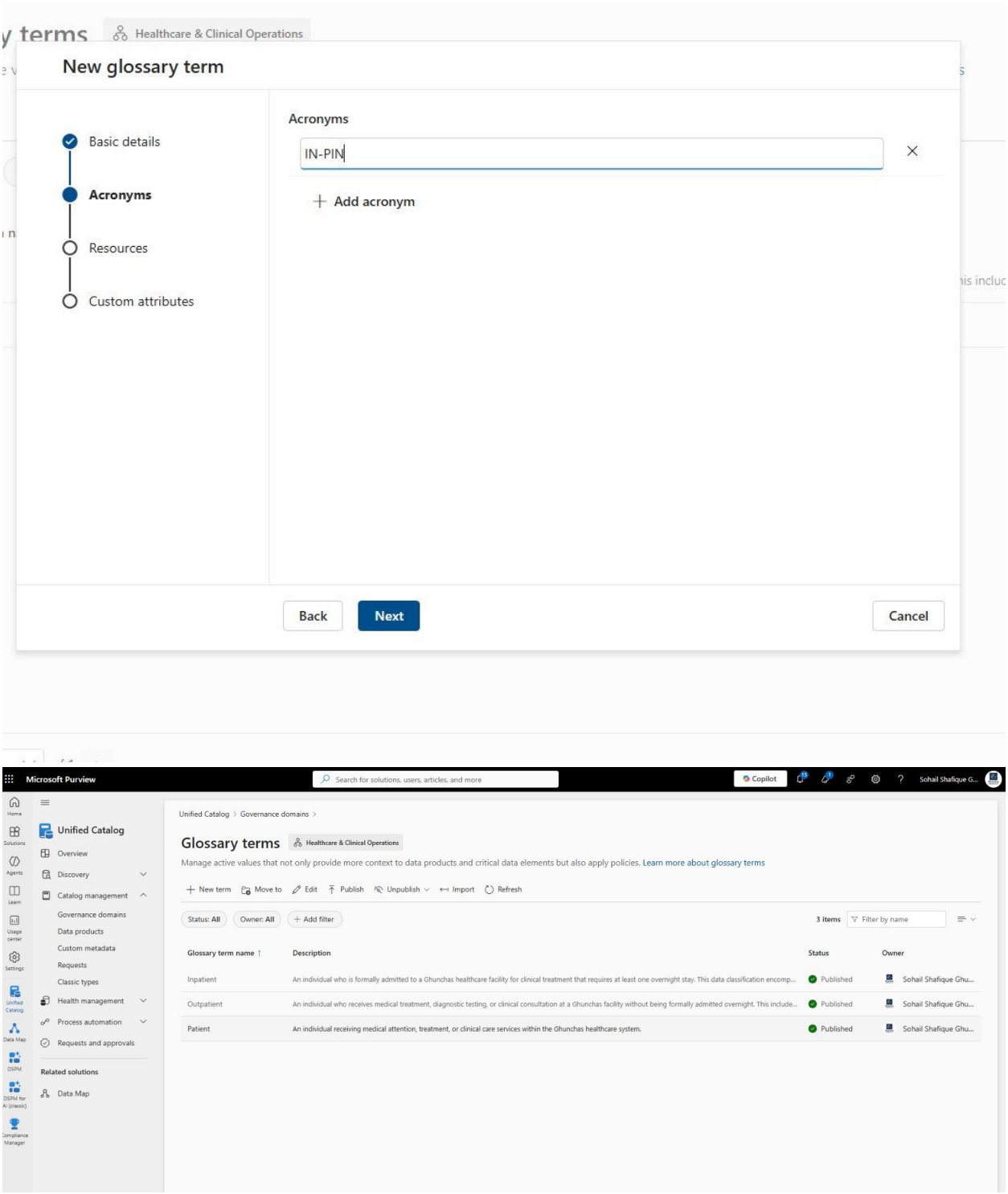


- 📸 **Screenshot:** `new glossary term acronym`


Unified Catalog > Governance domains >
Glossary terms
Healthcare & Clinical Operations
Manage active v
New term
Status: All
1 item
Glossary term n
Status
Patient
Publish
New glossary term
Basic details
Acronyms
Resources
Custom attributes
Governance domain
Healthcare & Clinical Operations
Name *
Outpatient
Description *
An individual who receives medical treatment, diagnostic testing, or clinical consultation at a Ghunchas facility without being formally admitted overnight. This includes day-clinic appointments, outpatient surgeries, laboratory checkups, and emergency room visits that do not lead to an inpatient stay.
Paragraph
Owner *
Sohail Shafique Ghuncha
Expert
Parent term
Patient
Next
Cancel


ossary terms
Healthcare & Clinical Operations
New term
1 item
Filter
Status
Published
New glossary term
Basic details
Acronyms
Resources
Custom attributes
Acronyms
OUT-PIN
Add acronym
Back
Next
Cancel

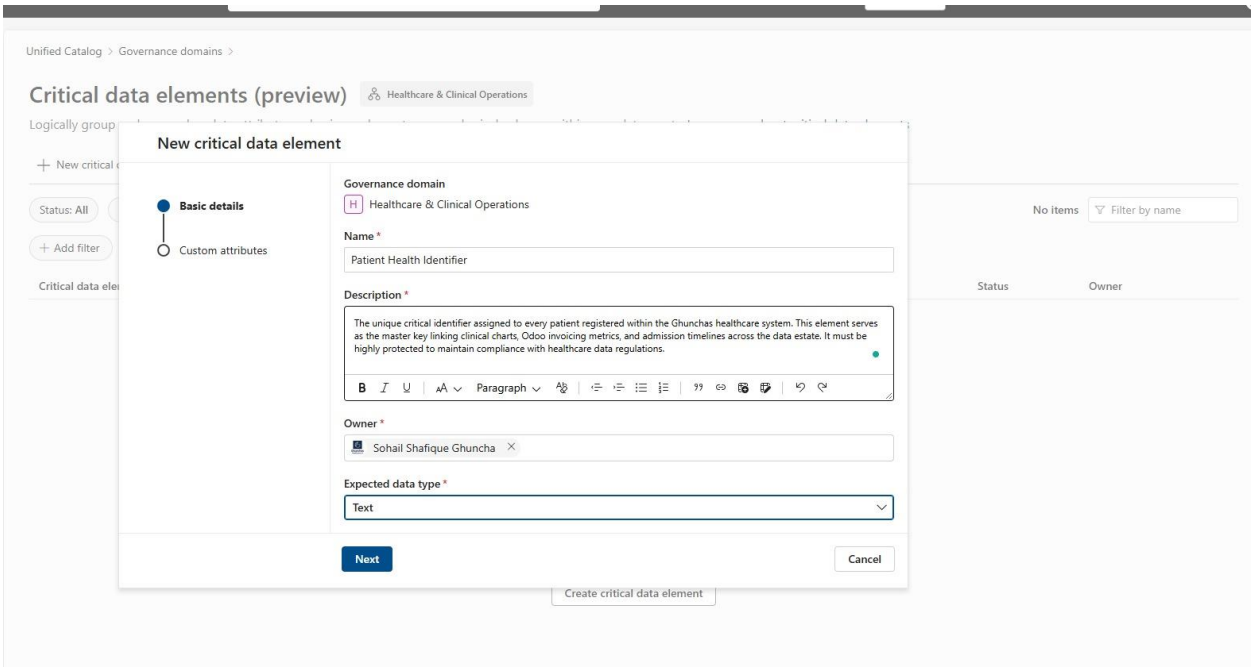

Unified Catalog
Governance domains
Glossary terms
Healthcare & Clinical Operations
Manage active v
New term
Status: All
Glossary term n
Outpatient
Patient
New glossary term
Basic details
Acronyms
Resources
Custom attributes
Governance domain
Healthcare & Clinical Operations
Name *
Inpatient
Description *
An individual who is formally admitted to a Ghunchas healthcare facility for clinical treatment that requires at least one overnight stay. This data classification encompasses ward allocations, intensive care monitoring, long-term residential treatment, and inpatient post-operative recovery tracking.
Paragraph
Owner *
Sohail Shafique Ghuncha
Expert
Parent term
Patient
Next
Cancel

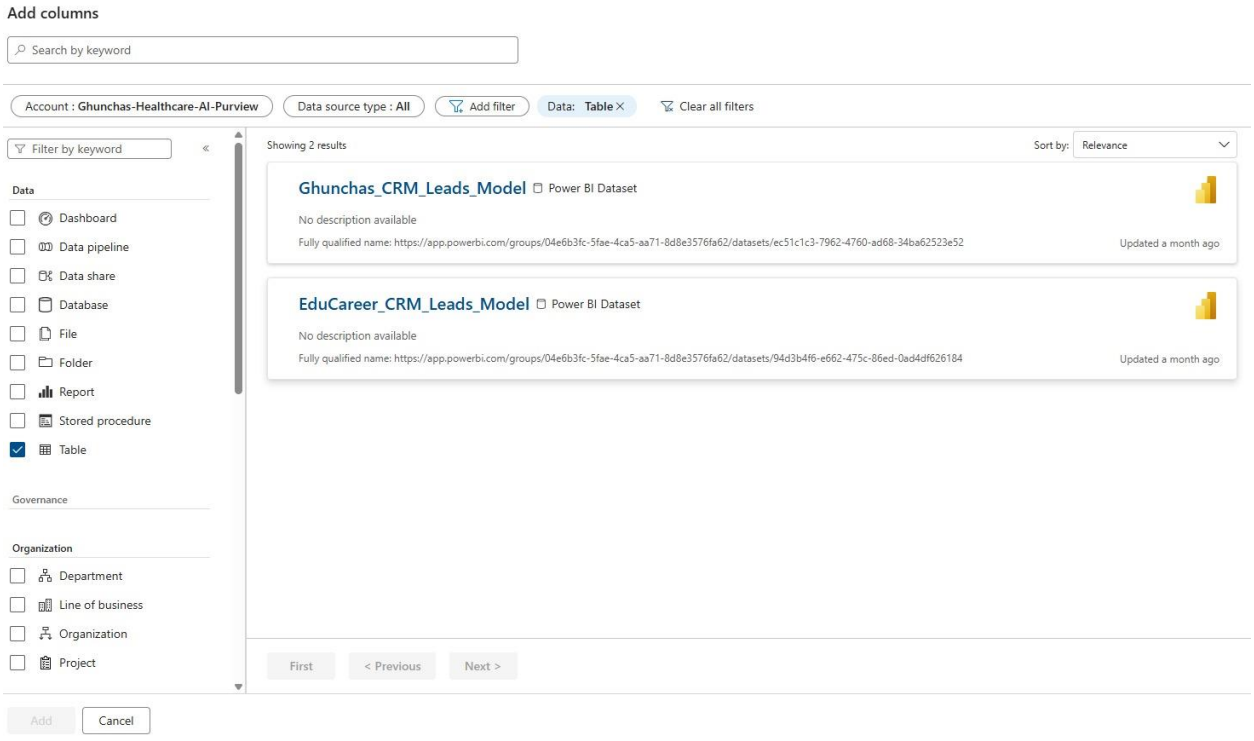


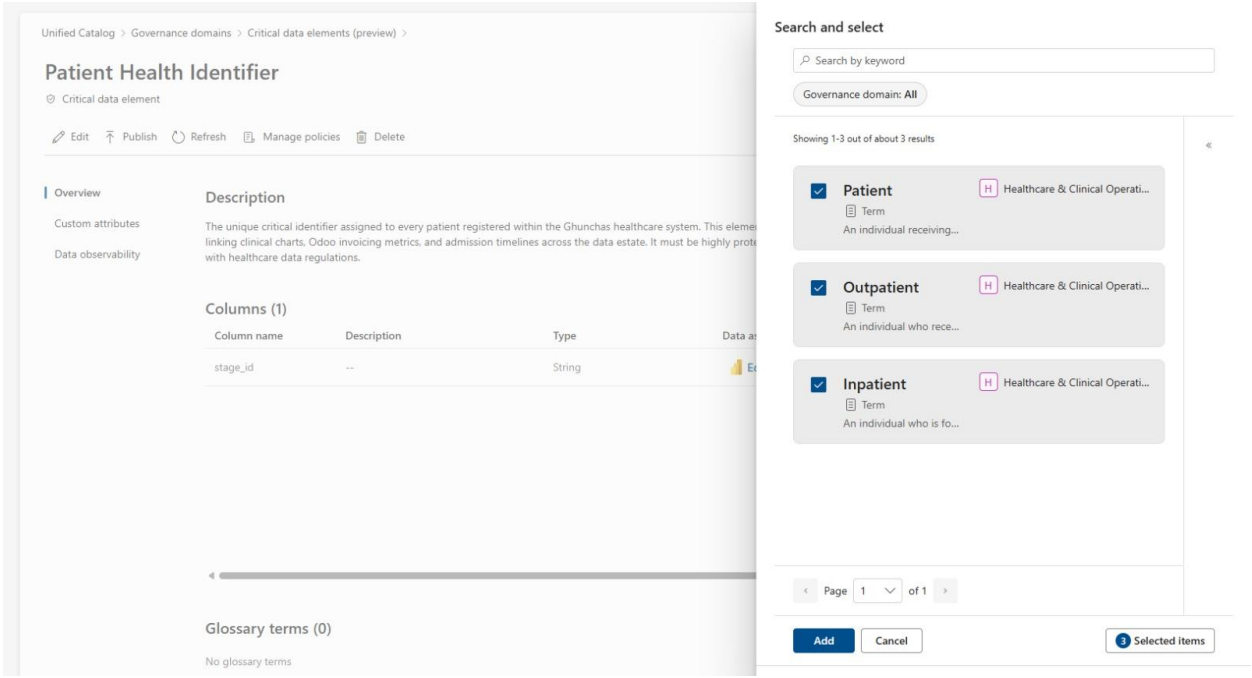
- *Caption:* "Figure 2.3: Mapping standard healthcare acronyms (e.g., IN-PIN, OUT-PIN) to their parent glossary terms."

Step 3: Defining Critical Data Elements (CDEs)
We identify the most sensitive identifiers (like the Patient Health Identifier) and link them to the business glossary.

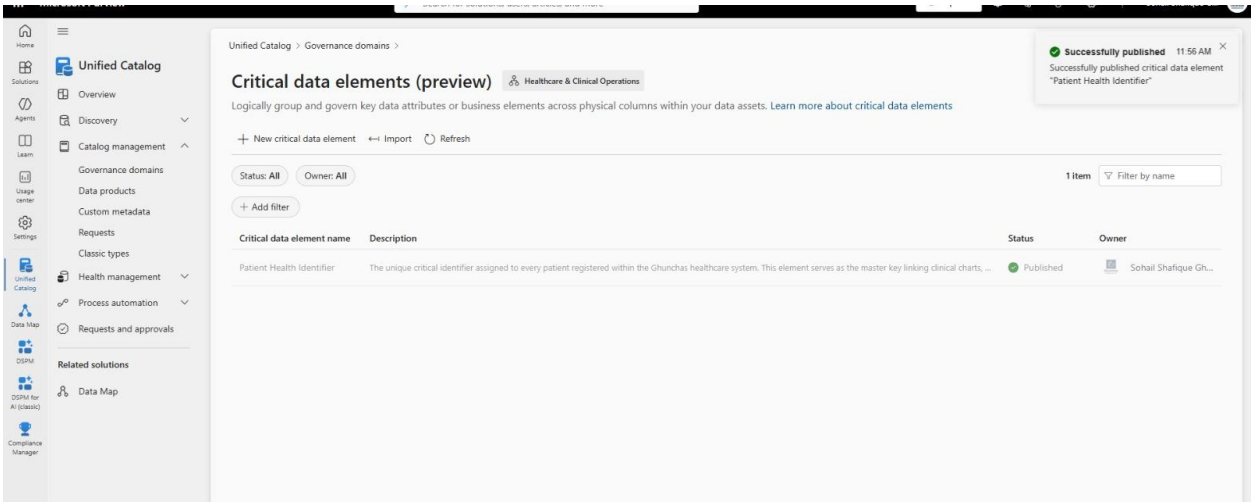
- 📸 **Screenshot:** `Adding a critical data element - adding column 1`


Unified Catalog > Governance domains >
Critical data elements (preview)
Healthcare & Clinical Operations
New critical data element
Basic details
Custom attributes
Governance domain
Healthcare & Clinical Operations
Name *
Patient Health Identifier
Description *
The unique critical identifier assigned to every patient registered within the Ghunchas healthcare system. This element serves as the master key linking clinical charts, Odoo invoicing metrics, and admission timelines across the data estate. It must be highly protected to maintain compliance with healthcare data regulations.
Paragraph
Owner *
Sohail Shafique Ghuncha
Expected data type *
Text
Next
Cancel
Create critical data element


Add columns
Search by keyword
Account : Ghunchas-Healthcare-AI-Purview
Data source type : All
Add filter
Data: Table
Clear all filters
Filter by keyword
Data
Dashboard
Data pipeline
Data share
Database
File
Folder
Report
Stored procedure
Table
Governance
Organization
Department
Line of business
Organization
Project
Showing 2 results
Sort by: Relevance
Ghunchas_CRM_Leads_Model
Power BI Dataset
No description available
Fully qualified name: https://app.powerbi.com/groups/04e6b3fc-5fae-4ca5-aa71-8d8e3576fa62/datasets/ec51c1c3-7962-4760-ad68-34ba62523e52
Updated a month ago
EduCareer_CRM_Leads_Model
Power BI Dataset
No description available
Fully qualified name: https://app.powerbi.com/groups/04e6b3fc-5fae-4ca5-aa71-8d8e3576fa62/datasets/94d3b4f6-e662-475c-86ed-0ad4df626184
Updated a month ago
First
< Previous
Next >
Add
Cancel



- *Caption:* "Figure 2.4: Defining a Critical Data Element (CDE) and linking the technical database column to the business glossary."
- 📸 **Screenshot:** `critical data element added`

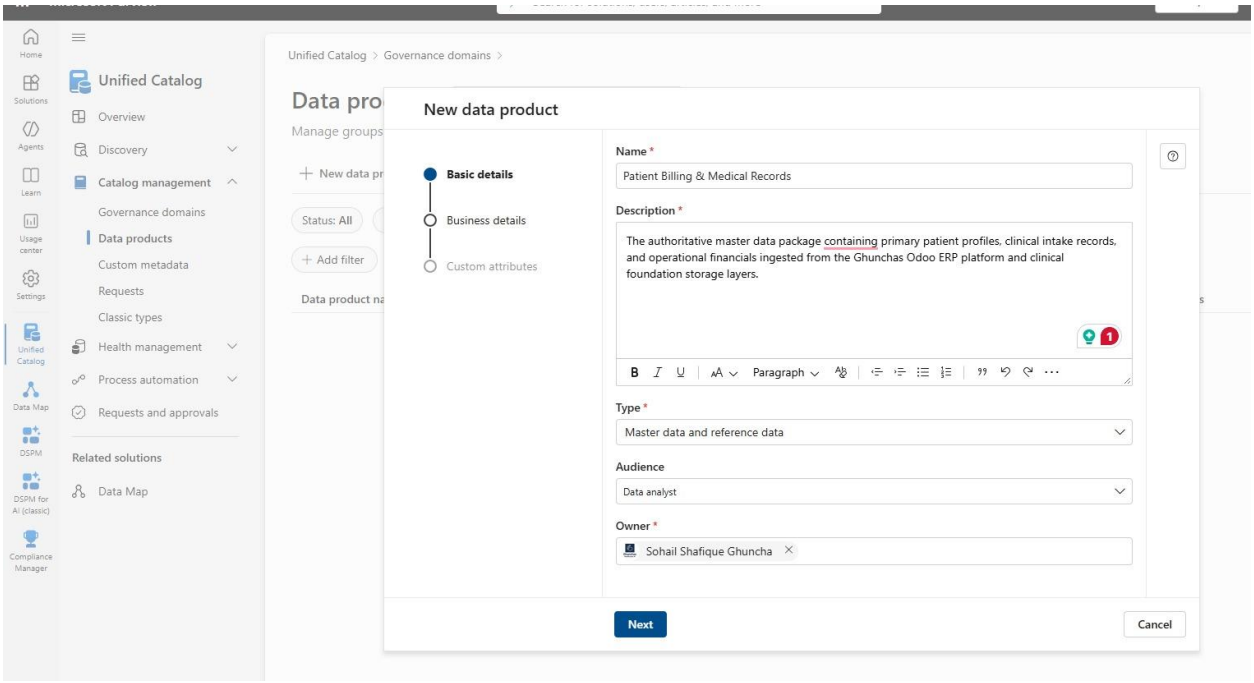


- *Caption:* "Figure 2.5: The published Patient Health Identifier CDE, showing ownership and publication status."

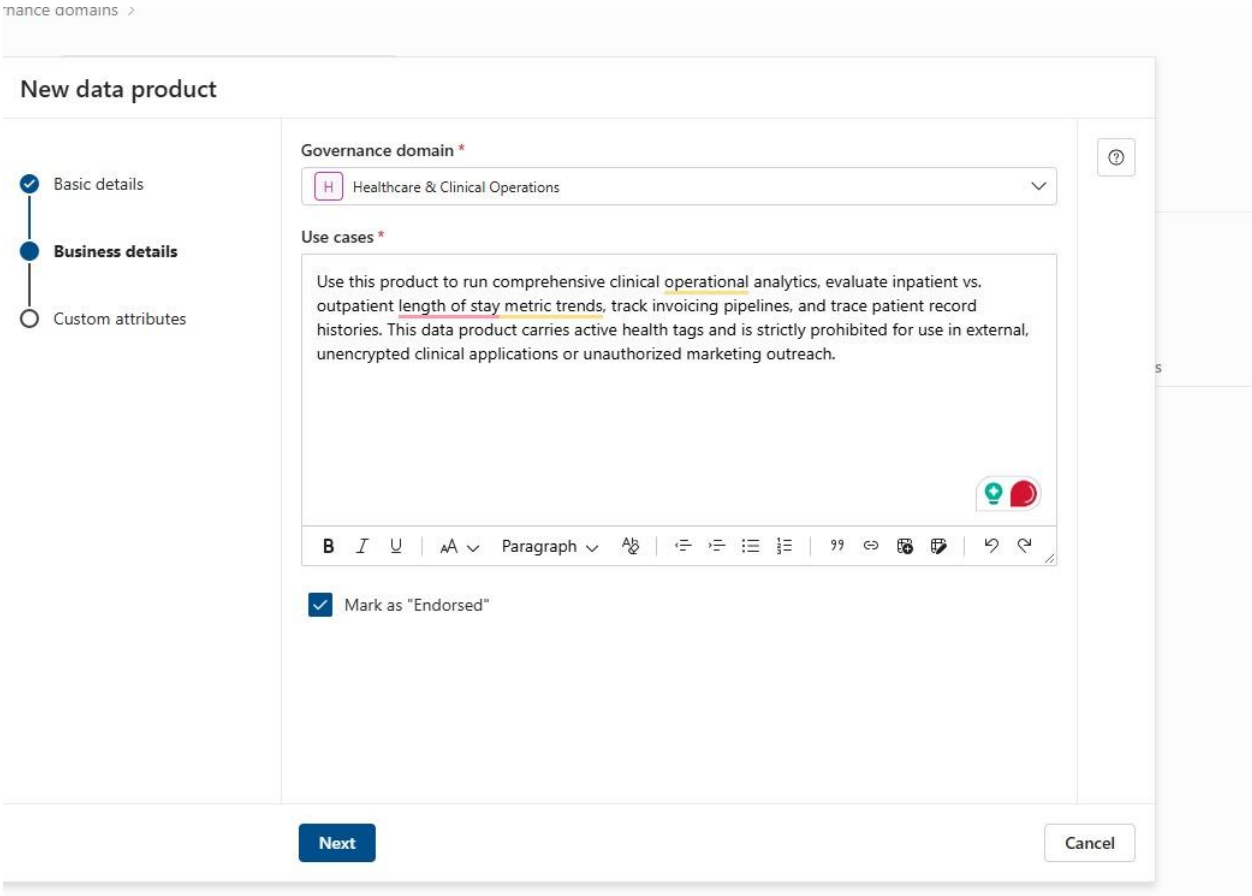
Step 4: Curating Data Products

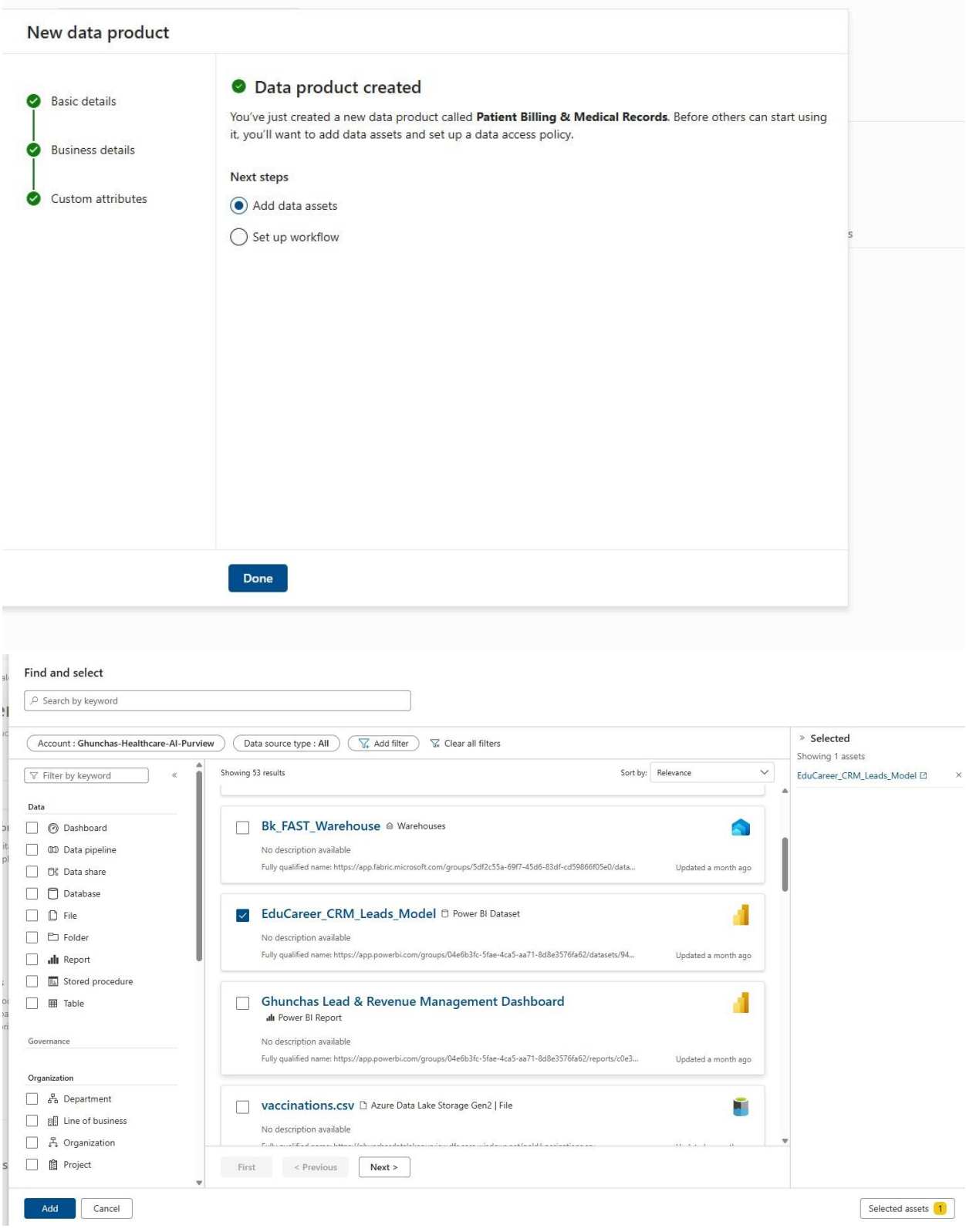
We package data assets together into "Data Products" that specific business units can request access to (e.g., "Patient Billing & Medical Records").

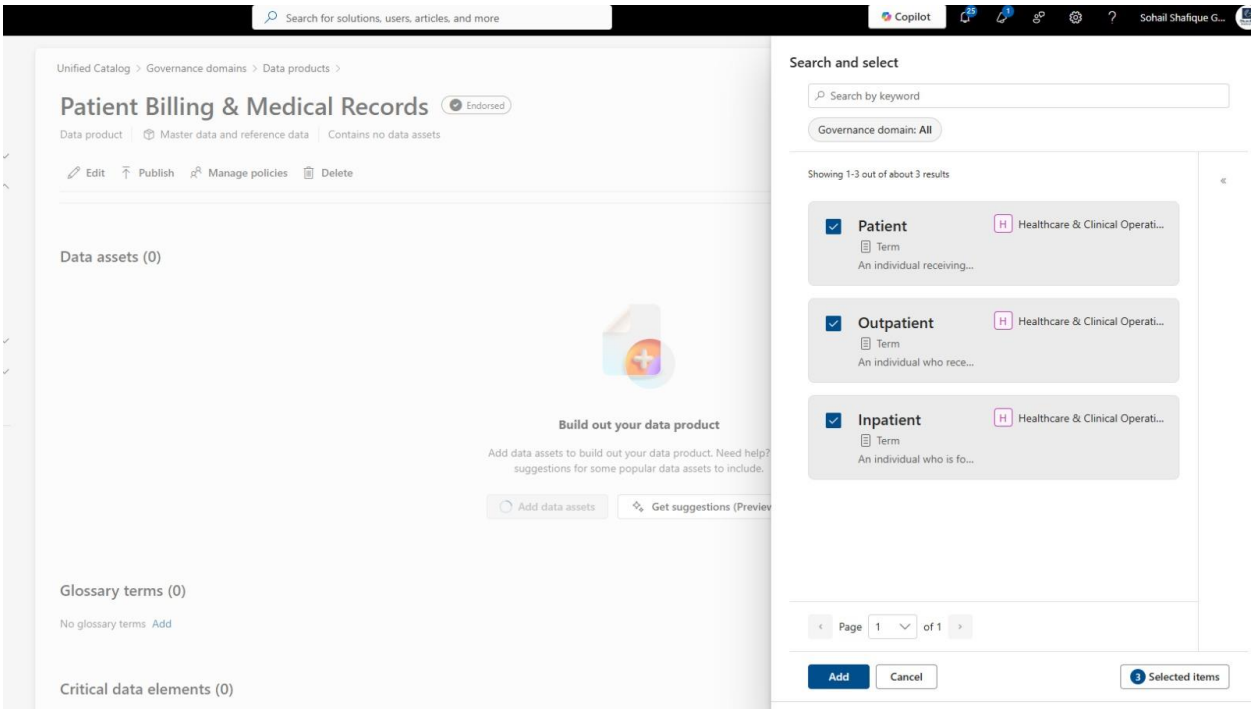
- 📸 **Screenshot:** `creating new data product 1` (or `creating new data product`)



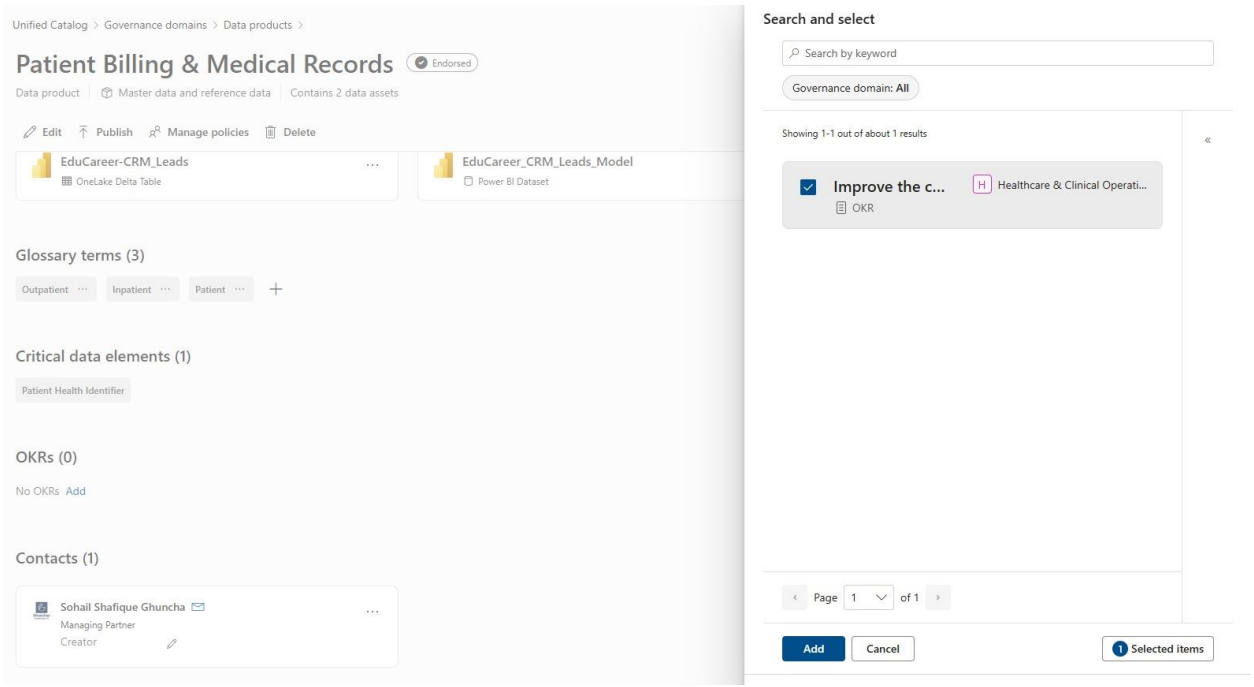
- *Caption:* "Figure 2.6: Creating the 'Patient Billing & Medical Records' Data Product."
- 📸 **Screenshot:** `creating new data product 4`

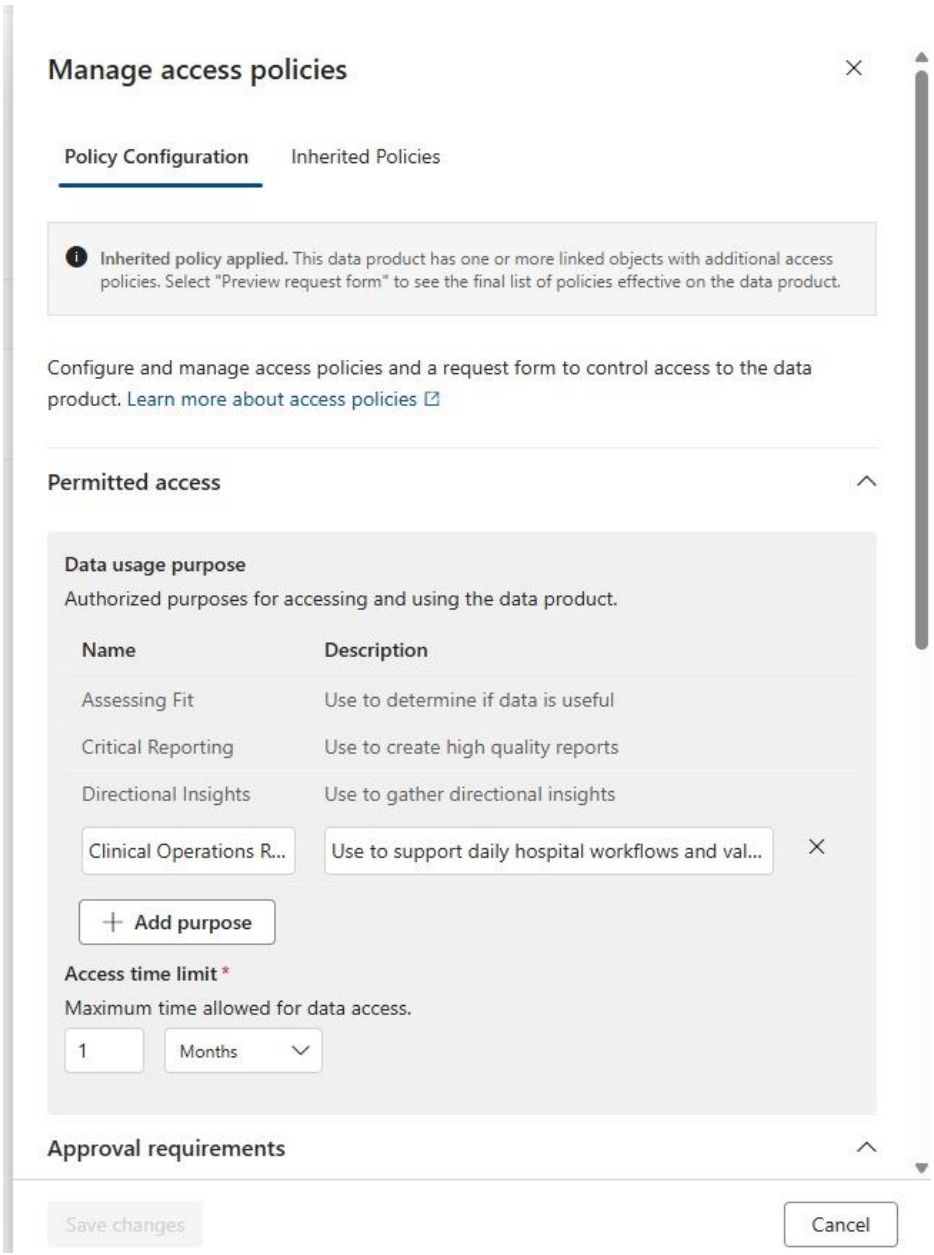

nance domains
New data product
Basic details
Business details
Custom attributes
Governance domain *
H
Healthcare & Clinical Operations
Use cases *
Use this product to run comprehensive clinical operational analytics, evaluate inpatient vs. outpatient length of stay metric trends, track invoicing pipelines, and trace patient record histories. This data product carries active health tags and is strictly prohibited for use in external, unencrypted clinical applications or unauthorized marketing outreach.
Paragraph
Mark as "Endorsed"
Next
Cancel

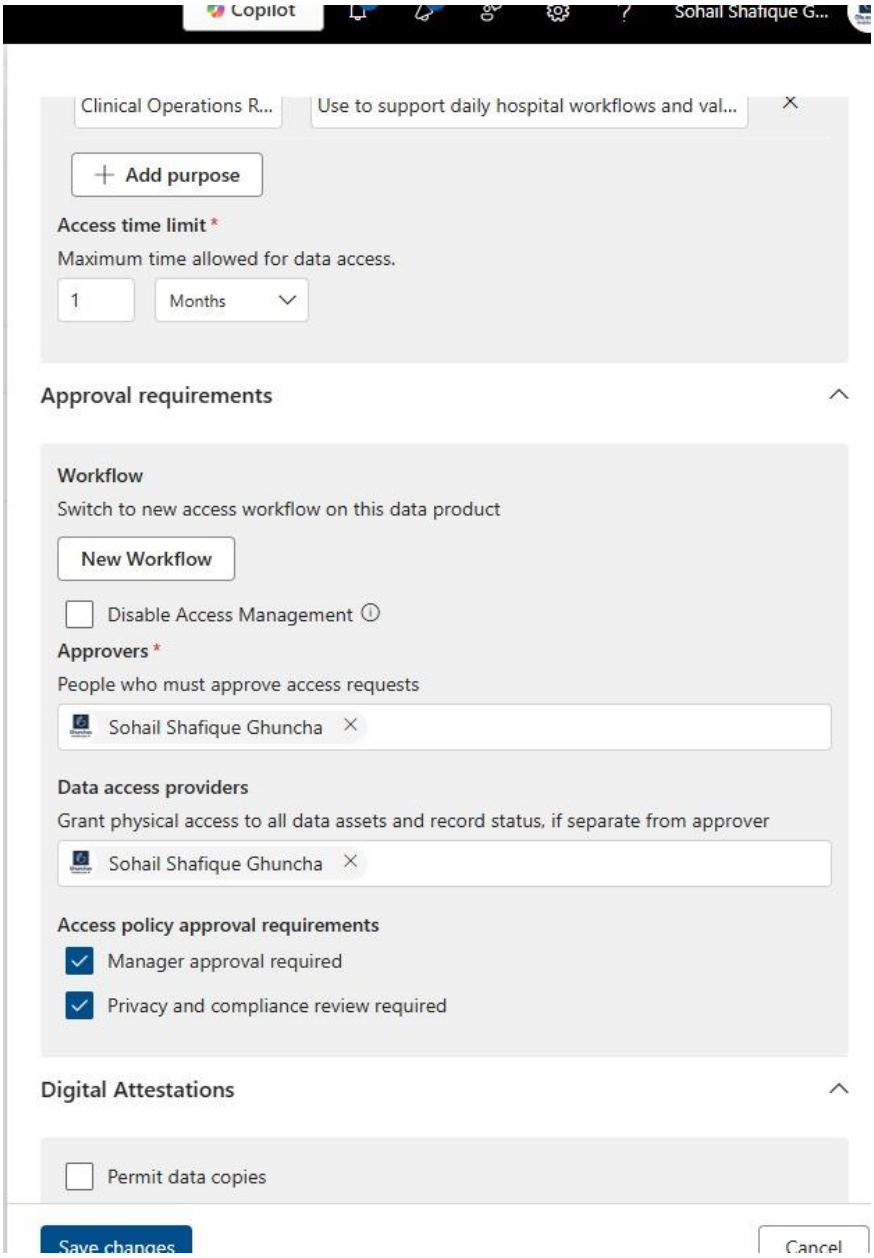

New data product
Basic details
Business details
Custom attributes
Data product created
You've just created a new data product called **Patient Billing & Medical Records**. Before others can start using it, you'll want to add data assets and set up a data access policy.
Next steps
Add data assets
Set up workflow
Done
Find and select
Search by keyword
Account : Ghunchas-Healthcare-AI-Purview
Data source type : All
Add filter
Clear all filters
Filter by keyword
Showing 53 results
Sort by: Relevance
Data
Dashboard
Data pipeline
Data share
Database
File
Folder
Report
Stored procedure
Table
Governance
Organization
Department
Line of business
Organization
Project
Bk_FAST_Warehouse
Warehouses
No description available
Fully qualified name: https://app.fabric.microsoft.com/groups/5df2c55a-69f7-45d6-83df-cd59866f05e0/data...
Updated a month ago
EduCareer_CRM_Leads_Model
Power BI Dataset
No description available
Fully qualified name: https://app.powerbi.com/groups/04e6b3fc-5fae-4ca5-aa71-8d8e3576fa62/datasets/94...
Updated a month ago
Ghunchas Lead & Revenue Management Dashboard
Power BI Report
No description available
Fully qualified name: https://app.powerbi.com/groups/04e6b3fc-5fae-4ca5-aa71-8d8e3576fa62/reports/c0e3...
Updated a month ago
vaccinations.csv
Azure Data Lake Storage Gen2 | File
No description available
First
< Previous
Next >
Selected
Showing 1 assets
EduCareer_CRM_Leads_Model
Add
Cancel
Selected assets 1

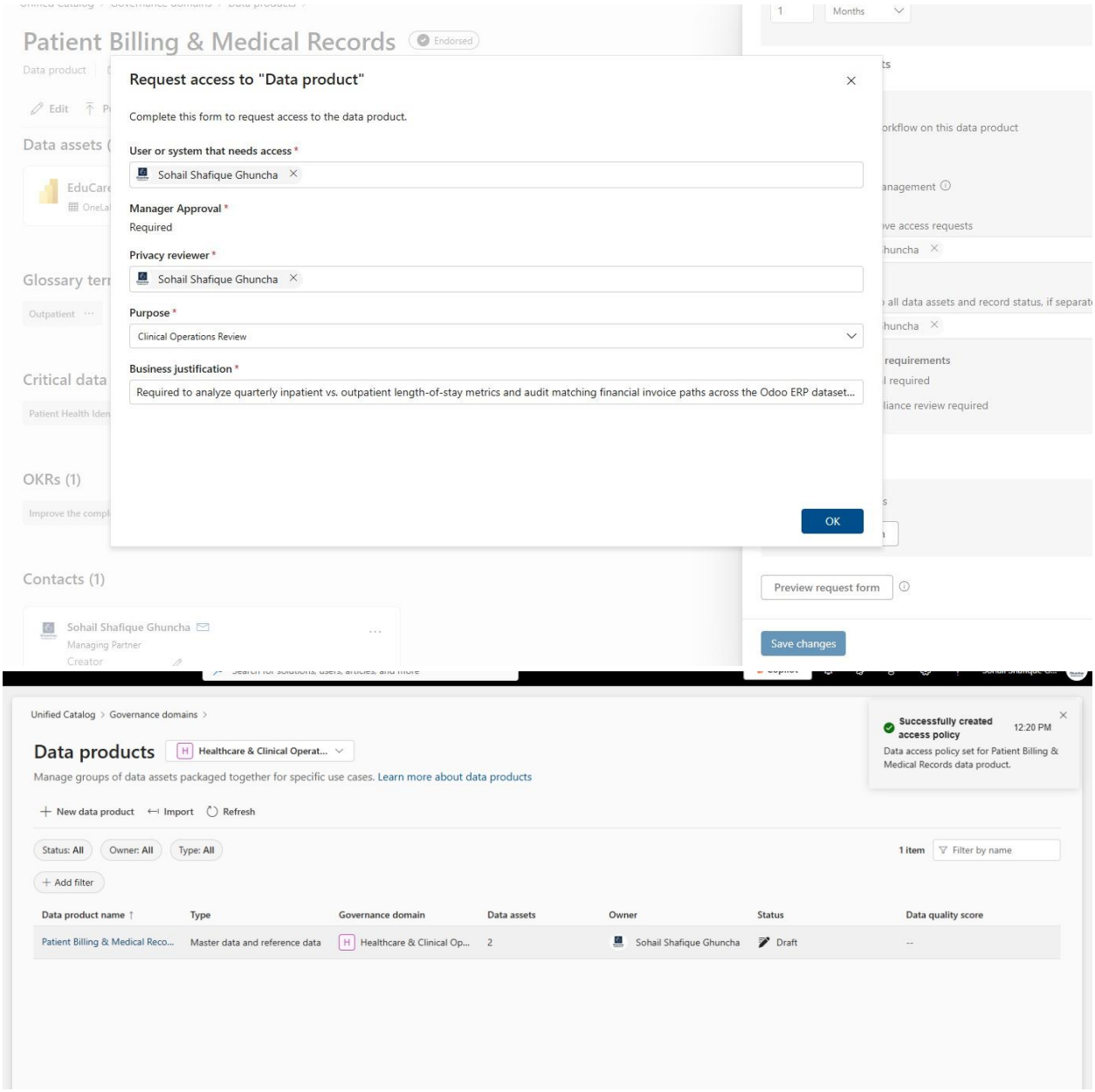


- *Caption:* "Figure 2.7: Defining the business use case and access restrictions for the Data Product."
- 🖻 **Screenshot:** `creating new data product 8`


Unified Catalog > Governance domains > Data products >
Patient Billing & Medical Records
Endorsed
Data product
Master data and reference data
Contains 2 data assets
Edit
Publish
Manage policies
Delete
EduCareer-CRM_Leads
OneLake Delta Table
EduCareer_CRM_Leads_Model
Power BI Dataset
Glossary terms (3)
Outpatient
Inpatient
Patient
Critical data elements (1)
Patient Health Identifier
OKRs (0)
No OKRs Add
Contacts (1)
Sohail Shafique Ghuncha
Managing Partner
Creator
Search and select
Search by keyword
Governance domain: All
Showing 1-1 out of about 1 results
Improve the c...
OKR
Healthcare & Clinical Operati...
Page 1 of 1
Add
Cancel
1 Selected items


Manage access policies
Policy Configuration
Inherited Policies
Inherited policy applied. This data product has one or more linked objects with additional access policies. Select "Preview request form" to see the final list of policies effective on the data product.
Configure and manage access policies and a request form to control access to the data product. Learn more about access policies
Permitted access
Data usage purpose
Authorized purposes for accessing and using the data product.
Name
Description
Assessing Fit
Use to determine if data is useful
Critical Reporting
Use to create high quality reports
Directional Insights
Use to gather directional insights
Clinical Operations R...
Use to support daily hospital workflows and val...
Add purpose
Access time limit *
Maximum time allowed for data access.
1
Months
Approval requirements
Save changes
Cancel


Copilot
Sohail Shafique G...
Clinical Operations R...
Use to support daily hospital workflows and val...
Add purpose
Access time limit *
Maximum time allowed for data access.
1
Months
Approval requirements
Workflow
Switch to new access workflow on this data product
New Workflow
Disable Access Management
Approvers *
People who must approve access requests
Sohail Shafique Ghuncha
Data access providers
Grant physical access to all data assets and record status, if separate from approver
Sohail Shafique Ghuncha
Access policy approval requirements
Manager approval required
Privacy and compliance review required
Digital Attestations
Permit data copies
Save changes
Cancel

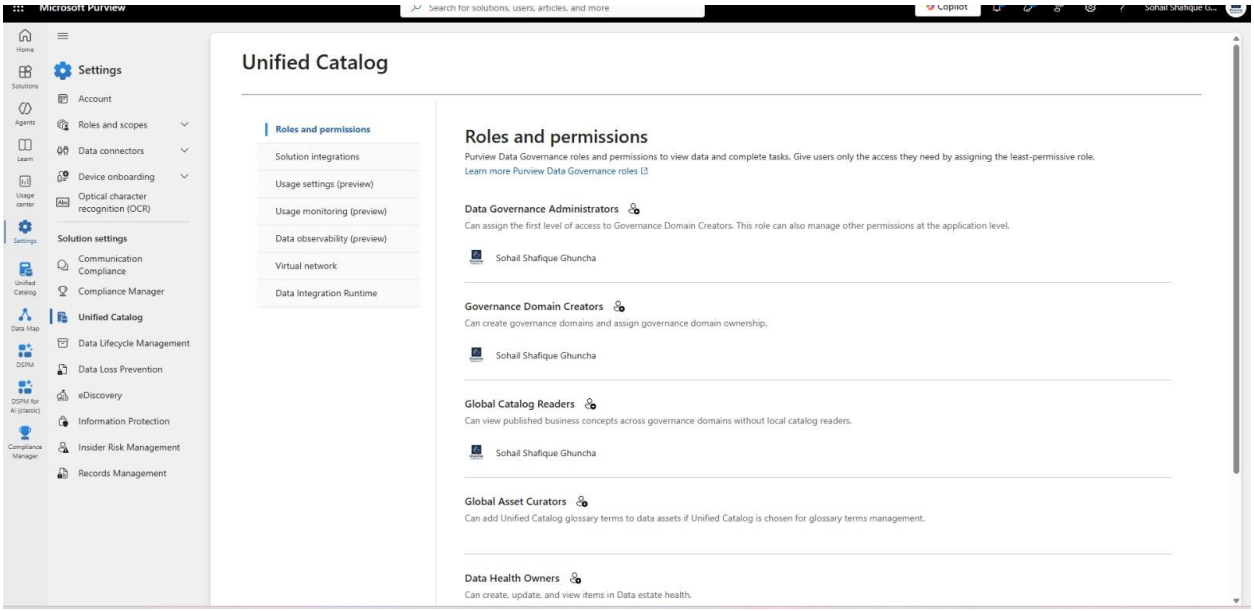


- *Caption:* "Figure 2.8: Linking the new Data Product to the established Glossary Terms and Critical Data Elements."

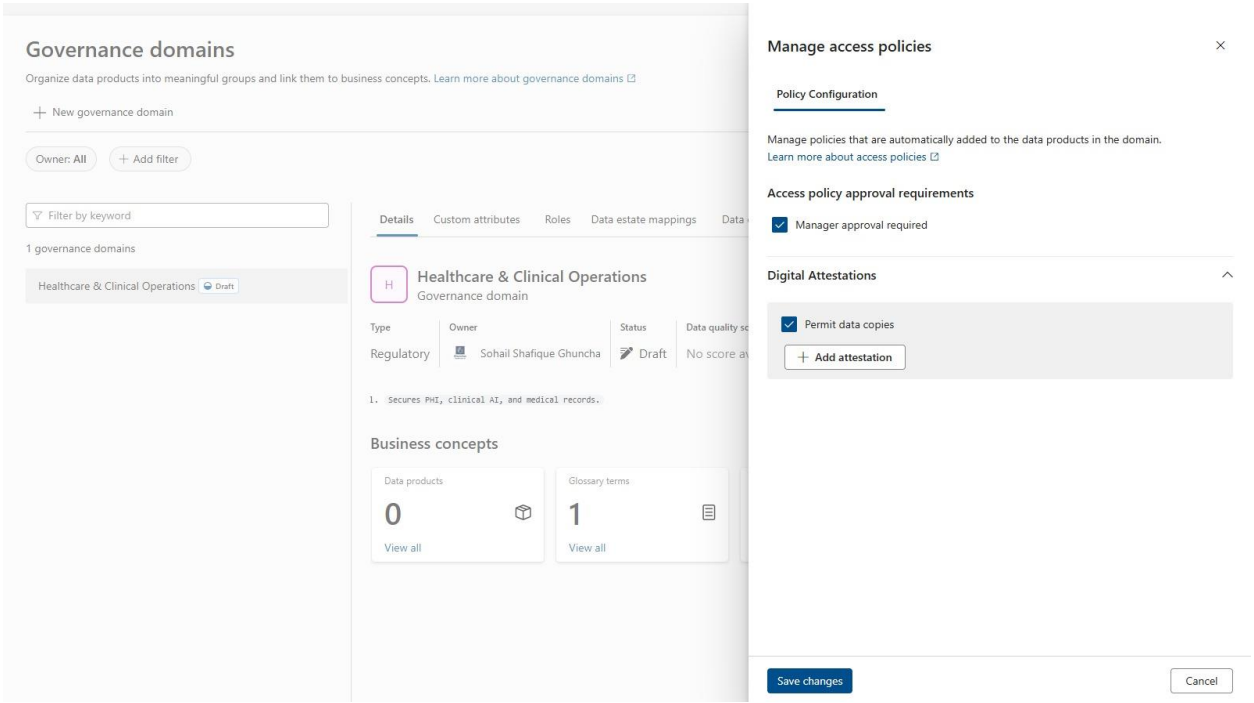
Step 5: Establishing Access Policies

We do not just create data products; we secure them. We configure approval workflows so that if a user wants to access the "Patient Billing" product, they must provide a business justification, and a manager must approve.

- 📸 **Screenshot:** `Assigning roles for unified catalog`



- *Caption:* "Figure 2.9: Configuring Role-Based Access Control (RBAC) for the Unified Catalog."
- 📸 **Screenshot:** `Adjusting new governance domain settings` (or `Unified Catalog Classification Page`)



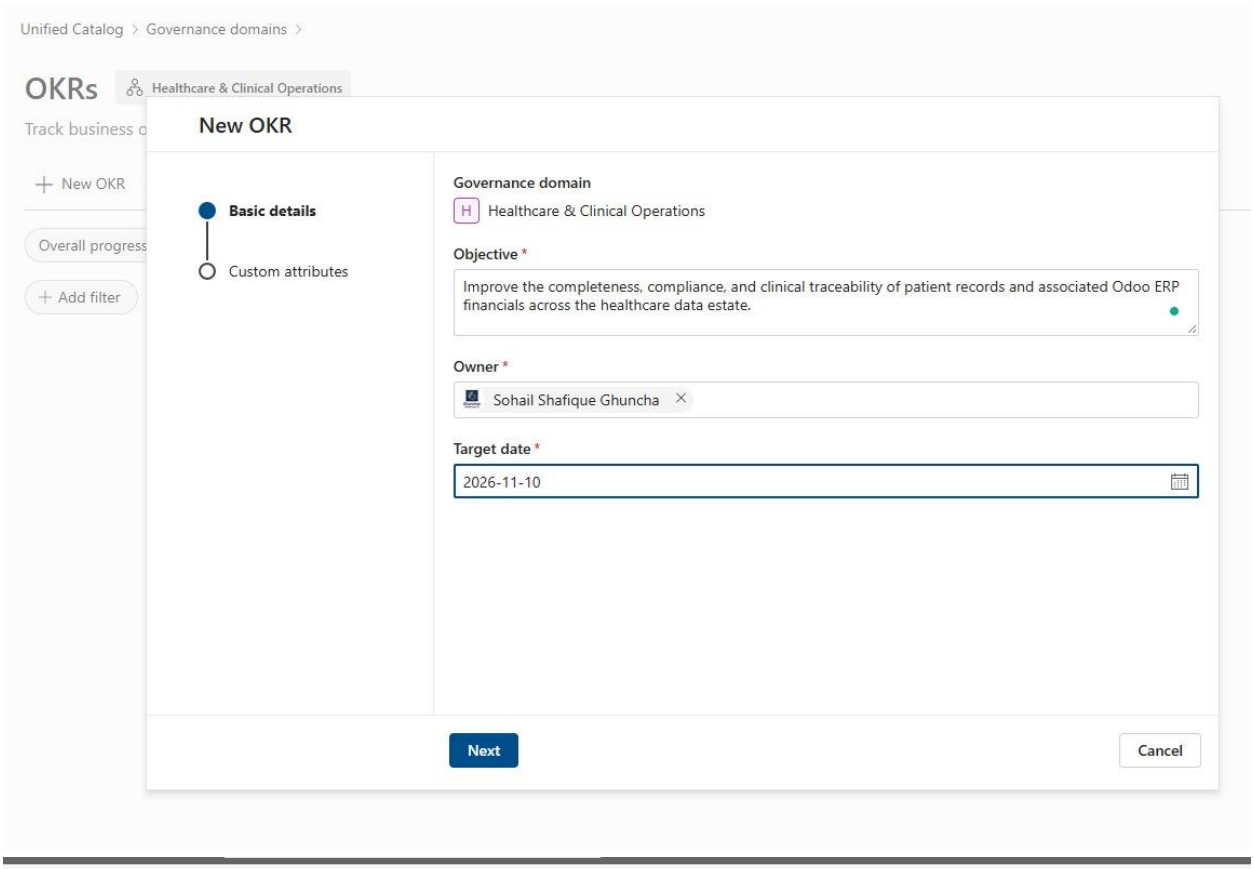
- *Caption:* "Figure 2.10: Configuring access policies and approval requirements for the Governance Domain."

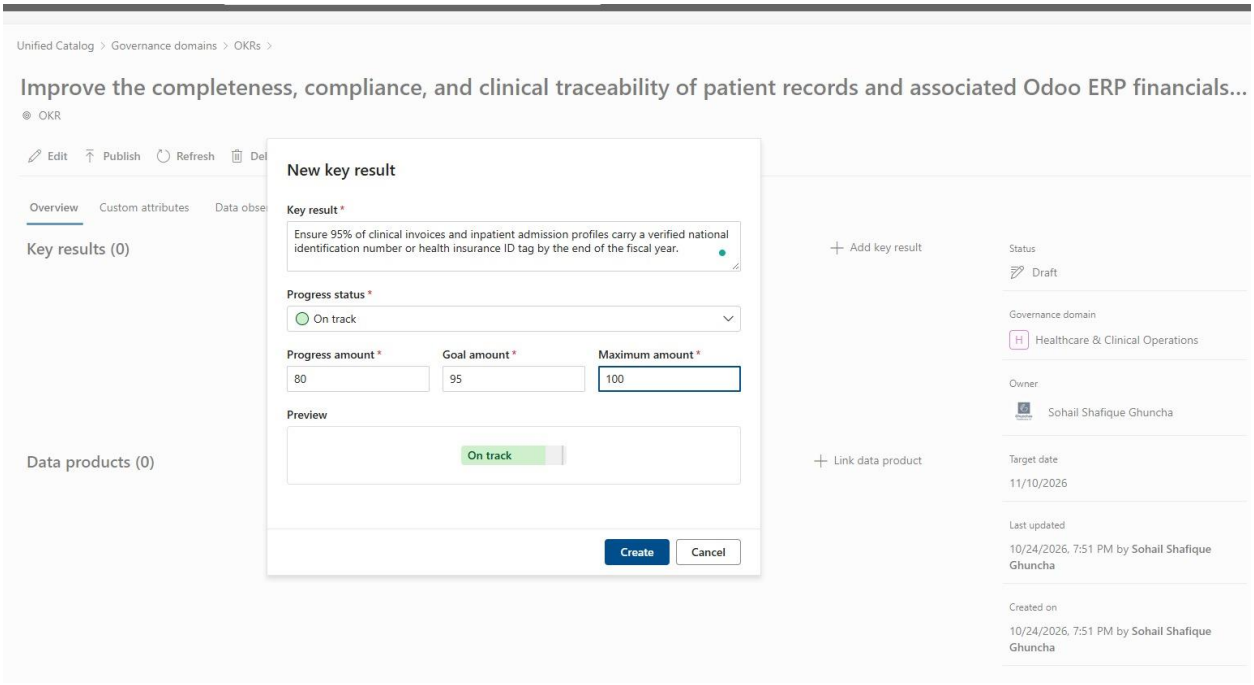
Step 6: Setting Objectives and Key Results (OKRs)

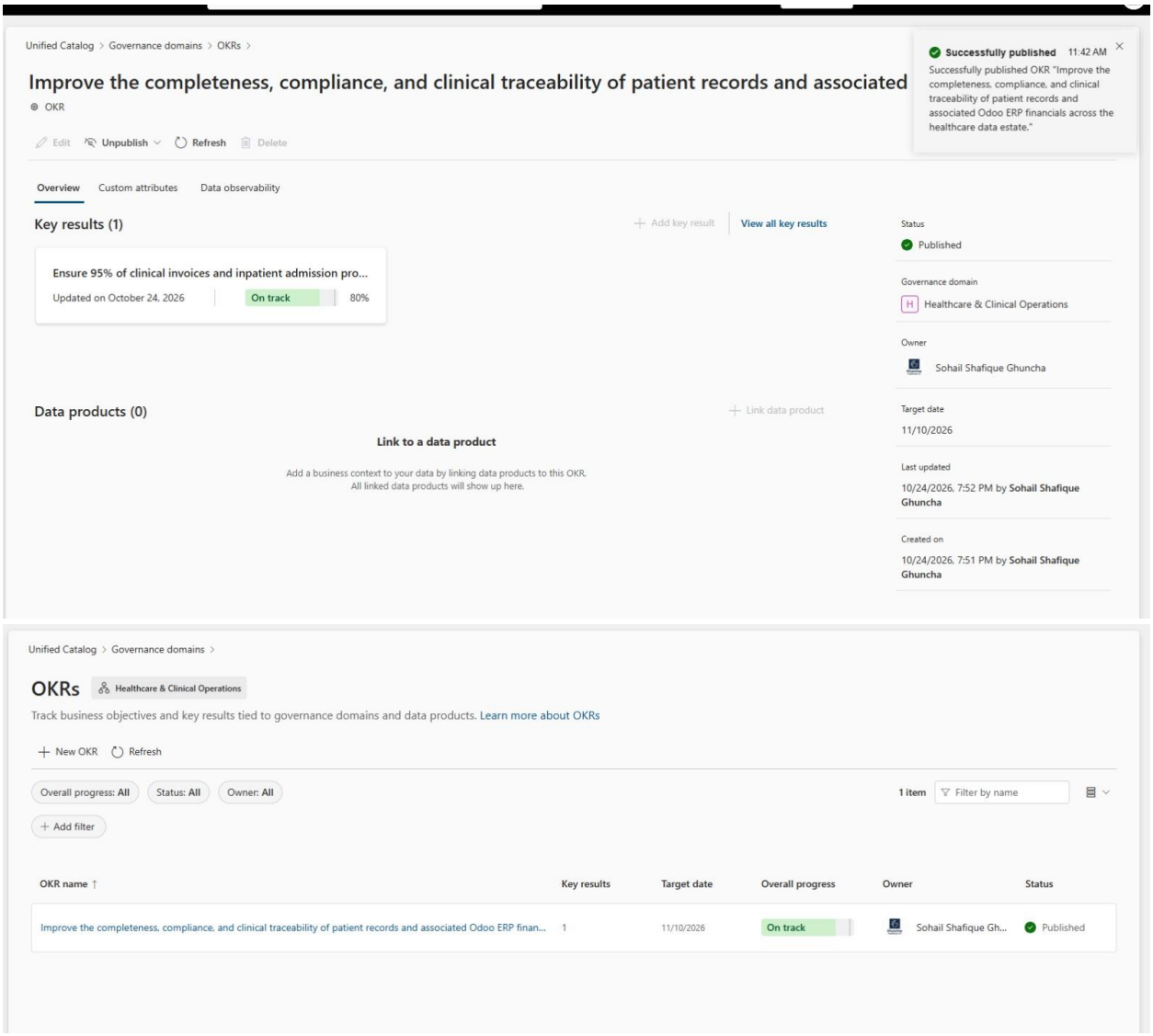
To prove the governance program is actually working, we track OKRs. For example,

tracking the percentage of clinical invoices that carry a verified national identification number.

- 📸 **Screenshot:** `Creating an OKR` (or `Published OKR`)







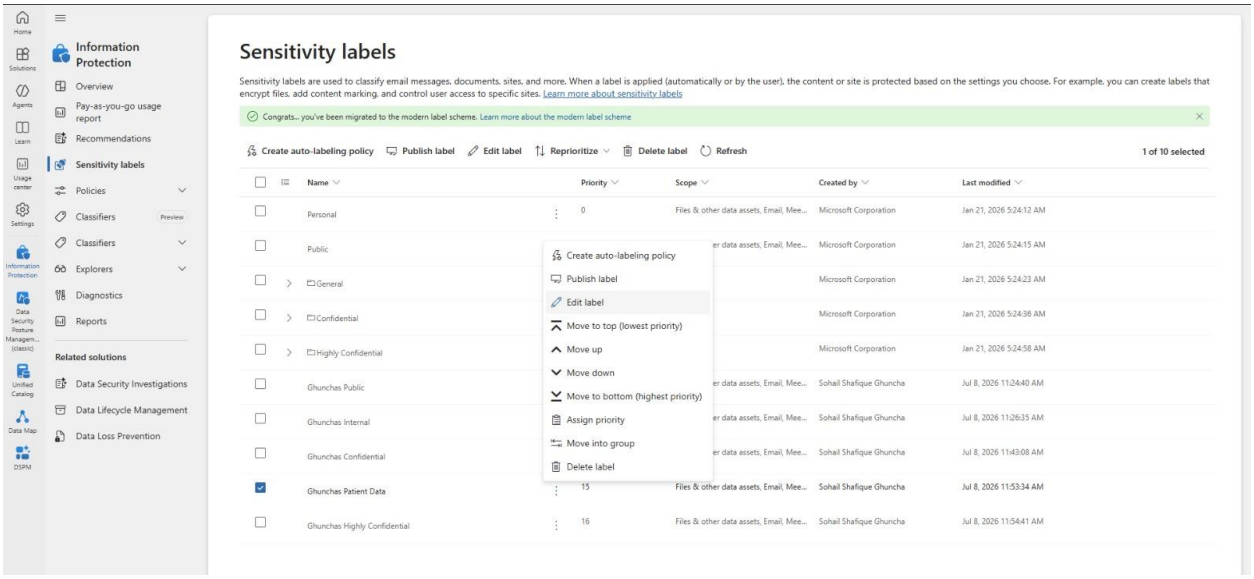
- *Caption:* "Figure 2.11: Publishing an OKR to track data completeness and clinical traceability."

PHASE 3: INFORMATION PROTECTION & AUTOMATED CLASSIFICATION (CONTINUED)

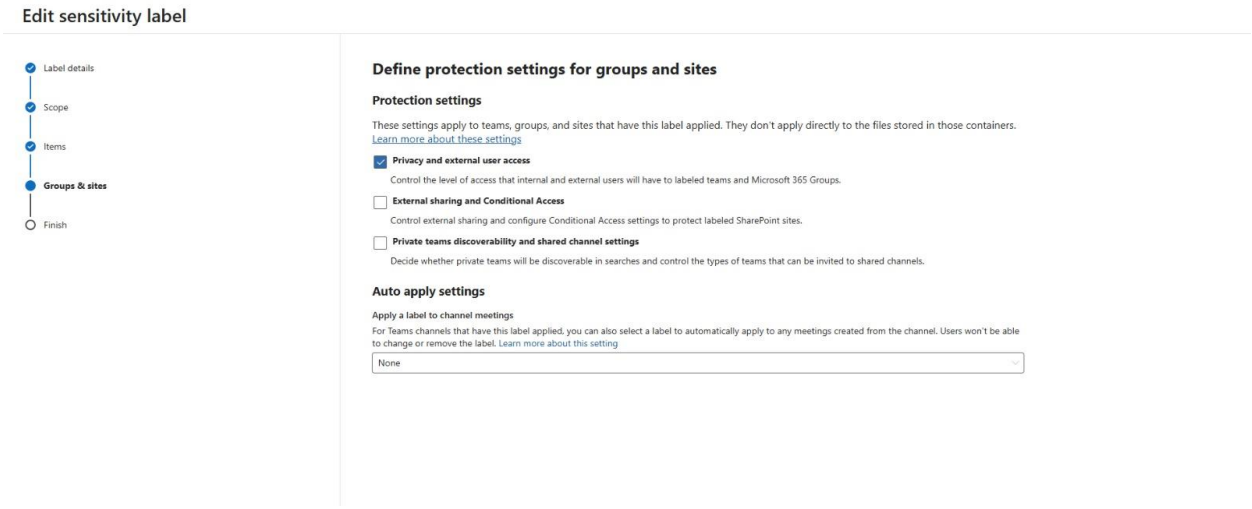
Step 7: Creating and Editing the Sensitivity Label

What we did: We opened the "Ghunchas Patient Data" label to edit its protection settings.
Why we did it: To ensure that when this label is applied, it not only marks the file but also enforces encryption and restricts who can access it. We configure container-level settings so that if applied to a SharePoint site or Teams channel, it locks down the whole container.

- **[Insert Image: Sensitivity labels list - Edit label menu]**

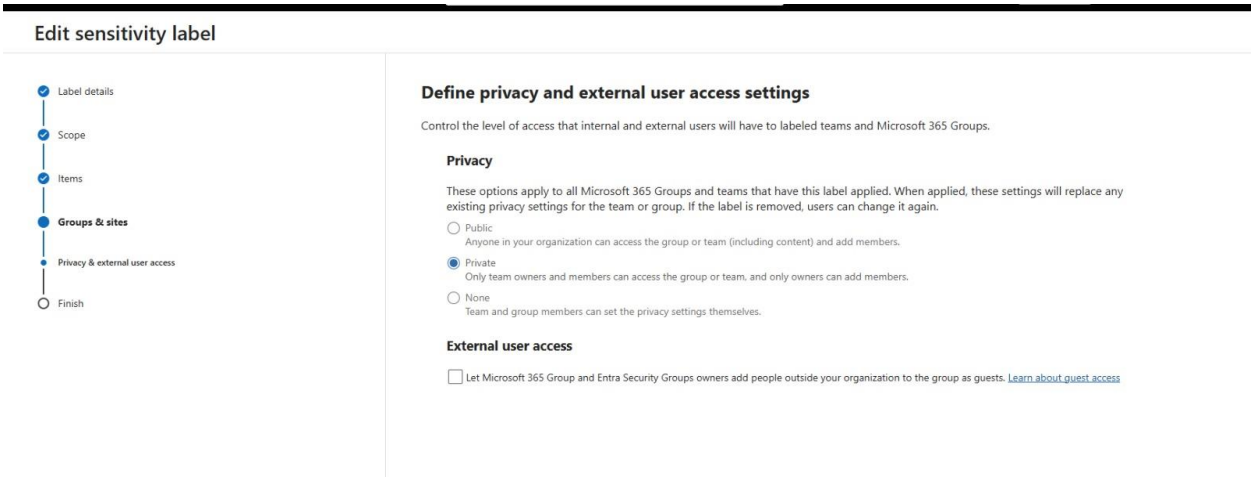


  - *Figure 3.11: Selecting the "Ghunchas Patient Data" label and accessing the Edit menu to configure its properties.*
- **[Insert Image: Define protection settings for groups and sites]**



- *Figure 3.12: Enabling Privacy and external user access controls for containers (Teams/Sites).*

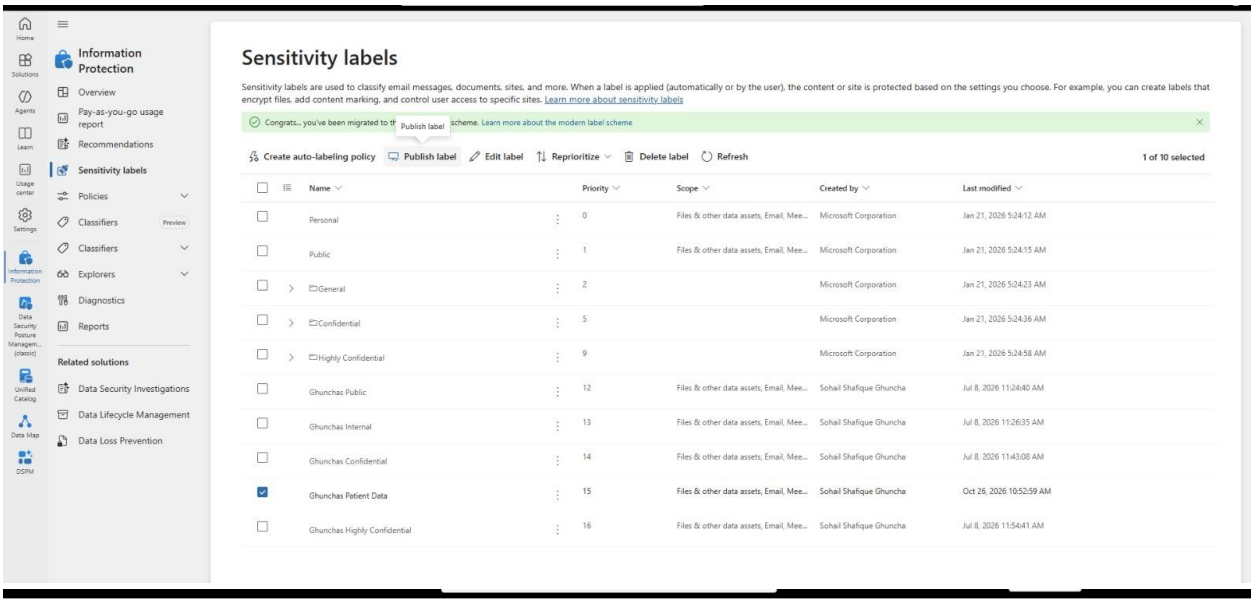
- **[Insert Image: Define privacy and external user access settings]**

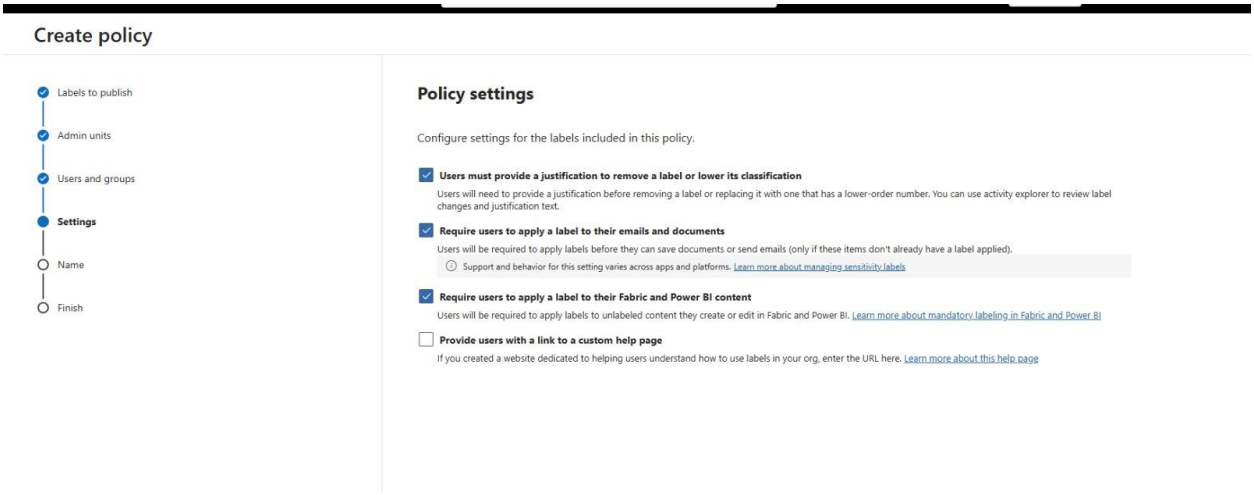


- *Figure 3.13: Setting the privacy level to "Private" and blocking external guest access for any site that carries this label.*

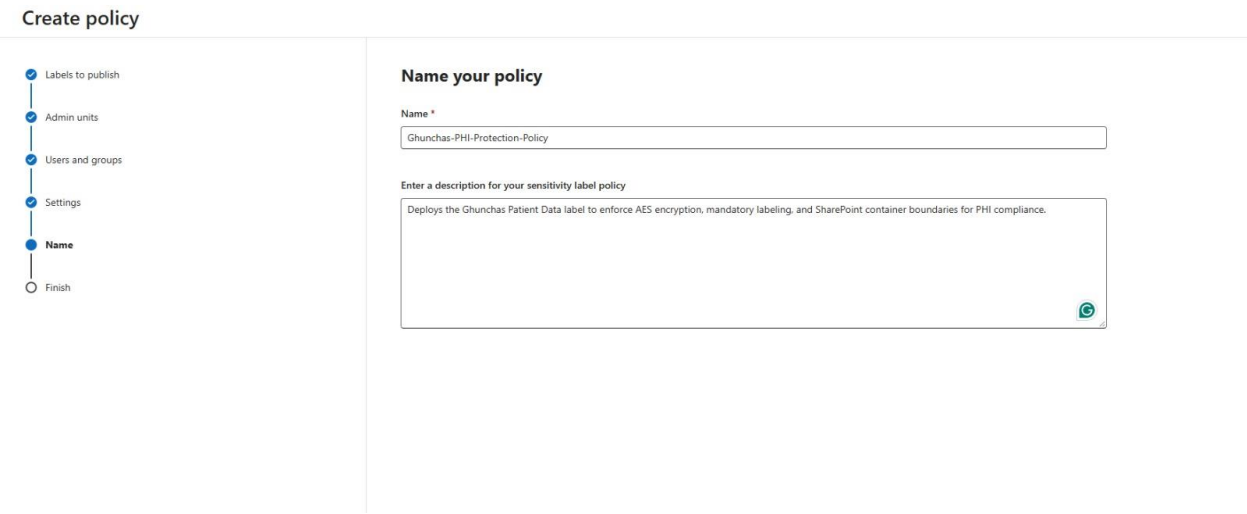
Step 8: Publishing the Label Policy

What we did: We created a Label Publishing Policy to deploy the label to the organization.
Why we did it: Labels do nothing if users can't see them. We enforce mandatory labeling, which forces users to classify documents before saving. We also require a justification if a user tries to downgrade or remove a label, ensuring an audit trail.





- **[Insert Image: Create policy - Policy settings]**
  - *Figure 3.14: Enforcing mandatory labeling and requiring justification for label removal.*

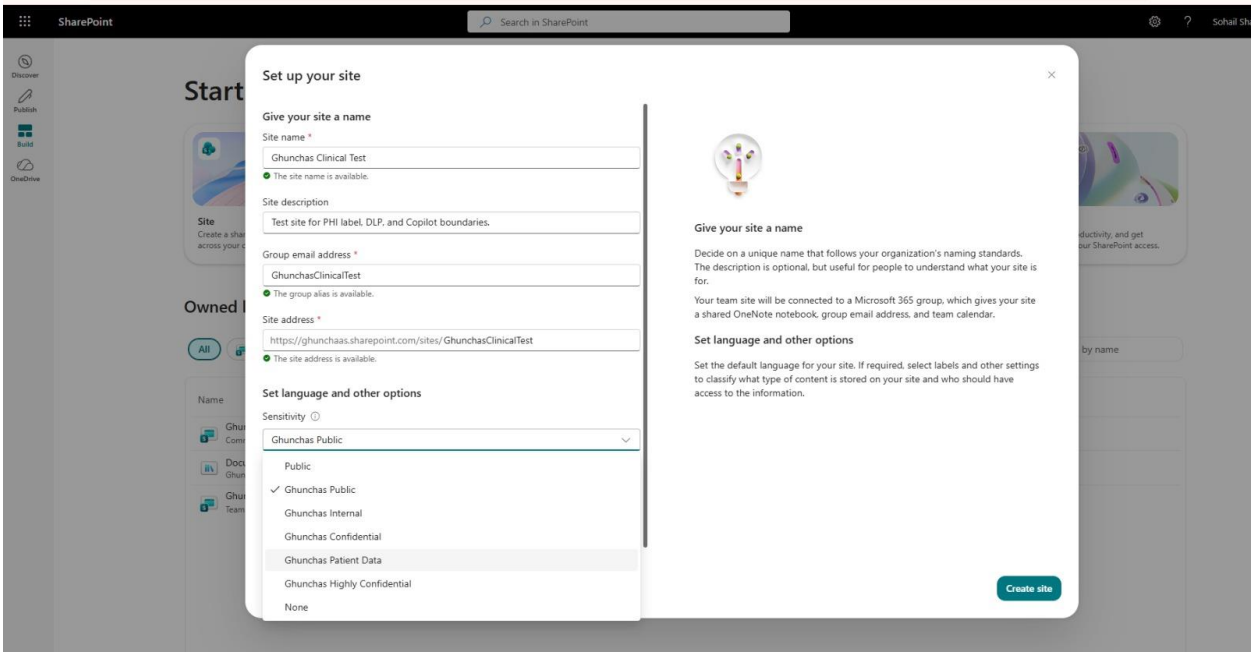


- **[Insert Image: Create policy - Name your policy]**
  - *Figure 3.15: Naming the policy "Ghunchas-PHI-Protection-Policy".*

Step 9: Creating the SharePoint Test Site & Applying the Label

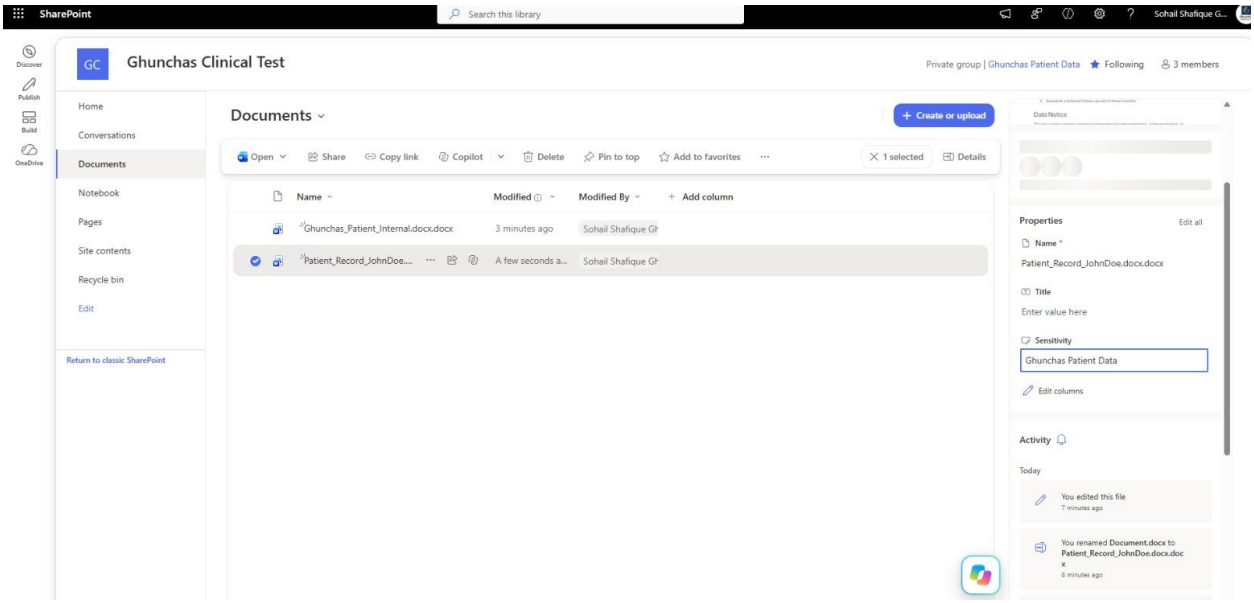
What we did: We created a new SharePoint site ("Ghunchas Clinical Test") and applied the "Ghunchas Patient Data" label at the site level.
Why we did it: This is our live lab environment. Applying the label to the container ensures that any document uploaded to this site automatically inherits the sensitivity label, testing container-level protection.

- **[Insert Image: SharePoint - Set up your site - Sensitivity]**



- *Figure 3.16: Creating the SharePoint site and assigning the sensitivity label during setup.*

- **[Insert Image: SharePoint Documents - Sensitivity column]**

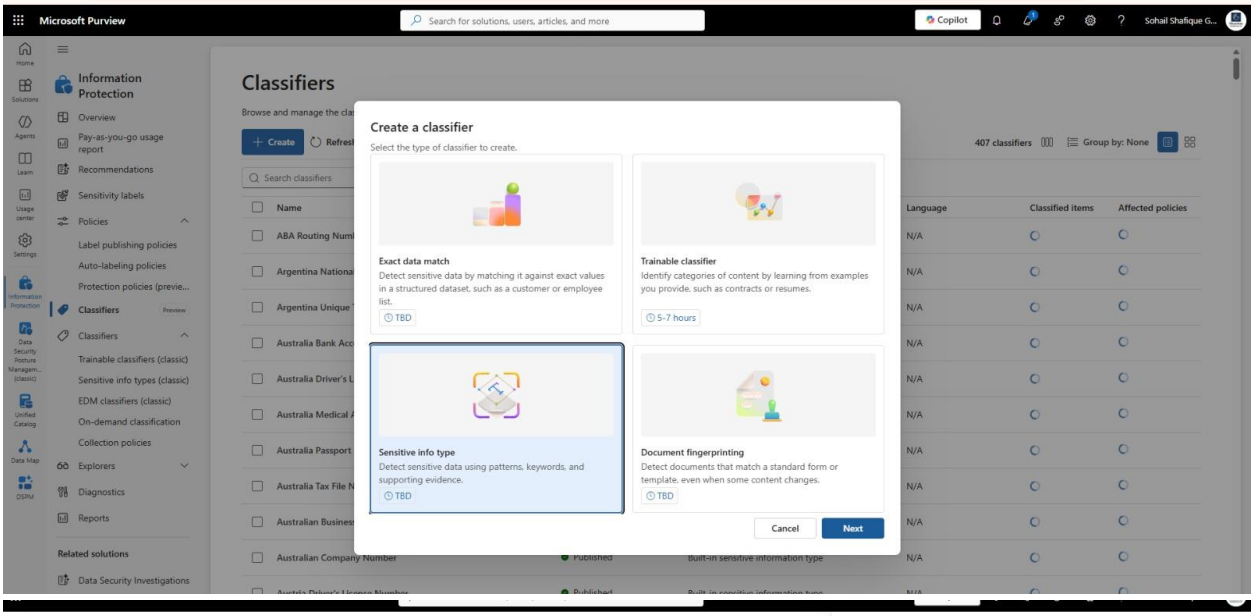


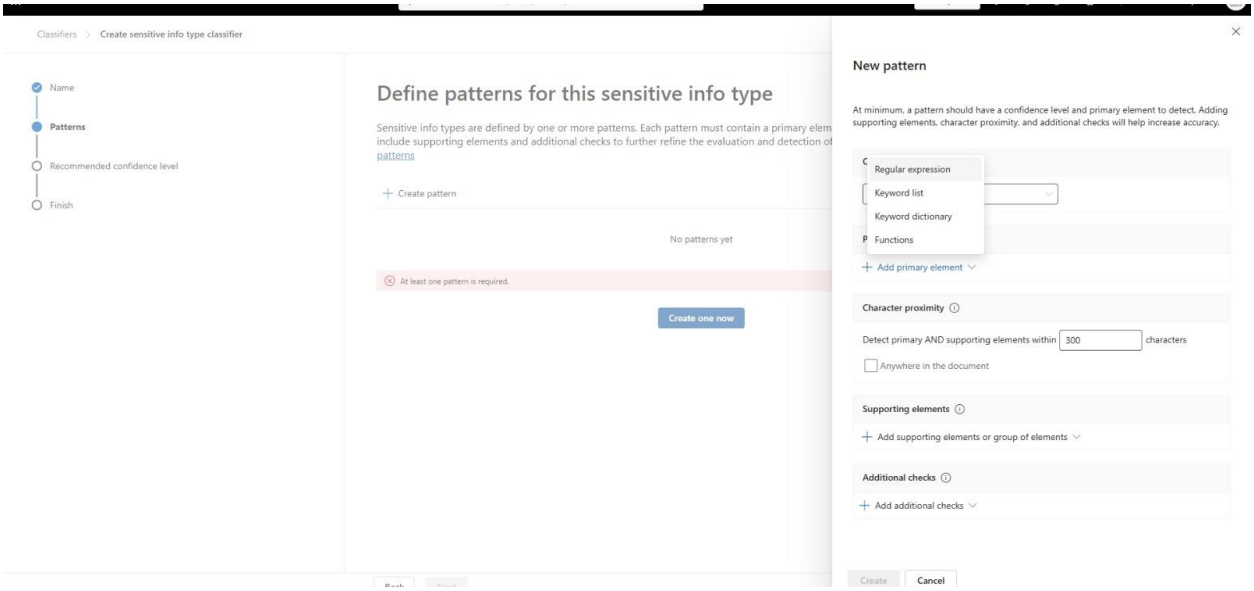
- *Figure 3.17: A document inside the site automatically inheriting the "Ghunchas Patient Data" sensitivity label.*

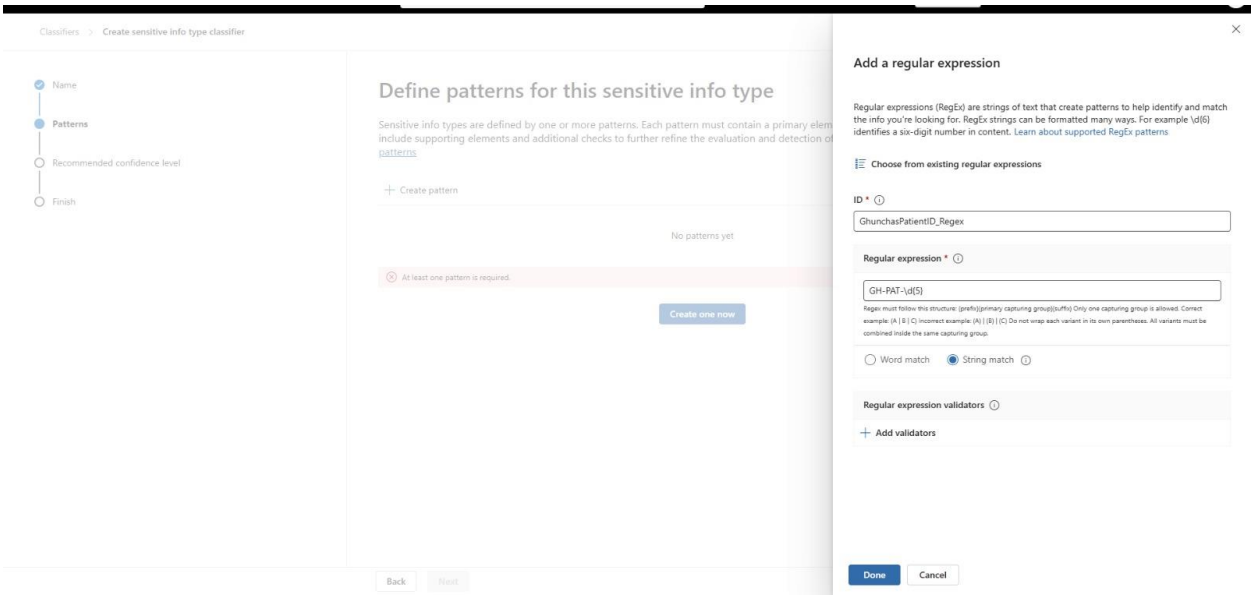
Step 10: Verifying the Classifiers

What we did: We verified that our custom Regex and EDM classifiers were successfully published.
Why we did it: Auto-labeling policies rely on these classifiers. If they aren't published and active, the policy will not trigger.

- **[Insert Image: Classifiers - Sensitive info types list]**

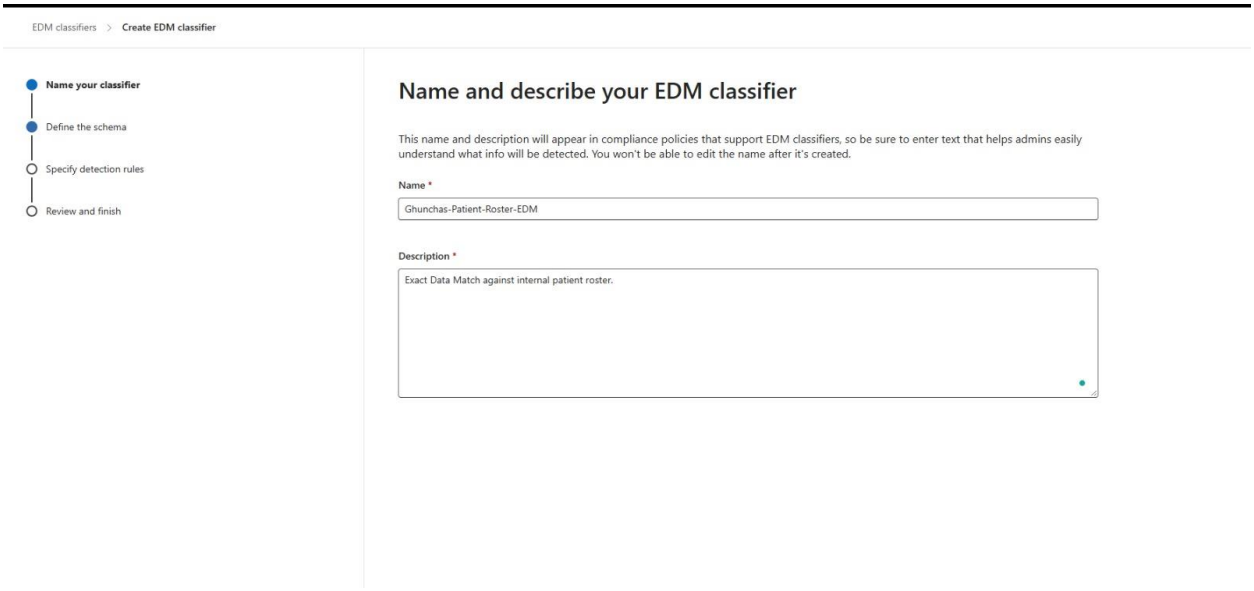


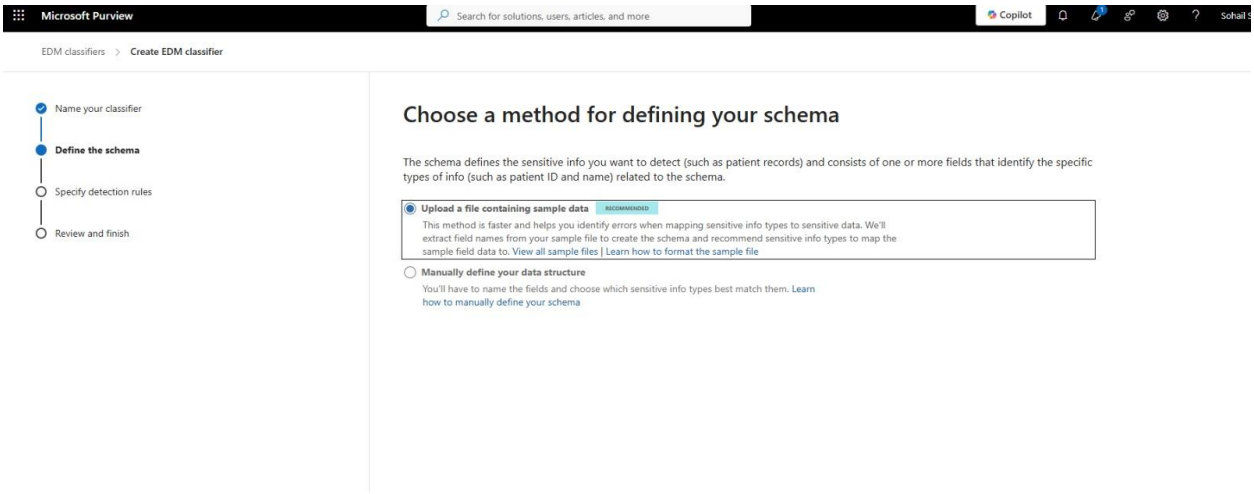


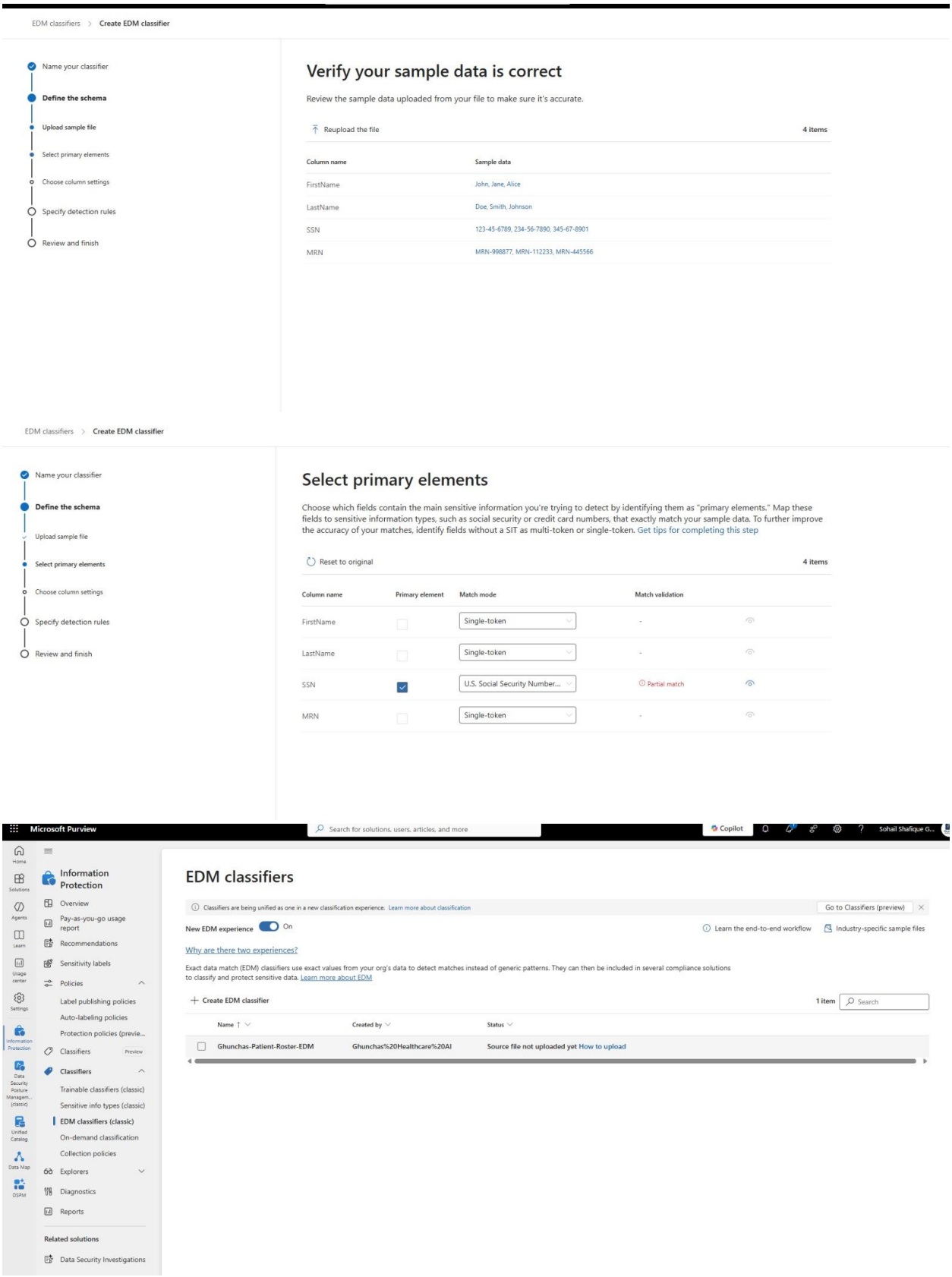


- *Figure 3.18: The list of active Sensitive Info Types, including our custom Regex.*

- **[Insert Image: EDM classifiers list]**


EDM classifiers > Create EDM classifier
Name your classifier
Define the schema
Specify detection rules
Review and finish
Name and describe your EDM classifier
This name and description will appear in compliance policies that support EDM classifiers, so be sure to enter text that helps admins easily understand what info will be detected. You won't be able to edit the name after it's created.
Name *
Ghunchas-Patient-Roster-EDM
Description *
Exact Data Match against internal patient roster.


Microsoft Purview
Search for solutions, users, articles, and more
Copilot
EDM classifiers > Create EDM classifier
Name your classifier
Define the schema
Specify detection rules
Review and finish
Choose a method for defining your schema
The schema defines the sensitive info you want to detect (such as patient records) and consists of one or more fields that identify the specific types of info (such as patient ID and name) related to the schema.
Upload a file containing sample data
RECOMMENDED
This method is faster and helps you identify errors when mapping sensitive info types to sensitive data. We'll extract field names from your sample file to create the schema and recommend sensitive info types to map the sample field data to. View all sample files | Learn how to format the sample file
Manually define your data structure
You'll have to name the fields and choose which sensitive info types best match them. Learn how to manually define your schema

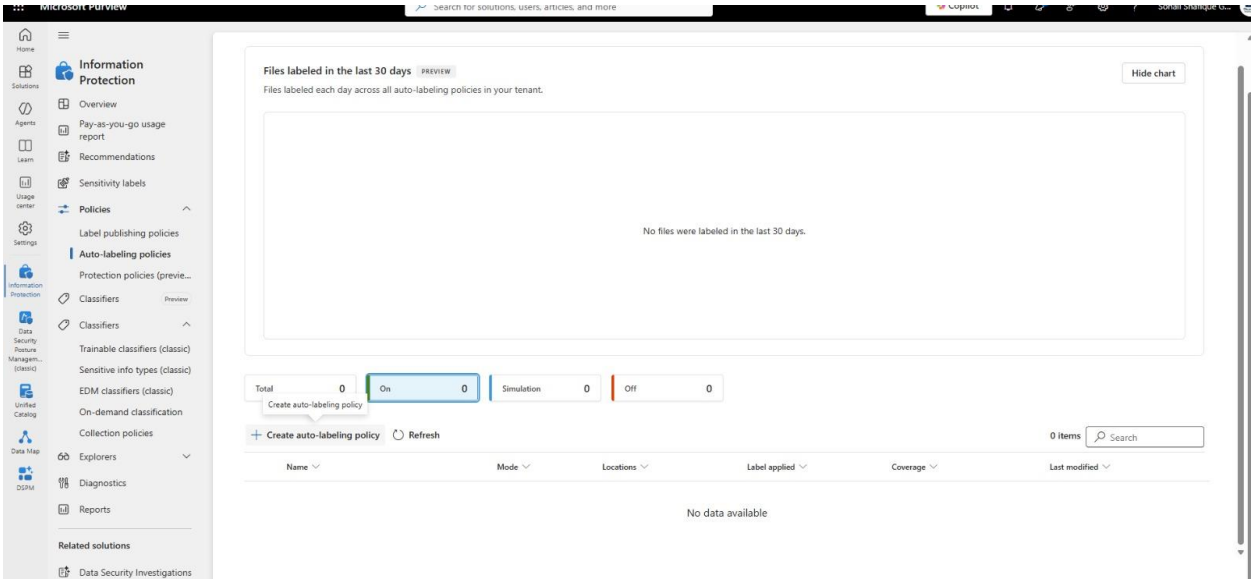


- *Figure 3.19: The published EDM classifier (Ghunchas-Patient-Roster-EDM).*

Step 11: Creating the Auto-Labeling Policy

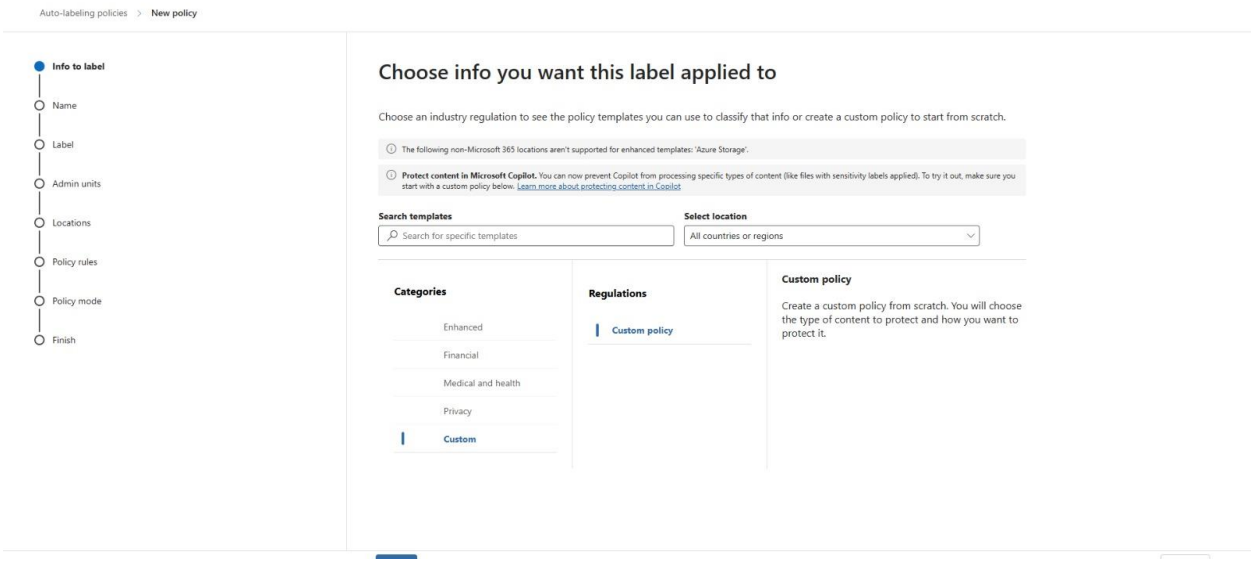
What we did: We initiated a new Auto-labeling policy from scratch.
Why we did it: Manual labeling relies on the user. Auto-labeling uses our classifiers to scan the environment and automatically apply the "Ghunchas Patient Data" label the moment our EDM or Regex patterns are detected.

- **[Insert Image: Auto-labeling policies - Create policy]**



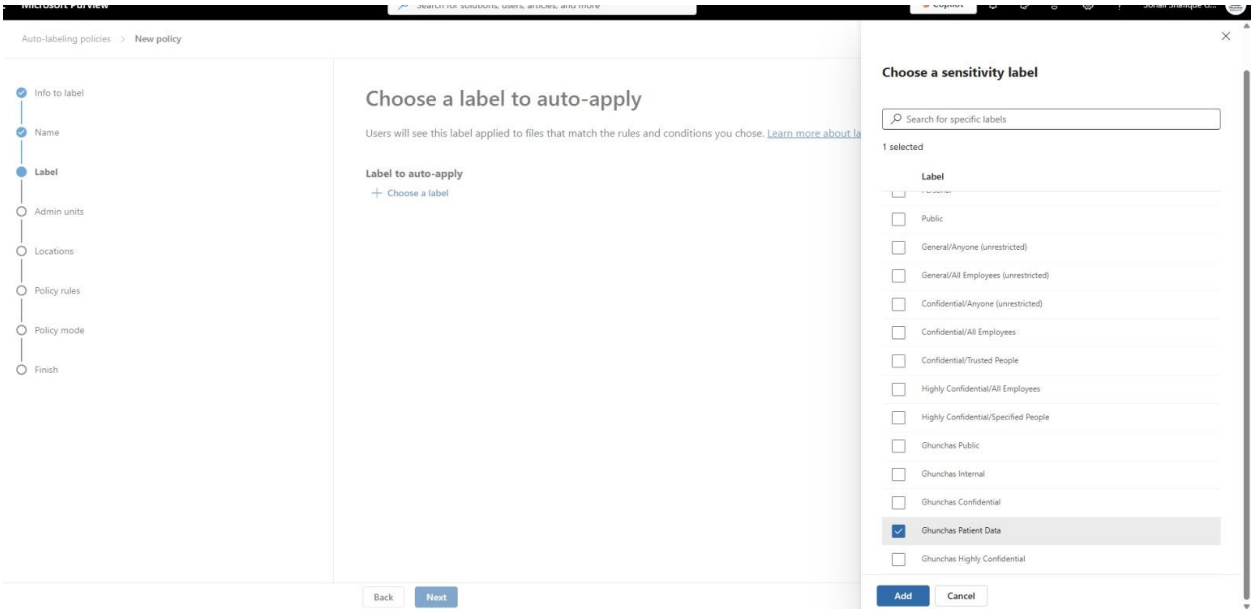
  - *Figure 3.20: Starting the auto-labeling policy creation.*

- **[Insert Image: Create auto-labeling policy - Choose info]**



  - *Figure 3.21: Selecting "Custom policy" to build the rules from scratch.*

- **[Insert Image: Create auto-labeling policy - Choose a label]**

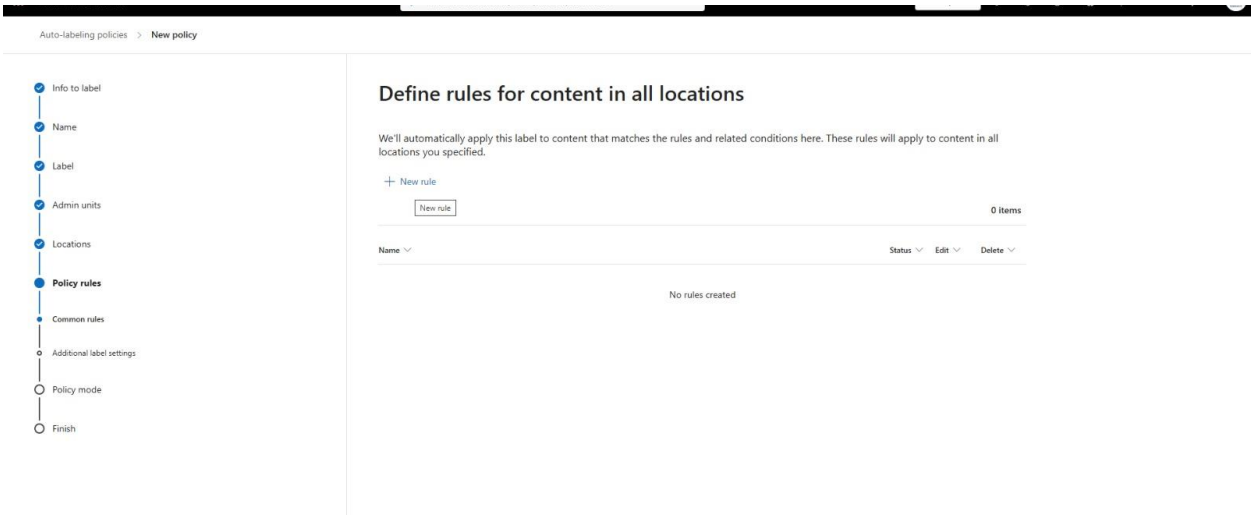


- *Figure 3.22: Selecting the "Ghunchas Patient Data" label to be automatically applied.*

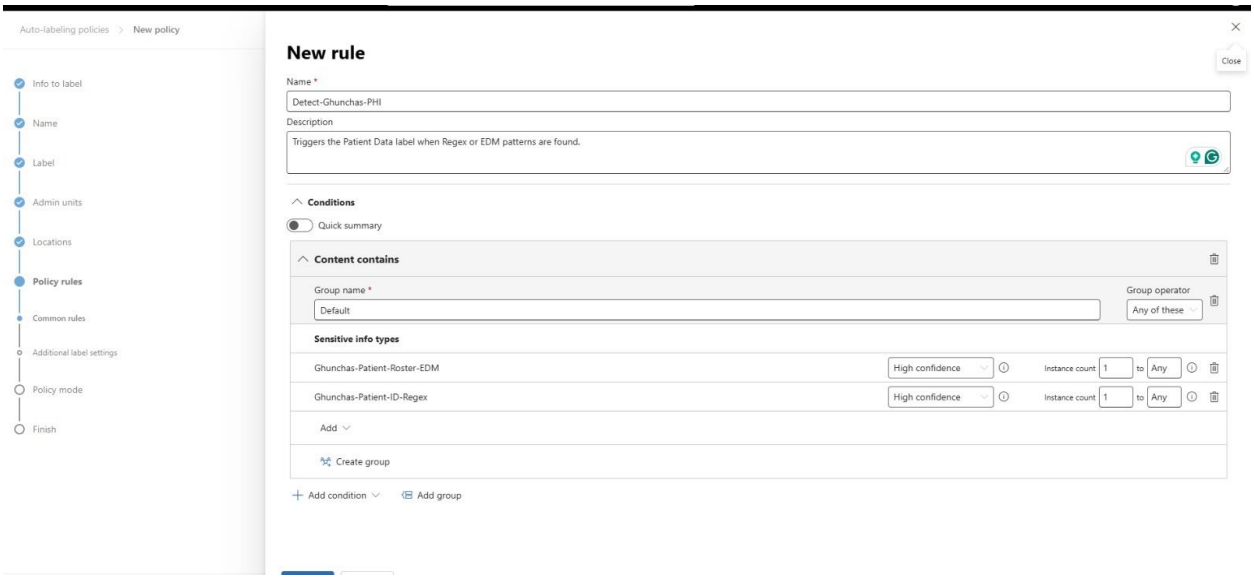
Step 12: Defining the Auto-Label Rules

What we did: We created a rule that looks for our custom classifiers.
Why we did it: This is the trigger. If the system finds the Ghunchas-Patient-Roster-EDM or the Ghunchas-Patient-ID-Regex, it applies the label.

- **[Insert Image: Auto-labeling policy - Define rules]**

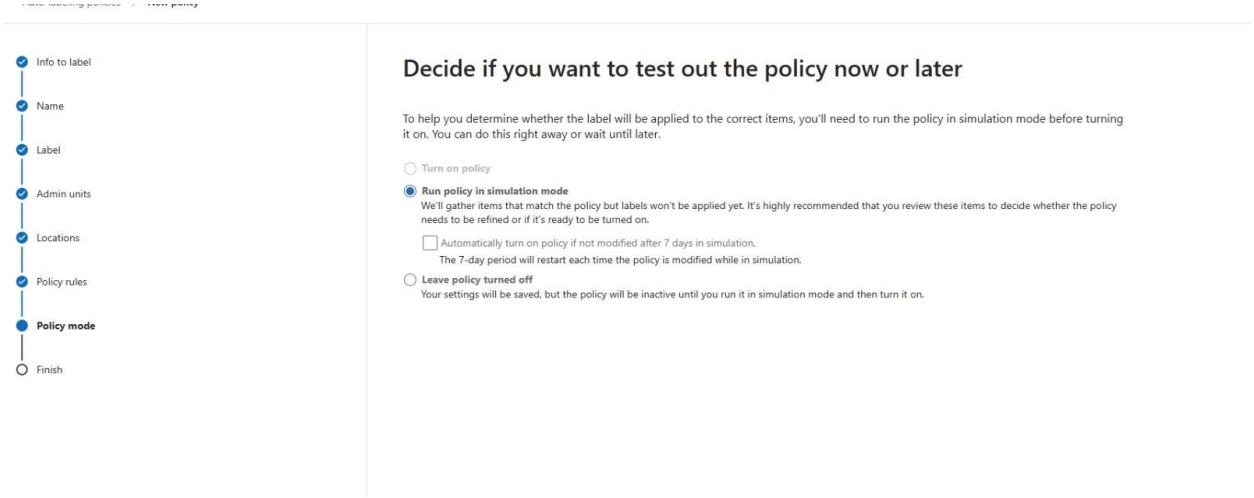


- *Figure 3.23: Creating the new rule for the policy.*
- **[Insert Image: Auto-labeling policy - Content contains]**



- *Figure 3.24: Configuring the condition to trigger on the Ghunchas-Patient-Roster-EDM and Ghunchas-Patient-ID-Regex.*

- **[Insert Image: Auto-labeling policy - Policy mode]**

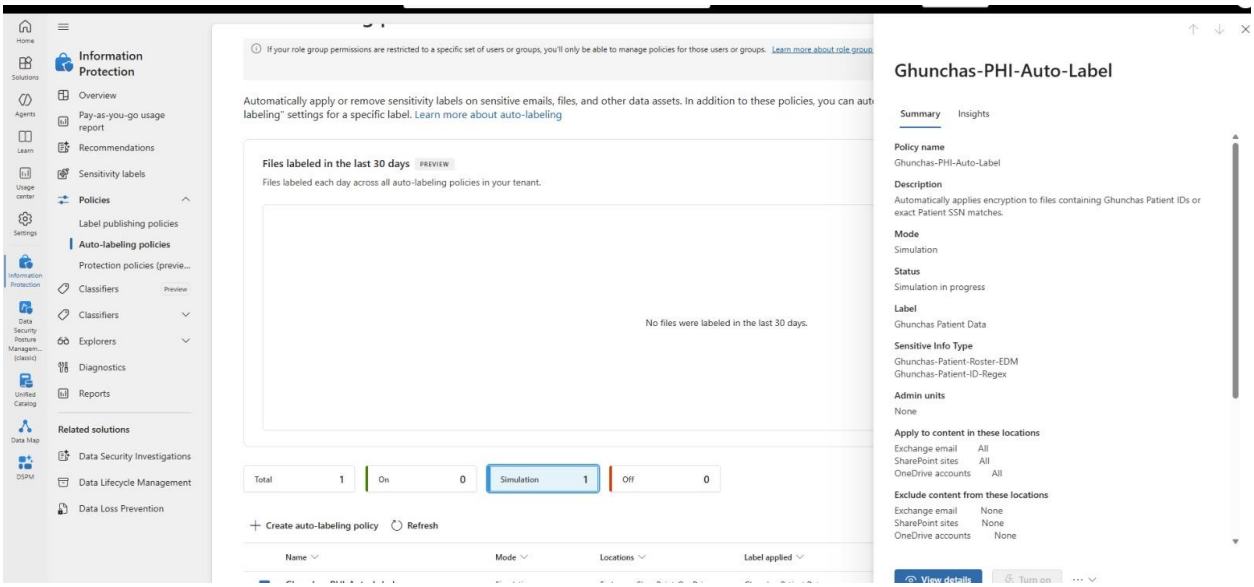


- *Figure 3.25: Setting the policy to "Simulation mode" to review matches before enforcing.*

Step 13: Editing the Auto-Labeling Policy Locations

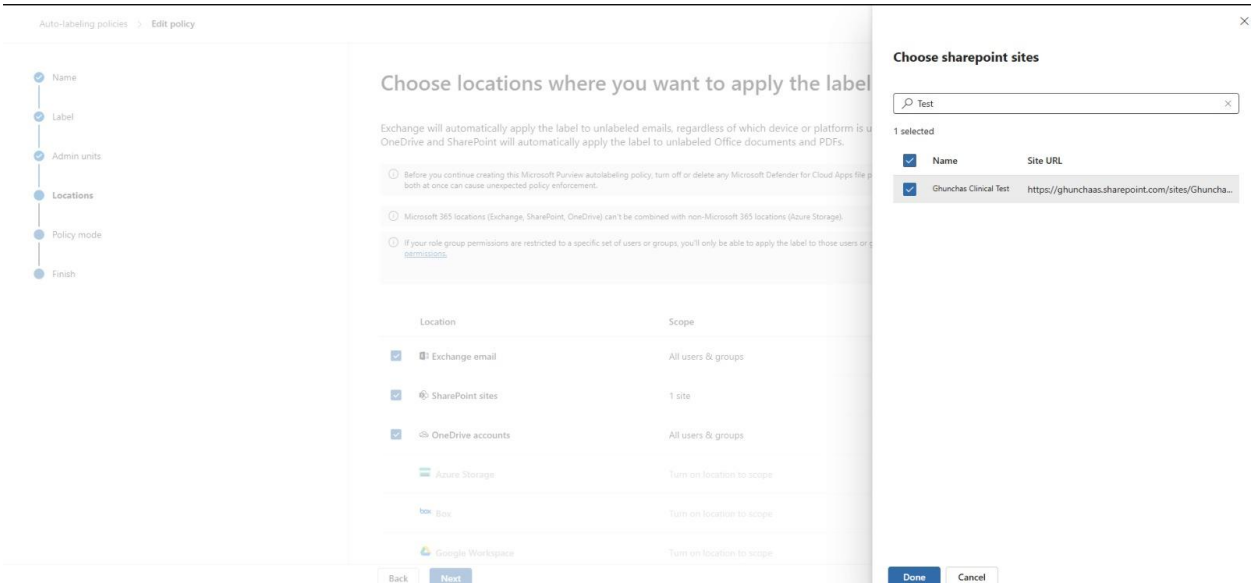
What we did: We edited the auto-labeling policy to apply only to our specific test site.
Why we did it: In a production environment, we would target "All locations." For our lab test, we want to target only the "Ghunchas Clinical Test" site to verify the policy works without affecting the rest of the tenant.

- **[Insert Image: Auto-labeling policy - Summary]**



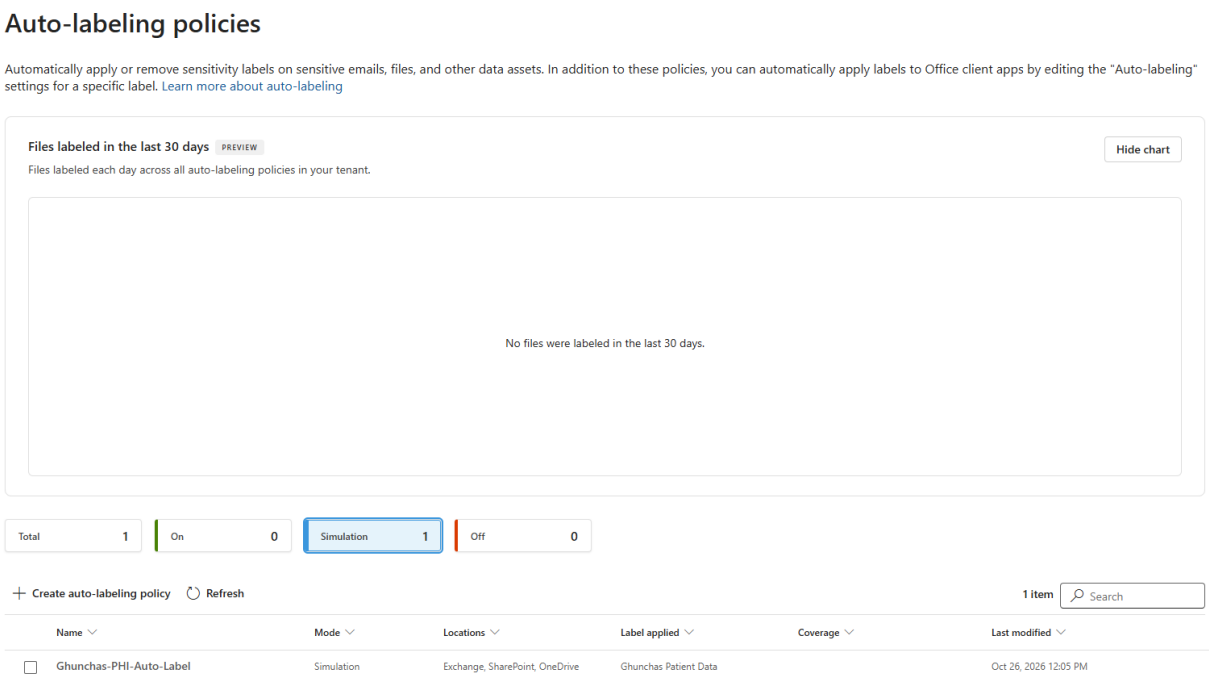
- *Figure 3.26: The policy summary, showing it is running in simulation mode.*

- **[Insert Image: Auto-labeling policy - Choose locations]**



- *Figure 3.27: Editing the locations to target only the "Ghunchas Clinical Test" SharePoint site.*

- **[Insert Image: Auto-labeling policies - Final list]**



- *Figure 3.28: The final list showing the active auto-labeling policy.*

PHASE 4: DATA LOSS PREVENTION (DLP) & ENDPOINT SECURITY

Objective: Stop sensitive data from leaving the organization's boundaries. This phase configures DLP policies to block external sharing of PHI via email, SharePoint, AI (Copilot), and endpoint devices (USB/Clipboard).

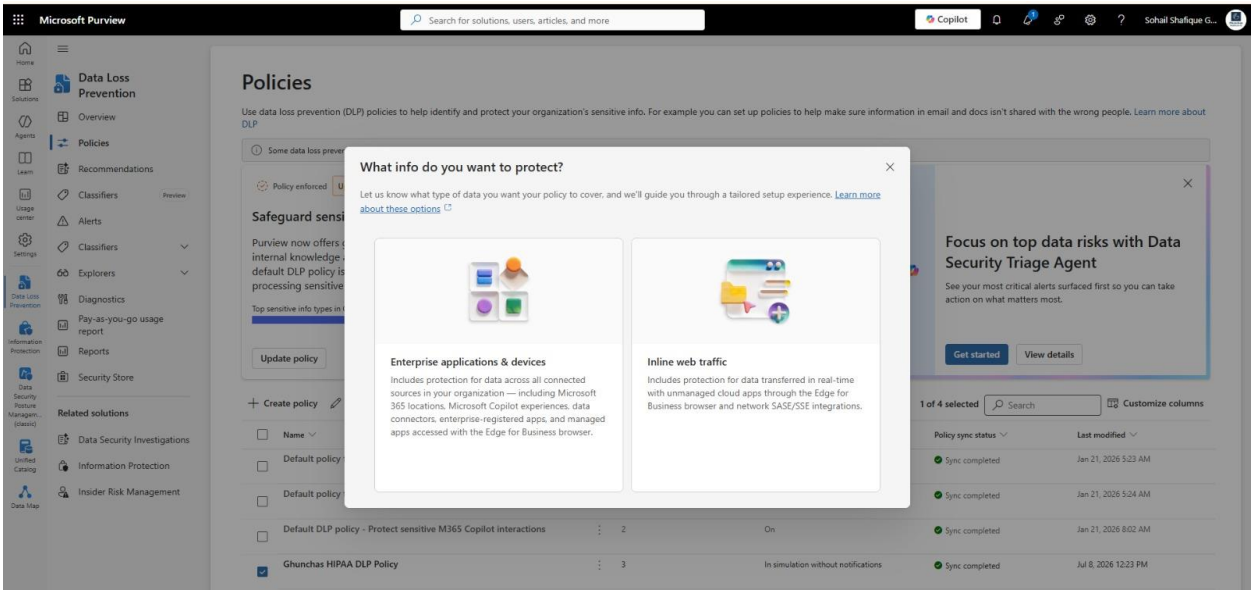
4.1 The Business Value (Why We Do This)

Sensitivity labels protect data at rest, but DLP protects data in motion. For HITRUST compliance, we must prove that PHI cannot be exfiltrated. We deploy DLP rules that detect the Patient Data label and automatically block the action, whether the user is trying to email a patient roster to their personal Gmail, ask Copilot to summarize it, or copy a file to a USB drive.

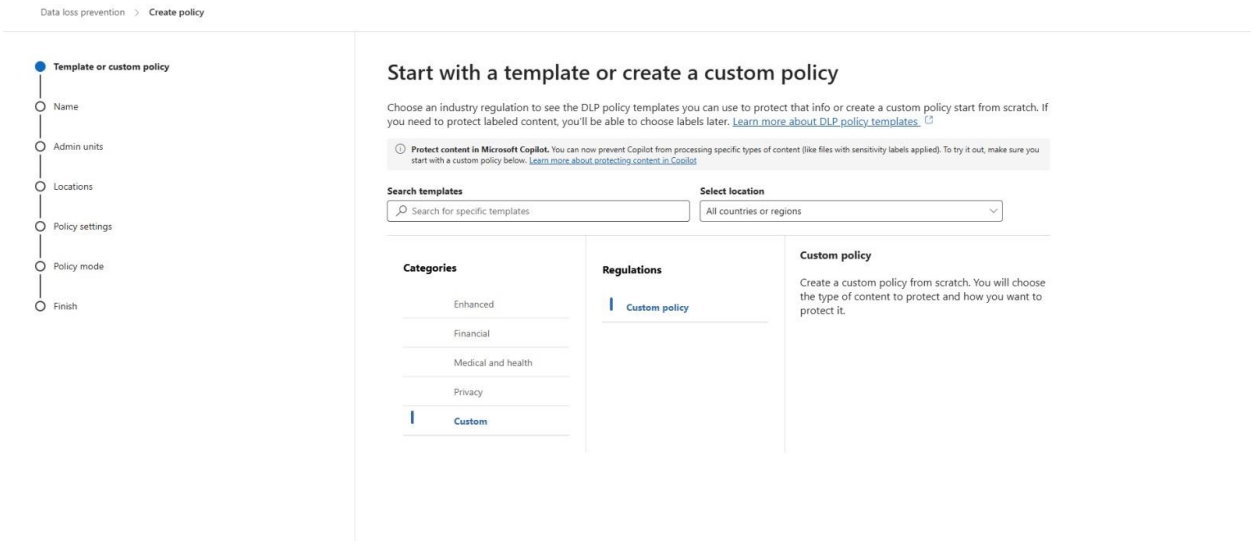
4.2 The Ghunchas Configuration Standard

Step 1: Creating the DLP Policy for Email & Copilot (Custom Policy)
We create a custom DLP policy scoped to Exchange and Copilot. The rule triggers whenever a file is shared externally and contains the "Ghunchas Patient Data" label or matches the EDM/Regex classifiers.

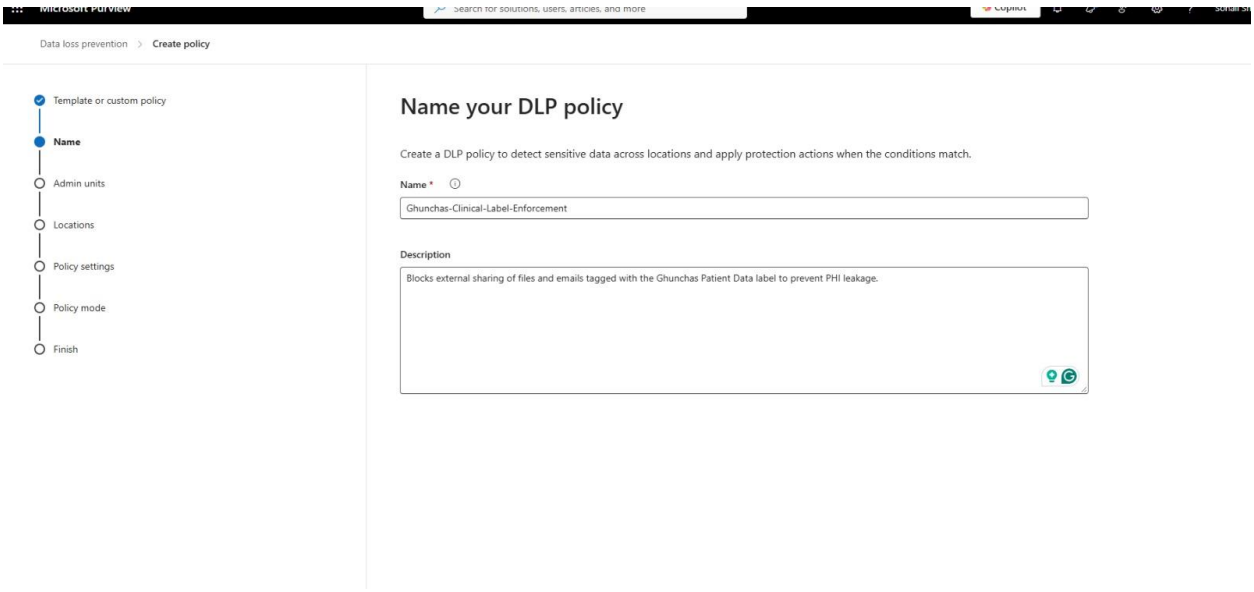
- **[Insert Image: What info do you want to protect? - Enterprise applications & devices]**



  - *Figure 4.1: Selecting the scope for the DLP policy (Enterprise applications).*
- **[Insert Image: Start with a template or create a custom policy]**

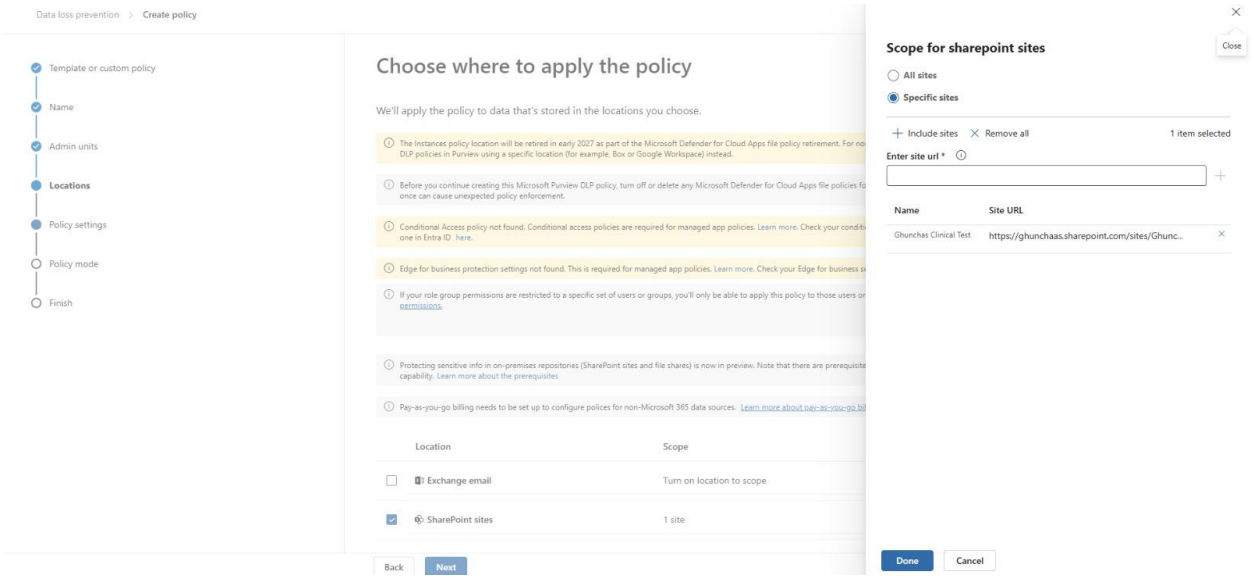


  - *Figure 4.2: Creating a custom policy from scratch.*
- **[Insert Image: Name your DLP policy - Ghunchas-Clinical-Label Enforcement]**



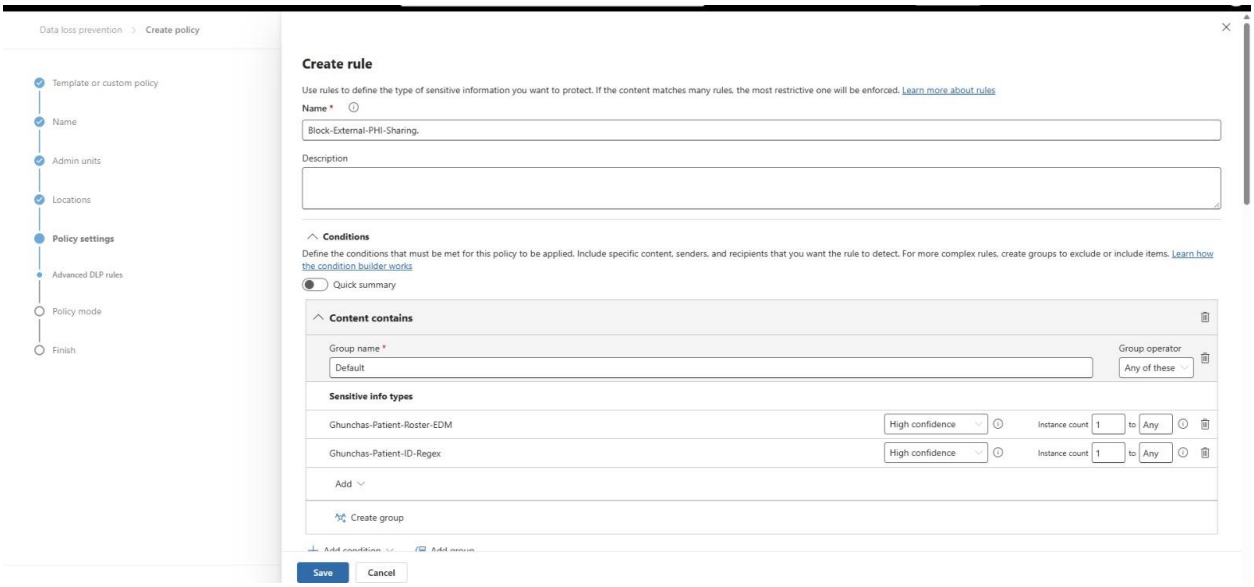
- *Figure 4.3: Naming the policy to reflect its purpose (Clinical Label Enforcement).*

- **[Insert Image: Choose where to apply the policy]**



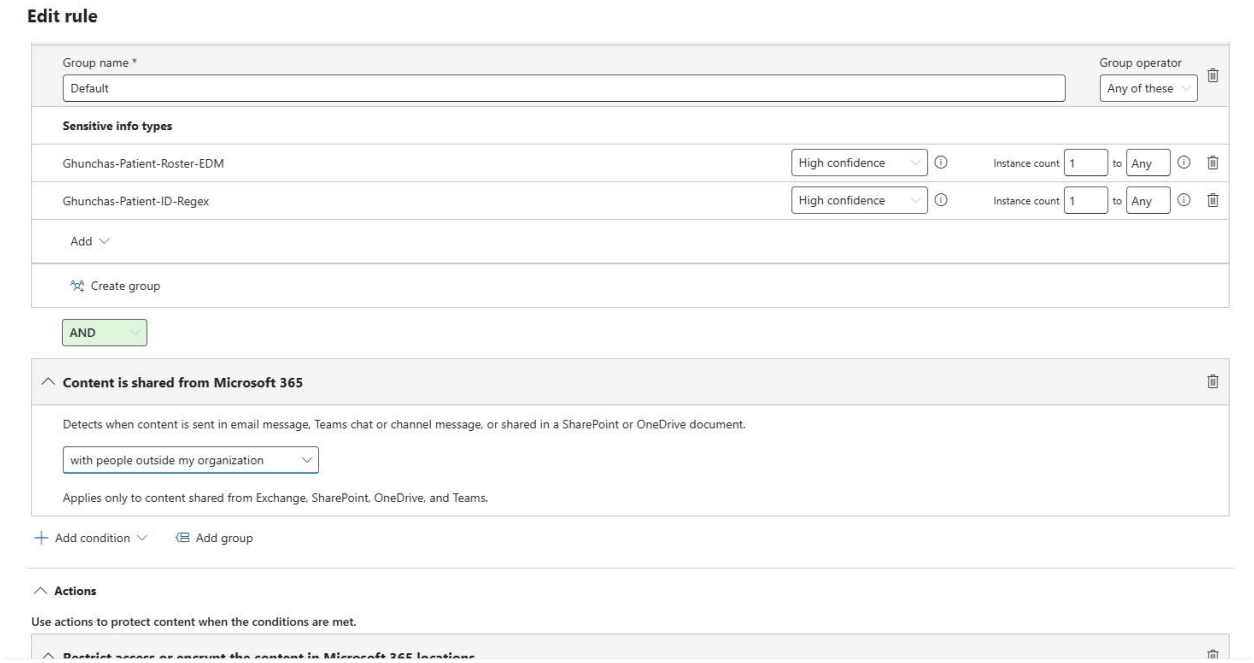
- *Figure 4.4: Scoping the policy to the specific SharePoint test site.*

- **[Insert Image: Create rule - Block External PHI Sharing]**



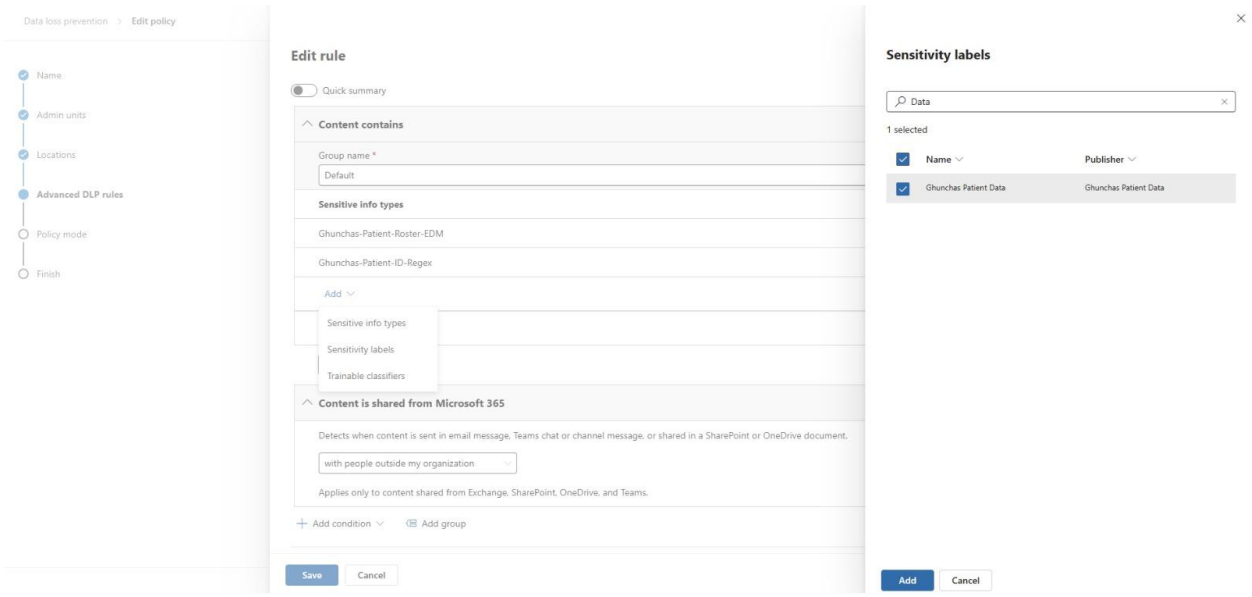
- *Figure 4.5: Configuring the rule to detect the Patient Data label and EDM classifiers.*

- **[Insert Image: Content is shared from Microsoft 365]**



- *Figure 4.6: Adding the condition to block sharing with people outside the organization.*

- **[Insert Image: Add sensitivity labels to DLP rule]**

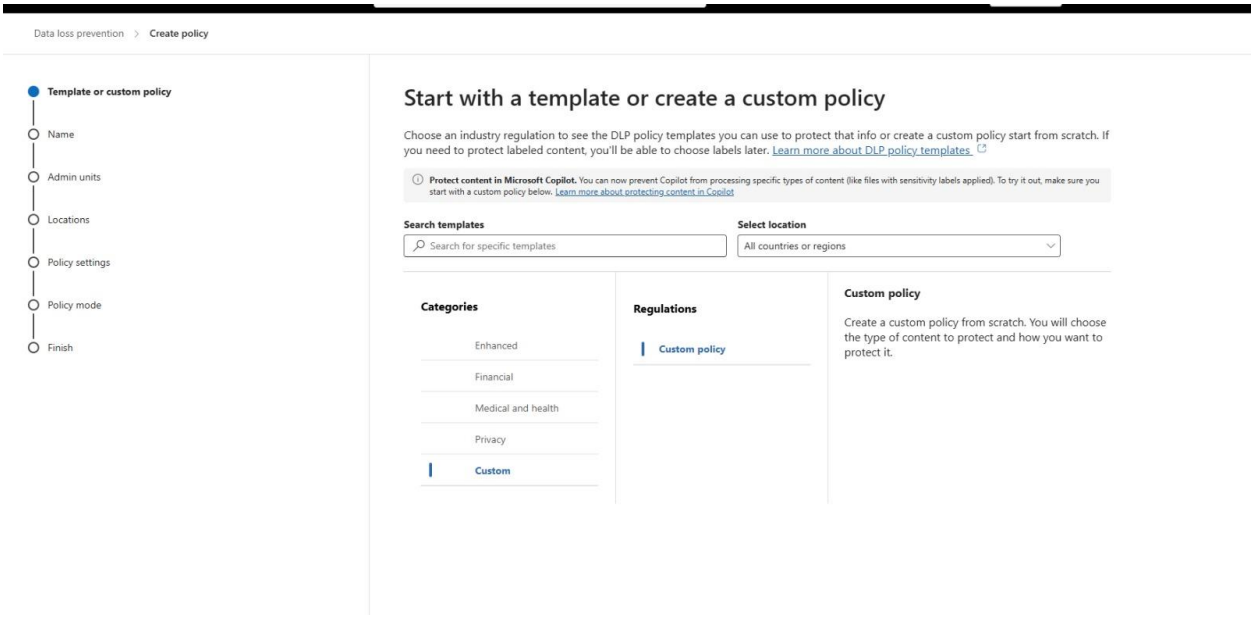


- *Figure 4.7: Adding the "Ghunchas Patient Data" sensitivity label as a condition.*

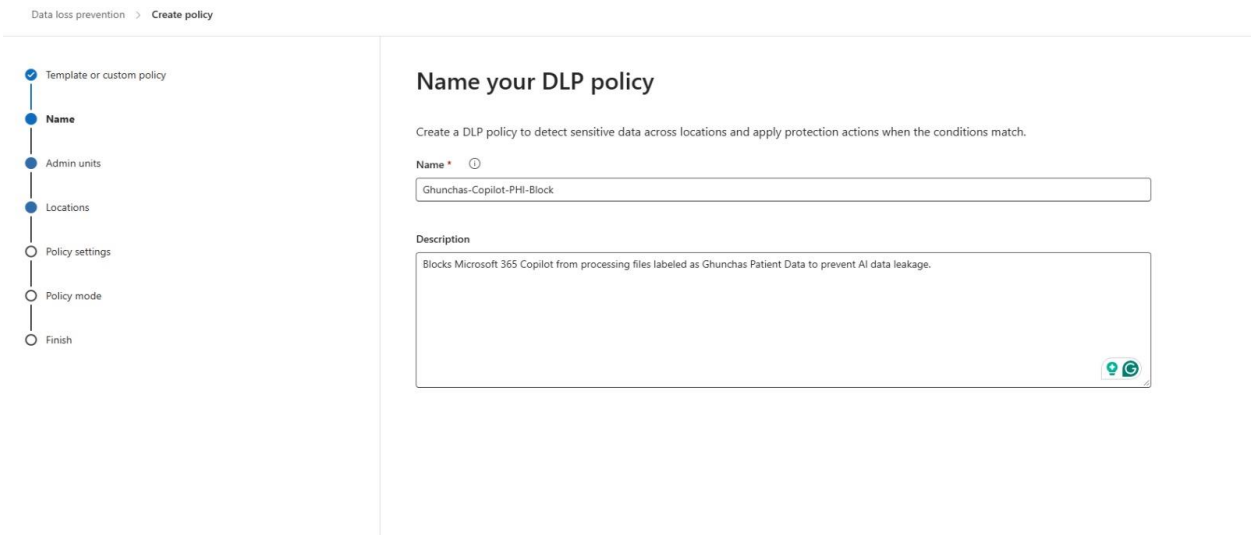
Step 2: Creating the Copilot-Specific DLP Policy

To ensure AI doesn't leak data, we create a dedicated policy that blocks Microsoft 365 Copilot from processing files tagged with the Patient Data label.

- **[Insert Image: Start with a template - Custom policy (Copilot)]**

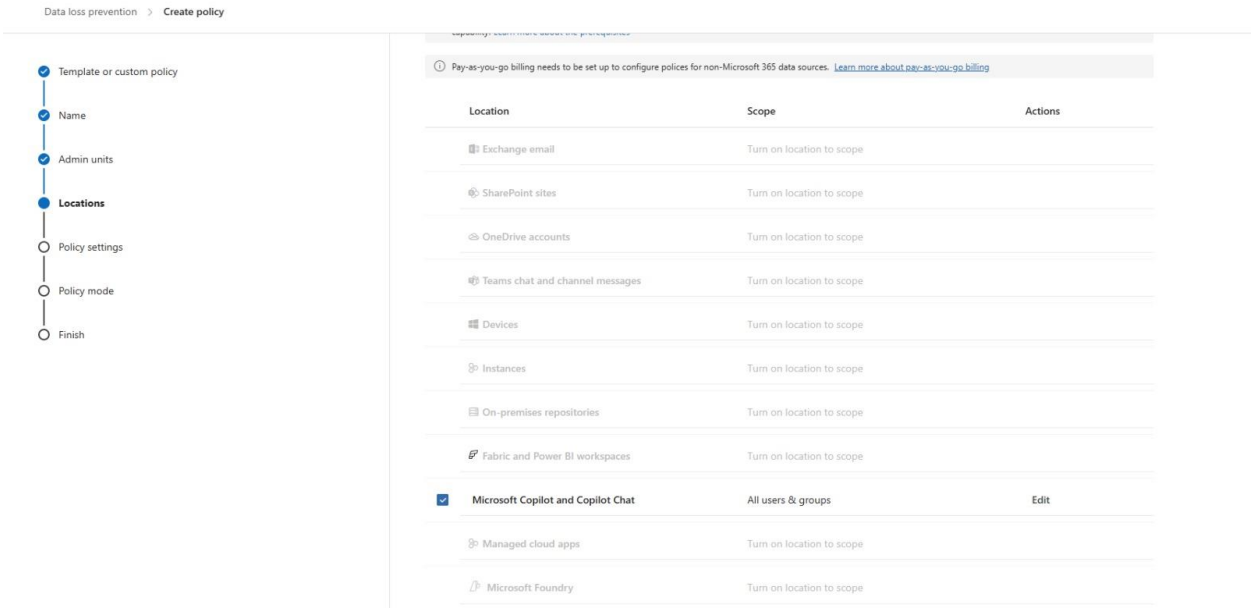


- *Figure 4.8: Creating a new custom policy specifically for Copilot.*
- **[Insert Image: Name your DLP policy - Ghunchas-Copilot-PHI-Block]**



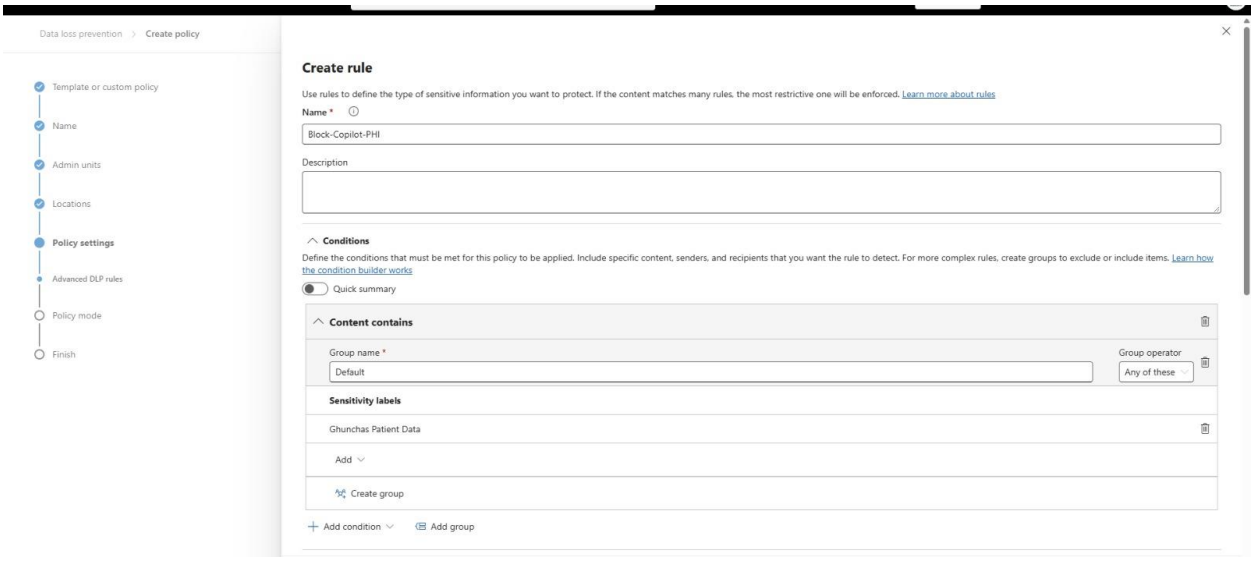
- *Figure 4.9: Naming the Copilot DLP policy.*

- **[Insert Image: Locations - Microsoft Copilot and Copilot Chat]**



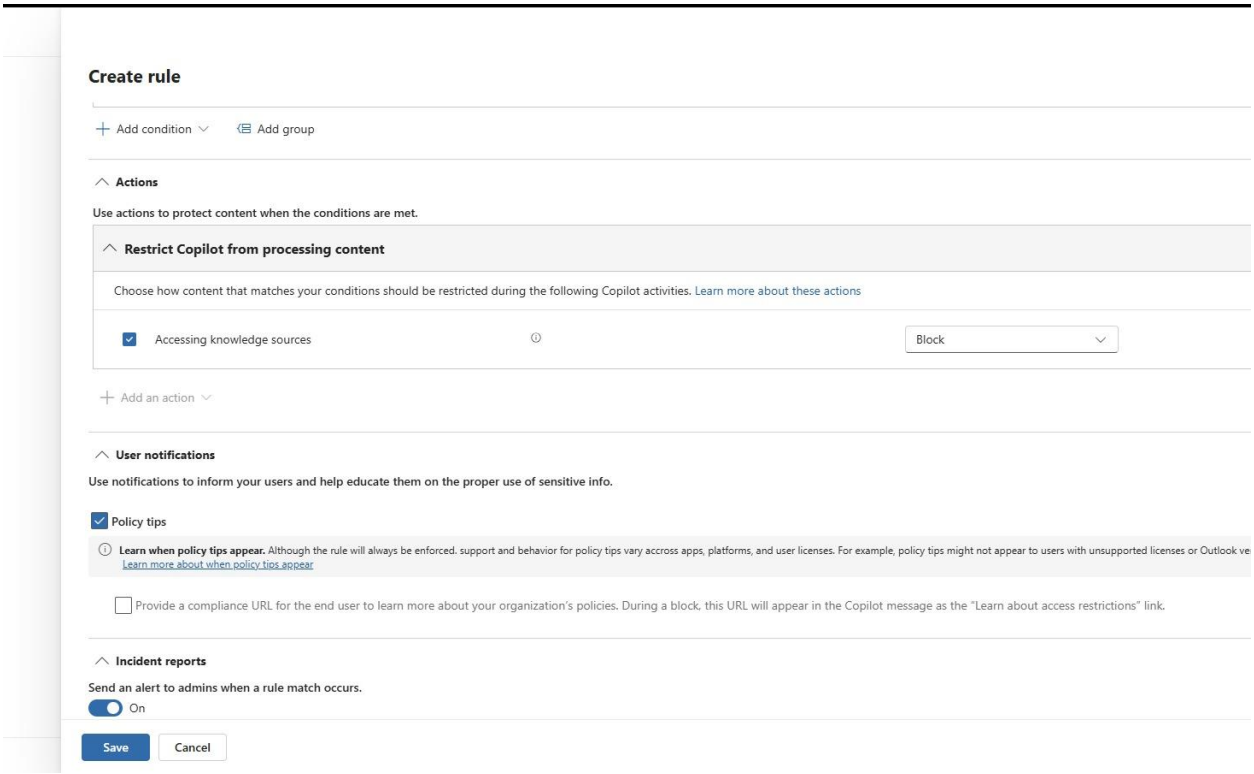
- *Figure 4.10: Scoping the policy only to Microsoft Copilot and Copilot Chat.*

- **[Insert Image: Create rule - Block Copilot PHI]**



- *Figure 4.11: Configuring the rule to trigger on the Patient Data label.*

- **[Insert Image: Restrict Copilot from processing content]**

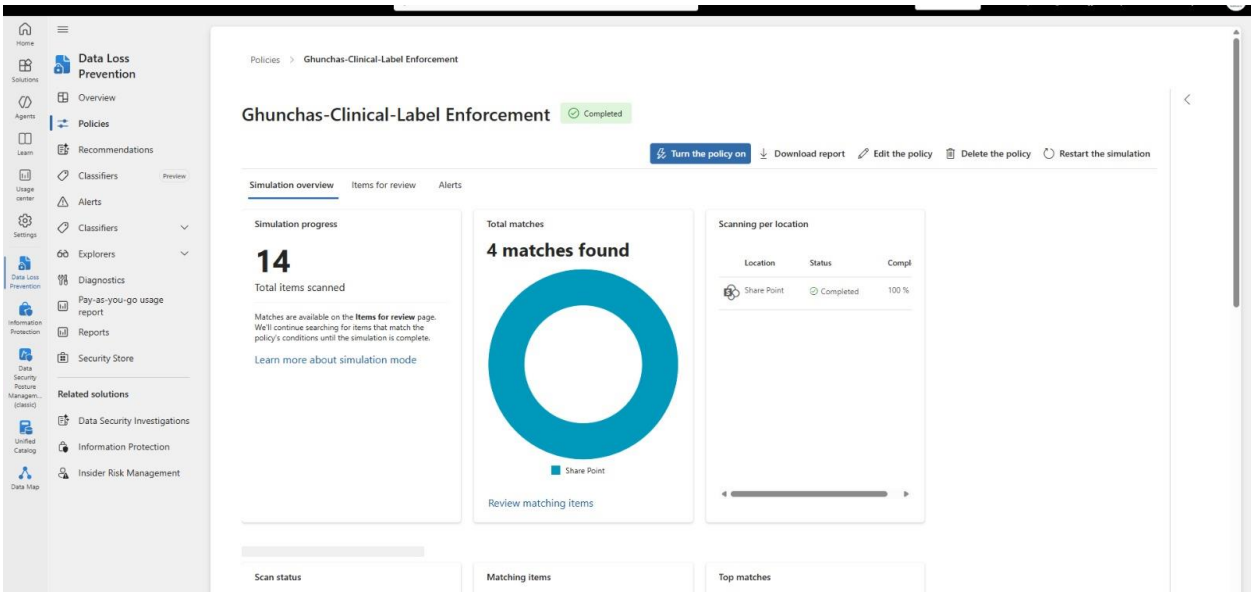


- *Figure 4.12: Setting the action to "Block" when Copilot accesses knowledge sources.*

Step 3: Testing & Validation (Lab Proof)

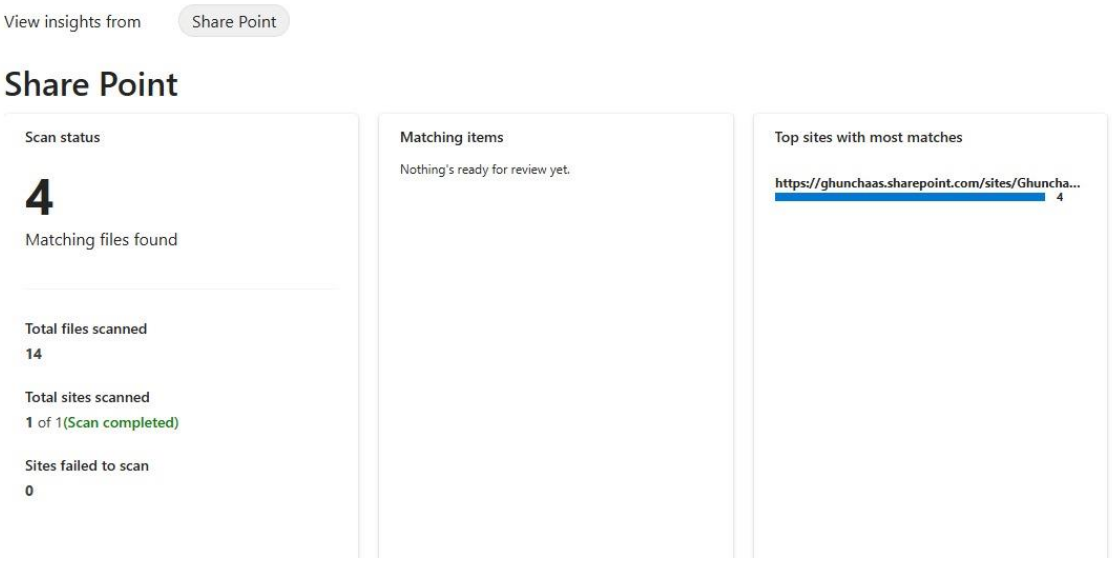
We validate that the policies work by simulating real user behavior. We test sending an email with PHI to an external address, and we test attempting to use Copilot with protected files.

- **[Insert Image: DLP Simulation - 4 matches found]**



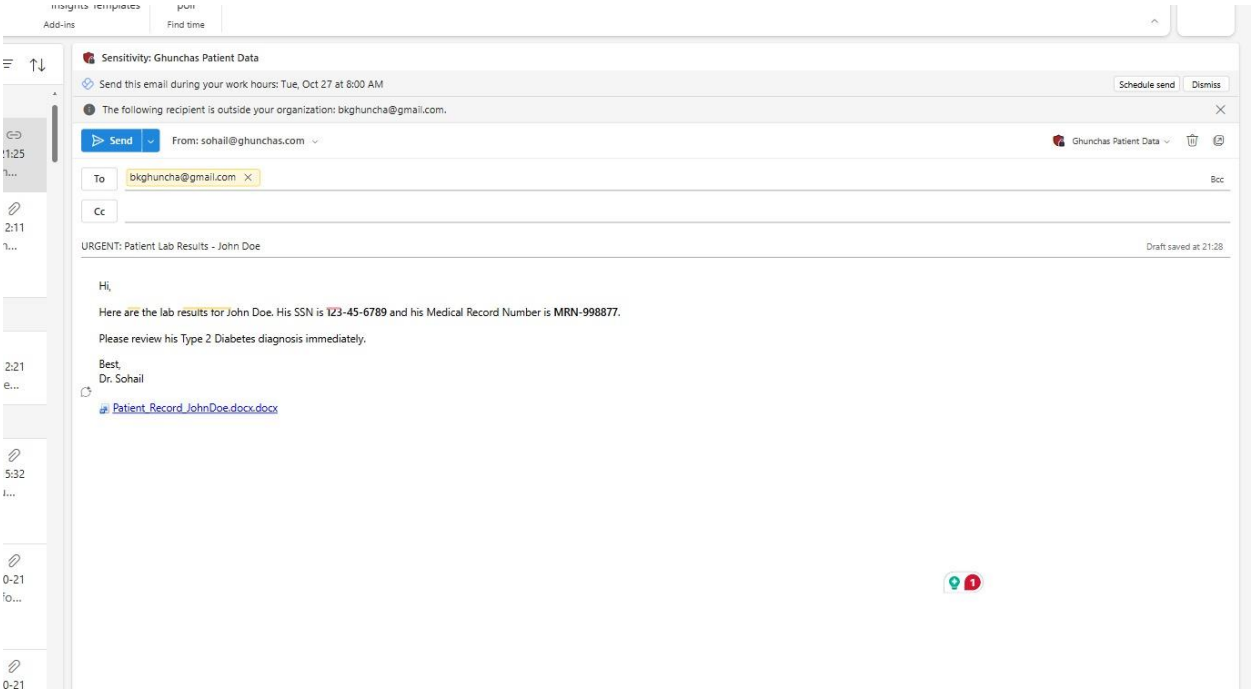
  - *Figure 4.13: The DLP simulation catching PHI in SharePoint.*

- **[Insert Image: SharePoint insight - 4 matching files]**



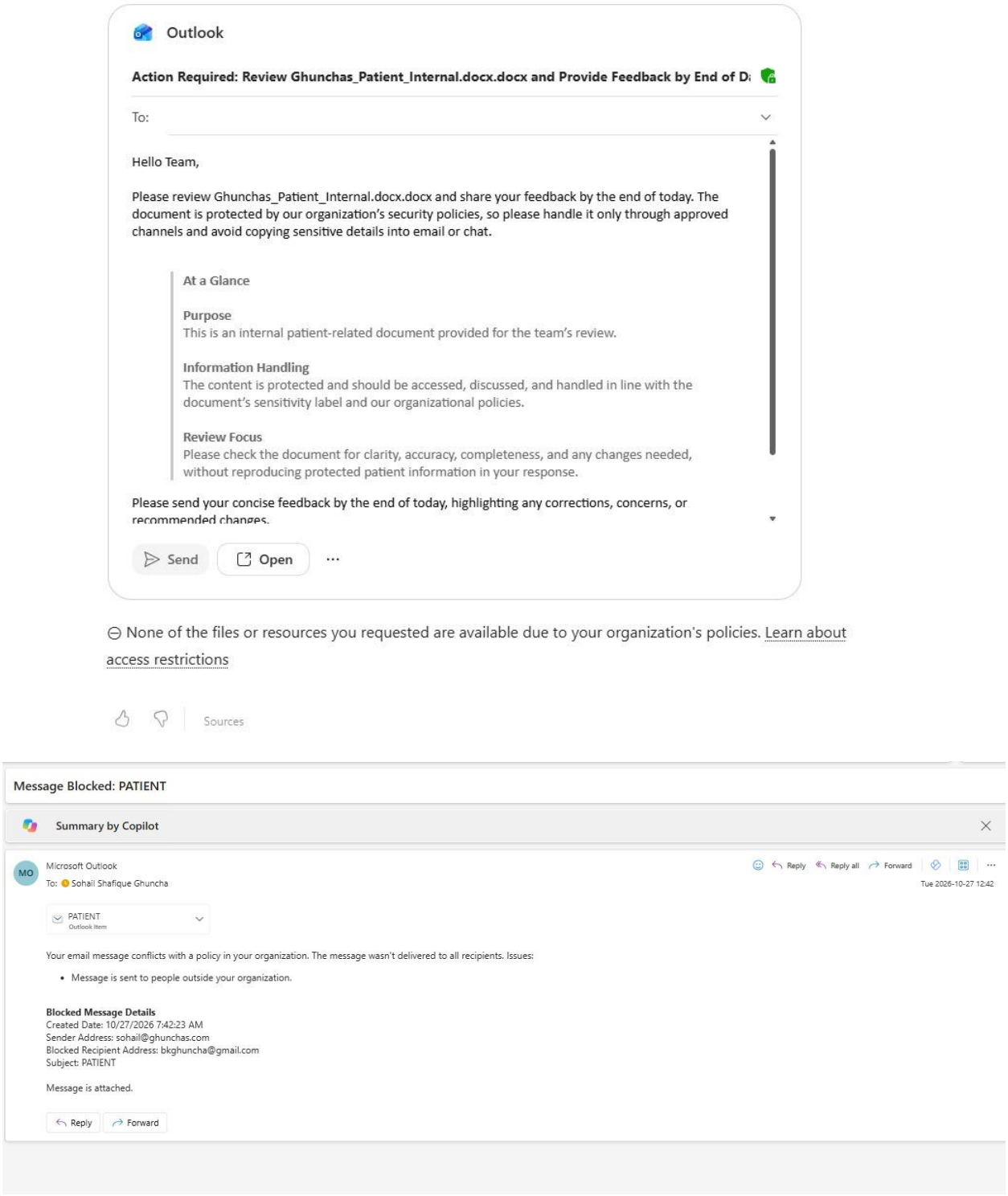
  - *Figure 4.14: Detailed breakdown of the 4 matching files in SharePoint.*

- **[Insert Image: Outlook - Sensitivity Ghunchas Patient Data]**



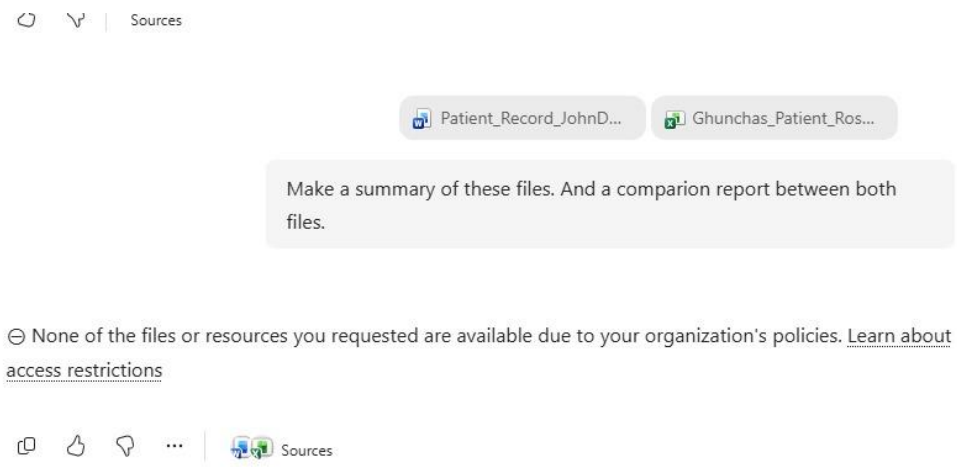
- *Figure 4.15: The email composed to an external address, showing the "Ghunchas Patient Data" label.*

- **[Insert Image: Message Blocked - PATIENT]**



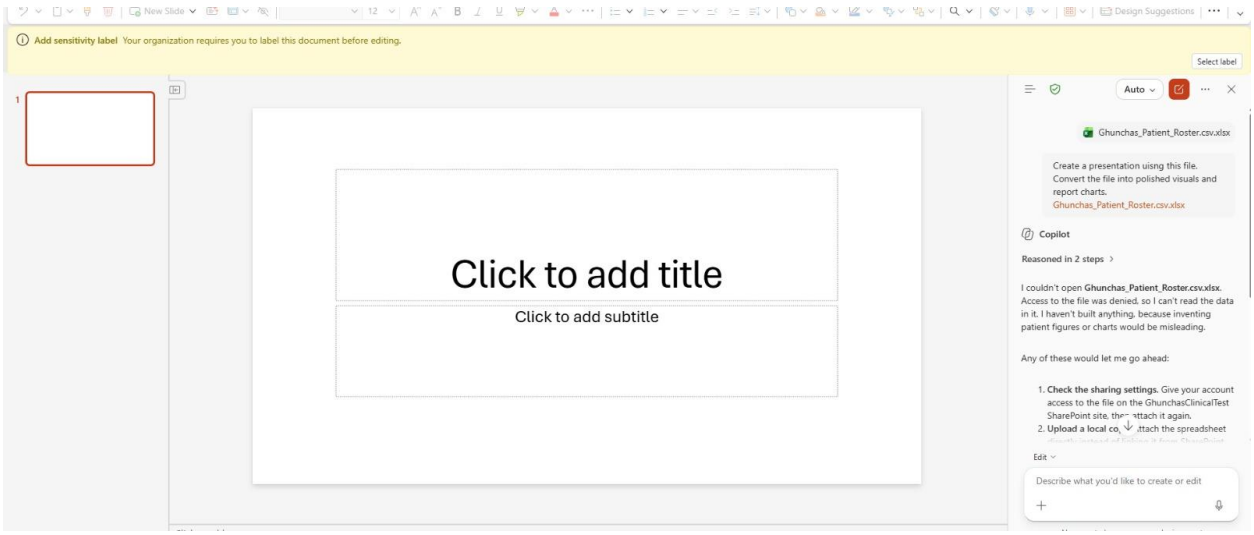
- *Figure 4.16: The blocked email notification. The user cannot send PHI externally.*

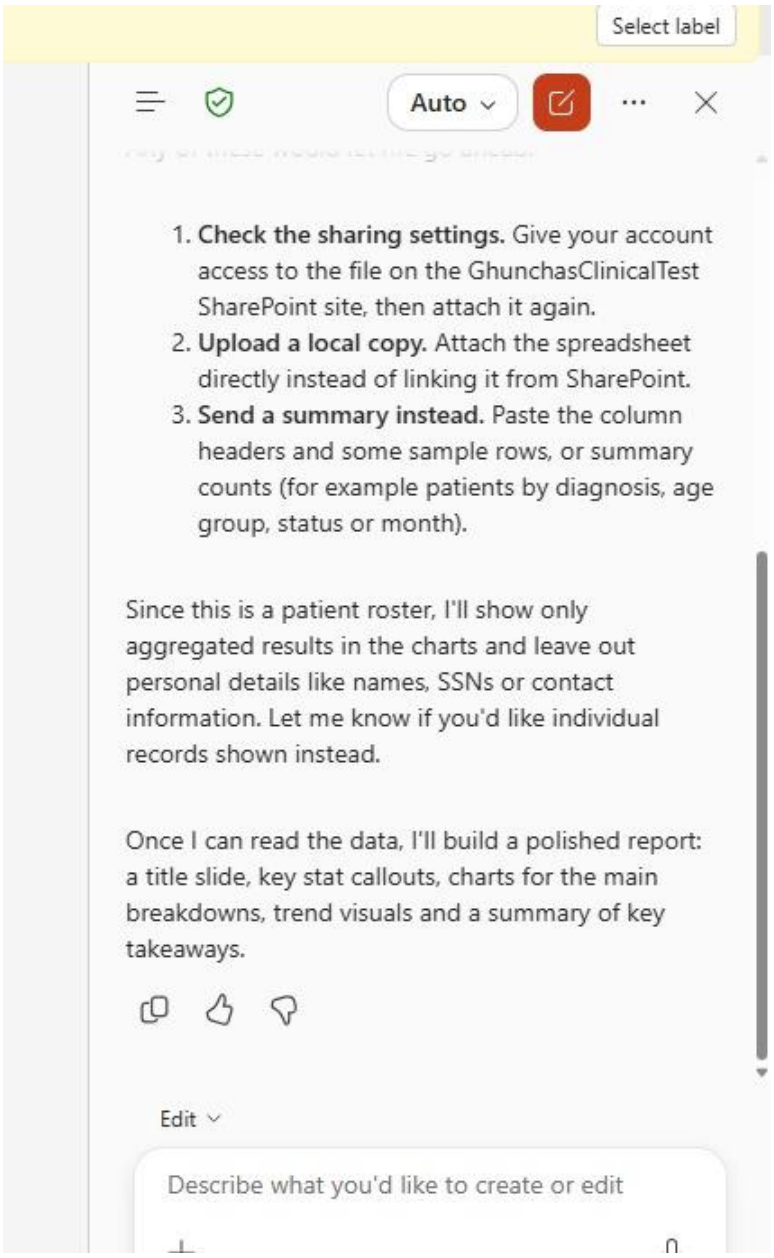
- **[Insert Image: Copilot - None of the files are available]**



- *Figure 4.17: Copilot refusing to process the request because the files are protected by DLP.*

- **[Insert Image: PowerPoint - Add sensitivity label]**


New Slide
Design Suggestions
Add sensitivity label Your organization requires you to label this document before editing.
Select label
Click to add title
Click to add subtitle
Auto
Ghunchas_Patient_Roster.csv.xlsx
Create a presentation uisng this file. Convert the file into polished visuals and report charts.
Ghunchas_Patient_Roster.csv.xlsx
Copilot
Reasoned in 2 steps
I couldn't open Ghunchas_Patient_Roster.csv.xlsx. Access to the file was denied, so I can't read the data in it. I haven't built anything, because inventing patient figures or charts would be misleading.
Any of these would let me go ahead:
1. Check the sharing settings. Give your account access to the file on the GhunchasClinicalTest SharePoint site, then attach it again.
2. Upload a local co ttach the spreadsheet
Edit
Describe what you'd like to create or edit

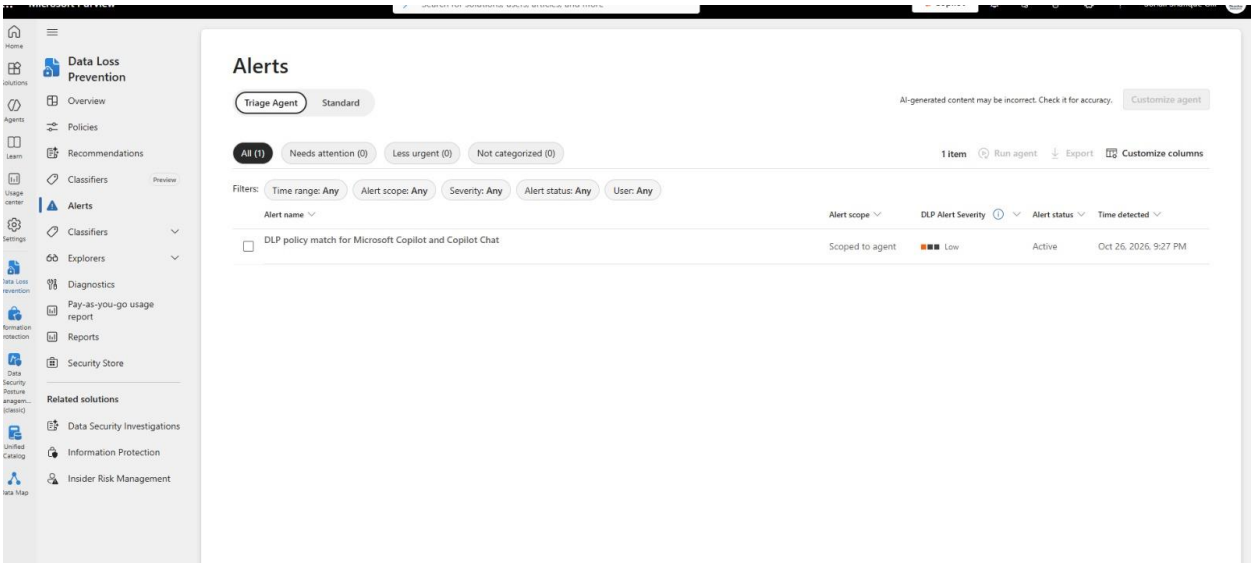


- *Figure 4.18: PowerPoint blocking editing because the document requires a sensitivity label.*

Step 4: Reviewing the DLP Alerts

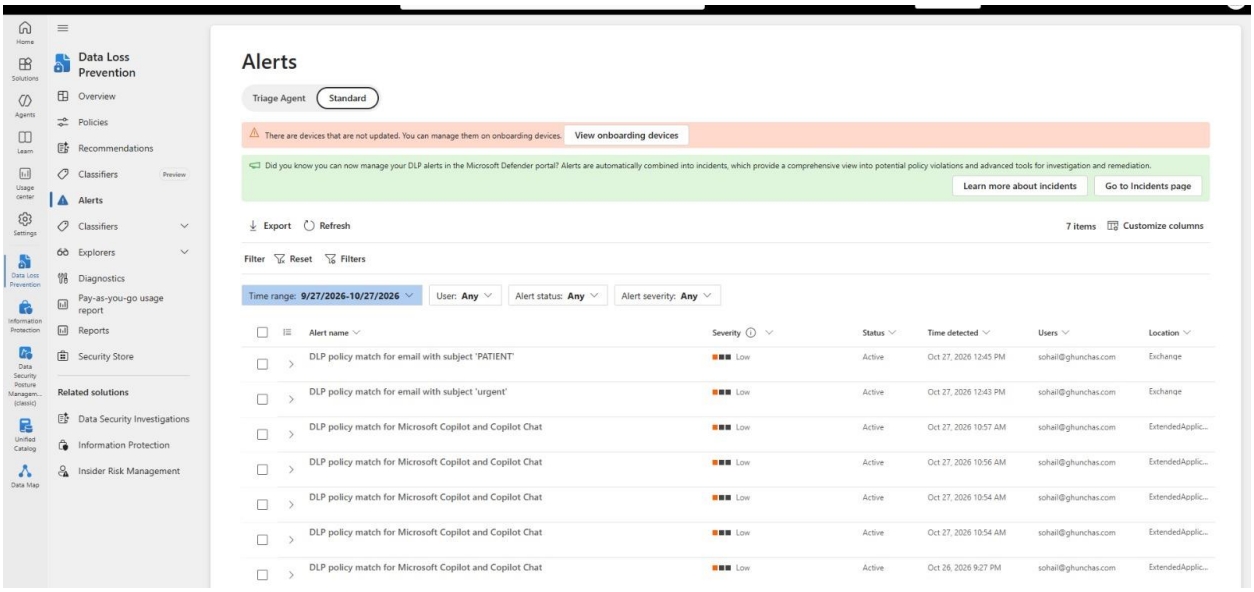
We review the alert dashboard to ensure the policies are logging incidents for investigation.

- **[Insert Image: DLP Alerts - Copilot policy match]**



- *Figure 4.19: The alert generated by the Copilot DLP policy.*

- **[Insert Image: DLP Alerts - Email and Copilot matches]**

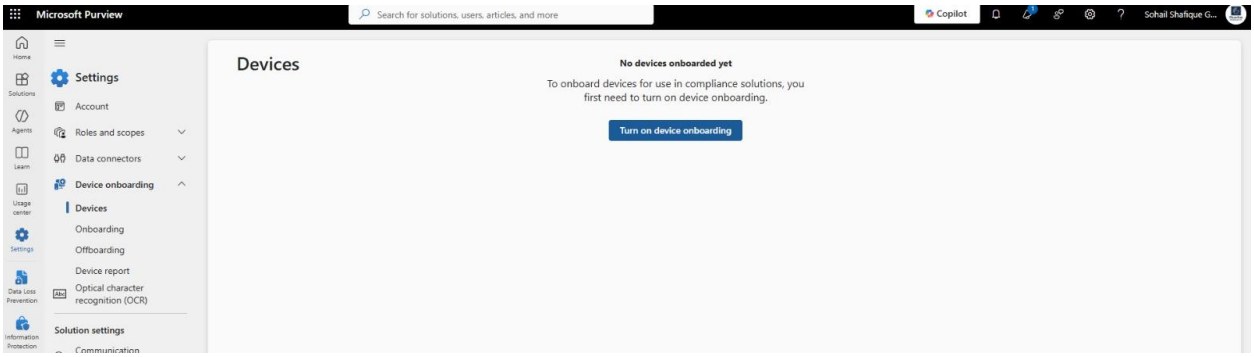


- *Figure 4.20: The full alert list, showing both email and Copilot matches.*

Step 5: Endpoint Device Onboarding

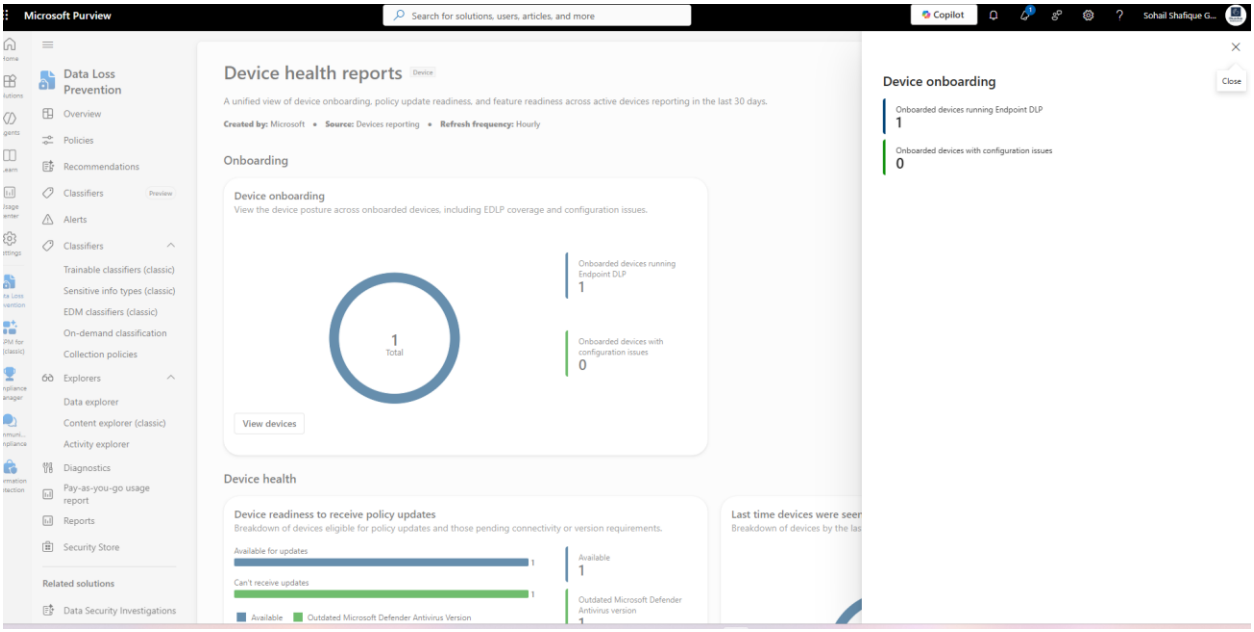
To protect data on local devices (USB, Clipboard, Browser), we enable device onboarding in Purview.

- **[Insert Image: Settings - Device onboarding]**



- *Figure 4.21: Enabling device onboarding in Purview Settings.*

- **[Insert Image: Device health reports]**

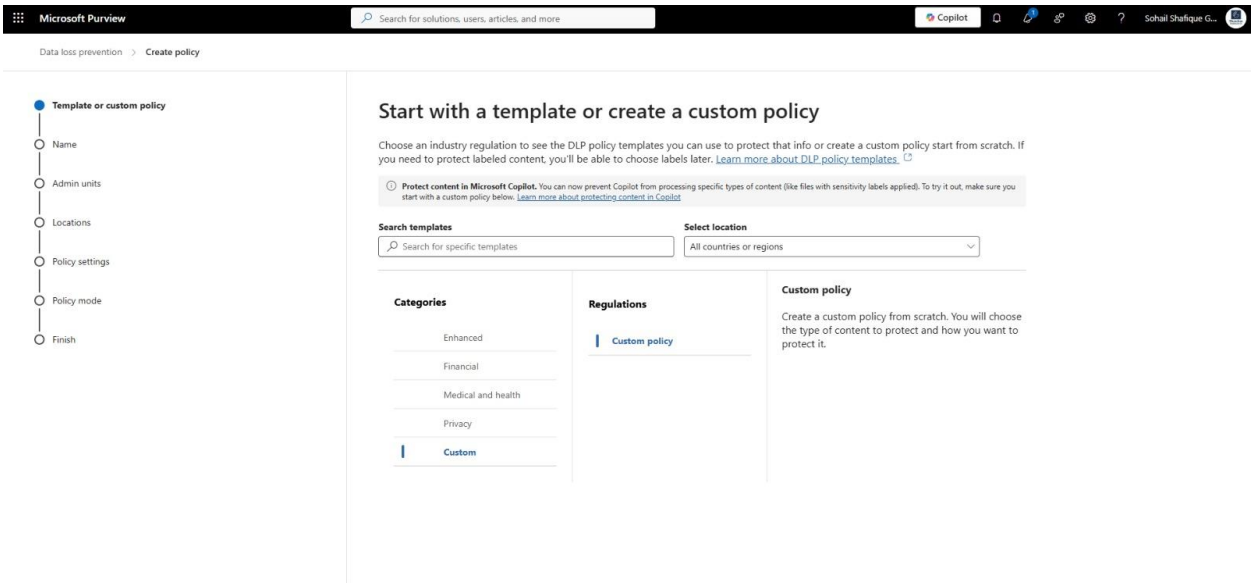


- *Figure 4.22: The device health dashboard, showing 1 onboarded device running Endpoint DLP.*

Step 6: Creating the Endpoint DLP Policy

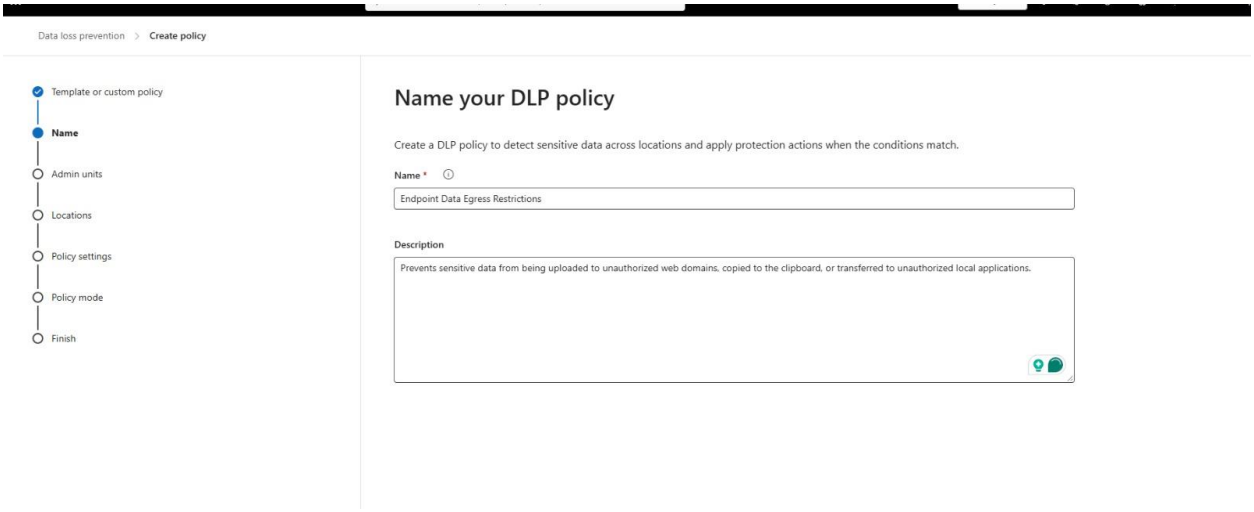
We create a custom Endpoint DLP policy to block sensitive data from being uploaded to unauthorized web domains, copied to the clipboard, or transferred to unauthorized local applications.

- **[Insert Image: Start with a template - Custom policy (Endpoint)]**



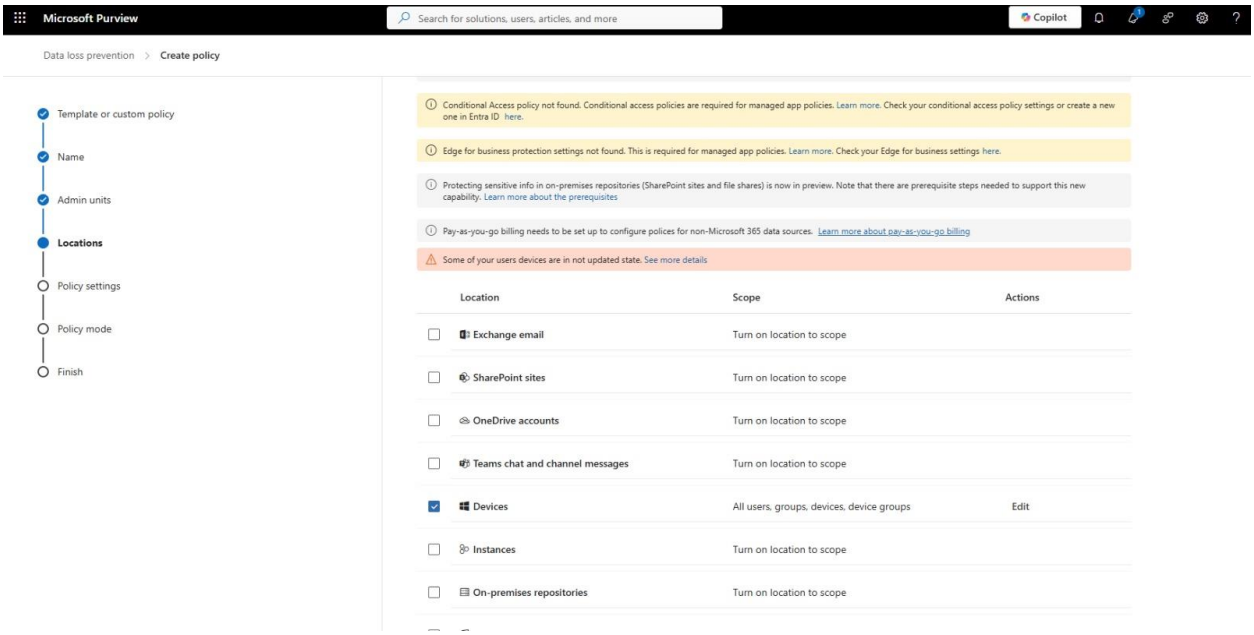
- *Figure 4.23: Creating the custom Endpoint DLP policy.*

- **[Insert Image: Name your DLP policy - Endpoint Data Egress Restrictions]**



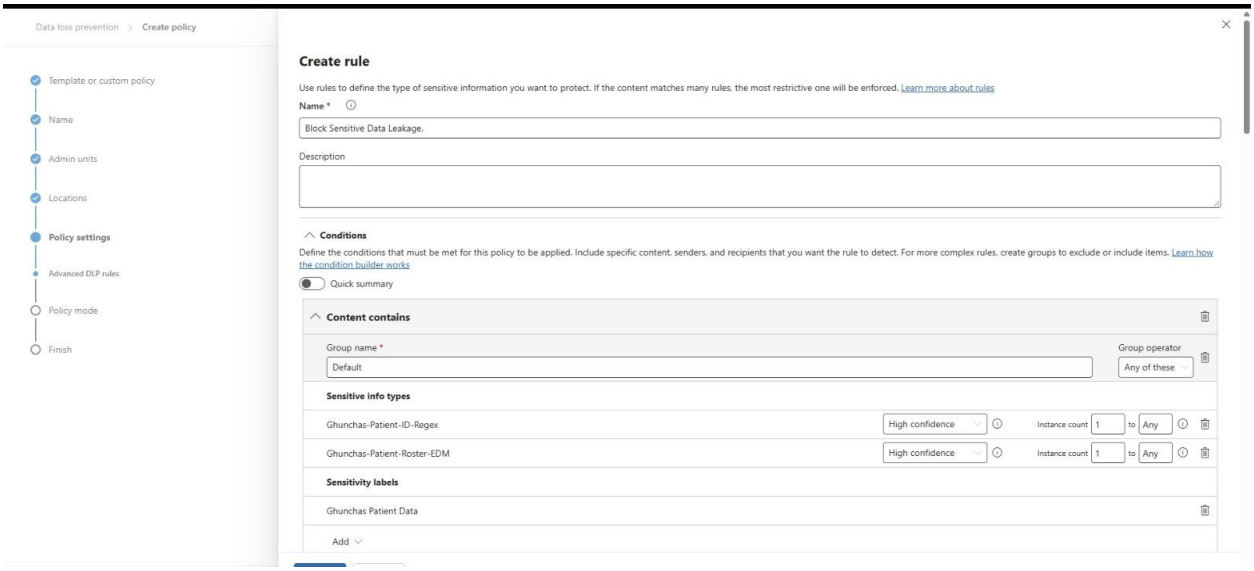
- *Figure 4.24: Naming the Endpoint DLP policy.*

- **[Insert Image: Locations - Devices]**



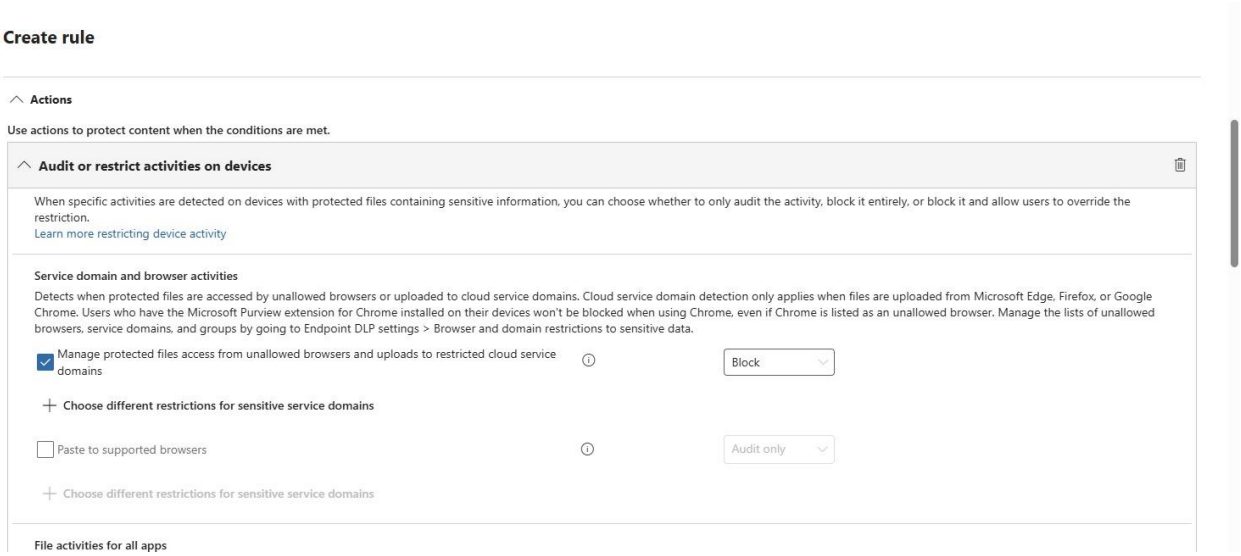
- *Figure 4.25: Scoping the policy to all onboarded devices.*

- **[Insert Image: Create rule - Block Sensitive Data Leakage]**



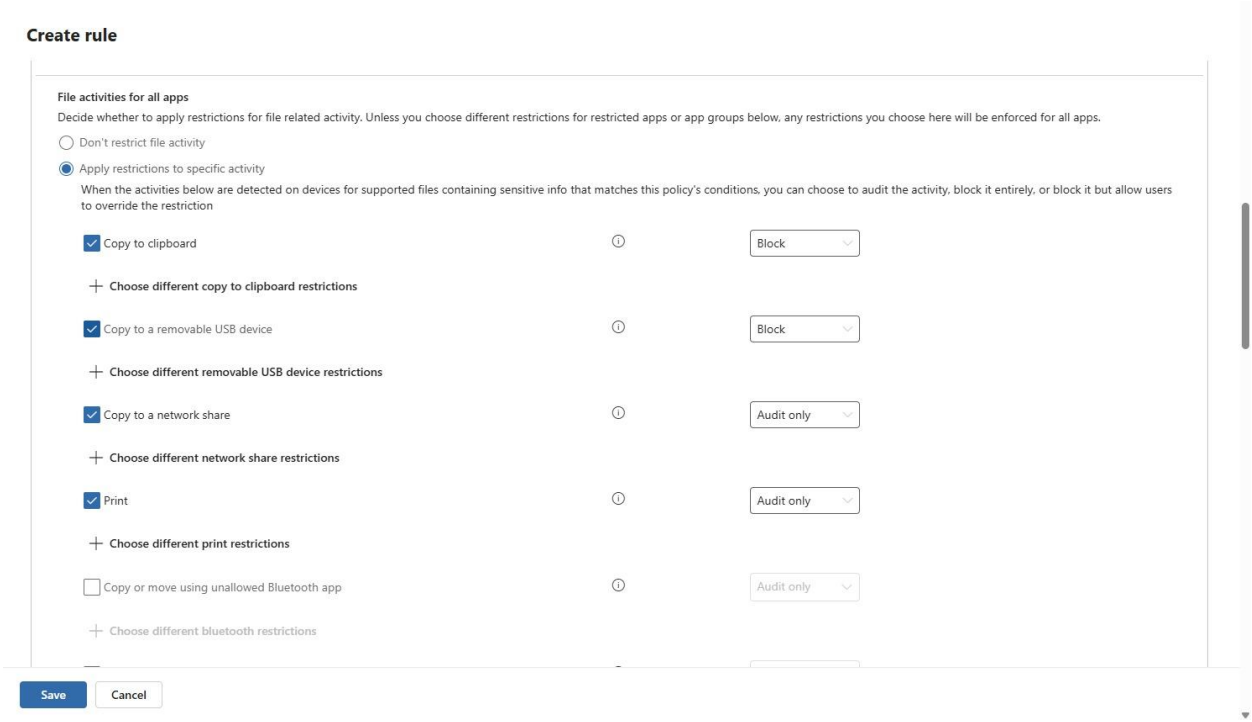
- *Figure 4.26: Configuring the rule to detect the Patient Data label.*

- **[Insert Image: Audit or restrict activities on devices]**



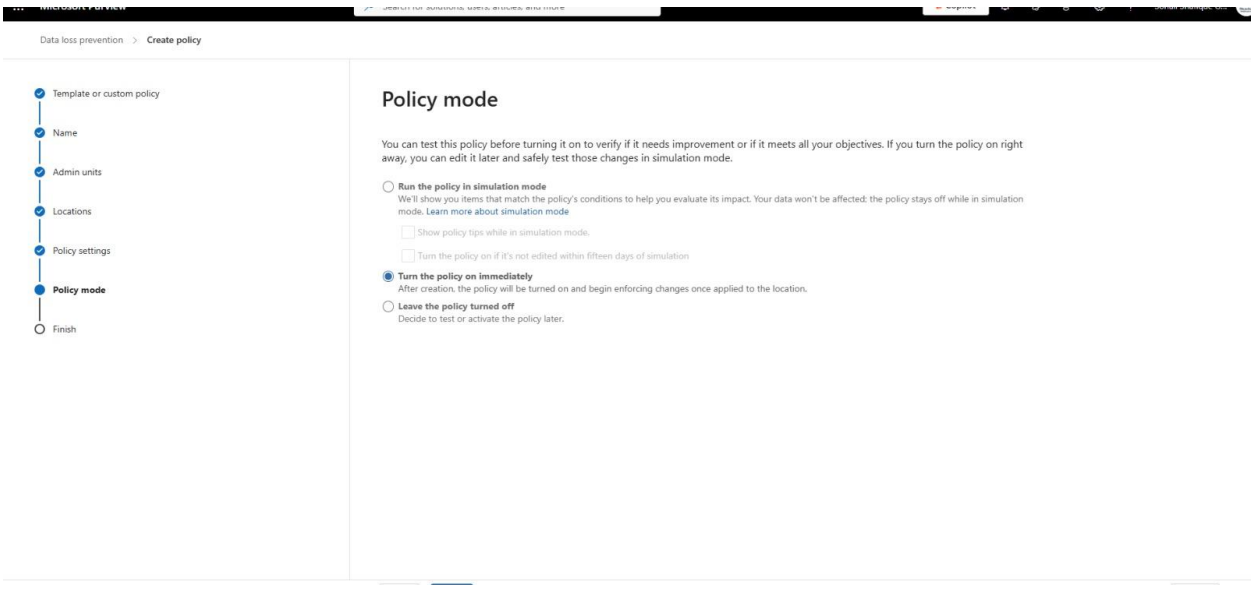
- *Figure 4.27: Setting the action to Block uploads to unauthorized web domains.*

- **[Insert Image: File activities for all apps]**



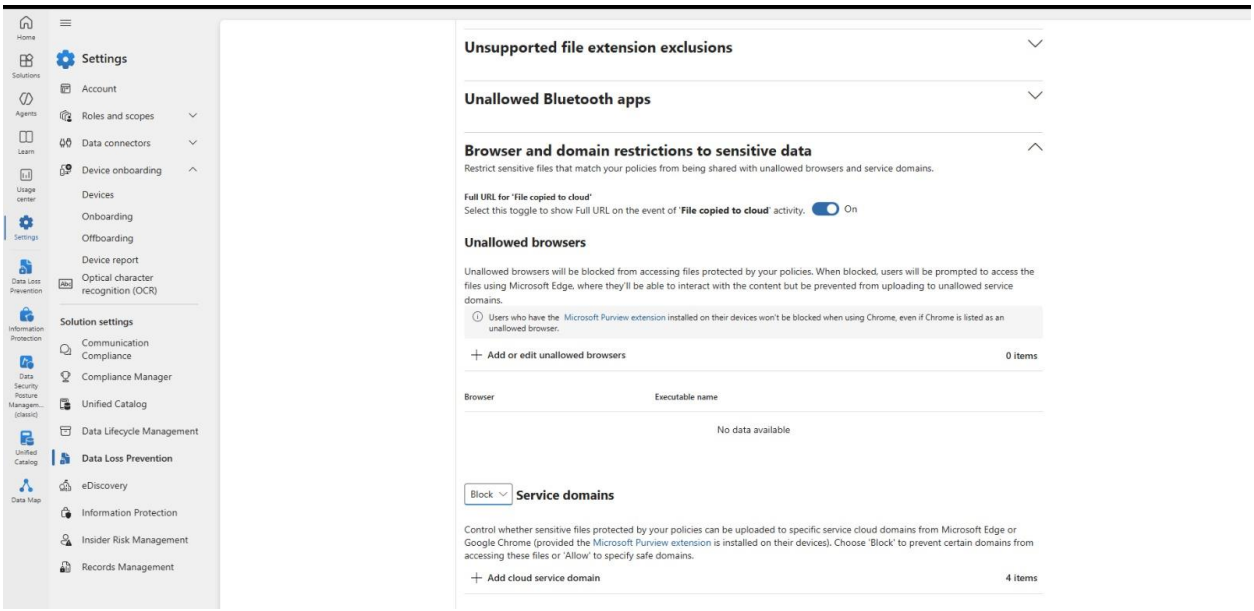
- *Figure 4.28: Enforcing Block actions for Copy to Clipboard and USB Devices.*

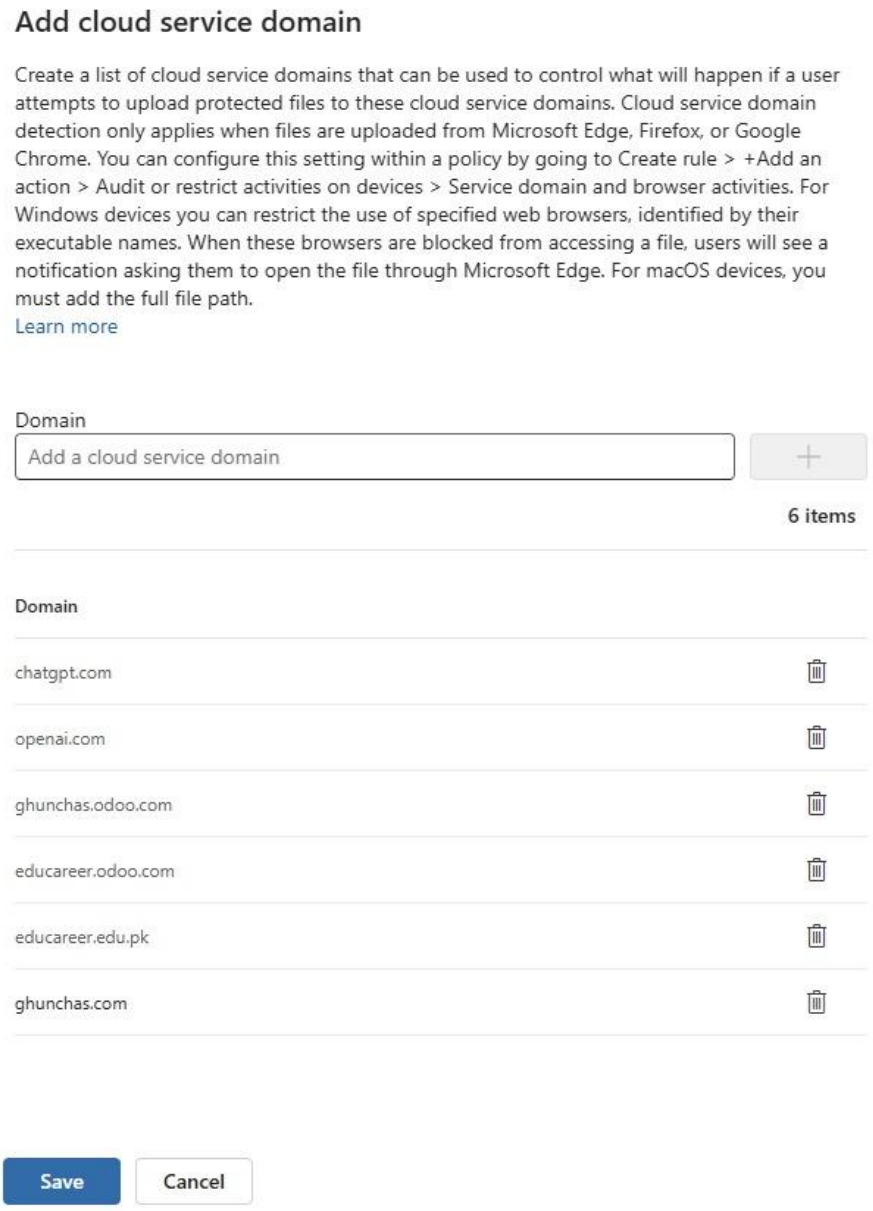
- **[Insert Image: Policy mode - Turn on immediately]**



- *Figure 4.29: Enforcing the endpoint DLP policy immediately.*

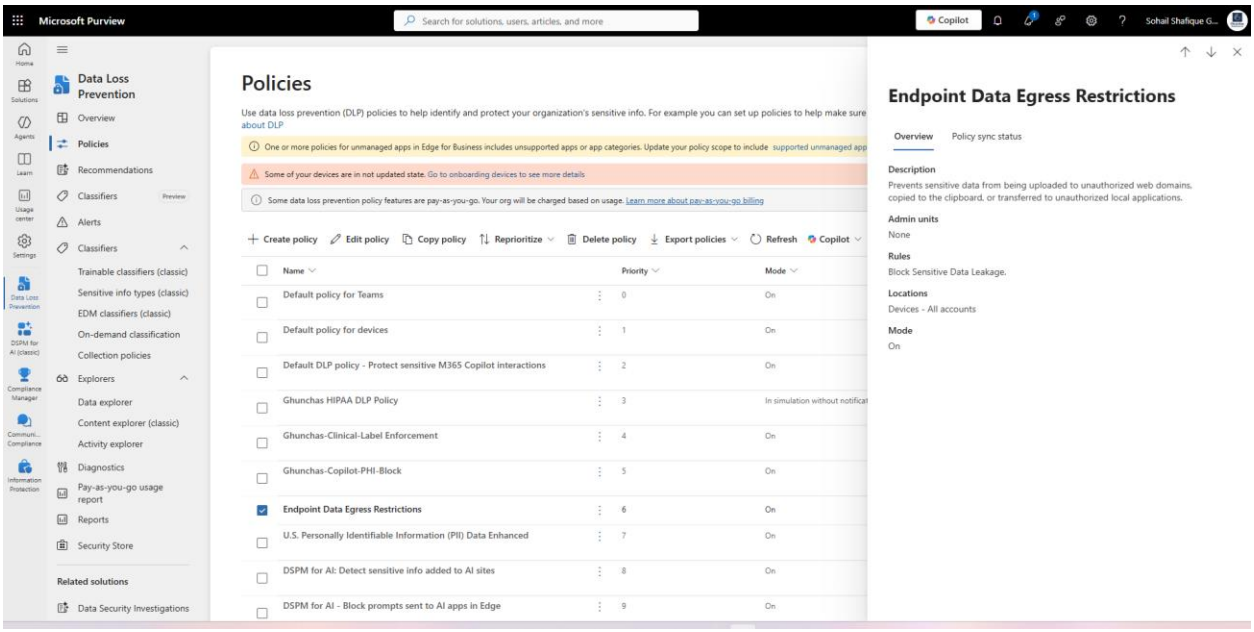
- **[Insert Image: Settings - Add cloud service domain]**


Home
Solutions
Agents
Learn
Usage center
Settings
Data Loss Prevention
Information Protection
Data Security Posture Managem... (classic)
Unified Catalog
Data Map
Settings
Account
Roles and scopes
Data connectors
Device onboarding
Devices
Onboarding
Offboarding
Device report
Optical character recognition (OCR)
Solution settings
Communication Compliance
Compliance Manager
Unified Catalog
Data Lifecycle Management
Data Loss Prevention
eDiscovery
Information Protection
Insider Risk Management
Records Management
Unsupported file extension exclusions
Unallowed Bluetooth apps
Browser and domain restrictions to sensitive data
Restrict sensitive files that match your policies from being shared with unallowed browsers and service domains.
Full URL for 'File copied to cloud'
Select this toggle to show Full URL on the event of 'File copied to cloud' activity.
On
Unallowed browsers
Unallowed browsers will be blocked from accessing files protected by your policies. When blocked, users will be prompted to access the files using Microsoft Edge, where they'll be able to interact with the content but be prevented from uploading to unallowed service domains.
Users who have the Microsoft Purview extension installed on their devices won't be blocked when using Chrome, even if Chrome is listed as an unallowed browser.
Add or edit unallowed browsers
0 items
Browser
Executable name
No data available
Block
Service domains
Control whether sensitive files protected by your policies can be uploaded to specific service cloud domains from Microsoft Edge or Google Chrome (provided the Microsoft Purview extension is installed on their devices). Choose 'Block' to prevent certain domains from accessing these files or 'Allow' to specify safe domains.
Add cloud service domain
4 items



- *Figure 4.30: Defining restricted service domains (e.g., chatgpt.com, openai.com).*

- **[Insert Image: DLP policies list - Endpoint Data Egress Restrictions]**

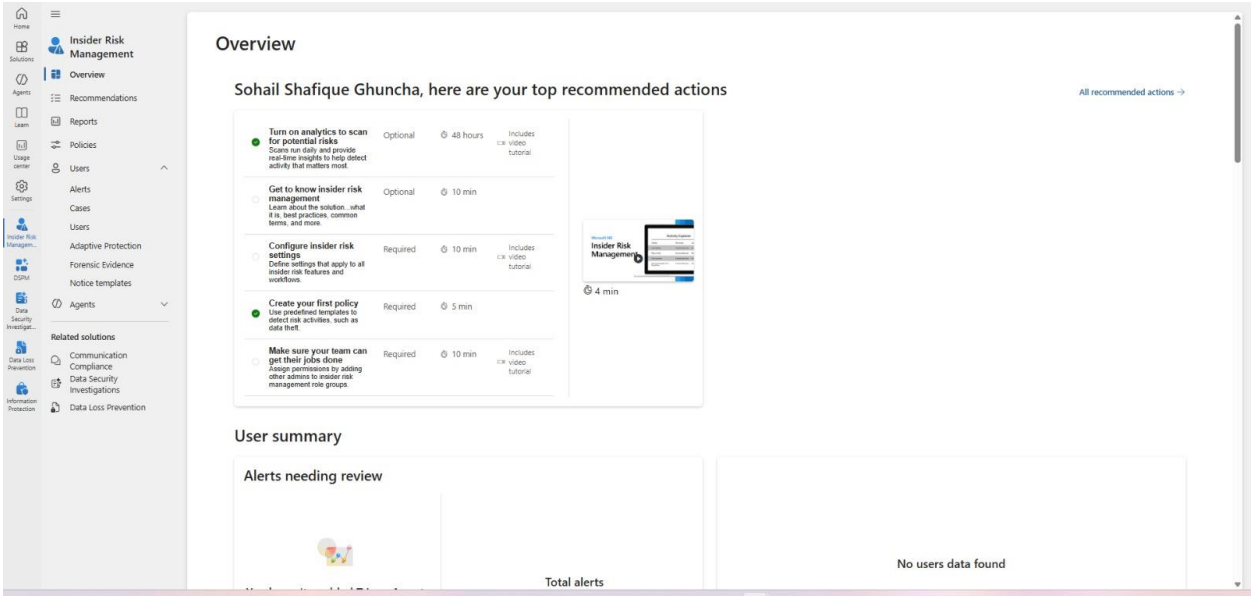


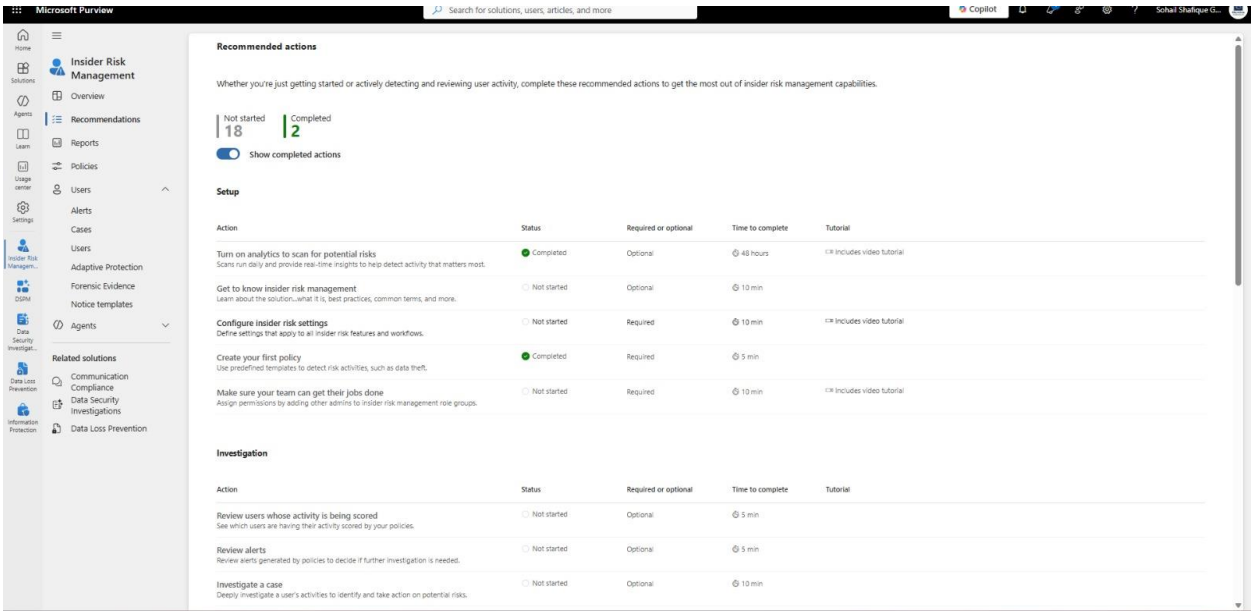
- *Figure 4.31: The final list of DLP policies, showing the Endpoint policy active and synced.*

5.2 The Ghunchas Configuration Standard

Step 1: Onboarding and Recommendations
We begin by reviewing the IRM dashboard to ensure analytics and policies are properly configured. This ensures the system is actively scanning for anomalous behavior.

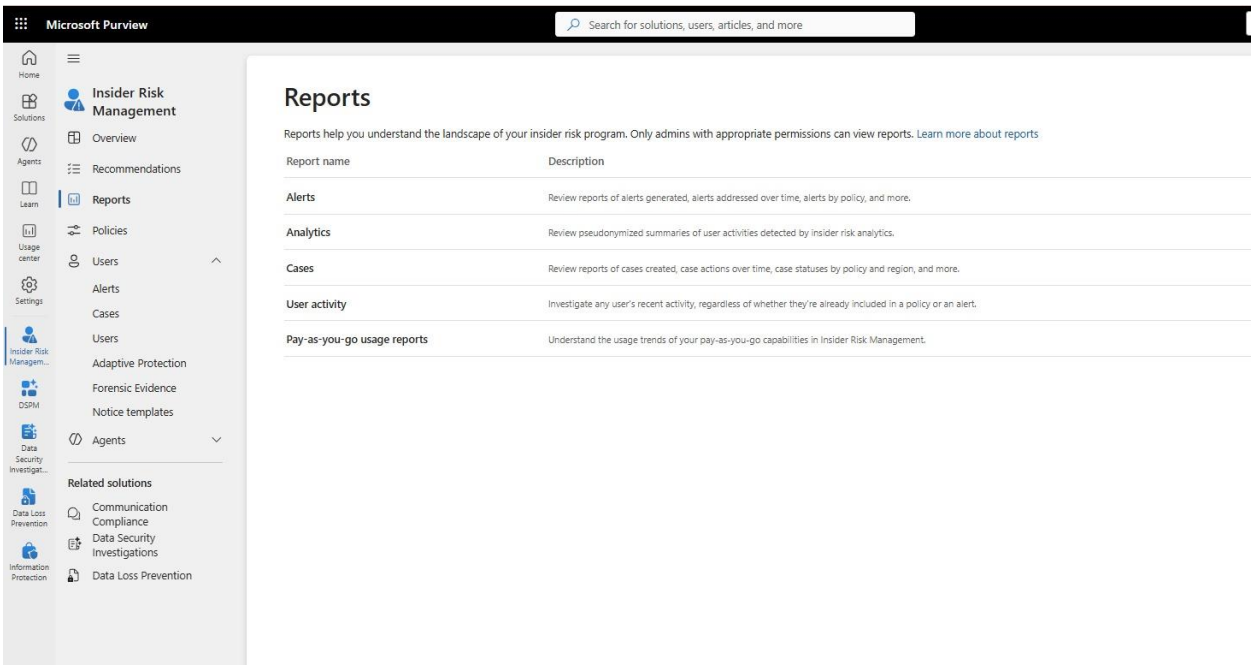
- **[Insert Image: Insider Risk Management - Recommended actions]**





- *Figure 5.1: The IRM Recommendations dashboard, showing Analytics and the initial policy are completed.*

- **[Insert Image: IRM Reports list]**

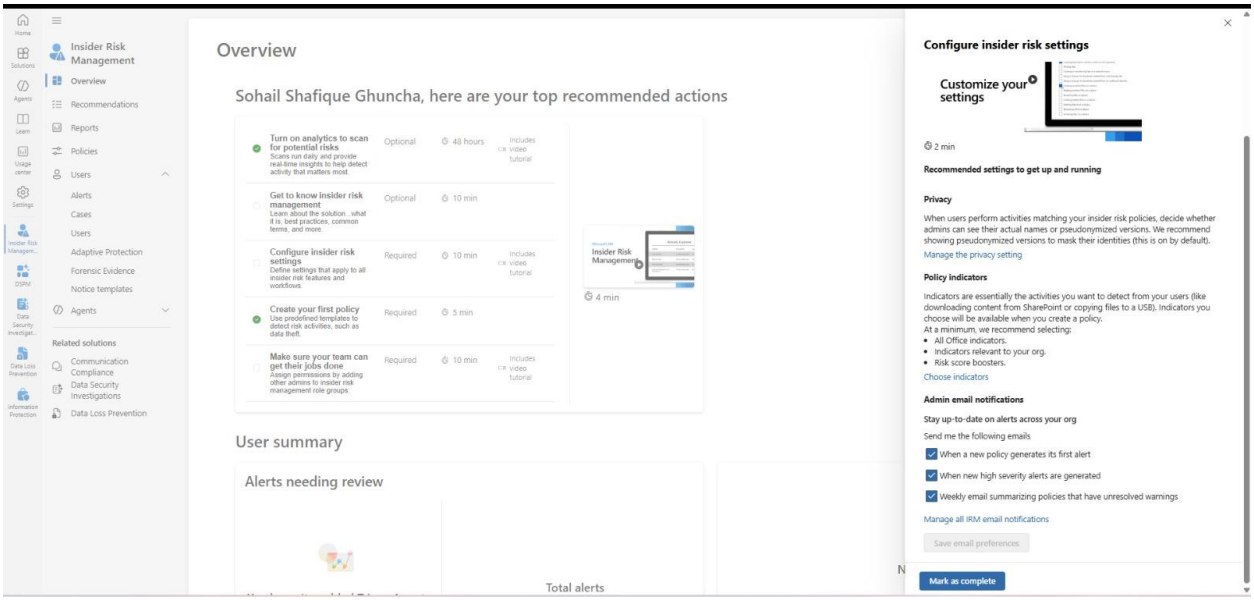


- *Figure 5.2: The Reports dashboard, providing access to Alerts, Analytics, Cases, and User Activity logs.*

Step 2: Configuring Privacy & Settings

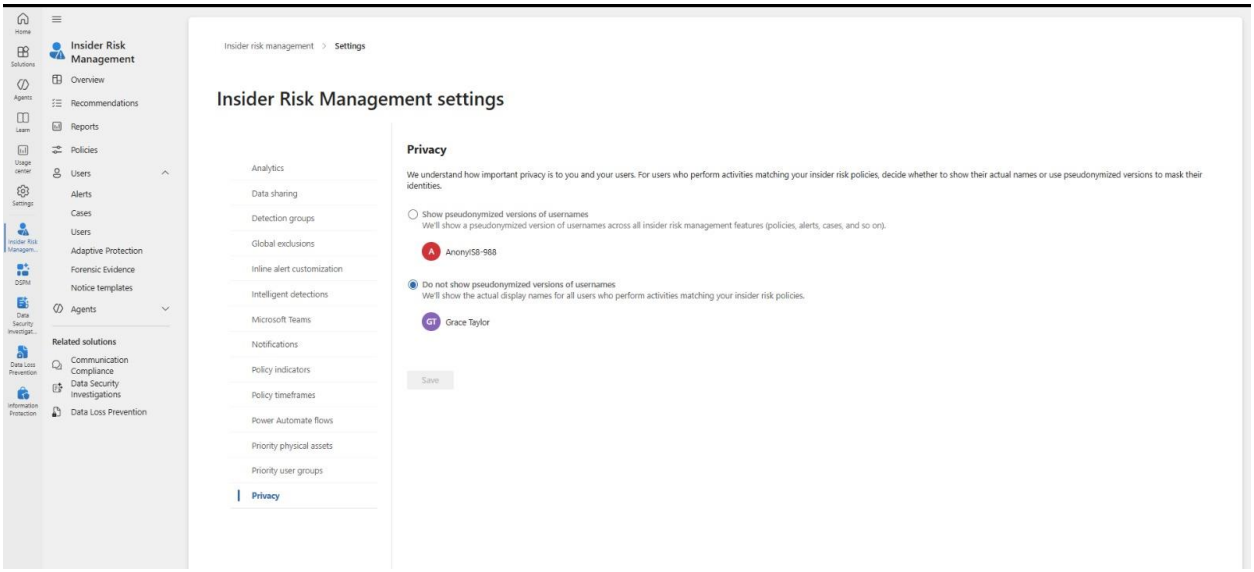
We configure the global IRM settings. The most critical control here is **Privacy**. We ensure that usernames are pseudonymized (e.g., "AnonIS8-988") across all alerts and analytics. This ensures compliance with employee privacy laws while still detecting risk.

- **[Insert Image: Configure insider risk settings]**

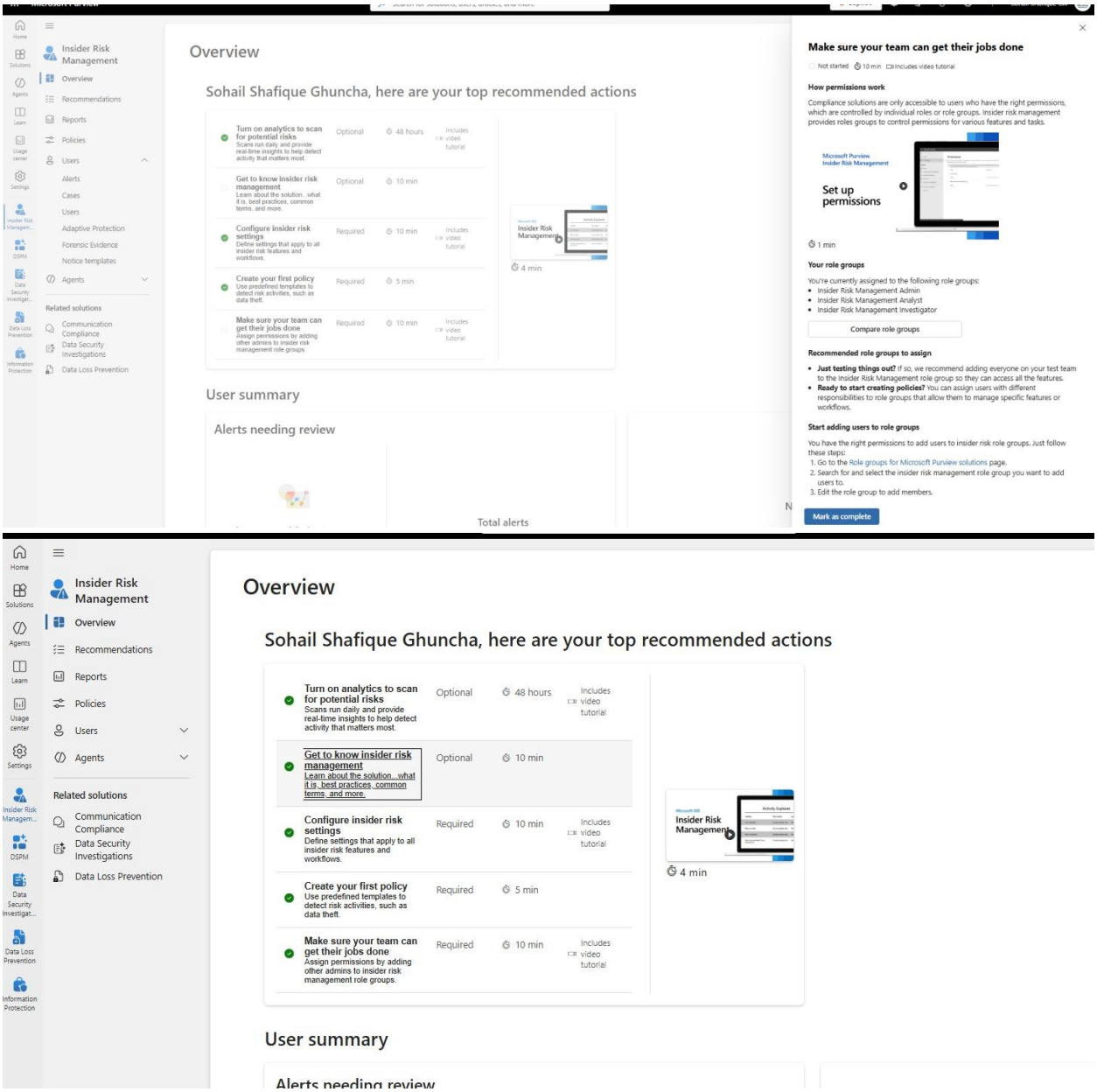


- *Figure 5.3: The settings panel, confirming the recommended privacy and indicator configurations.*

- **[Insert Image: Insider Risk Management settings - Privacy]**



  - *Figure 5.4: Enforcing "Show pseudonymized versions of usernames" to protect employee identities.*
- **[Insert Image: Make sure your team can get their jobs done]**

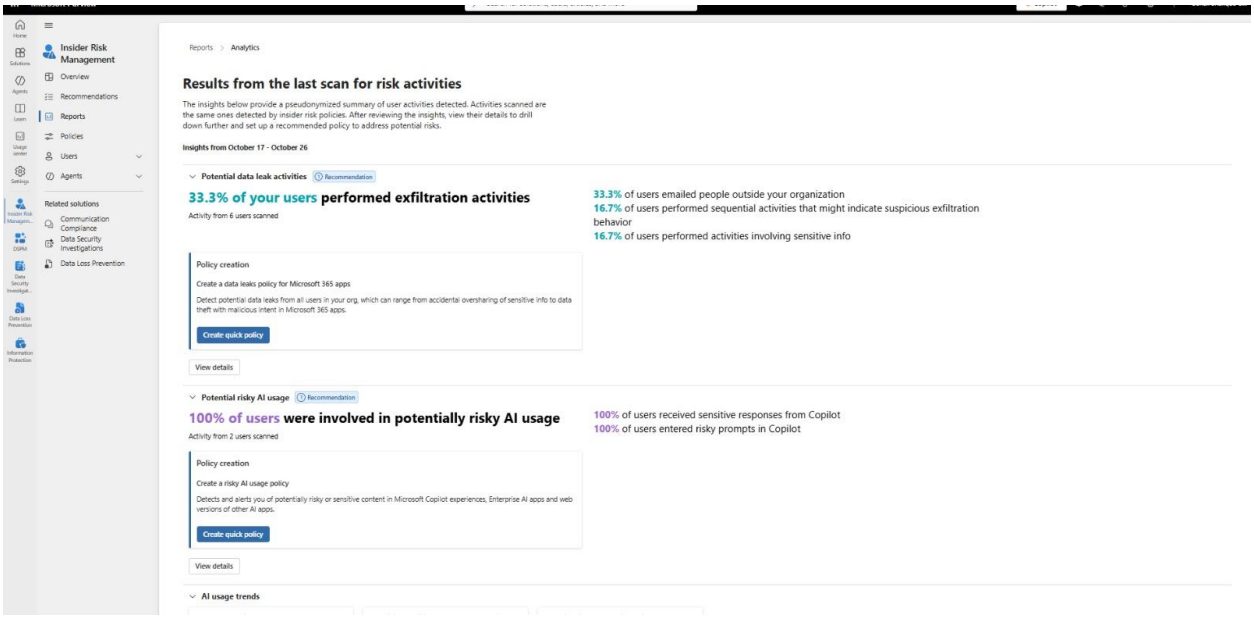


- *Figure 5.5: Assigning the necessary IRM role groups (Admin, Analyst, Investigator) to the security team.*

Step 3: Reviewing Analytics & Risk Insights

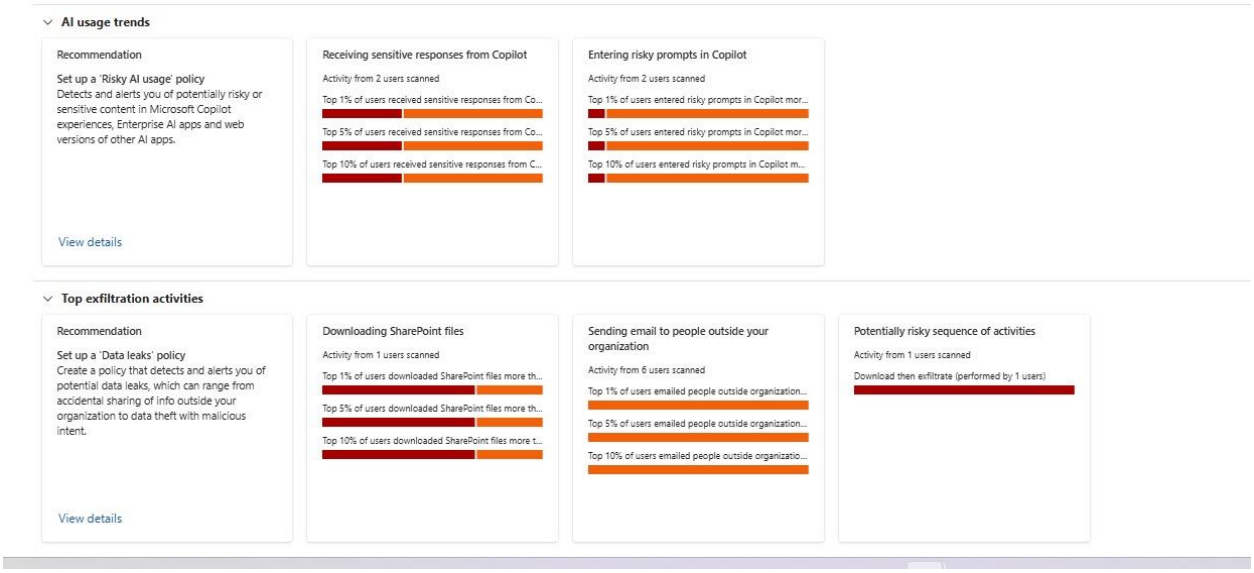
Before creating a policy, we review the Analytics scan. This shows us the current landscape of risk in the tenant (e.g., how many users are performing exfiltration activities or interacting with sensitive AI).

- **[Insert Image: Results from the last scan for risk activities]**



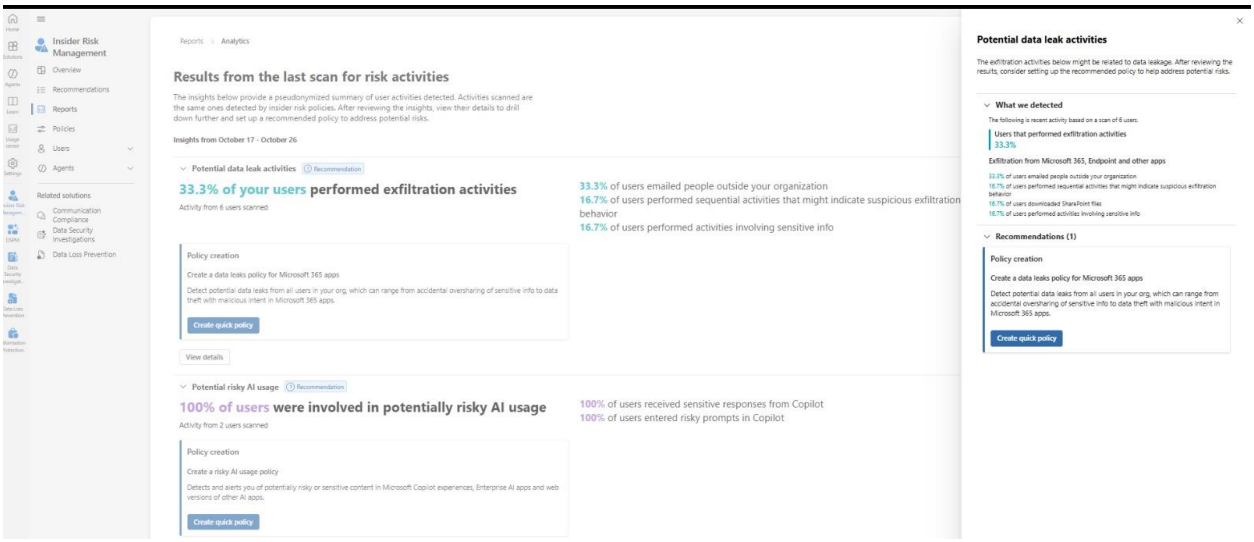
- *Figure 5.6: The Analytics dashboard, showing 33.3% of users performed exfiltration activities.*

- **[Insert Image: AI usage trends and Top exfiltration activities]**



- *Figure 5.7: Detailed insights into risky AI usage (Copilot) and top exfiltration methods (SharePoint downloads, external emails).*

- **[Insert Image: Potential data leak activities - Details]**

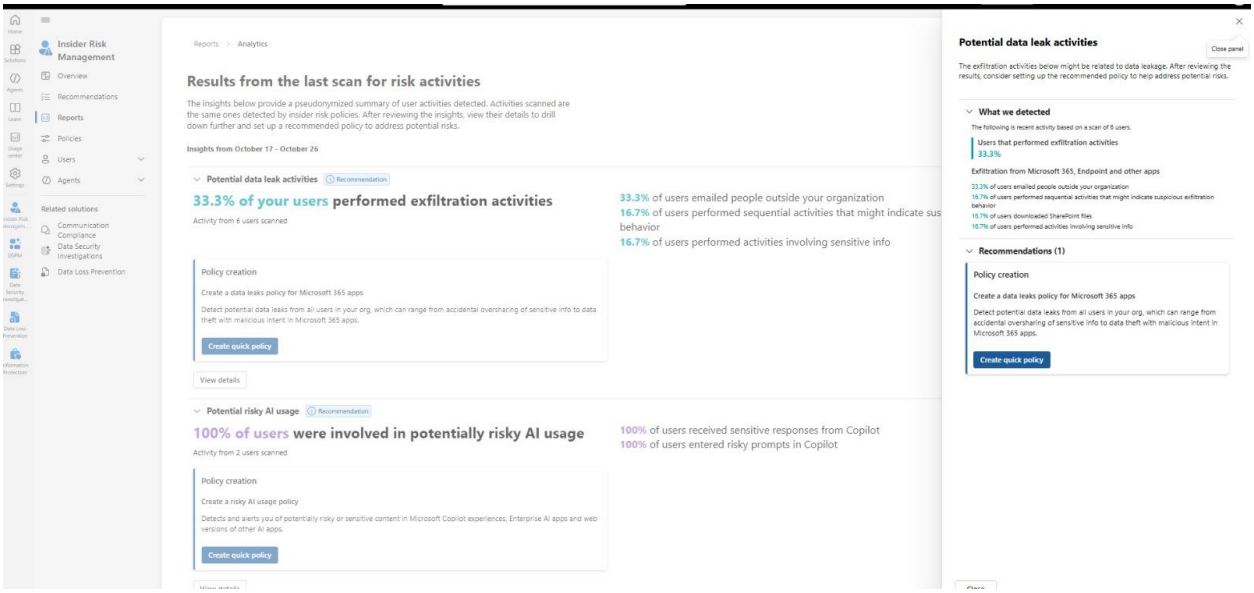


- *Figure 5.8: Drilling into the data leak activities to see specific counts (e.g., 16.7% of users downloaded SharePoint files).*

Step 4: Creating the Data Leak Policy

We use the quick policy creation tool based on the analytics scan. We create a "Data leaks" policy that triggers when a user performs an exfiltration activity (e.g., sharing SharePoint files externally or sending emails with attachments).

- **[Insert Image: Create a data leak policy - Quick policy]**



- *Figure 5.9: Creating the data leak policy, scoped to "Include all users and groups."*
- **[Insert Image: Your data leak policy is being created]**

Create a data leak policy

Close

2 minutes to complete

Data leaks can range from accidental oversharing of info outside your organization to data theft with malicious intent. Most organizations with insider risk programs have a data leaks policy in place.

How do quick policies work?

Review the policy name and user scope we suggested and make changes if needed.

Policy name *

Data leaks quick policy - 10/28/2026

User scope *

Include all users and groups (Recommended for best coverage)

Settings we filled in for you

Settings below are based on the latest analytics scan. You can edit them later or click 'Customize' now to configure settings using the full policy wizard.

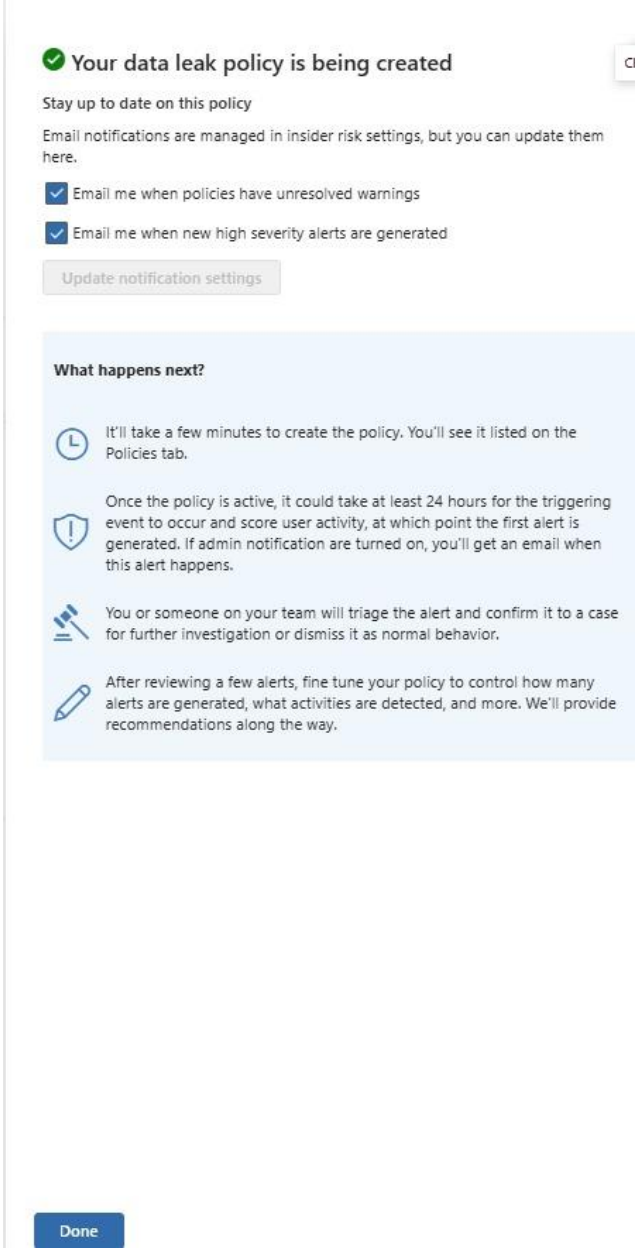
Triggering event

User performs an exfiltration activity

Indicators

- Sharing SharePoint files with people outside the organization
- Sharing SharePoint folders with people outside the organization
- Sharing SharePoint sites with people outside the organization
- Sending email with attachments to recipients outside the organization
- Sending email with attachments to free public domains
- Sending email with attachments to self
- Downloading content from Teams
- Download then exfiltrate
- Detect when a user's exfiltration activities exceed organizational norms
- Downloading content from SharePoint
- Syncing content from SharePoint
- Downloading content from OneDrive
- Syncing content from OneDrive
- Downgrade or remove label then exfiltrate
- Downgrade or remove label, download, then exfiltrate

Create policy | Customize

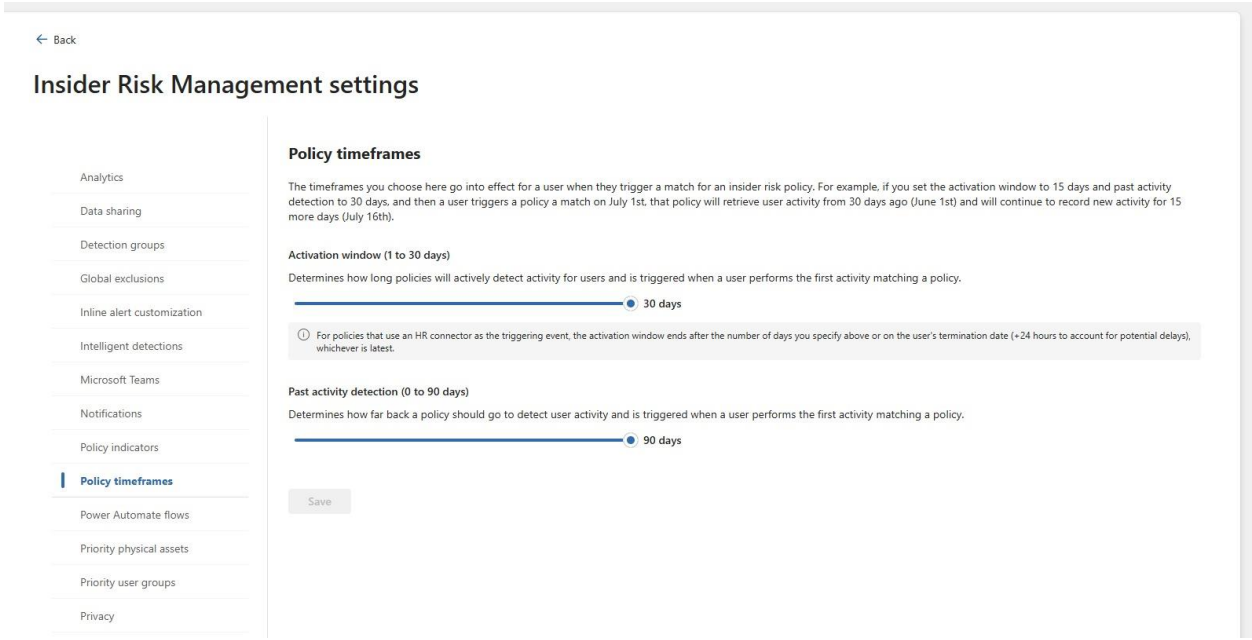


- *Figure 5.10: Confirmation that the policy is being created, with email notifications enabled for high-severity alerts.*

Step 5: Configuring Policy Timeframes

We adjust the policy timeframes to define how far back the system looks for past activity and how long it actively monitors a user once a triggering event occurs.

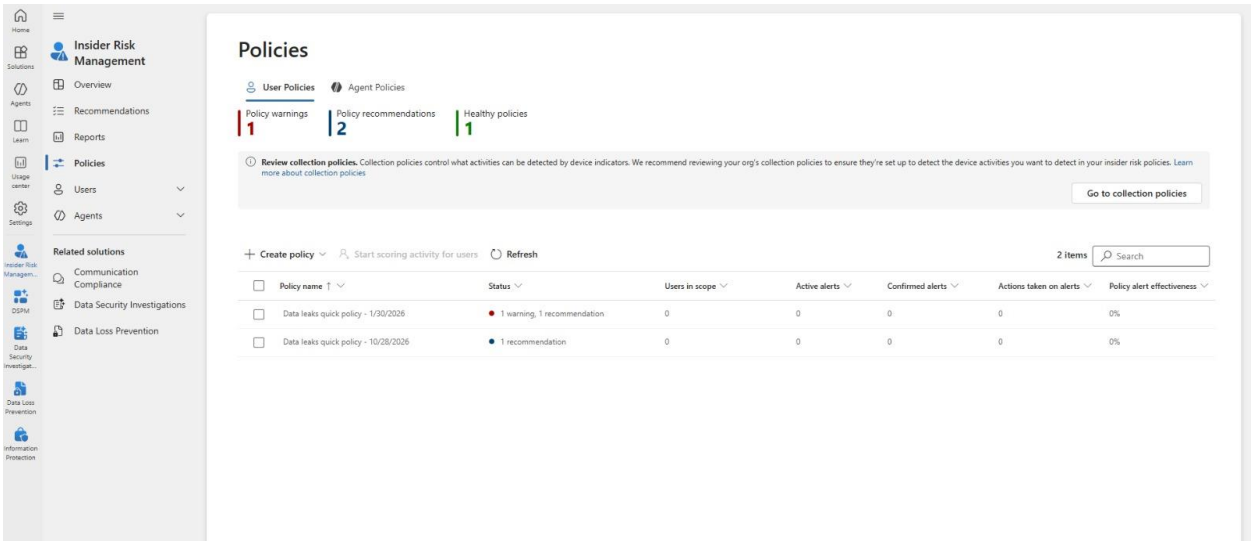
- **[Insert Image: Insider Risk Management settings - Policy timeframes]**
  - *Figure 5.11: Setting the activation window to 30 days and past activity detection to 90 days.*



Step 6: Reviewing the Active Policies

We verify that the policy is active and healthy.

- **[Insert Image: Policies - User Policies list]**

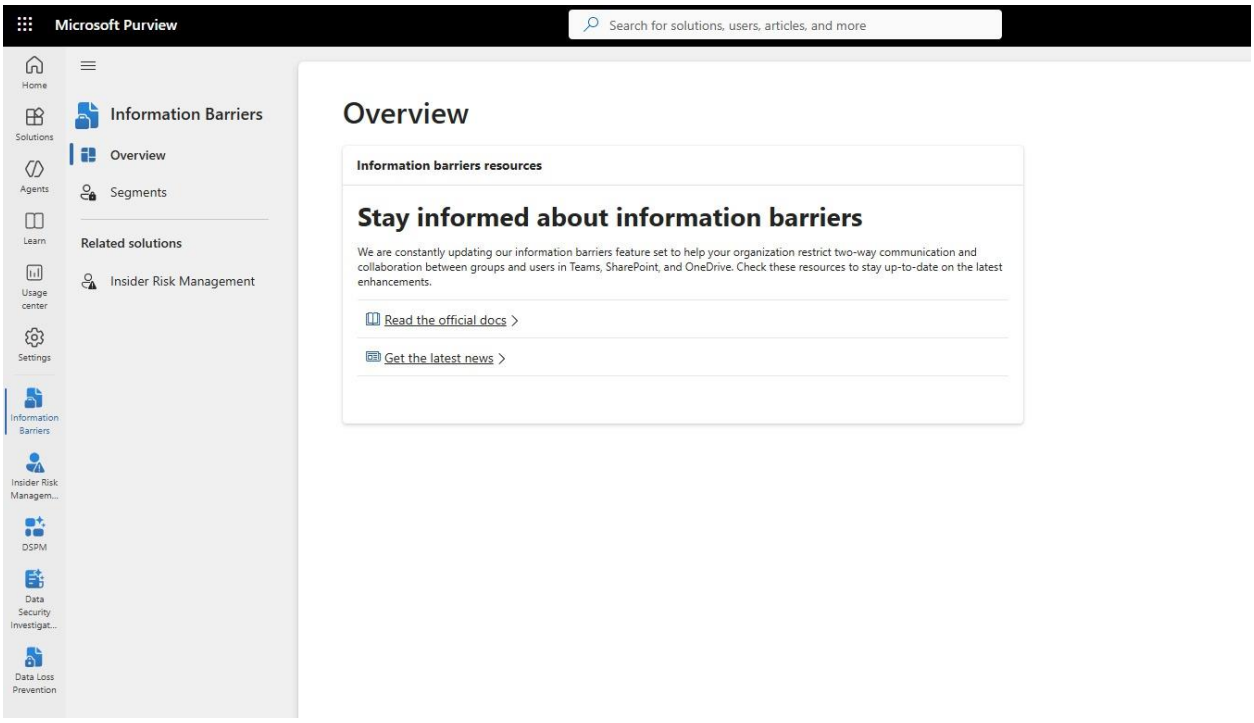


  - *Figure 5.12: The active policies list, showing the "Data leaks quick policy" with a healthy status.*

Step 7: Configuring Information Barriers (Segments)

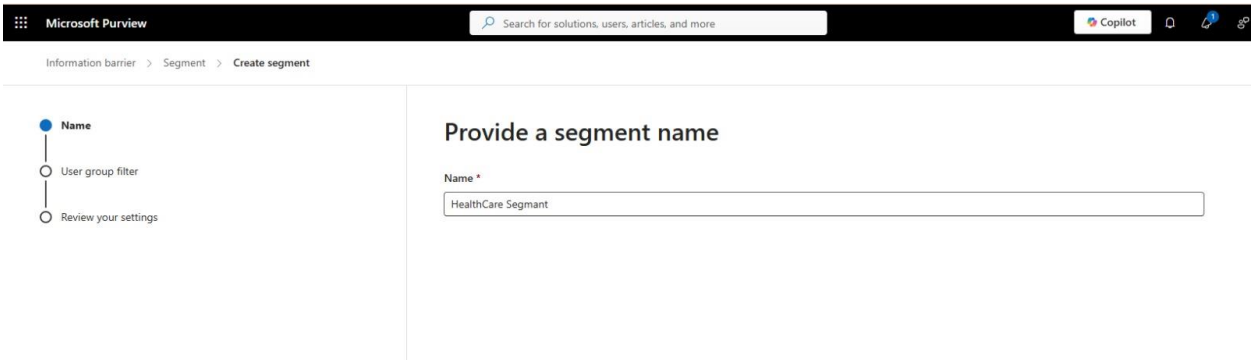
To further restrict collaboration and communication between conflicting groups (e.g., Clinical staff and Billing staff), we configure Information Barriers. We create a "Segment" (e.g., HealthCare Segment) to define the user groups.

- **[Insert Image: Information Barriers - Overview]**



  - *Figure 5.13: Navigating to the Information Barriers solution.*

- **[Insert Image: Create segment - Provide a segment name]**

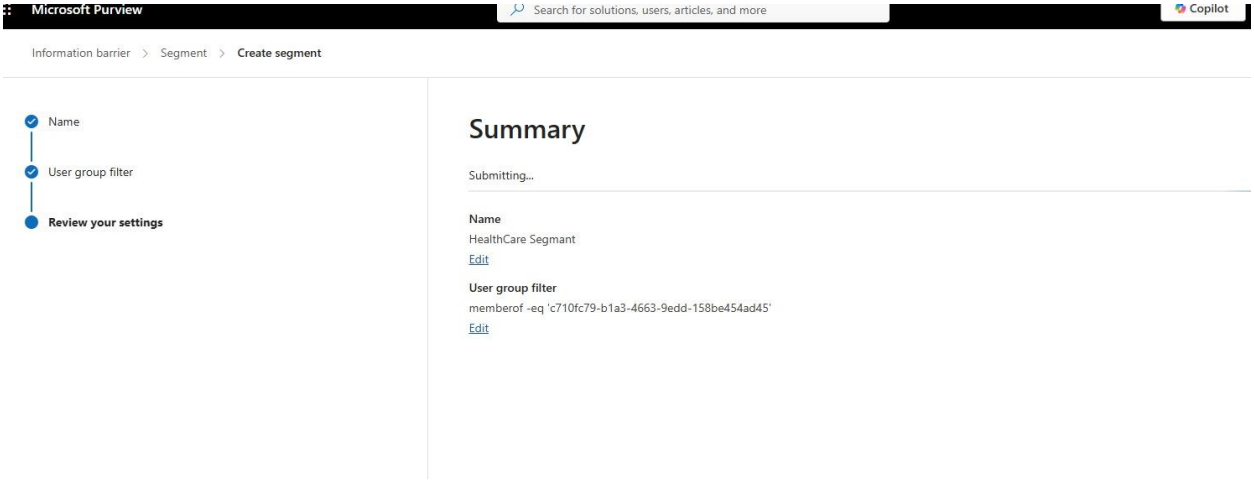


  - *Figure 5.14: Naming the new segment "HealthCare Segment".*

- **[Insert Image: Modify user group filters]**

- *Figure 5.15: Adding the User group filter (memberOf) to define the segment.*

- **[Insert Image: Create segment - Summary]**



- *Figure 5.16: Reviewing and submitting the segment configuration.*

PHASE 6: COMPLIANCE MANAGER & COMMUNICATION COMPLIANCE (PART 1)

Objective: Measure the organization's regulatory compliance (HITRUST/HIPAA) using Microsoft Compliance Manager, resolve failing controls, and configure the foundation for Communication Compliance.

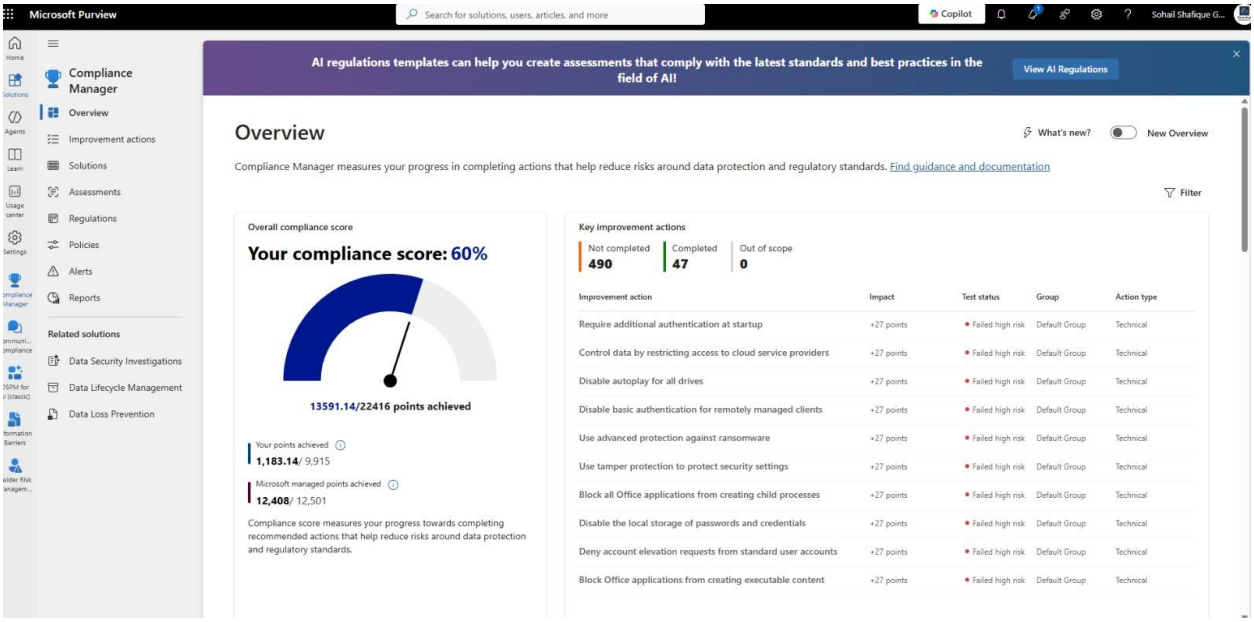
6.1 The Business Value (Why We Do This)

Auditors do not accept verbal confirmation; they require evidence. Compliance Manager calculates a real-time score based on the controls we implement. Furthermore, Communication Compliance ensures that even in internal chats (Teams), sensitive PHI or inappropriate conduct is detected, protecting the organization from internal threats and HR liabilities.

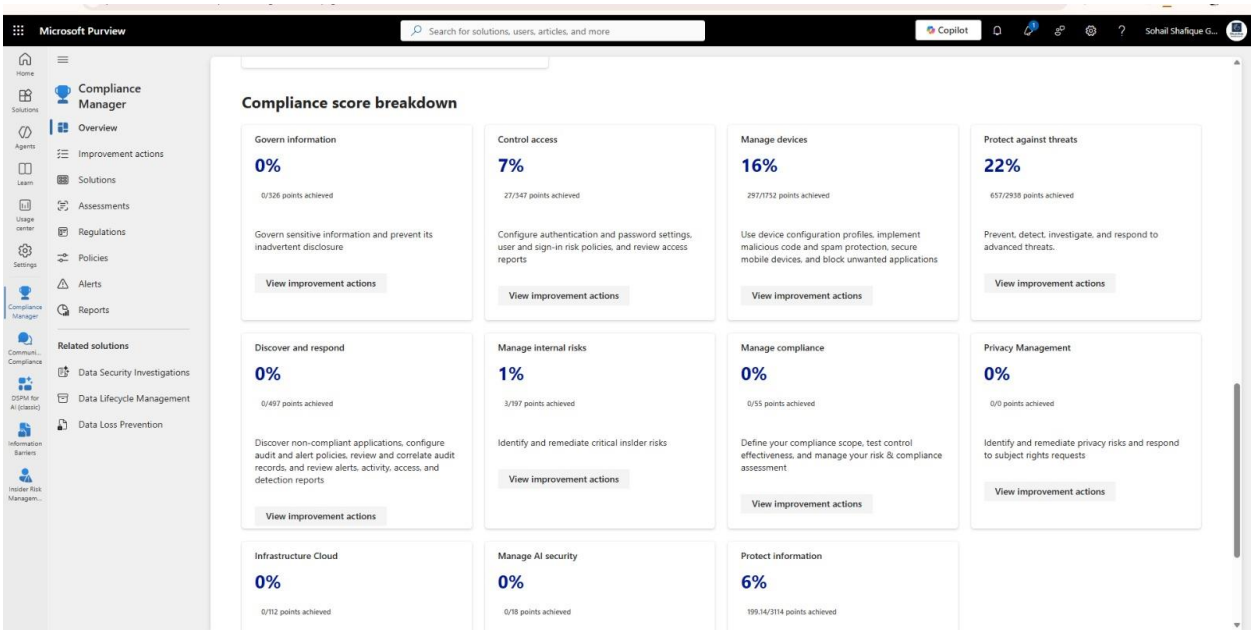
6.2 The Ghunchas Configuration Standard

Step 1: Reviewing the Compliance Score Breakdown
We begin by analyzing the compliance score across different categories (e.g., Manage devices, Protect information, Manage internal risks). This gives us a prioritized list of where security controls are weakest.

- **[Insert Image: Compliance Manager - Overview]**



  - *Figure 6.1: The overall compliance score (60%) and the list of Key Improvement Actions.*
- **[Insert Image: Compliance score breakdown]**

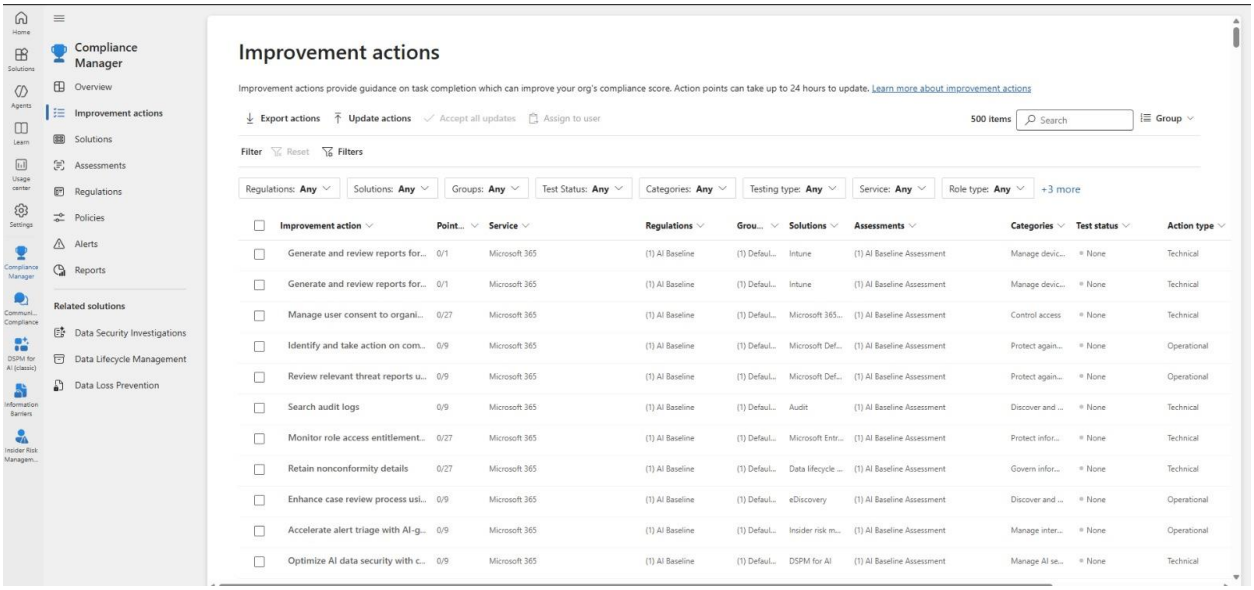


- *Figure 6.2: The breakdown of categories, showing 22% for "Protect against threats" and 6% for "Protect information."*

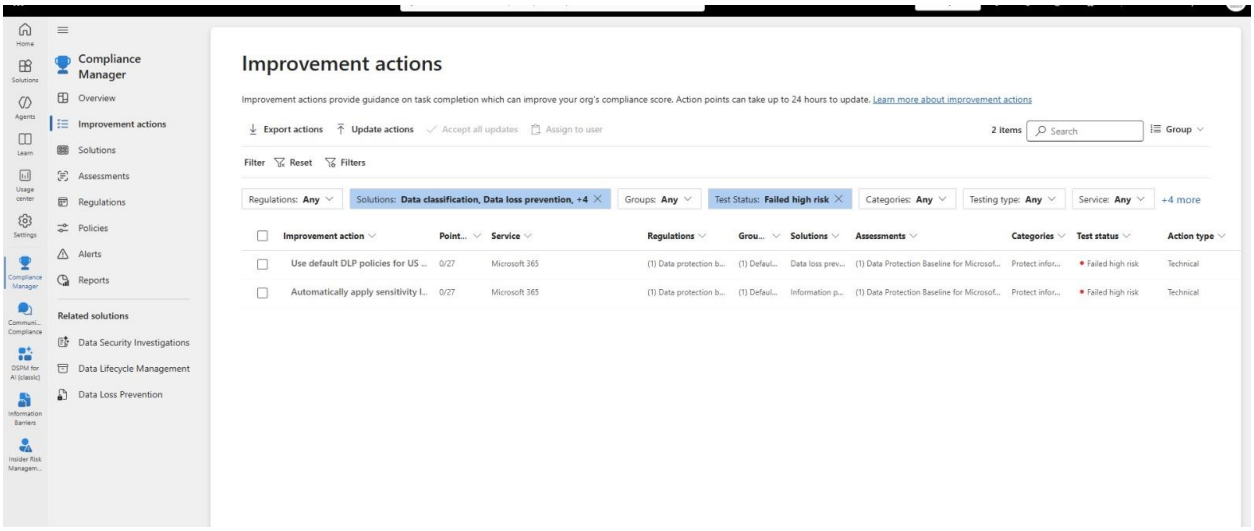
Step 2: Analyzing and Filtering Improvement Actions

We drill into the "Improvement actions" to identify specific technical tasks. We filter by high-risk failures to prioritize the most critical fixes.

- **[Insert Image: Improvement actions list]**

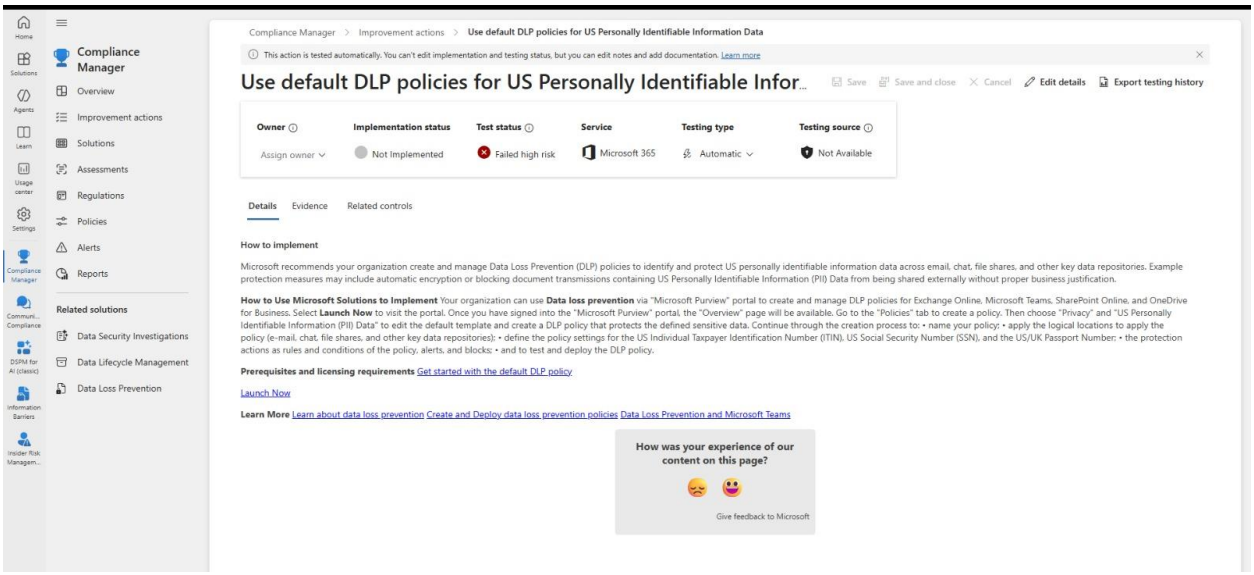


- *Figure 6.3: The full list of 500 improvement actions, showing points and impacted regulations.*
- **[Insert Image: Improvement actions - Filtered by Failed high risk]**



- *Figure 6.4: Filtering for "Failed high risk" actions to focus remediation efforts.*

- **[Insert Image: Use default DLP policies for US PII - Details]**

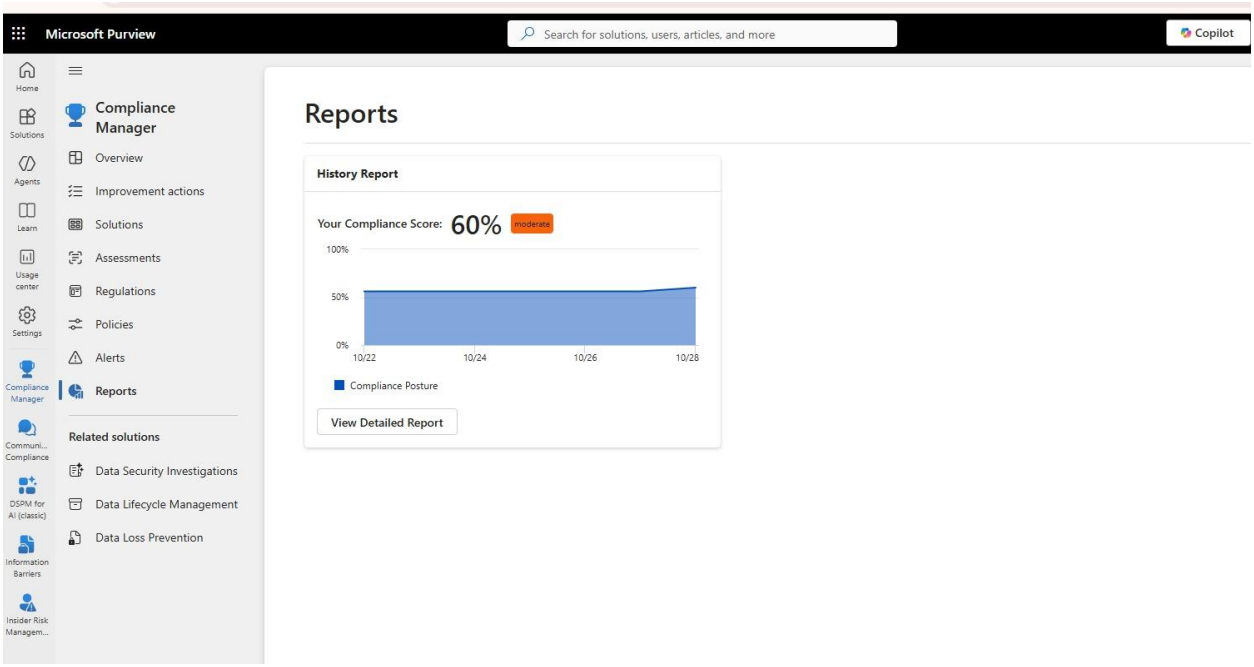


- *Figure 6.5: Reviewing the remediation steps for a failing DLP control.*

Step 3: Generating Historical Compliance Reports

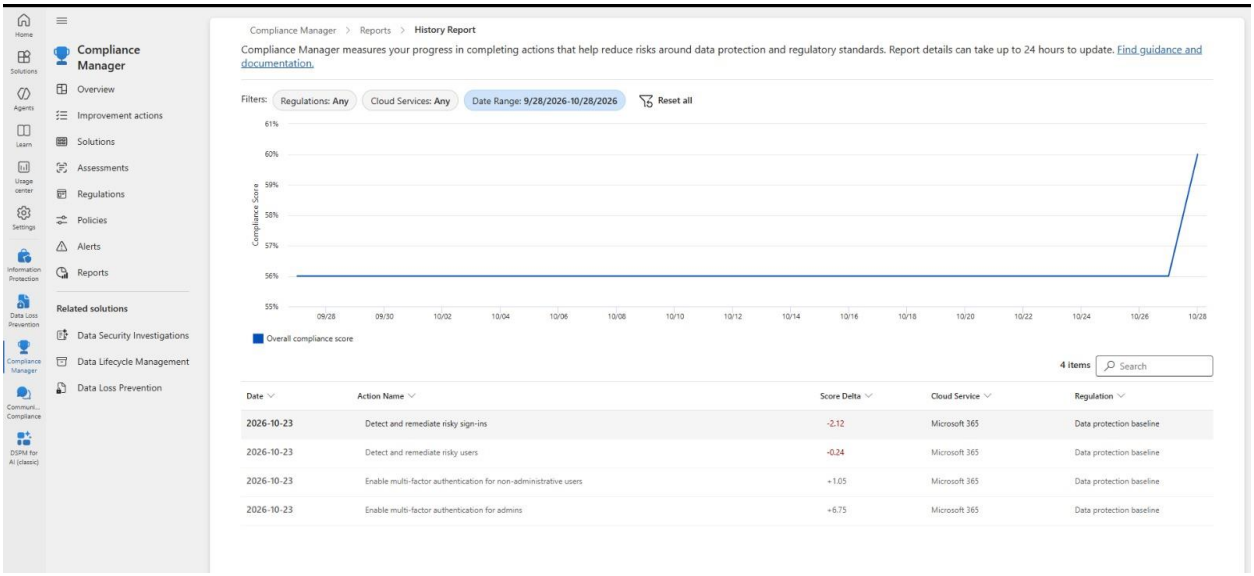
We generate a history report to prove the trajectory of the compliance posture over time.

- **[Insert Image: Reports - History Report]**



- *Figure 6.6: The 60% compliance score graph over a 30-day period.*

- **[Insert Image: History Report - Score changes]**

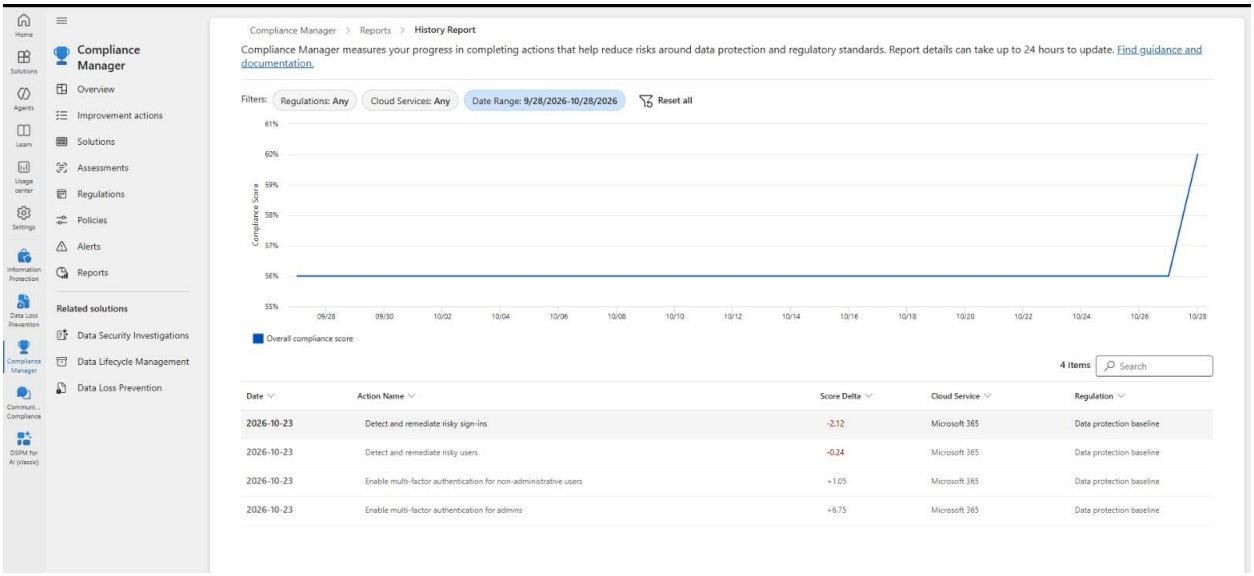


- *Figure 6.7: The detailed log showing exactly which actions increased or decreased the score.*

Step 3.5: Detailed Review of Score Changes and Remediation

After generating the historical report, we drill into the specific score changes to understand exactly why the compliance score moved. We identify that the "Detect and remediate risky sign-ins" action caused a **-2.12 point decrease** in the score, indicating a failing control that requires immediate remediation.

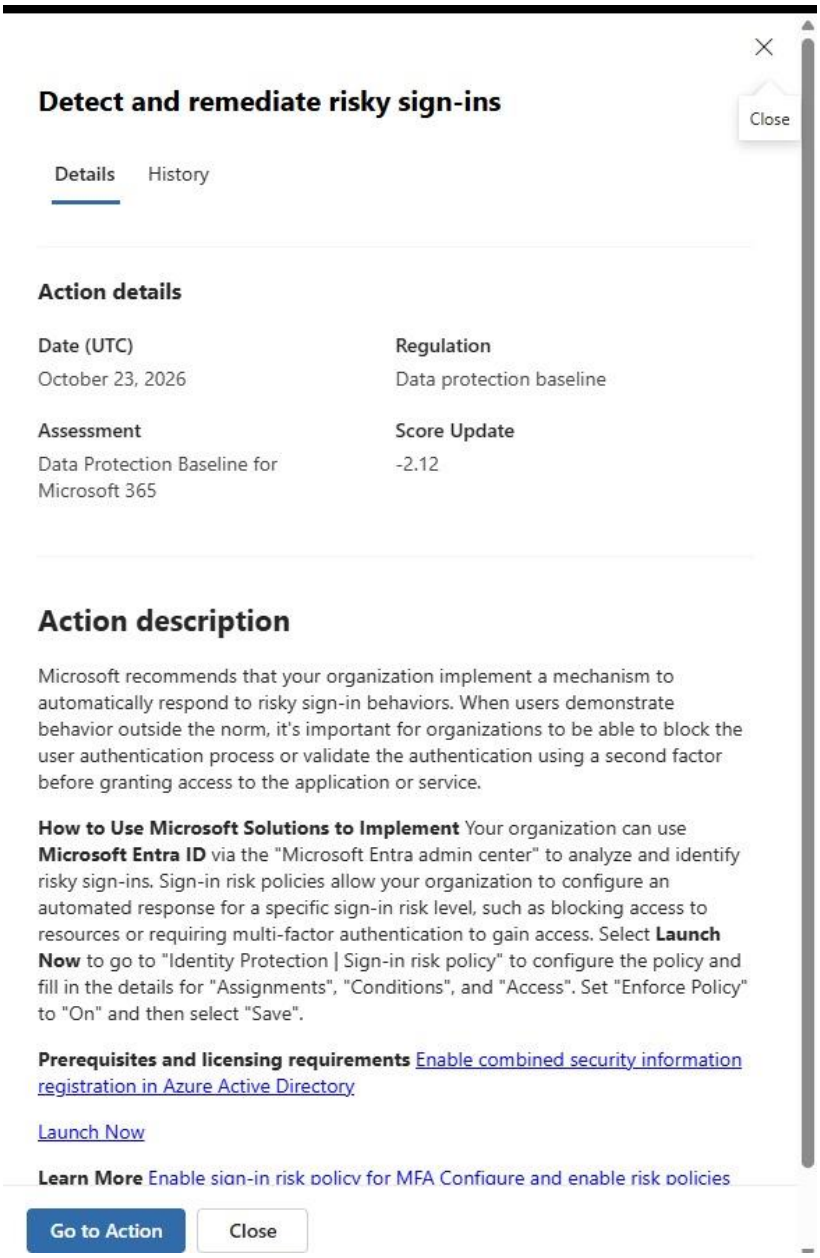
- **[Insert Image: Reports - History Report (Detailed)]**



  - *Figure 6.7a: The detailed history report, highlighting the -2.12 score delta for the "Detect and remediate risky sign-ins" action.*

We then click on this specific action to view the "Action details" and read Microsoft's remediation guidance. The guidance explains that we need to configure an automated response to risky sign-in behaviors in Microsoft Entra ID.

- **[Insert Image: Detect and remediate risky sign-ins - Details]**

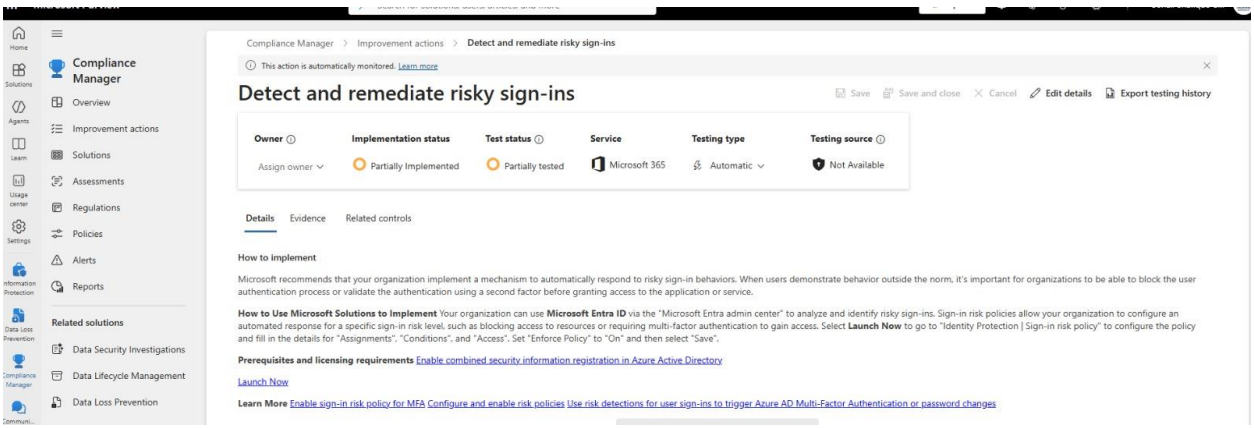


- *Figure 6.7b: The detailed action description, showing the -2.12 score update and the instructions to navigate to Entra ID.*

Step 3.6: Remediating the Failing Control in Entra ID

We navigate to the Microsoft Entra admin center to configure the required policy. We see a warning that "Legacy risk policy management is retired" and that we must create a replacement policy in Conditional Access.

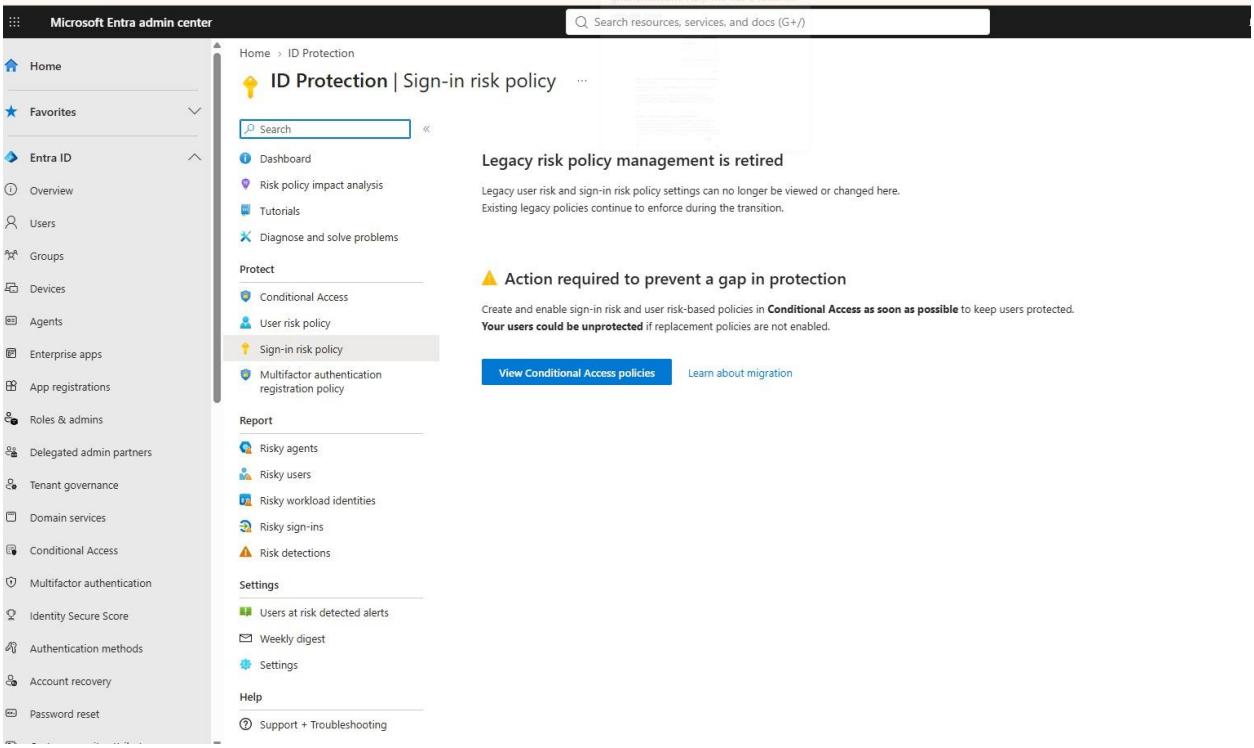
- **[Insert Image: Entra ID Protection - Sign-in risk policy]**

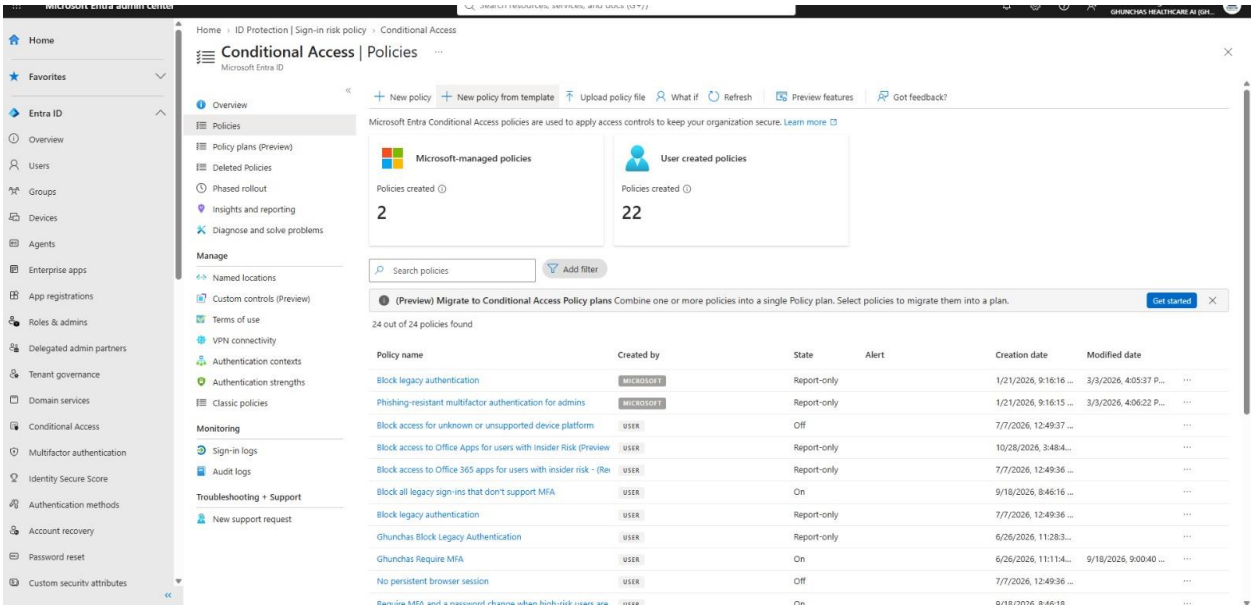


- *Figure 6.7c: The Entra ID Protection dashboard, showing the requirement to migrate to Conditional Access policies.*

We navigate to **Conditional Access > Policies** to view the existing policies and create a new one from a template.

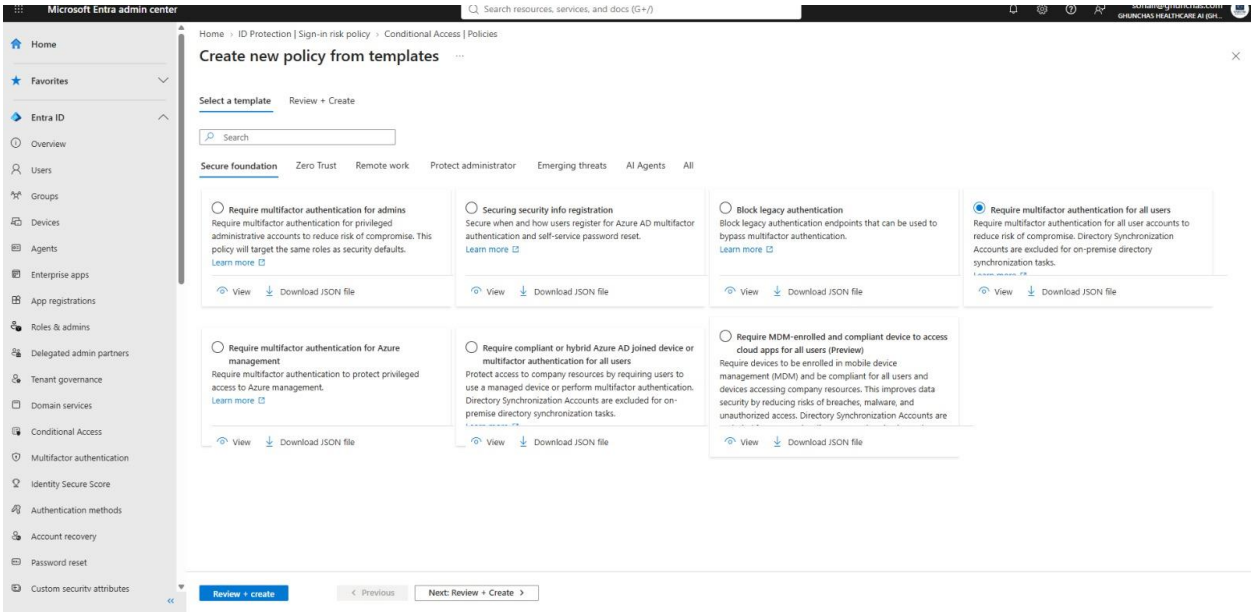
- **[Insert Image: Conditional Access - Policies list]**





- *Figure 6.7d: The list of active Conditional Access policies (24 out of 24 policies found).*

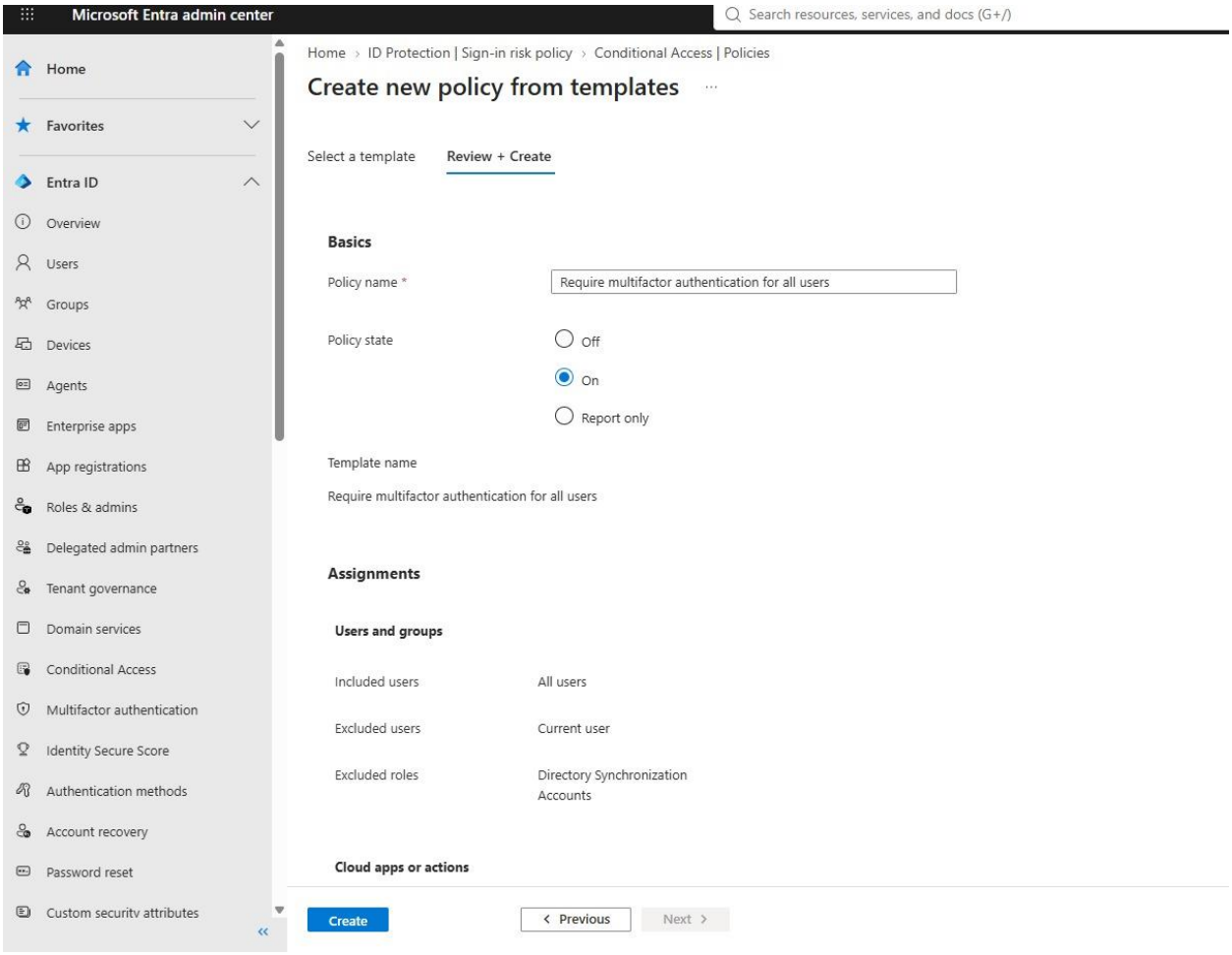
- **[Insert Image: Create new policy from templates - Secure foundation]**



- *Figure 6.7e: Selecting the template "Require multifactor authentication for all users" to remediate the risky sign-in control.*

We review the policy configuration to ensure it applies to "All users" (excluding the current user and directory sync accounts) and set the policy state to **"On"** to enforce it immediately.

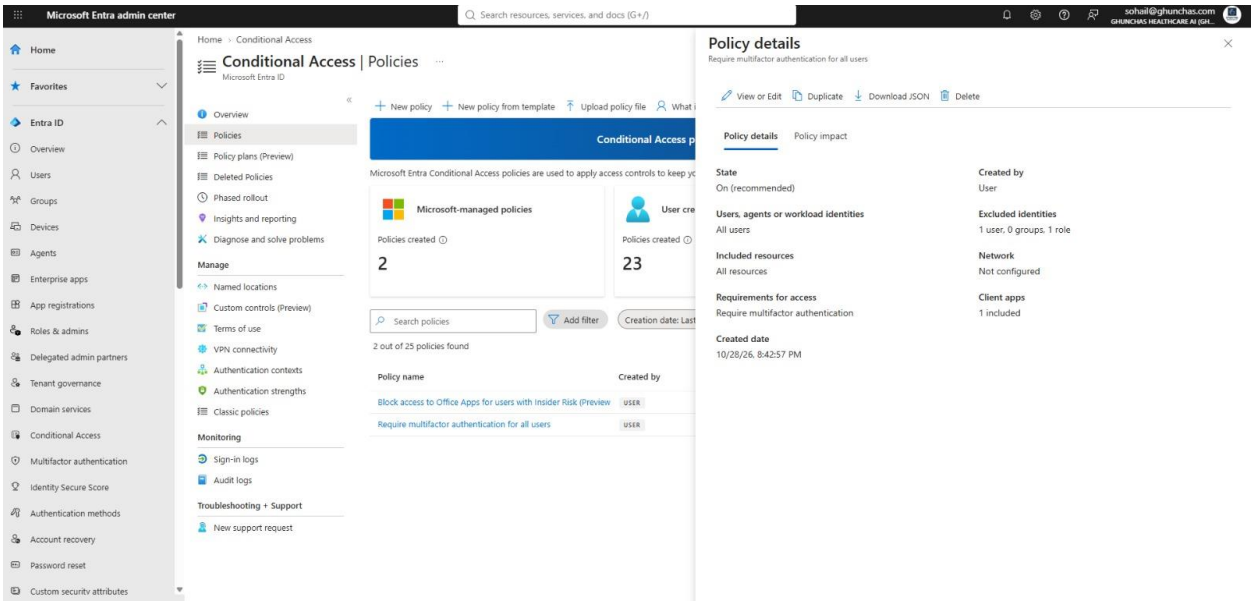
- **[Insert Image: Create new policy from templates - Review and Create]**



- *Figure 6.7f: Reviewing the policy assignments and setting the policy state to "On".*

After clicking "Create," we verify that the new policy is active in the Conditional Access list.

- **[Insert Image: Conditional Access - Policy details (MFA required)]**

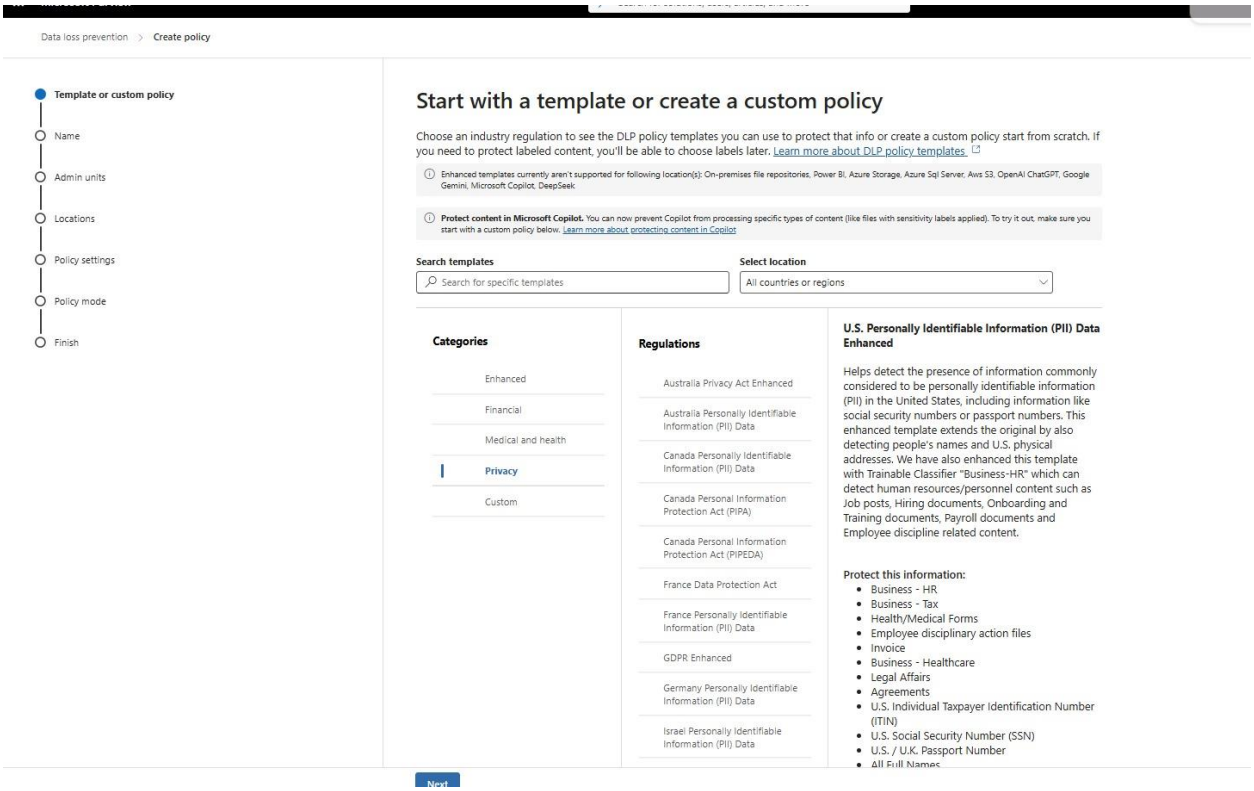


- *Figure 6.7g: Confirming the new MFA policy is active and enforcing access controls.*

Step 4: Creating the DLP Policy from the Compliance Template

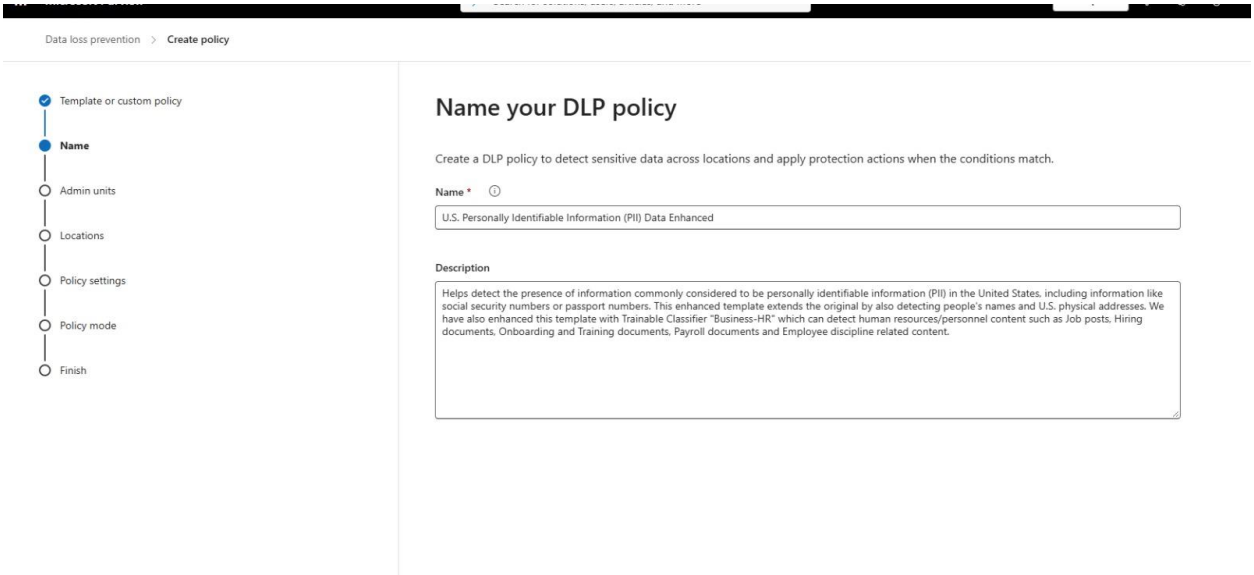
To fix the failing "Use default DLP policies for US PII" control, we create a policy directly from the recommended template.

- **[Insert Image: Create policy from template - US PII]**



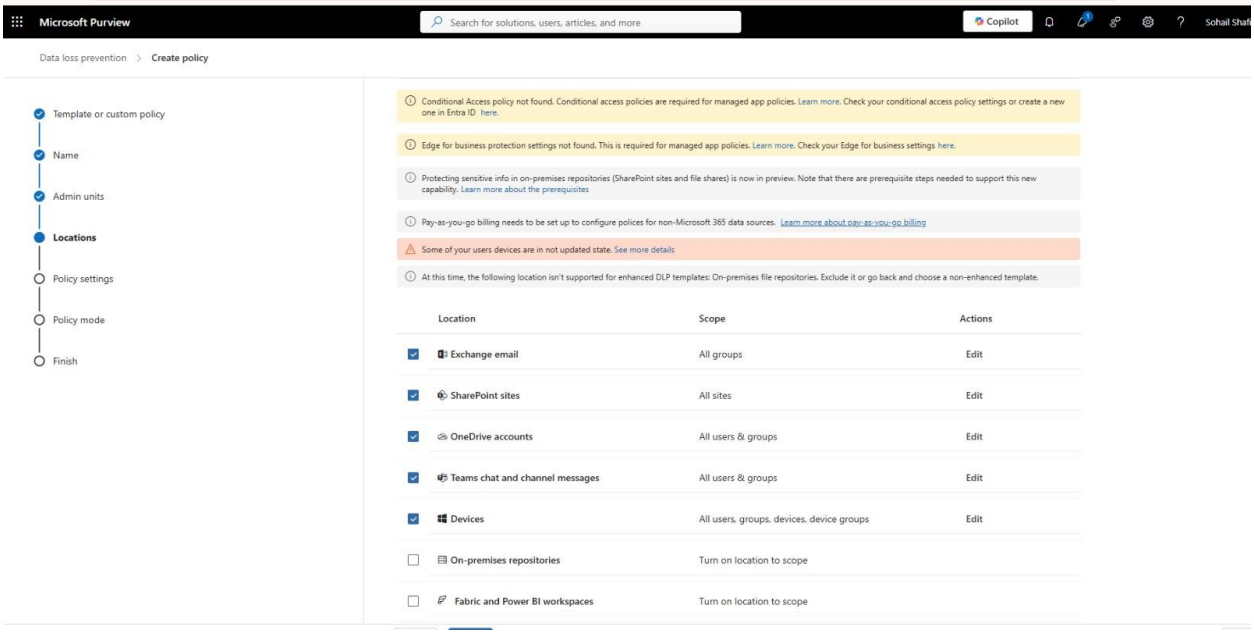
- *Figure 6.8: Selecting the "U.S. Personally Identifiable Information (PII) Data Enhanced" template.*

- **[Insert Image: Name your DLP policy - PII]**



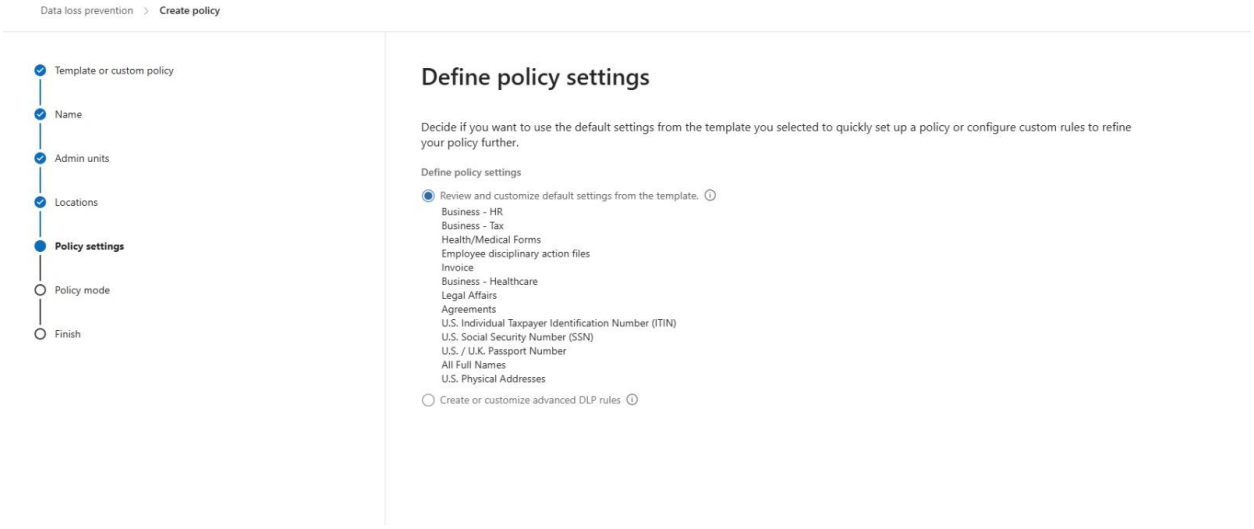
- *Figure 6.9: Naming the policy and reviewing the default sensitive info types.*

- **[Insert Image: Locations - All locations]**



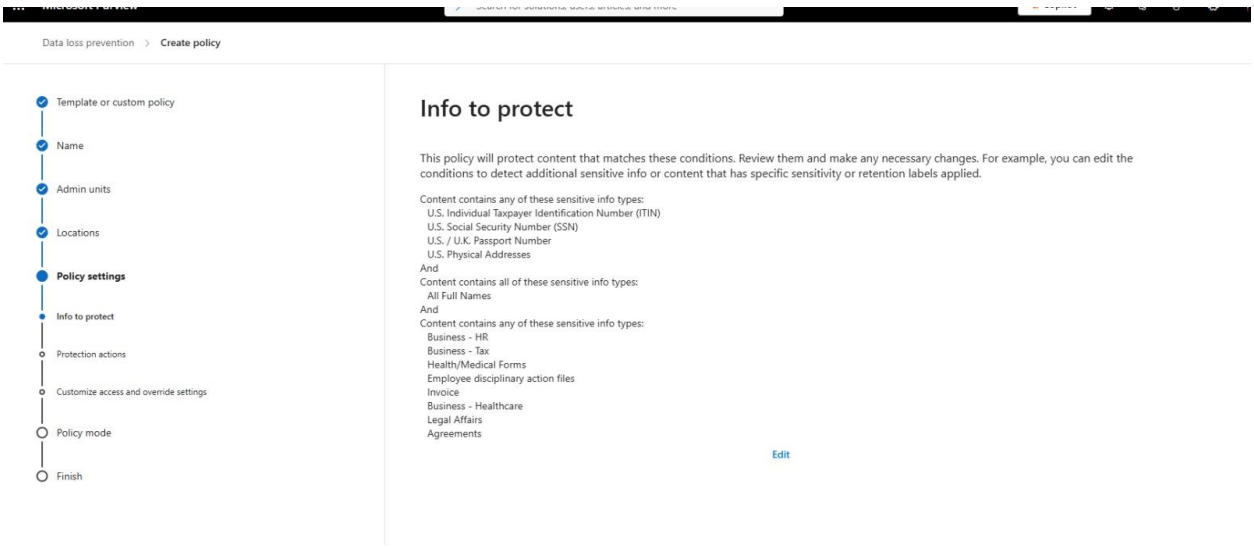
- *Figure 6.10: Scoping the policy to Exchange, SharePoint, OneDrive, Teams, and Devices.*

- **[Insert Image: Define policy settings - Review defaults]**



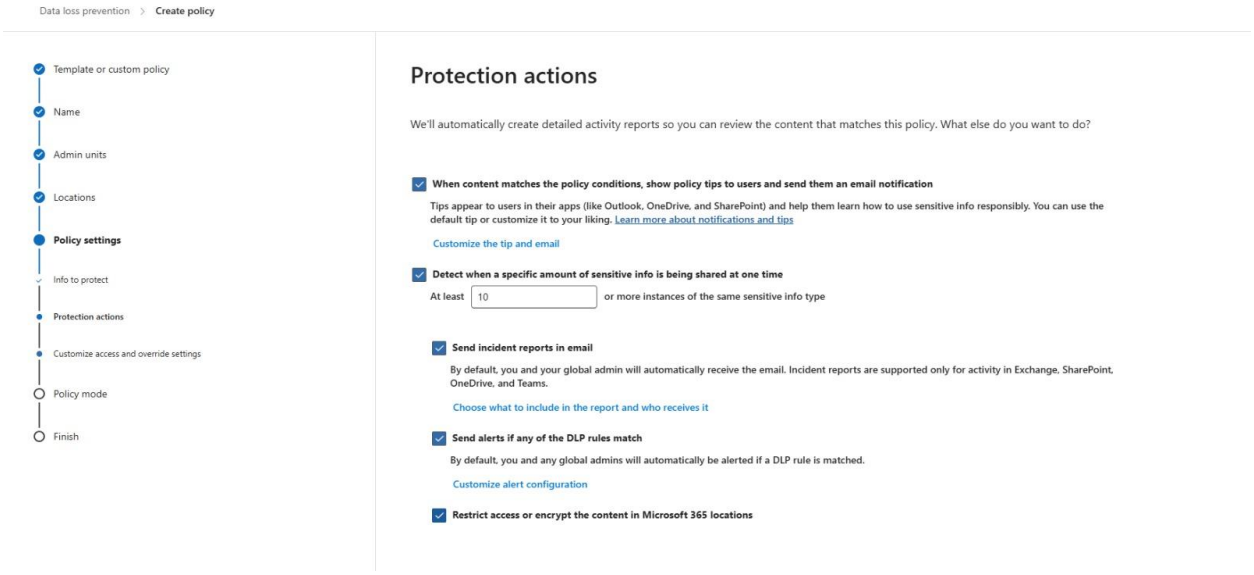
- *Figure 6.11: Reviewing the default settings and conditions for PII.*

- **[Insert Image: Info to protect - ITIN, SSN, Passport]**



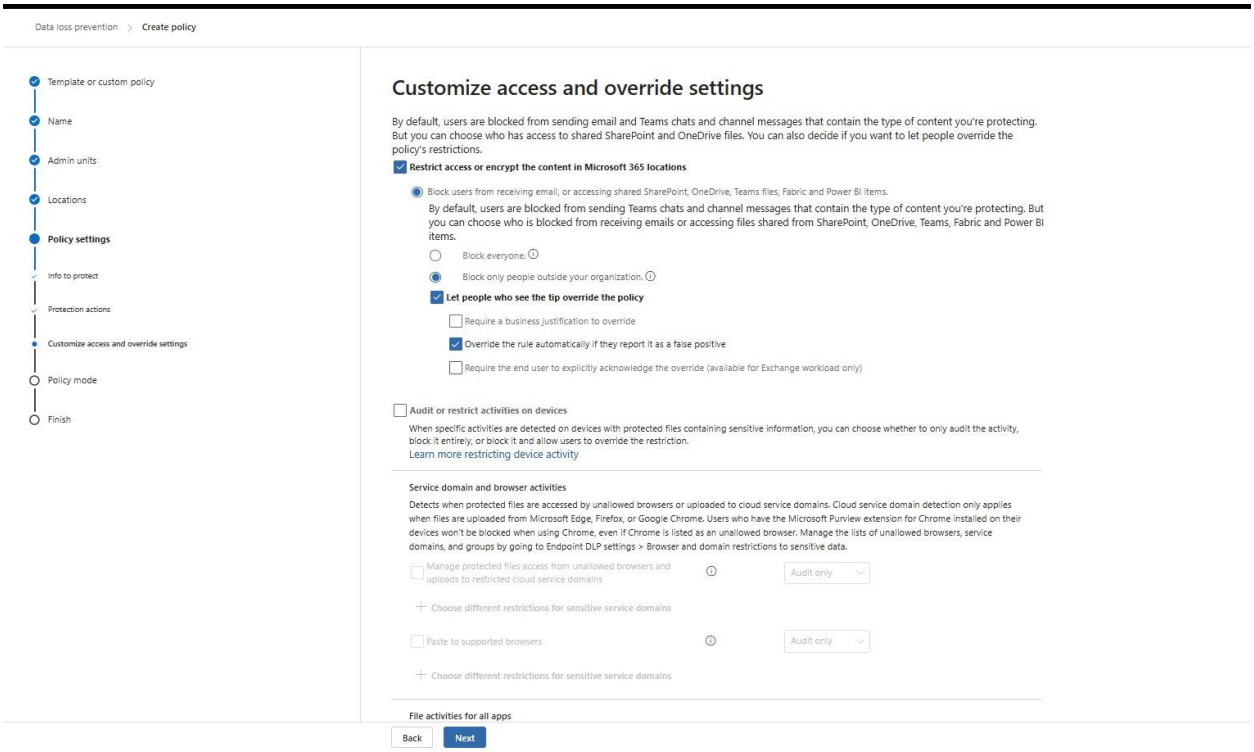
- *Figure 6.12: The list of sensitive info types included in the PII template.*

- **[Insert Image: Protection actions - Tips and alerts]**



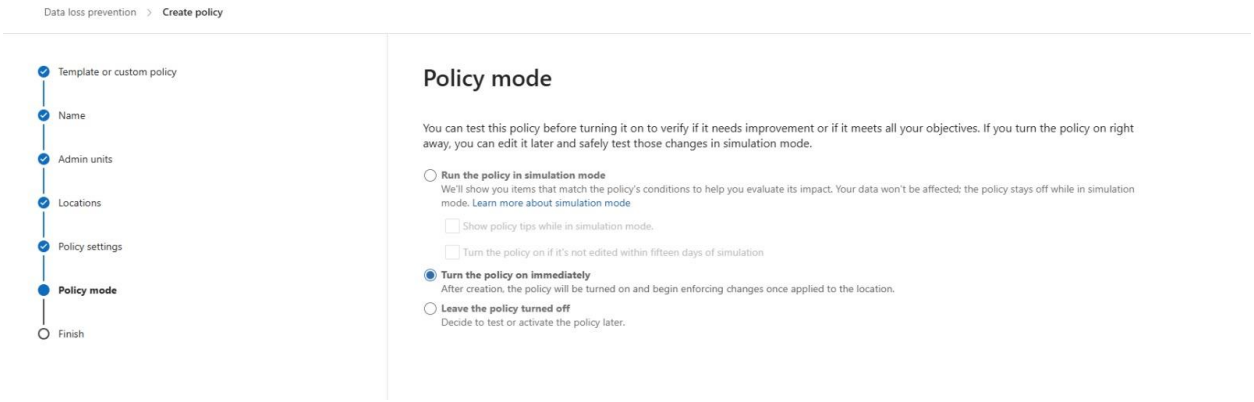
- *Figure 6.13: Configuring policy tips and incident reports.*

- **[Insert Image: Customize access and override settings]**



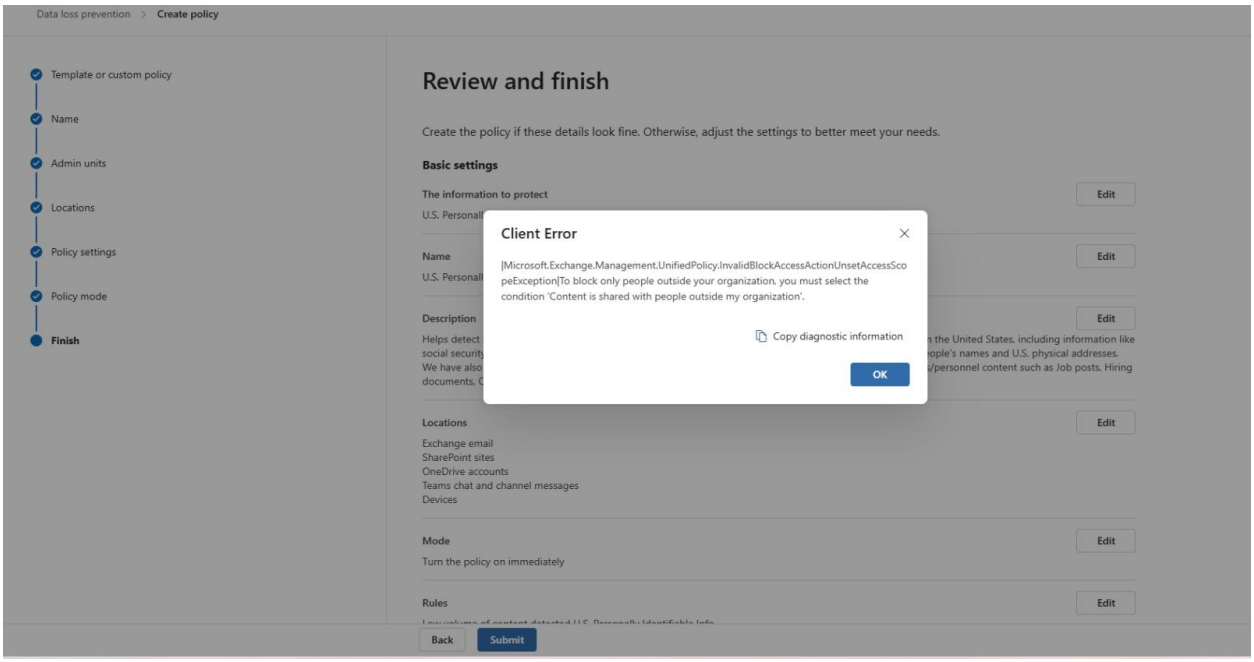
- *Figure 6.14: Setting the policy to block external sharing.*

- **[Insert Image: Policy mode - Turn on immediately]**



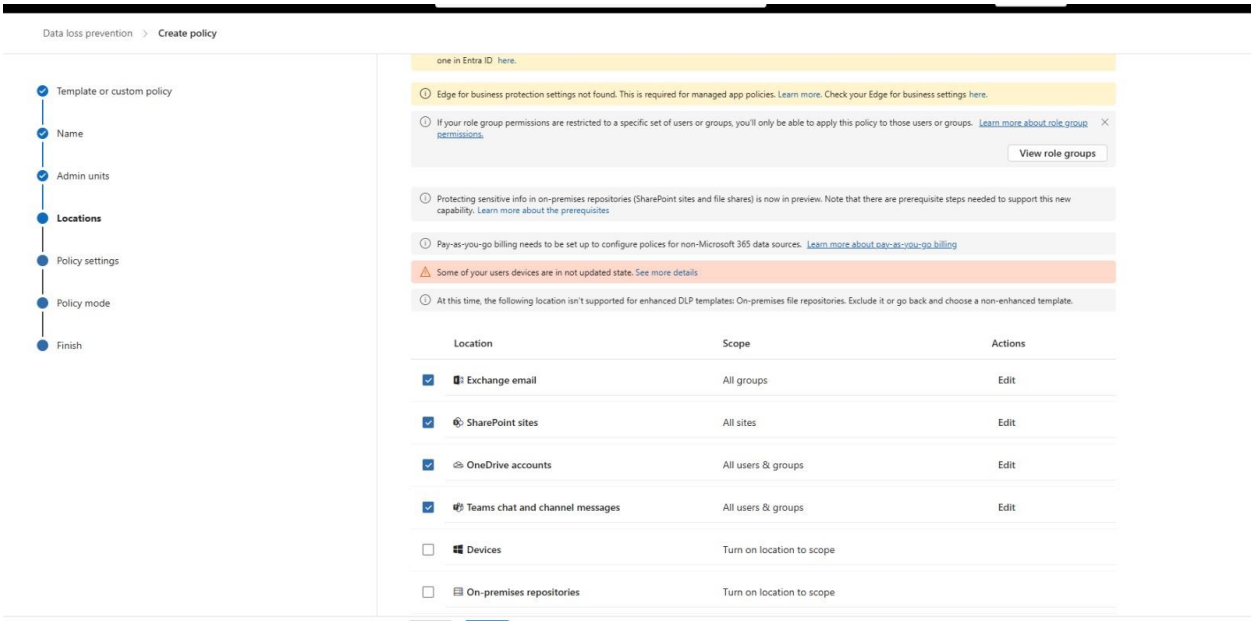
- *Figure 6.15: Setting the policy to enforce immediately.*

- **[Insert Image: Client Error - Invalid Block Access]**



- *Figure 6.16: The error encountered when attempting to submit the policy.*

- **[Insert Image: Review and finish - Adjusting locations]**

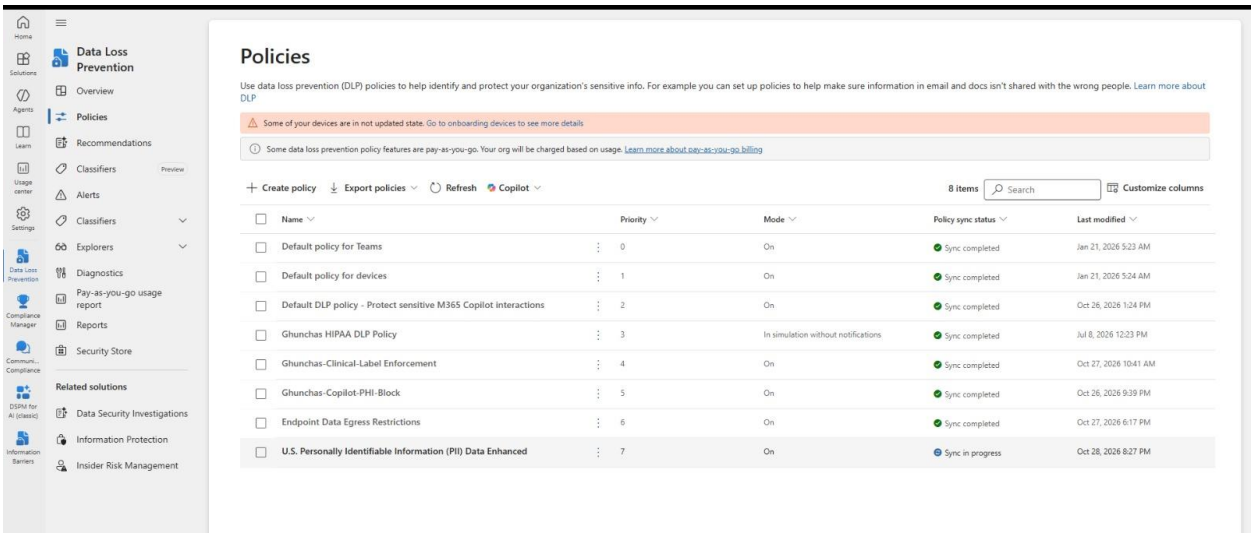


- *Figure 6.17: Adjusting the locations to resolve the error.*

Step 5: Verifying the Active DLP Policies

We verify that the policy is successfully syncing.

- **[Insert Image: DLP Policies list - PII Data Enhanced]**

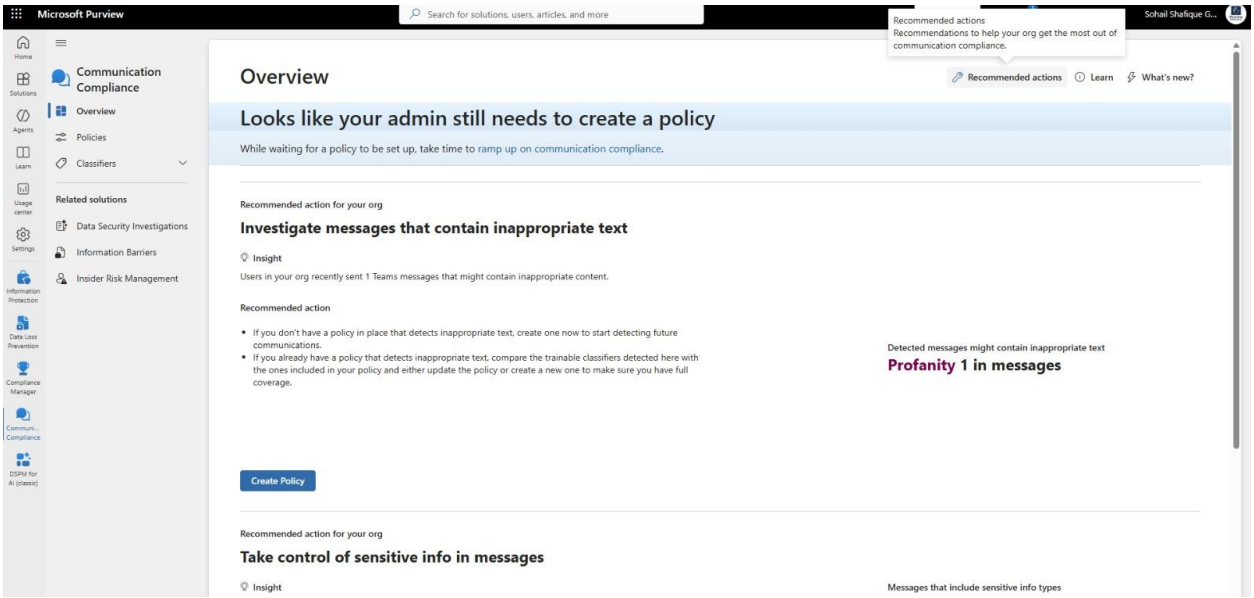


- *Figure 6.18: The DLP dashboard showing the new PII policy in "Sync in progress" status.*

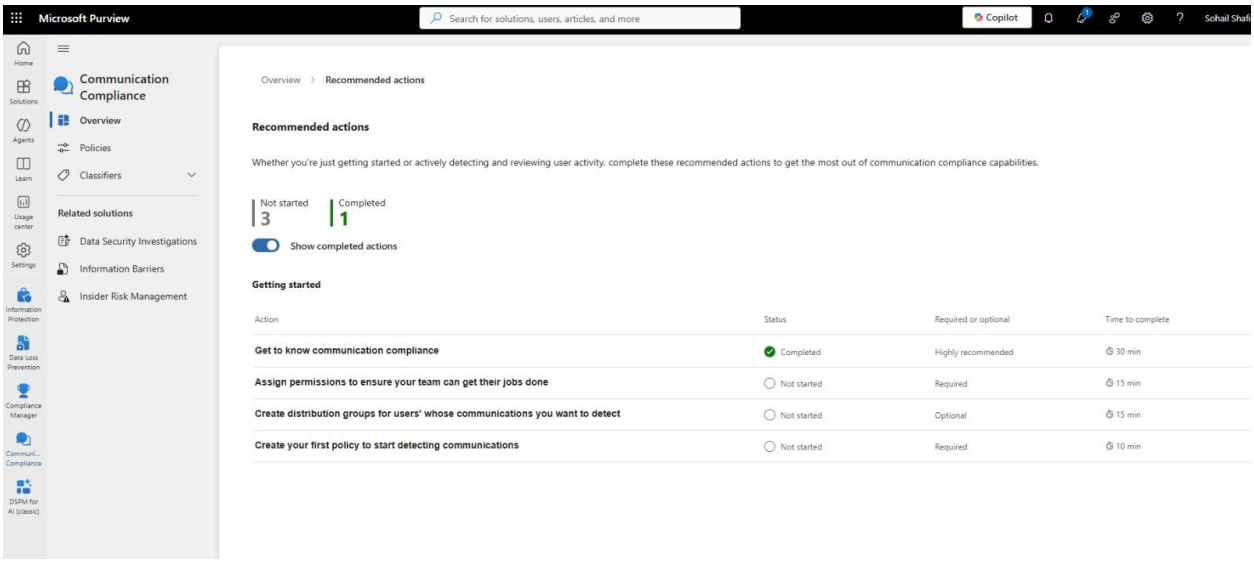
Step 6: Navigating to Communication Compliance

We move to the Communication Compliance solution to begin scanning internal communications for sensitive data and inappropriate text.

- **[Insert Image: Communication Compliance - Overview]**



- *Figure 6.19: The overview page indicating the need to create a policy.*
- **[Insert Image: Communication Compliance - Recommended actions]**

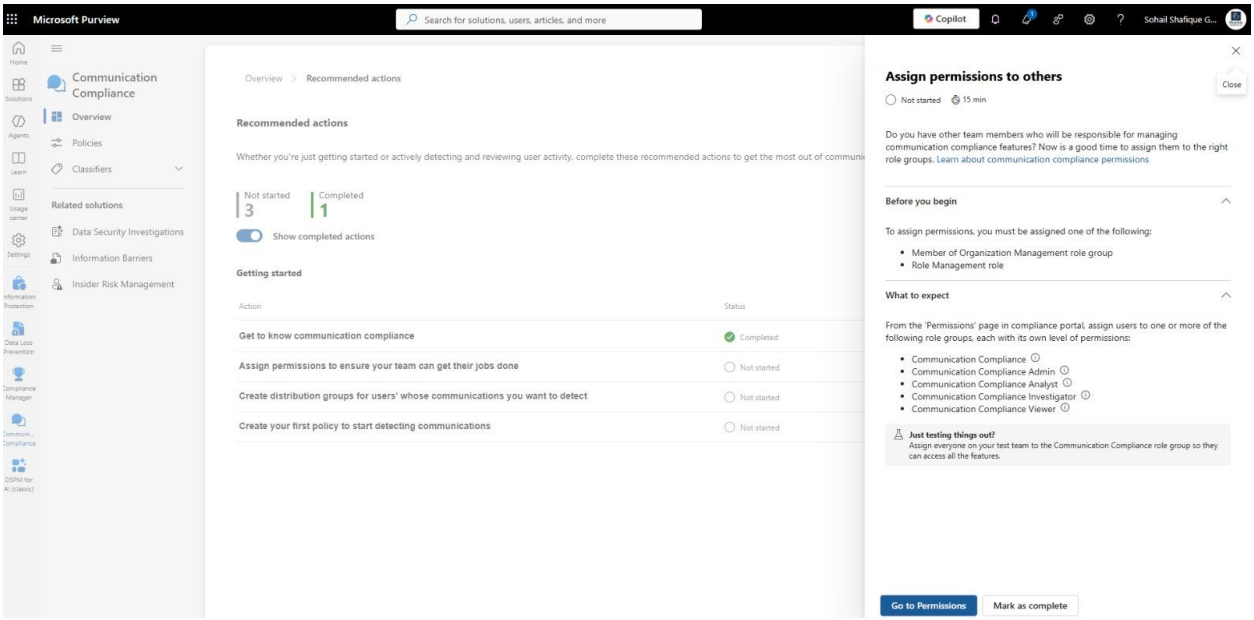


- *Figure 6.20: The recommended actions dashboard, showing permissions and group creation.*

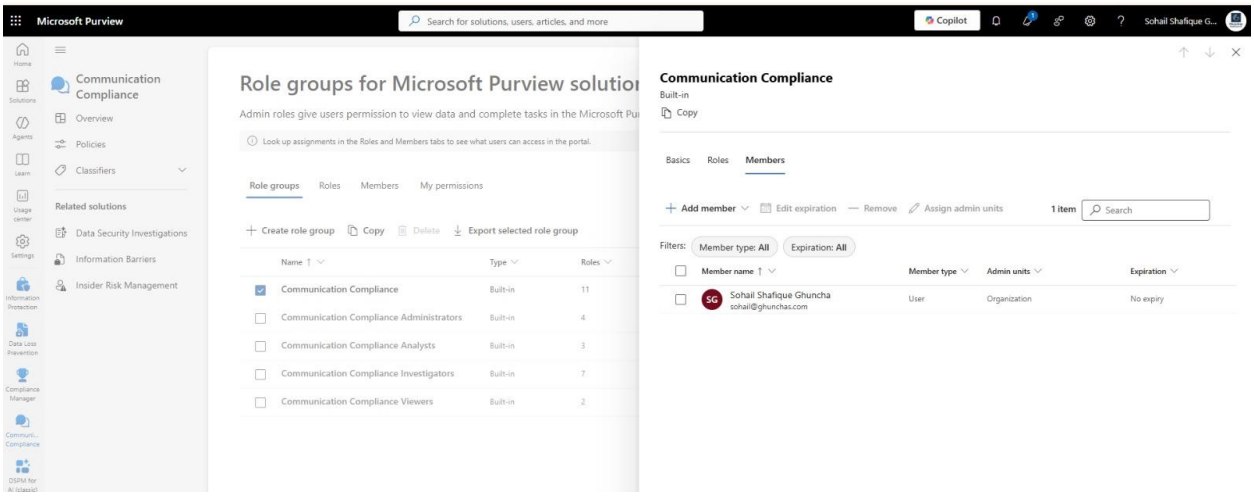
Step 7: Assigning Communication Compliance Roles

We assign the necessary role groups (Admin, Analyst, Investigator, Viewer) to the security team.

- **[Insert Image: Assign permissions to others]**

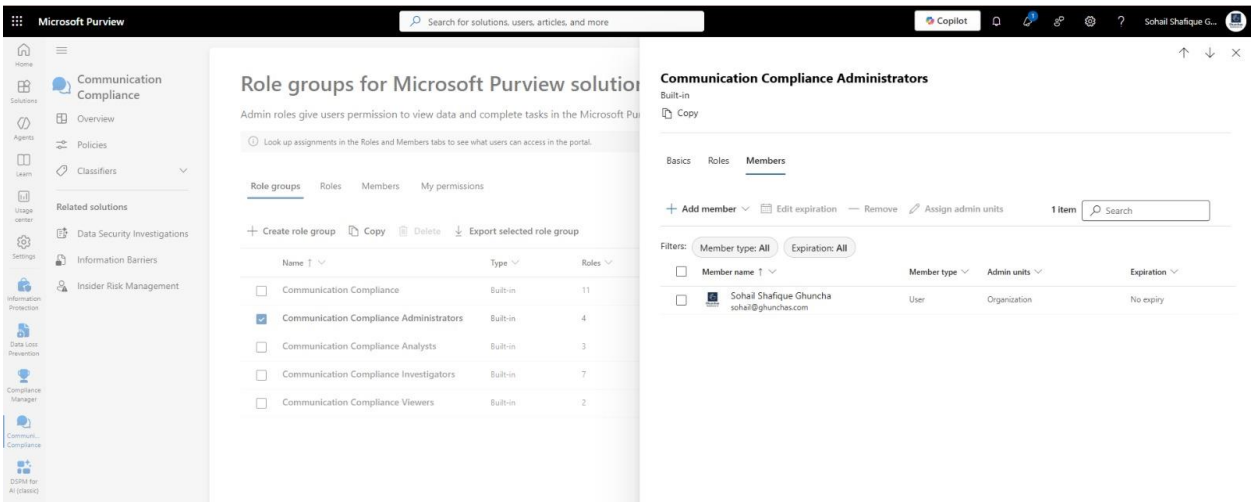


- *Figure 6.21: The recommendation to assign role groups.*
- **[Insert Image: Role groups - Communication Compliance]**



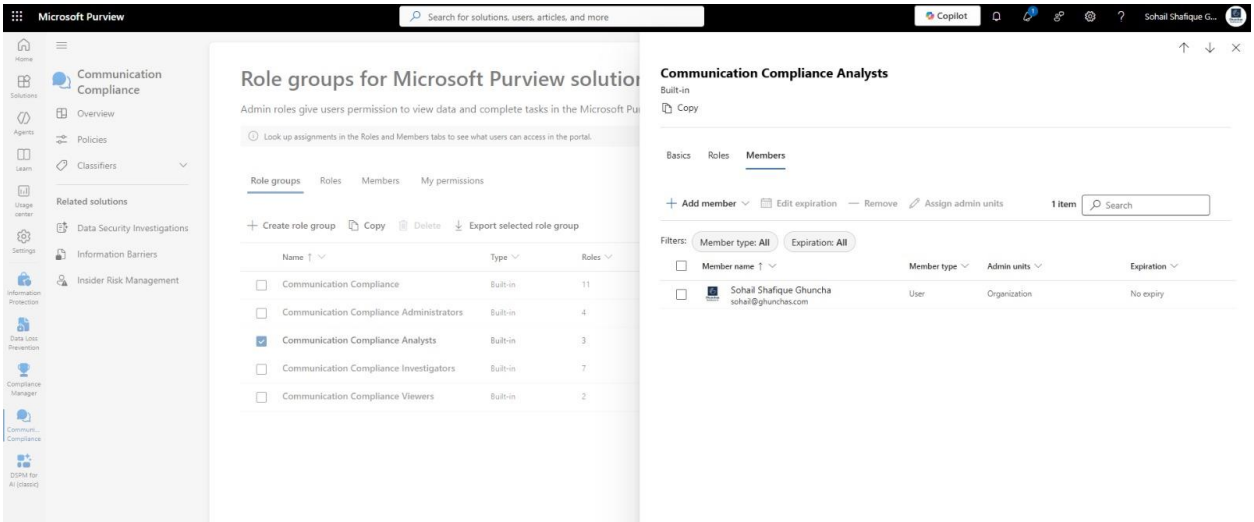
- *Figure 6.22: Viewing the role groups.*

- **[Insert Image: Communication Compliance - Admins]**



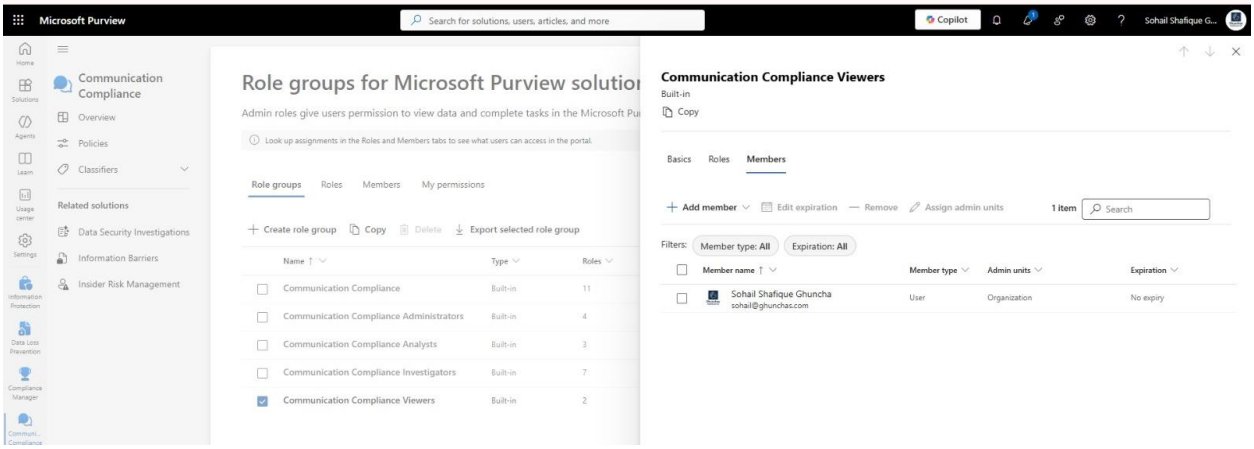
- *Figure 6.23: Assigning the user to the Administrators role group.*

- **[Insert Image: Communication Compliance - Analysts]**



- *Figure 6.24: Assigning the user to the Analysts role group.*

- **[Insert Image: Communication Compliance - Viewers]**

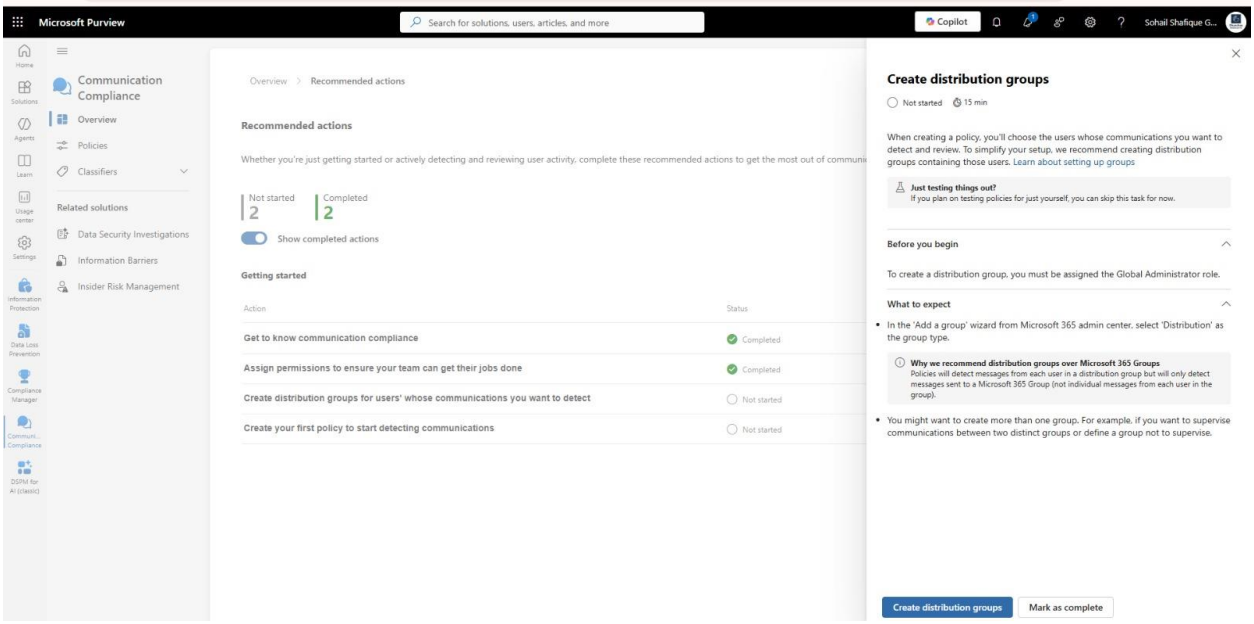


- *Figure 6.25: Assigning the user to the Viewers role group.*

Step 8: Creating the Distribution Group (Pilot)

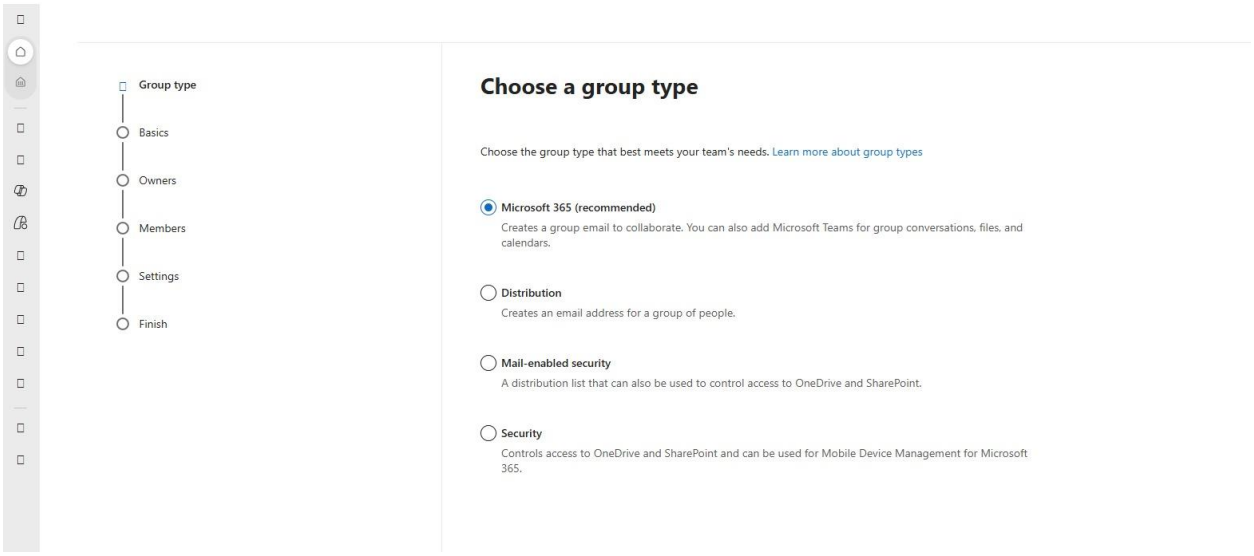
We create a specific Microsoft 365 Group to scope the Communication Compliance policy to a pilot set of users.

- **[Insert Image: Create distribution groups - Recommendation]**



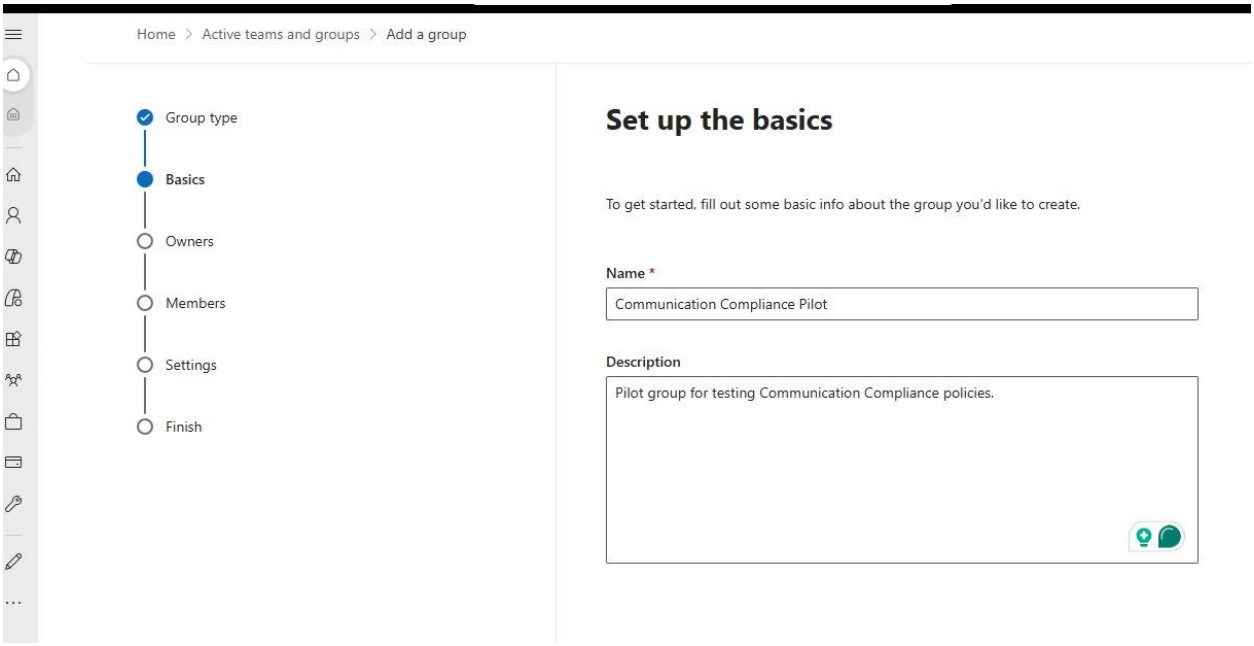
- *Figure 6.26: The recommendation to create a distribution group for monitoring.*

- **[Insert Image: Choose a group type - Microsoft 365]**



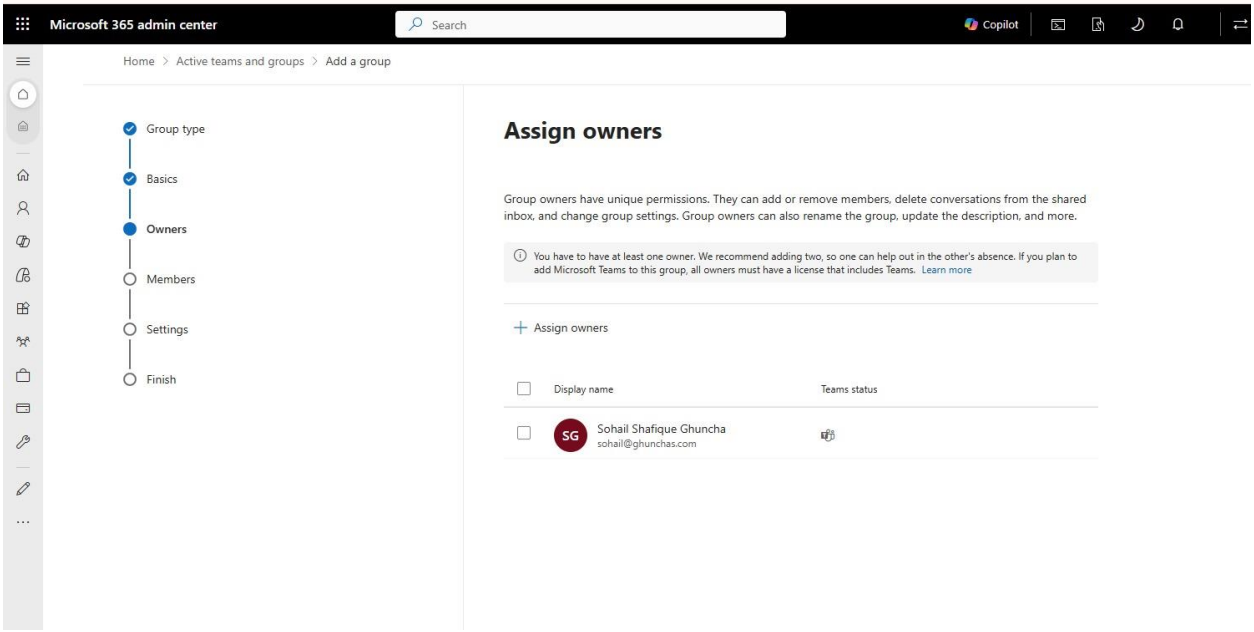
- *Figure 6.27: Selecting the Microsoft 365 group type.*

- **[Insert Image: Set up the basics - Communication Compliance Pilot]**



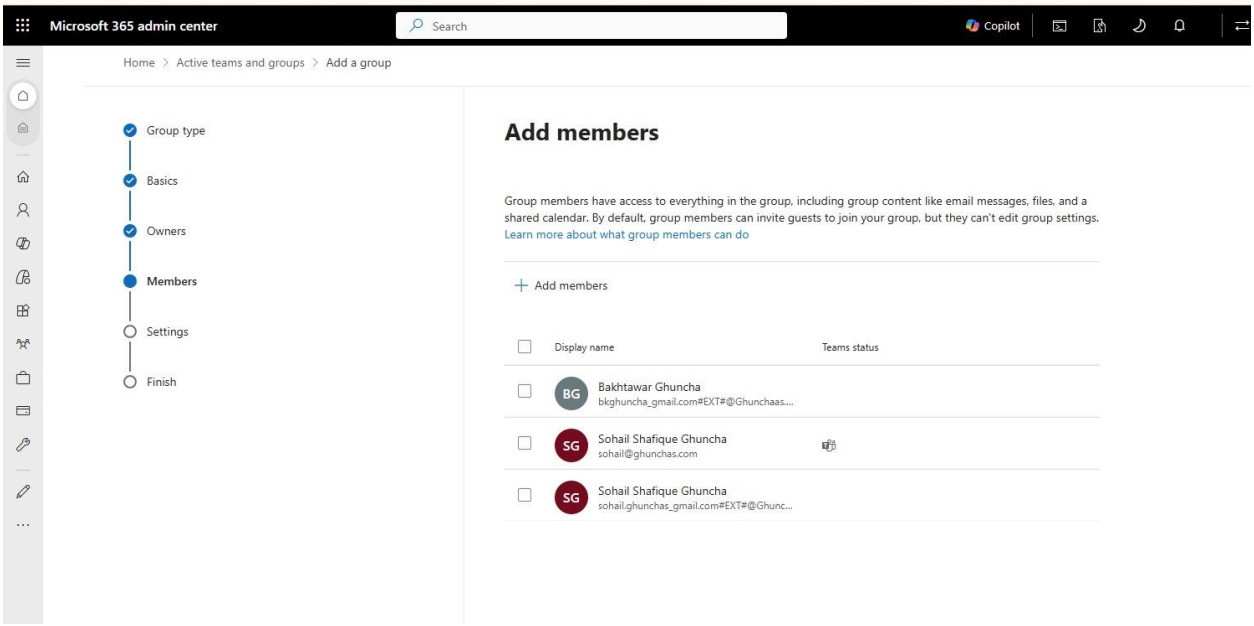
- *Figure 6.28: Naming the group "Communication Compliance Pilot".*

- **[Insert Image: Assign owners - Sohail]**



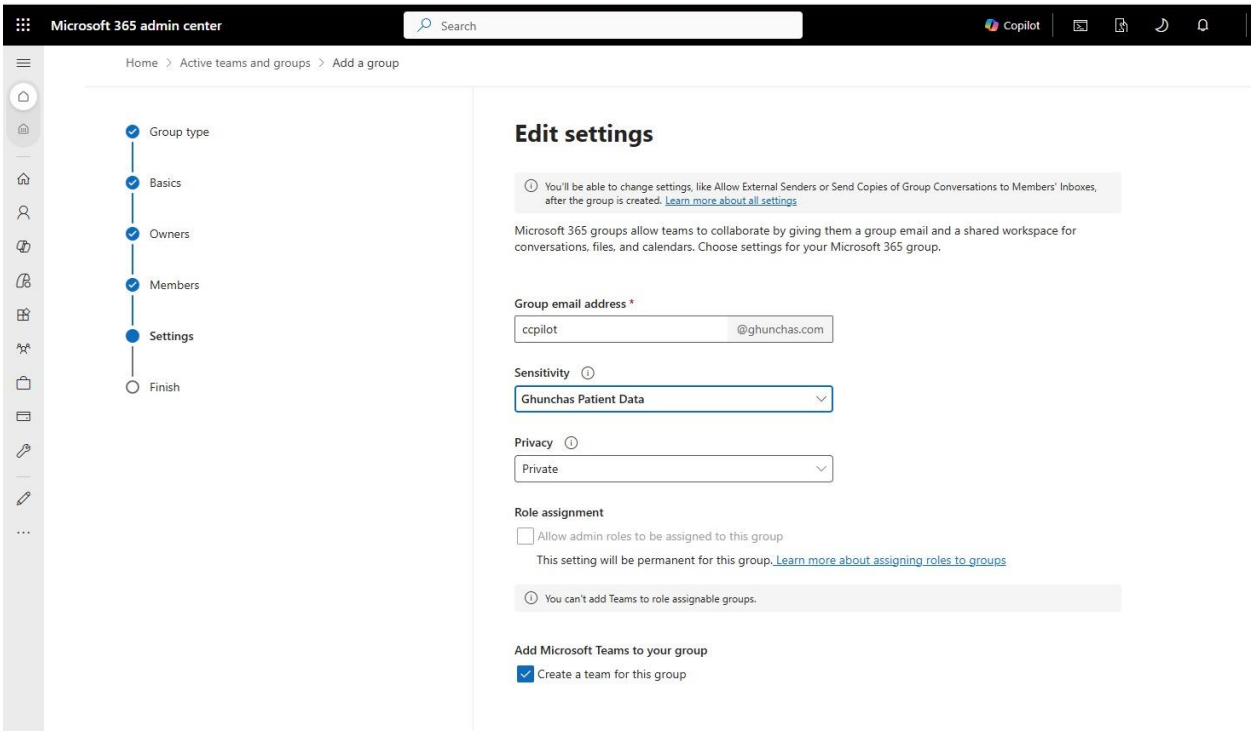
- *Figure 6.29: Assigning the group owner.*

- **[Insert Image: Add members - Bakhtawar, Sohail]**



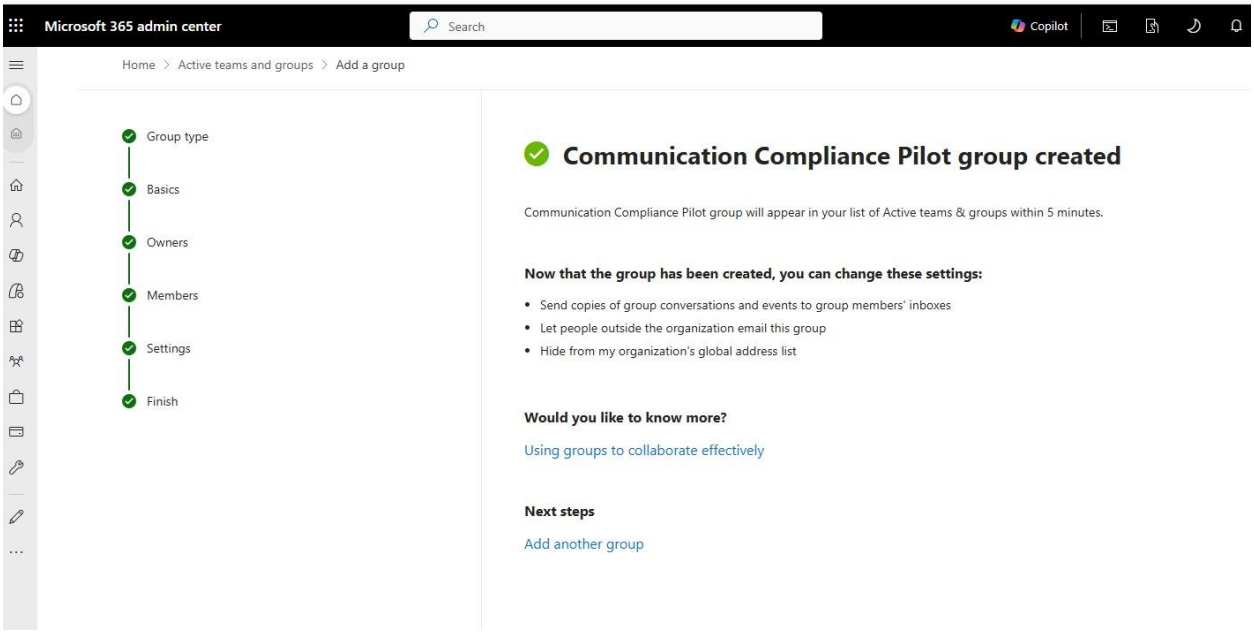
- *Figure 6.30: Adding the pilot users to the group.*

- **[Insert Image: Edit settings - Sensitivity label]**



- *Figure 6.31: Applying the "Ghunchas Patient Data" sensitivity label to the group.*

- **[Insert Image: Communication Compliance Pilot group created]**

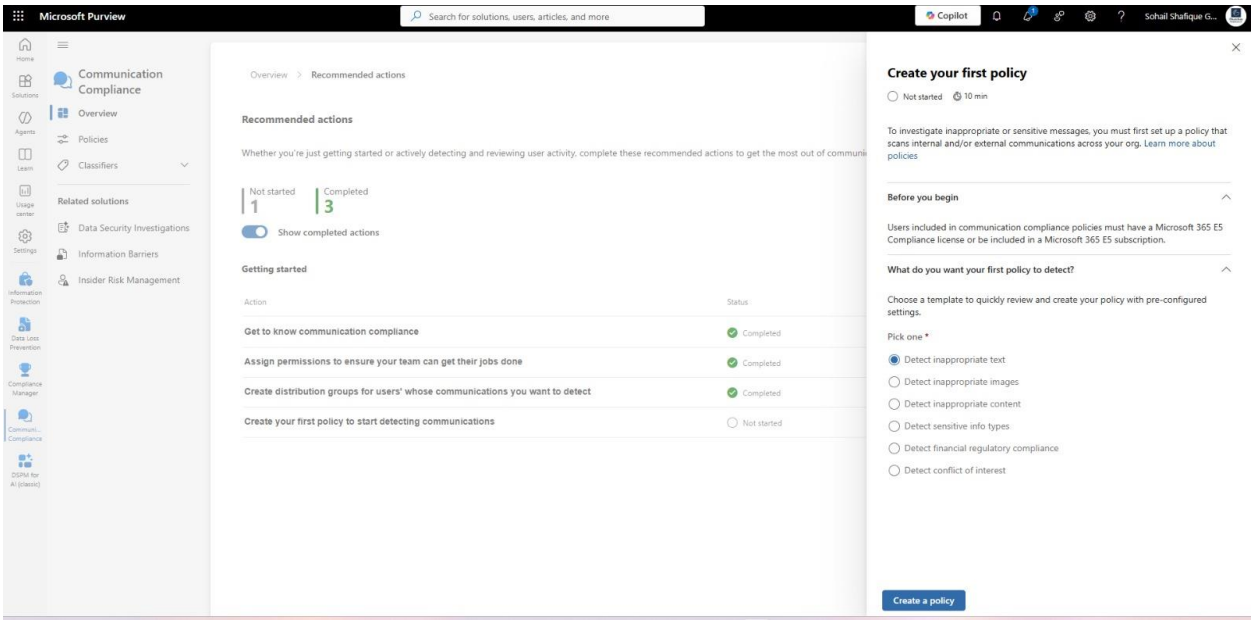


- *Figure 6.32: Confirmation of the group creation.*

Step 9: Creating the Communication Compliance Policies

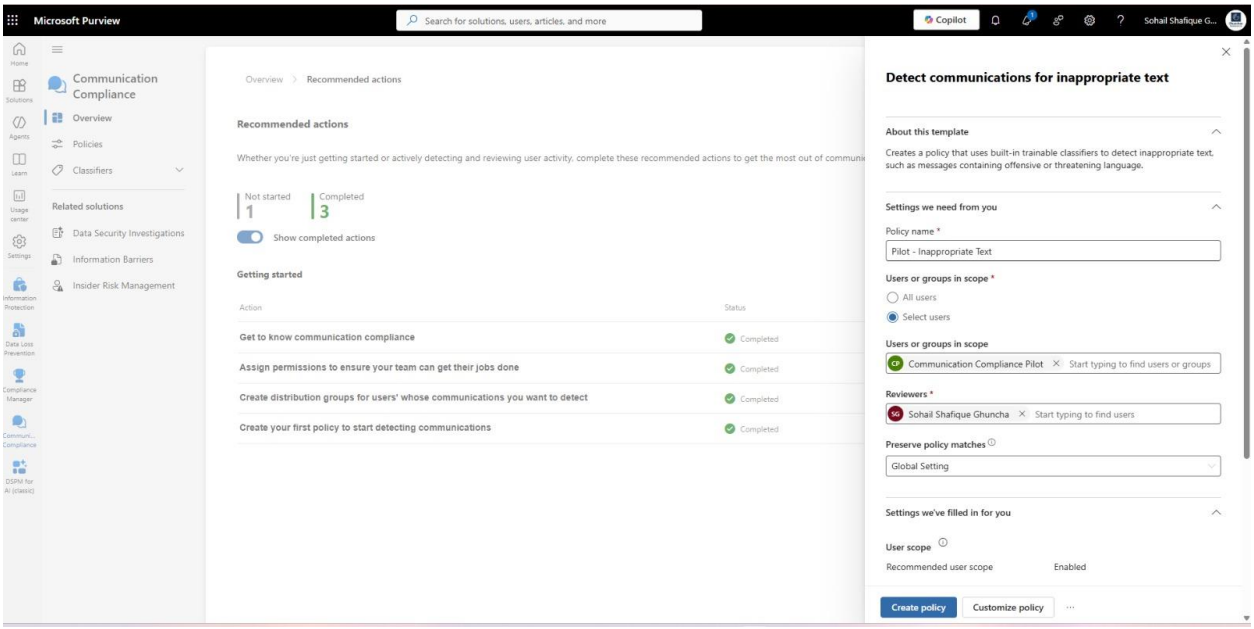
We create the actual policies to scan Teams and email for inappropriate text and sensitive information.

- **[Insert Image: Create your first policy - Detect inappropriate text]**



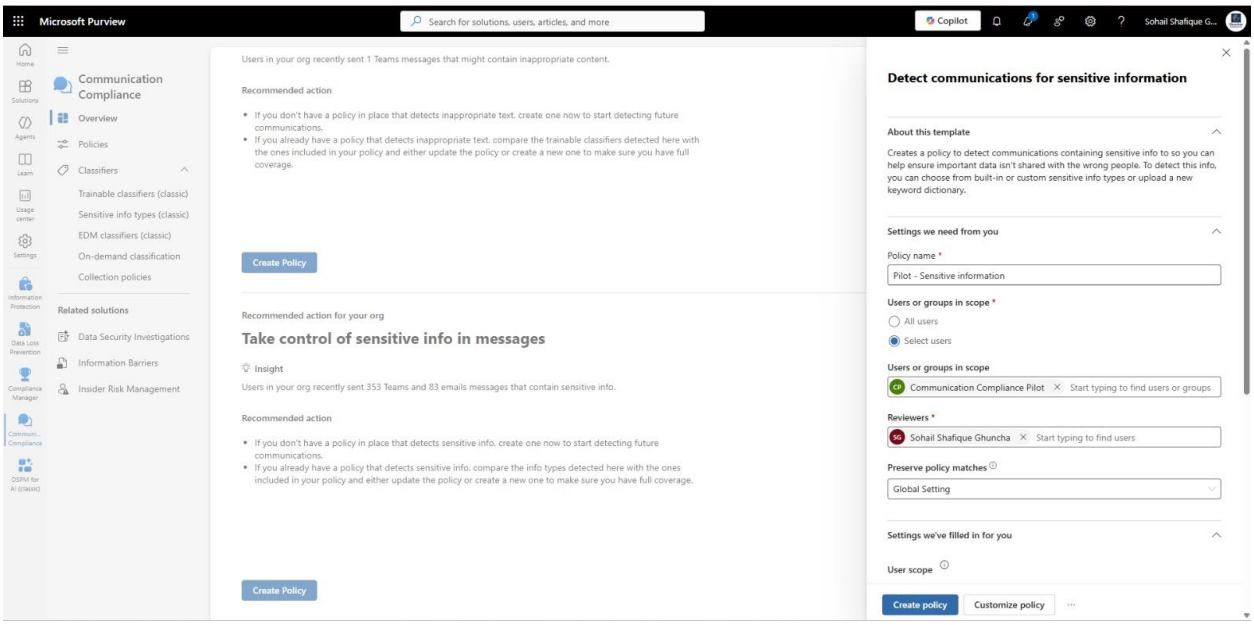
  - *Figure 6.33: Selecting the template to detect inappropriate text.*

- **[Insert Image: Detect communications for inappropriate text]**



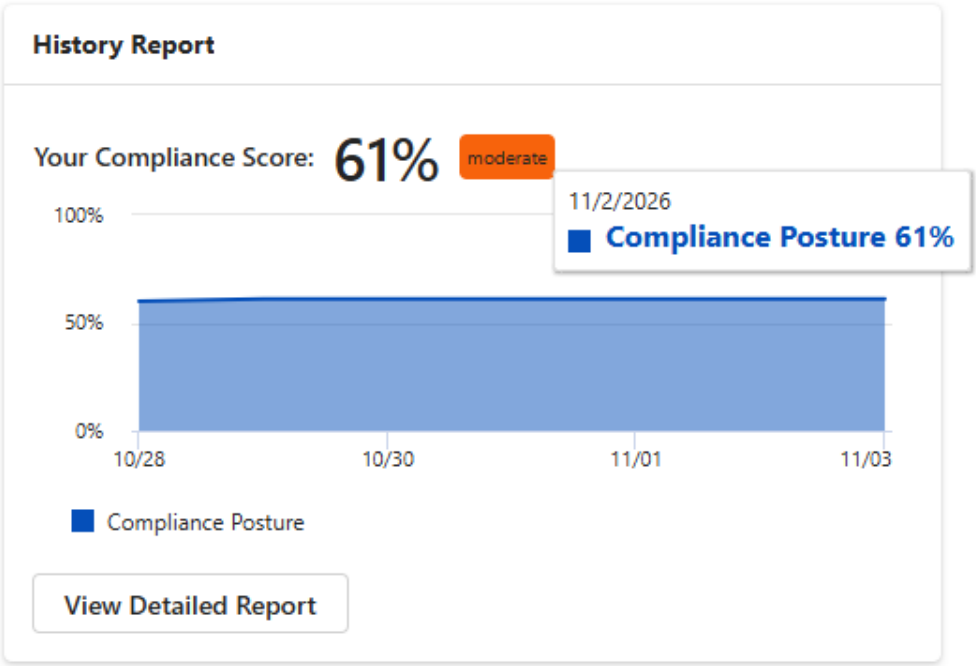
  - *Figure 6.34: Scoping the policy to the "Communication Compliance Pilot" group and assigning reviewers.*

- **[Insert Image: Detect communications for sensitive information]**



- *Figure 6.35: Creating the second policy to detect sensitive information.*

Reports



PHASE 7: DATA SECURITY POSTURE MANAGEMENT (DSPM) FOR AI

Objective: Gain visibility into how AI (Microsoft 365 Copilot, ChatGPT, etc.) is interacting with sensitive healthcare data, and deploy automated policies to prevent data leaks through AI prompts and responses.

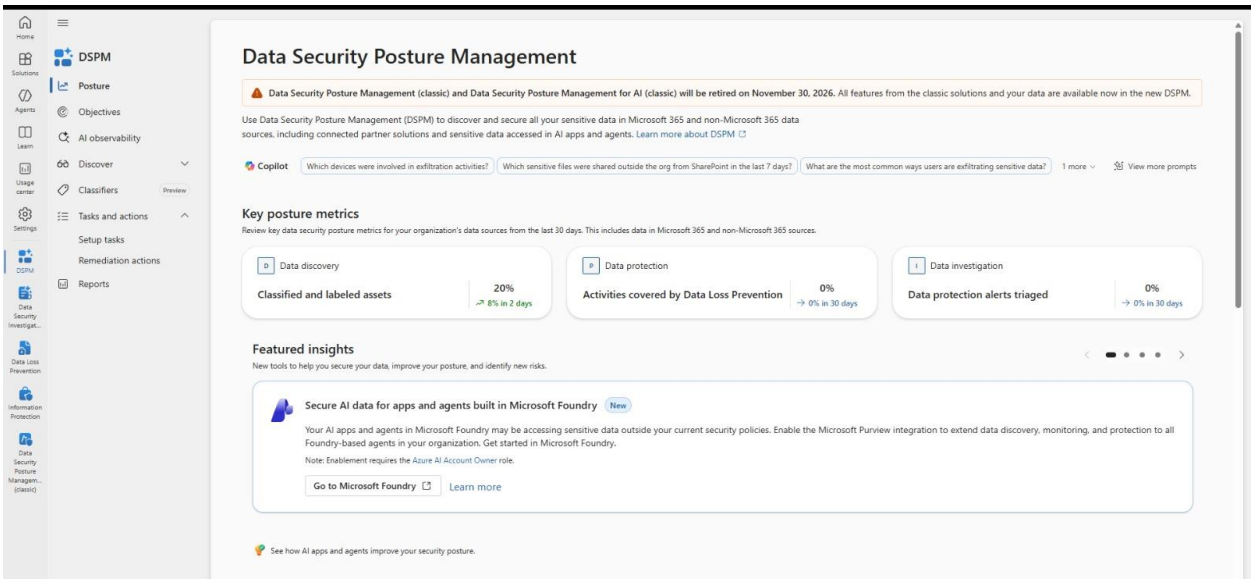
7.1 The Business Value (Why We Do This)

AI is the newest exfiltration channel. Employees can accidentally (or maliciously) paste PHI into ChatGPT, or ask Copilot to summarize a patient record. Microsoft Purview DSPM for AI provides the visibility needed to see these interactions and the controls to block them. For HITRUST compliance, this proves the organization is actively governing AI usage, not just ignoring it.

7.2 The Ghunchas Configuration Standard

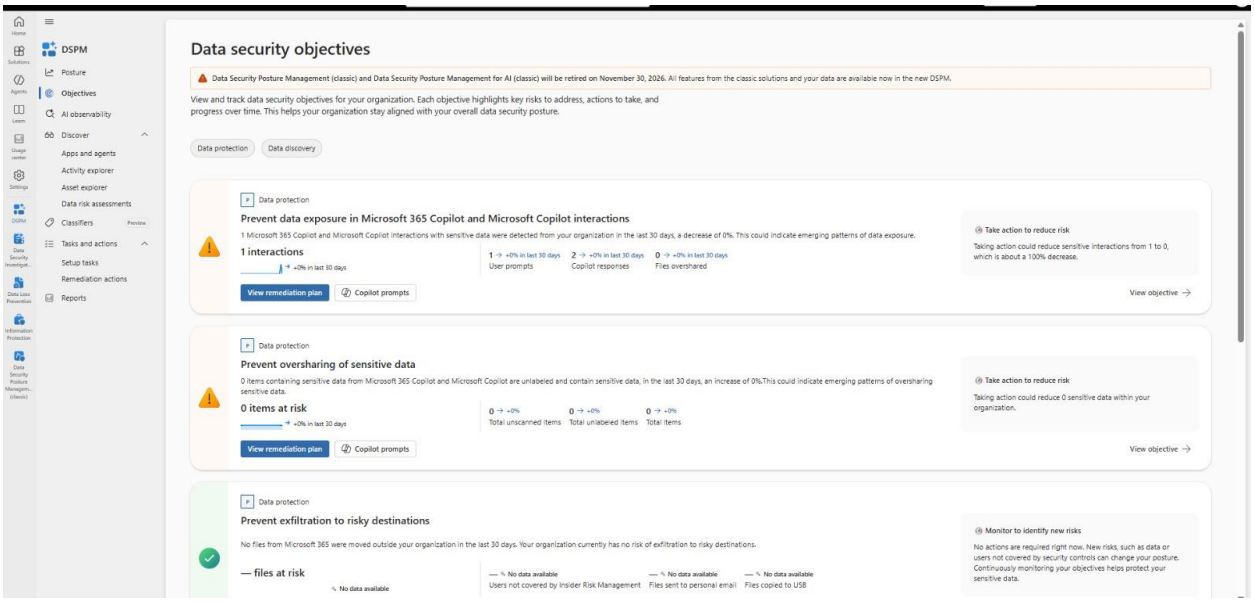
Step 1: Reviewing the DSPM Dashboard
We begin by reviewing the overall posture metrics. This shows the percentage of labeled assets, DLP coverage, and how many alerts have been triaged.

- **[Insert Image: DSPM - Posture Dashboard]**



- *Figure 7.1: The DSPM dashboard, showing key metrics like Classified assets (20%) and Data protection alerts triaged (0%).*

- **[Insert Image: DSPM - Objectives]**

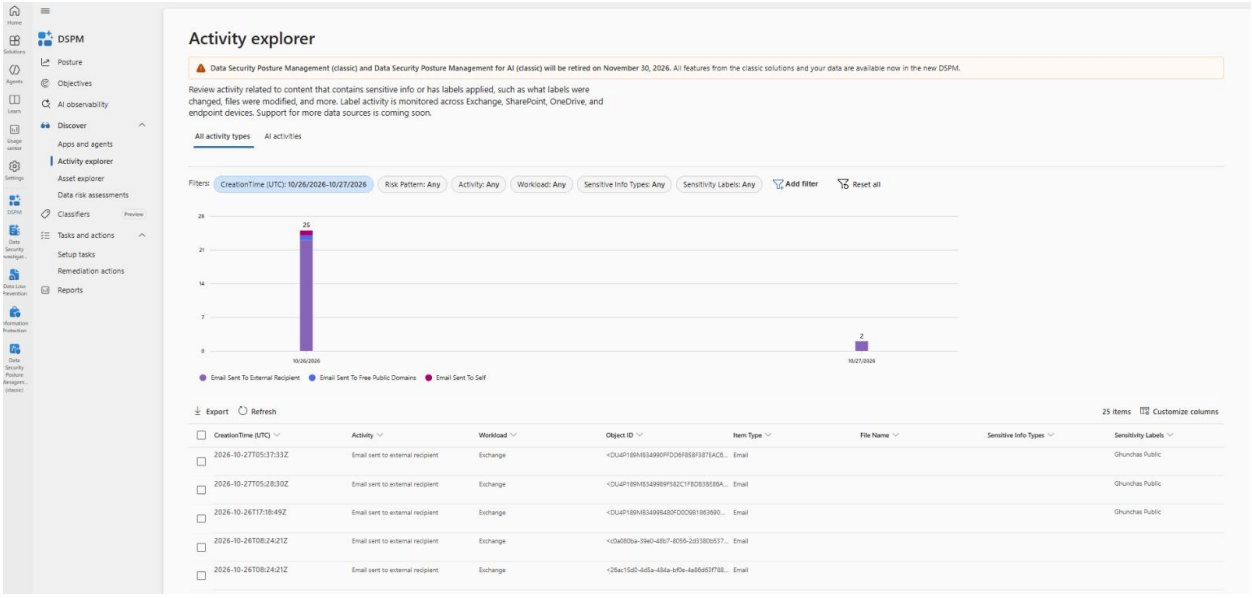


- *Figure 7.2: The Data security objectives, highlighting the goal to "Prevent data exposure in Copilot interactions" and "Prevent oversharing."*

Step 2: Investigating AI Activity & Assets

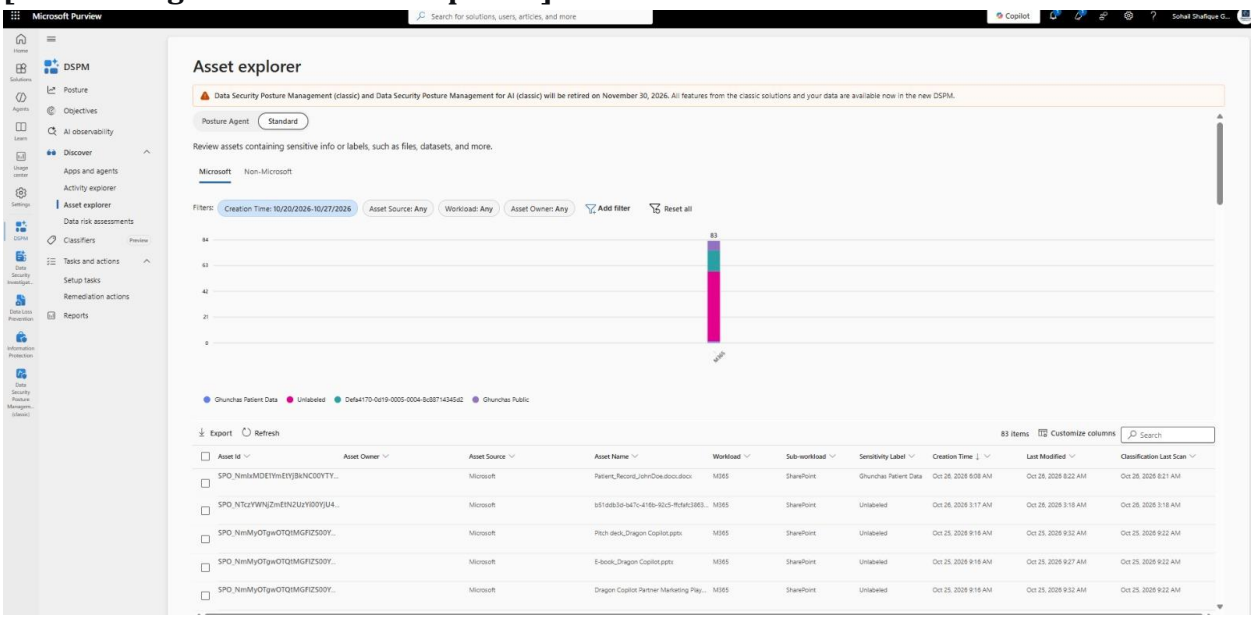
We use the Activity Explorer to see exactly what users are doing with AI, and the Asset Explorer to see which files are being referenced by AI.

- **[Insert Image: DSPM - Activity explorer]**



- *Figure 7.3: The Activity Explorer, showing email activity and sensitive info types detected over a 30-day period.*

- **[Insert Image: DSPM - Asset explorer]**



- *Figure 7.4: The Asset Explorer, showing files labeled as "Ghunchas Patient Data" and files that remain "Unlabeled" but contain sensitive data.*

Step 3: Reviewing Remediation Actions

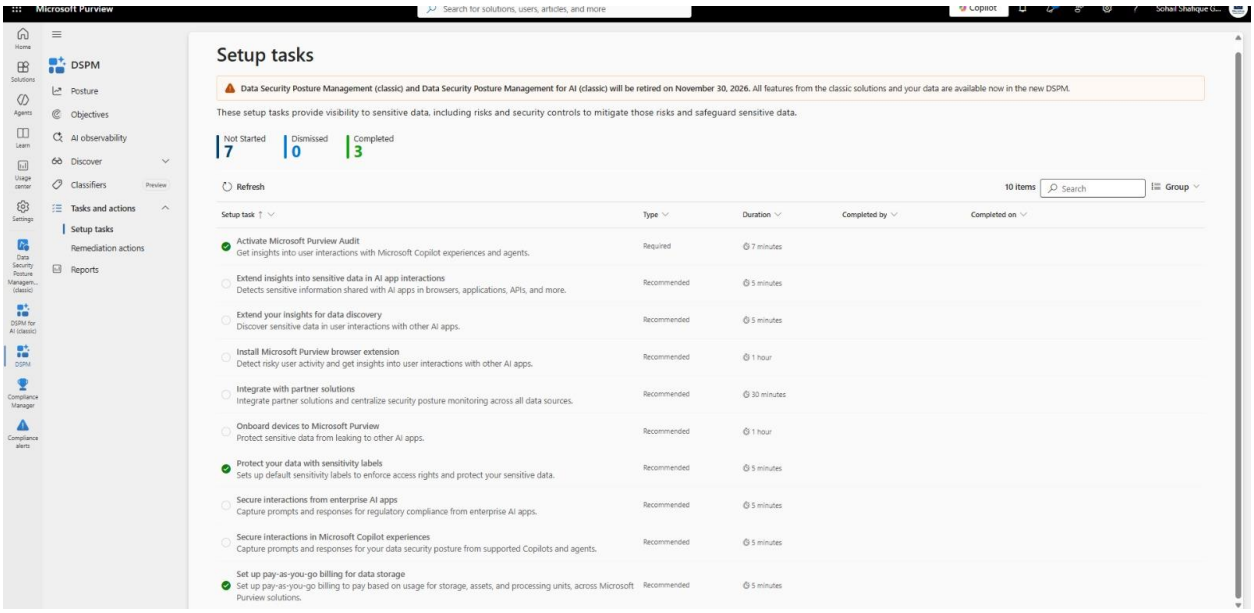
We review the recommended remediation actions to harden the AI environment. This acts as our to-do list for securing Copilot.

- **[Insert Image: DSPM - Remediation actions list]**

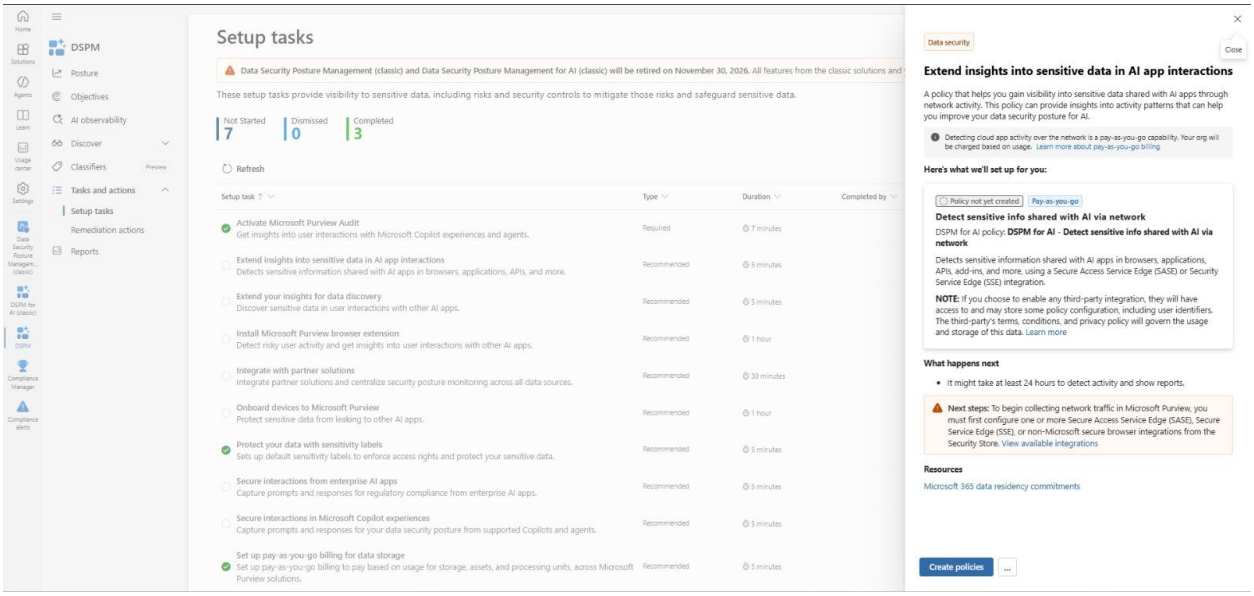
- *Figure 7.5: The list of remediation actions, showing what is not started vs. completed.*

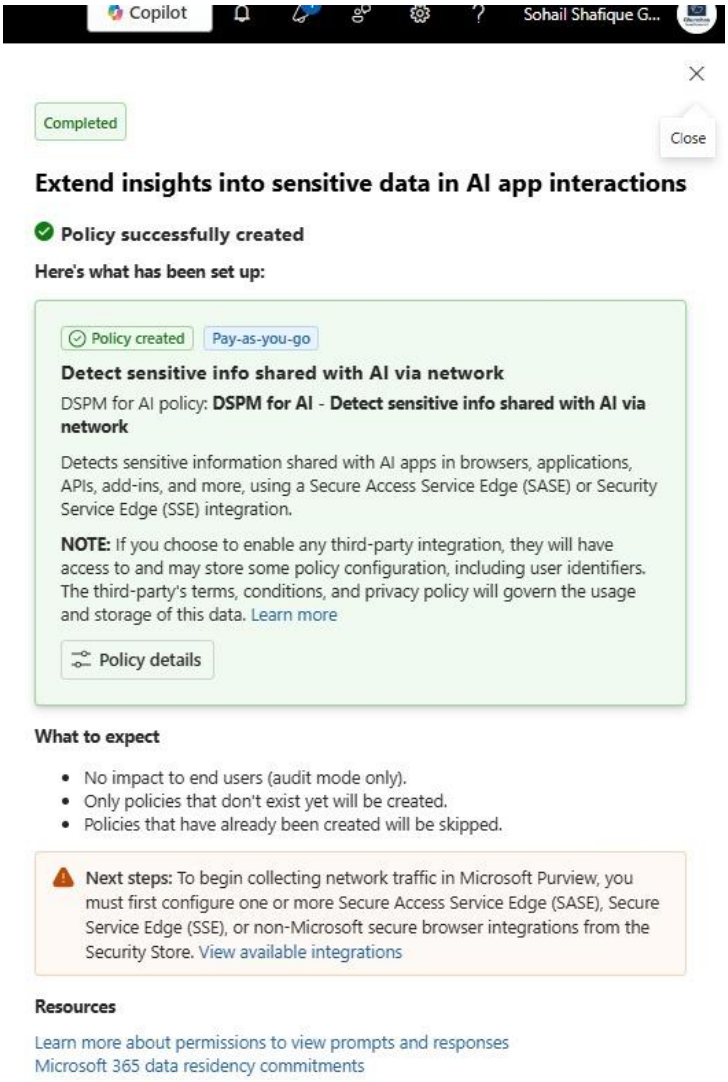
Step 4: Deploying AI Security Policies (Setup Tasks)
We execute the specific setup tasks to enable visibility and protection for AI. This includes extending insights to third-party AI apps (like ChatGPT) and configuring network detection.

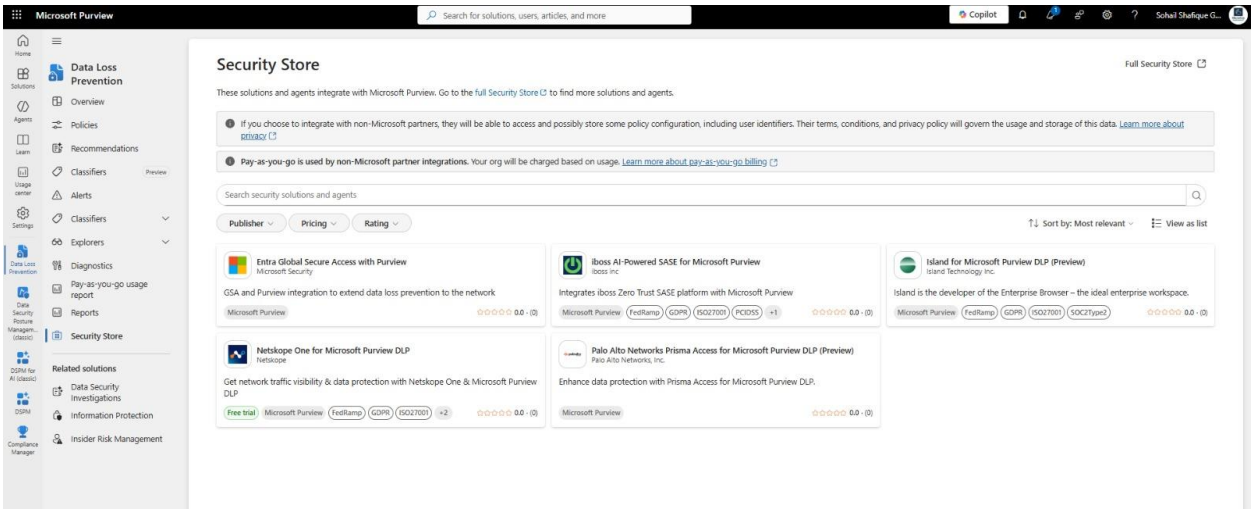
- **[Insert Image: DSPM - Setup tasks list]**



- *Figure 7.6: The Setup tasks dashboard, showing the status of AI protection policies.*
- **[Insert Image: Extend insights into sensitive data in AI app interactions]**


DSPM
Posture
Objectives
AI observability
Discover
Classifiers
Tasks and actions
Setup tasks
Remediation actions
Reports
Setup tasks
Data Security Posture Management (classic) and Data Security Posture Management for AI (classic) will be retired on November 30, 2026. All features from the classic solutions and
These setup tasks provide visibility to sensitive data, including risks and security controls to mitigate those risks and safeguard sensitive data.
Not Started 7
Dismissed 0
Completed 3
Refresh
Setup task
Type
Duration
Completed by
Activate Microsoft Purview Audit
Get insights into user interactions with Microsoft Copilot experiences and agents.
Required
7 minutes
Extend insights into sensitive data in AI app interactions
Detects sensitive information shared with AI apps in browsers, applications, APIs, and more.
Recommended
5 minutes
Extend your insights for data discovery
Discover sensitive data in user interactions with other AI apps.
Recommended
5 minutes
Install Microsoft Purview browser extension
Detect risky user activity and get insights into user interactions with other AI apps.
Recommended
1 hour
Integrate with partner solutions
Integrate partner solutions and centralize security posture monitoring across all data sources.
Recommended
30 minutes
Onboard devices to Microsoft Purview
Protect sensitive data from leaking to other AI apps.
Recommended
1 hour
Protect your data with sensitivity labels
Sets up default sensitivity labels to enforce access rights and protect your sensitive data.
Recommended
5 minutes
Secure interactions from enterprise AI apps
Capture prompts and responses for regulatory compliance from enterprise AI apps.
Recommended
5 minutes
Secure interactions in Microsoft Copilot experiences
Capture prompts and responses for your data security posture from supported Copilots and agents.
Recommended
5 minutes
Set up pay-as-you-go billing for data storage
Set up pay-as-you-go billing to pay based on usage for storage, assets, and processing units, across Microsoft Purview solutions.
Recommended
5 minutes
Data security
Close
Extend insights into sensitive data in AI app interactions
A policy that helps you gain visibility into sensitive data shared with AI apps through network activity. This policy can provide insights into activity patterns that can help you improve your data security posture for AI.
Detecting cloud app activity over the network is a pay-as-you-go capability. Your org will be charged based on usage. Learn more about pay-as-you-go billing
Here's what we'll set up for you:
Policy not yet created
Pay-as-you-go
Detect sensitive info shared with AI via network
DSPM for AI policy: DSPM for AI - Detect sensitive info shared with AI via network
Detects sensitive information shared with AI apps in browsers, applications, APIs, add-ins, and more, using a Secure Access Service Edge (SASE) or Security Service Edge (SSE) integration.
NOTE: If you choose to enable any third-party integration, they will have access to and may store some policy configuration, including user identifiers. The third-party's terms, conditions, and privacy policy will govern the usage and storage of this data. Learn more
What happens next
It might take at least 24 hours to detect activity and show reports.
Next steps: To begin collecting network traffic in Microsoft Purview, you must first configure one or more Secure Access Service Edge (SASE), Secure Service Edge (SSE), or non-Microsoft secure browser integrations from the Security Store. View available integrations
Resources
Microsoft 365 data residency commitments
Create policies
...


Copilot
Sohail Shafique G...
Completed
Close
Extend insights into sensitive data in AI app interactions
Policy successfully created
Here's what has been set up:
Policy created
Pay-as-you-go
Detect sensitive info shared with AI via network
DSPM for AI policy: DSPM for AI - Detect sensitive info shared with AI via network
Detects sensitive information shared with AI apps in browsers, applications, APIs, add-ins, and more, using a Secure Access Service Edge (SASE) or Security Service Edge (SSE) integration.
NOTE: If you choose to enable any third-party integration, they will have access to and may store some policy configuration, including user identifiers. The third-party's terms, conditions, and privacy policy will govern the usage and storage of this data. Learn more
Policy details
What to expect
No impact to end users (audit mode only).
Only policies that don't exist yet will be created.
Policies that have already been created will be skipped.
Next steps: To begin collecting network traffic in Microsoft Purview, you must first configure one or more Secure Access Service Edge (SASE), Secure Service Edge (SSE), or non-Microsoft secure browser integrations from the Security Store. View available integrations
Resources
Learn more about permissions to view prompts and responses
Microsoft 365 data residency commitments

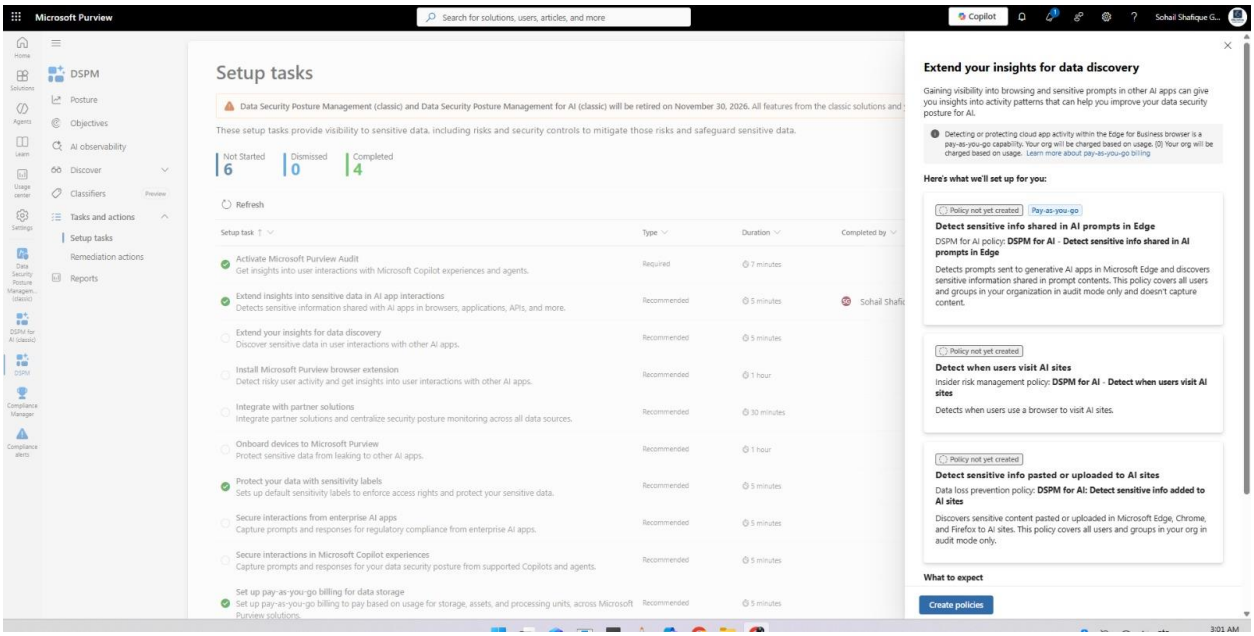


- *Figure 7.7: Enabling the policy to detect sensitive info shared with AI apps (via network or Security Store integration).*

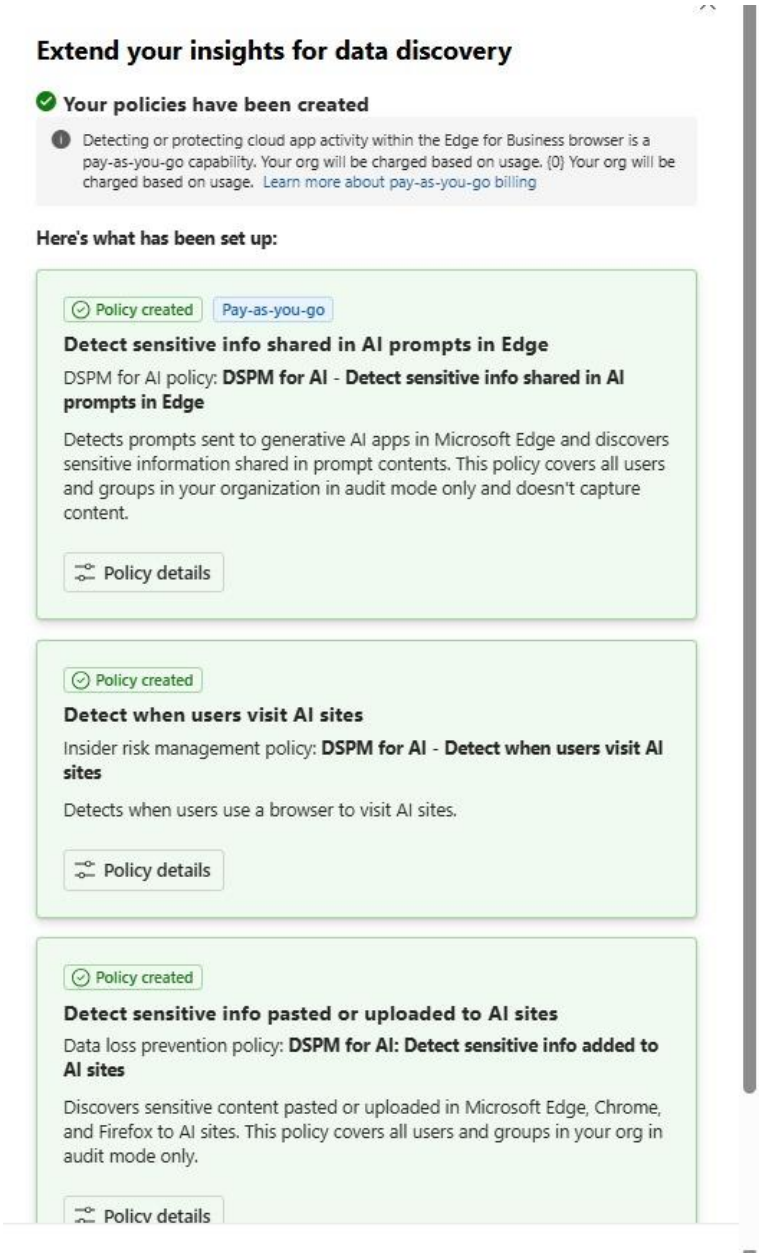
Step 5: Configuring Policies for Third-Party AI (ChatGPT)

We deploy policies to detect when users paste sensitive data into third-party AI apps. We also configure the Microsoft Purview browser extension to catch this activity in Edge, Chrome, and Firefox.

- **[Insert Image: Extend insights for data discovery]**

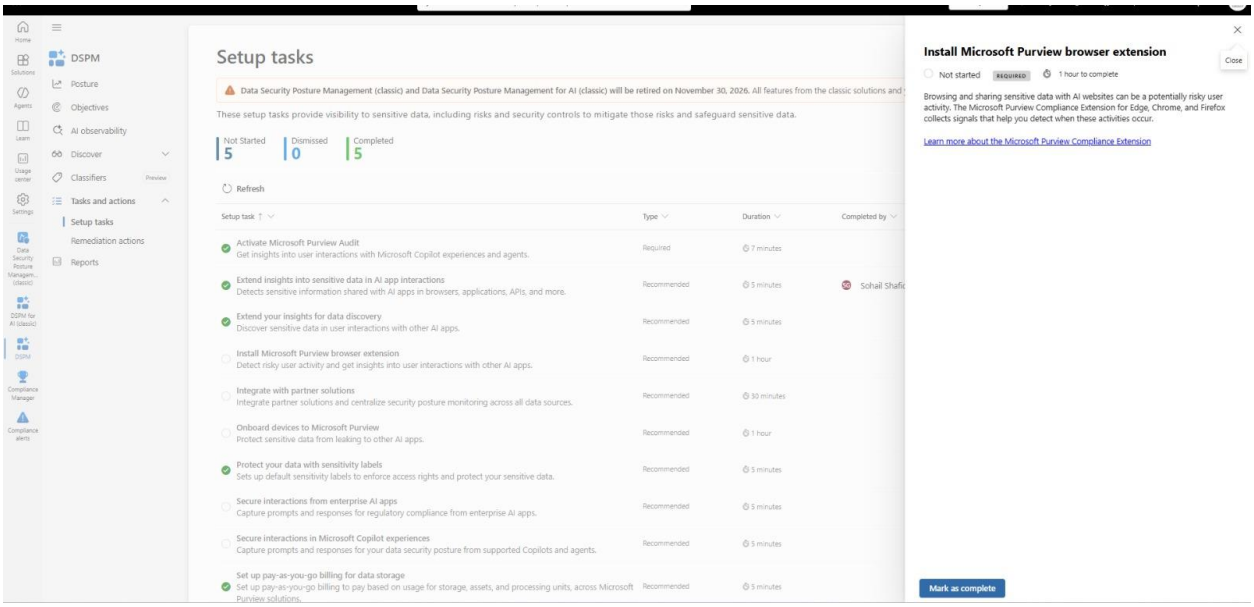


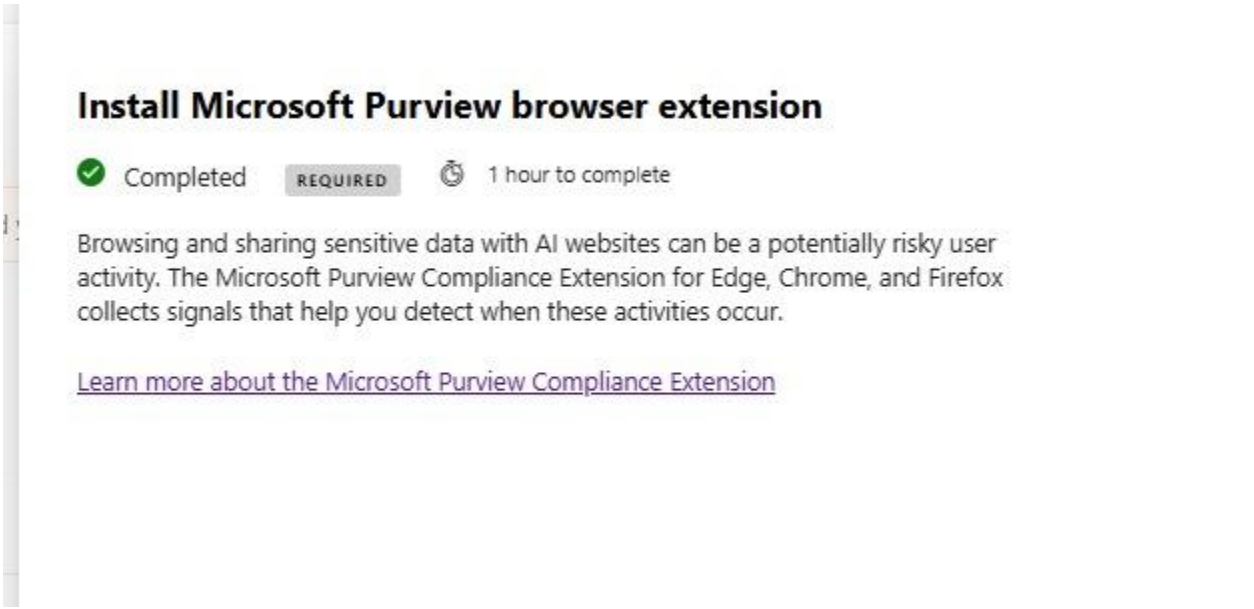
- *Figure 7.8: Configuring policies to detect sensitive info shared in AI prompts in Edge and when users visit AI sites.*
- **[Insert Image: Policies created for AI prompts and sites]**



- *Figure 7.9: Confirmation that the policies for Edge prompts and AI site visits are created.*

- **[Insert Image: Install Microsoft Purview browser extension]**



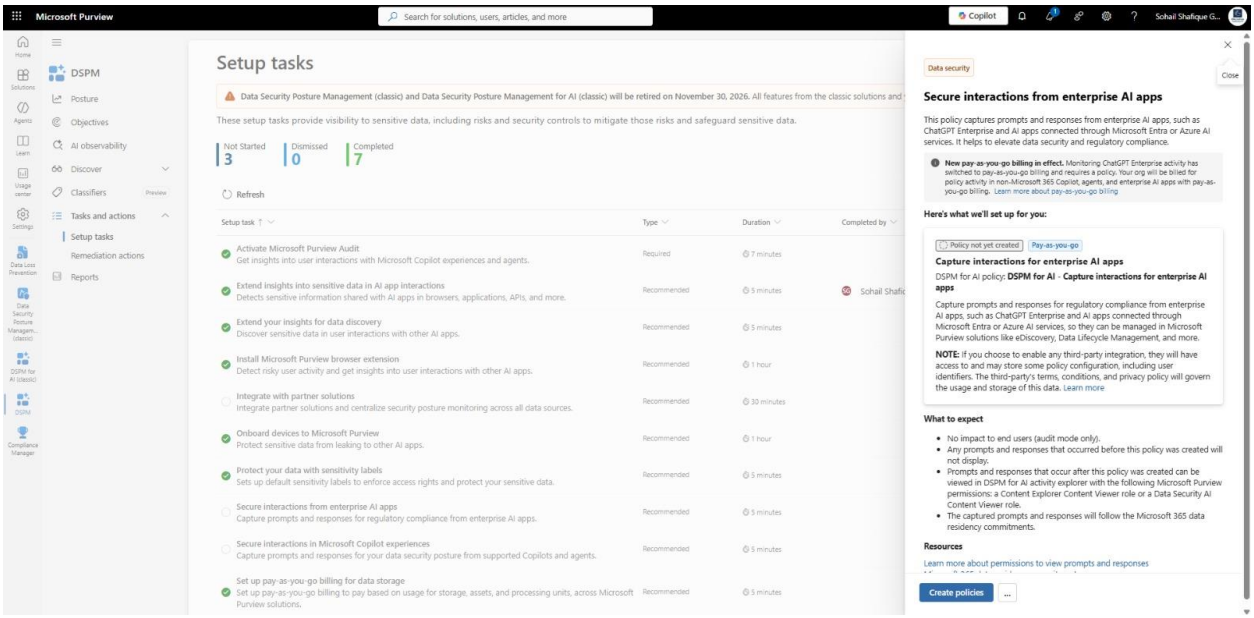


- *Figure 7.10: Marking the browser extension installation as complete (required for Chrome/Firefox detection).*

Step 6: Securing Enterprise AI Apps

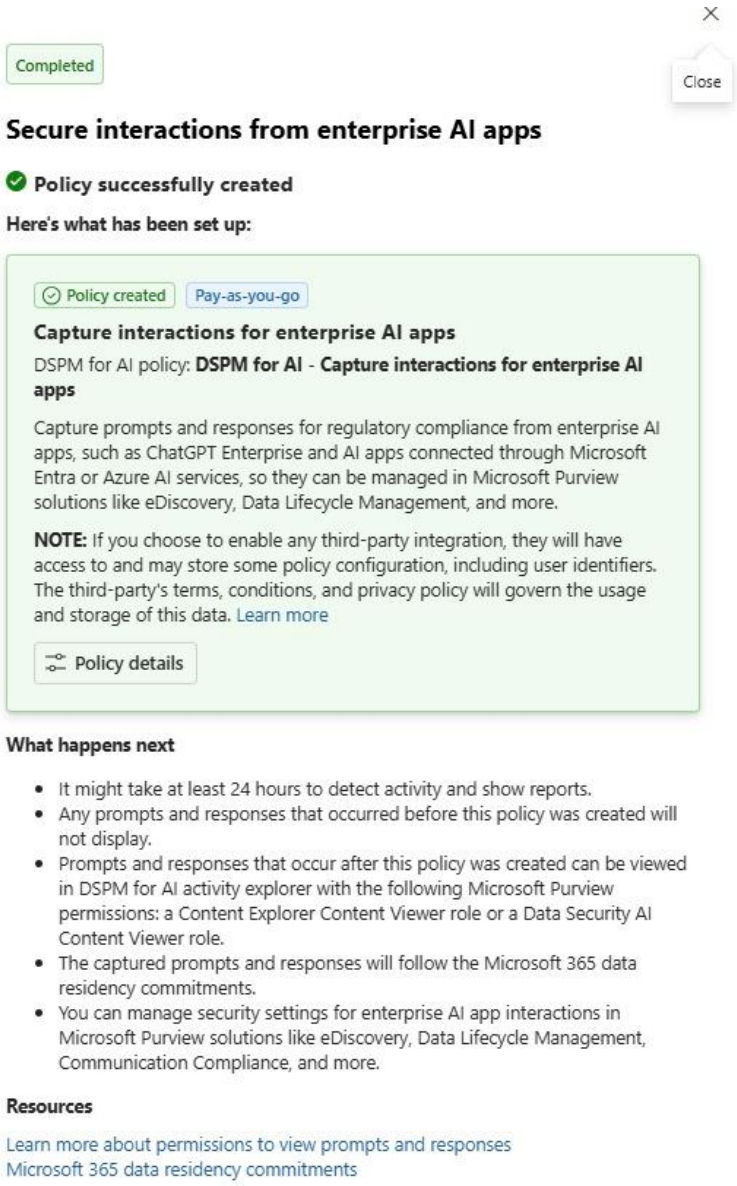
We configure policies to capture interactions from enterprise AI apps (like ChatGPT Enterprise) that are connected via Microsoft Entra or Azure services.

- **[Insert Image: Secure interactions from enterprise AI apps]**



- *Figure 7.11: Enabling the policy to capture prompts and responses from enterprise AI apps.*

- **[Insert Image: Enterprise AI policy created]**

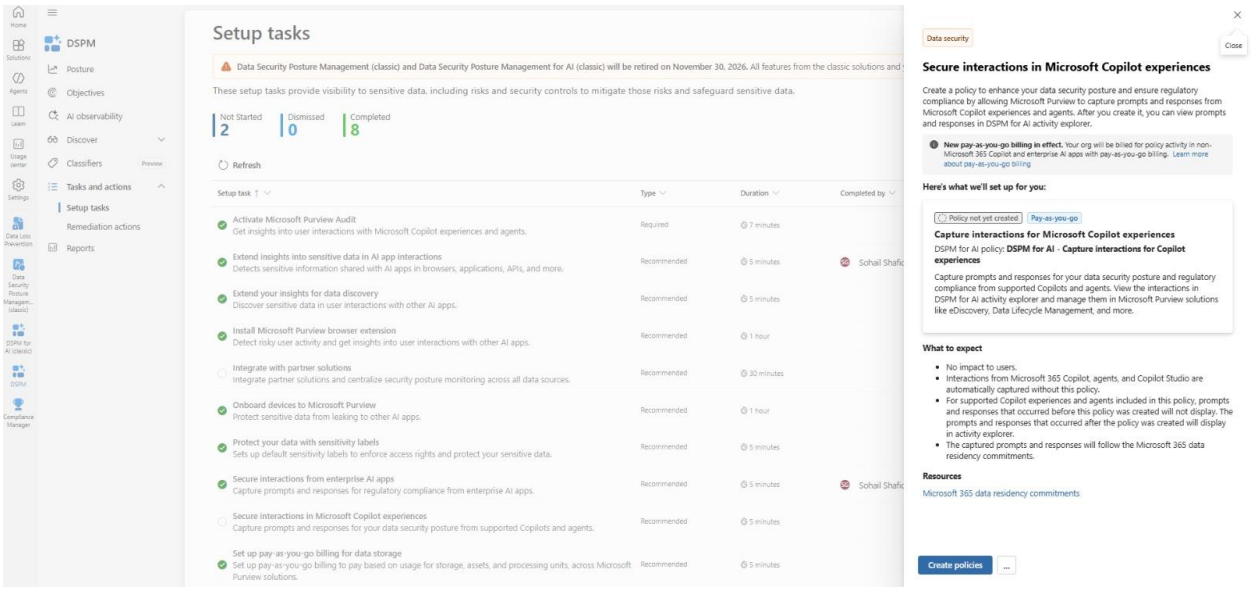


- *Figure 7.12: Confirmation that the enterprise AI interactions policy is active.*

Step 7: Securing Microsoft Copilot Experiences

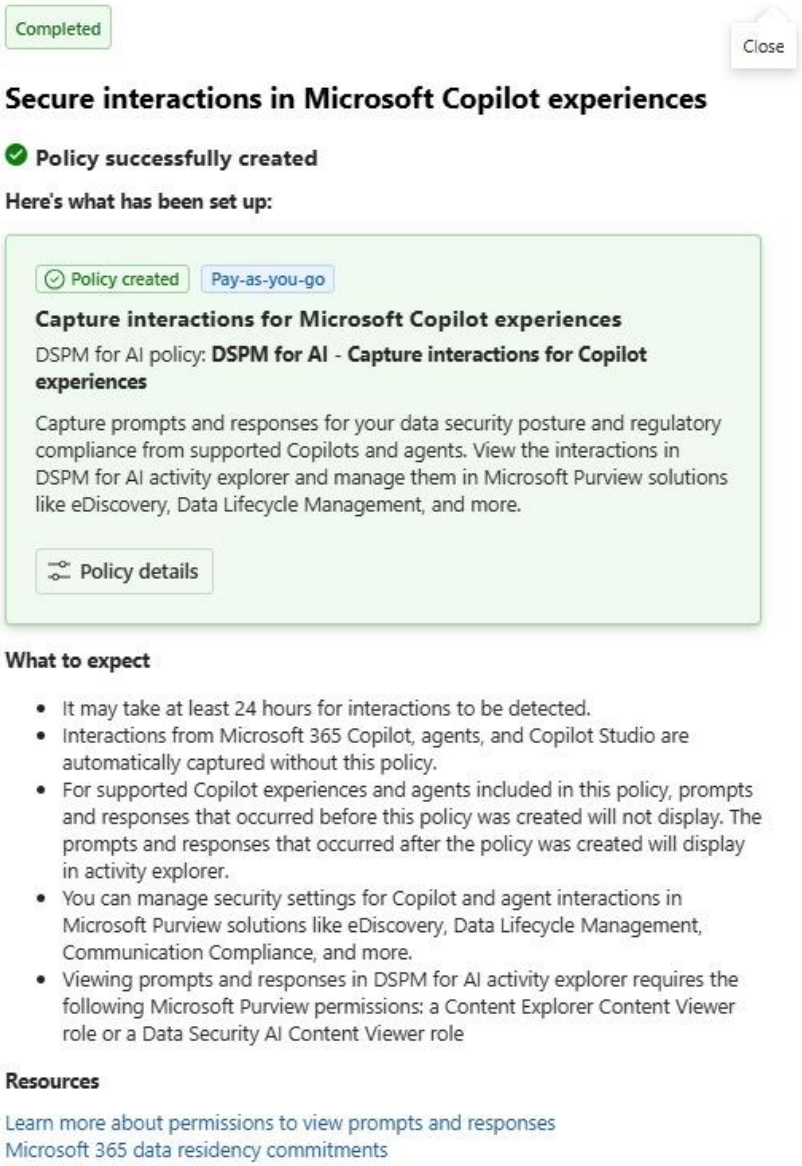
We configure the policy to capture prompts and responses specifically from Microsoft 365 Copilot and Copilot Studio agents.

- **[Insert Image: Secure interactions in Microsoft Copilot experiences]**



- *Figure 7.13: Enabling the policy to capture Copilot interactions.*

- **[Insert Image: Copilot experiences policy created]**

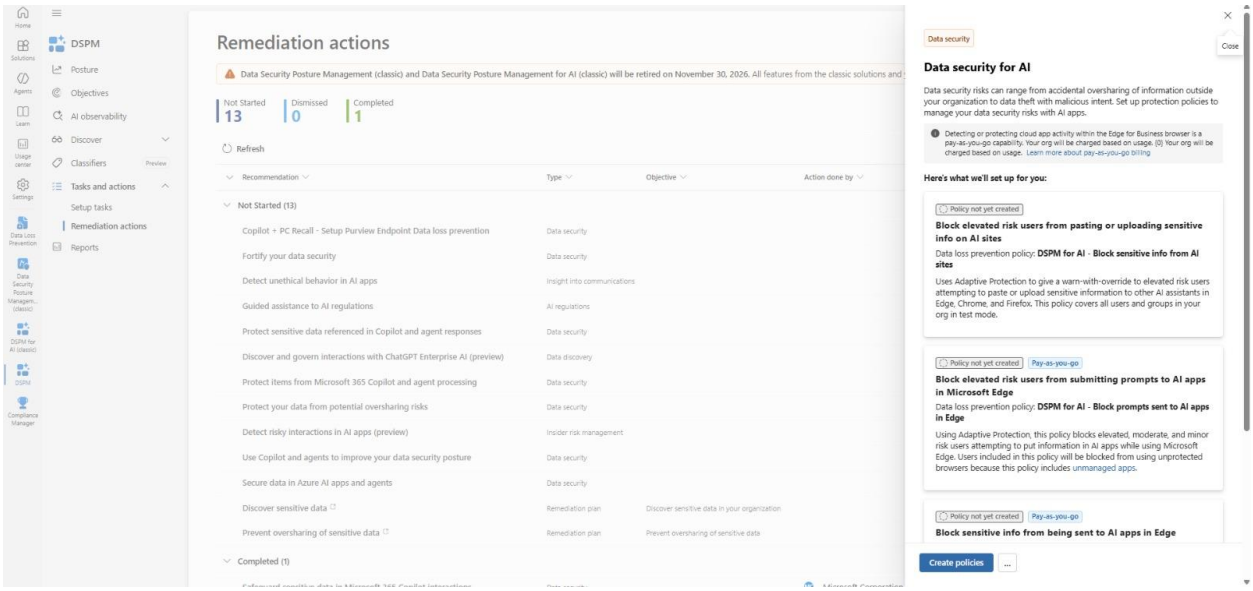


- *Figure 7.14: Confirmation that the Copilot experiences policy is active.*

Step 8: Configuring Remediation for AI Risks

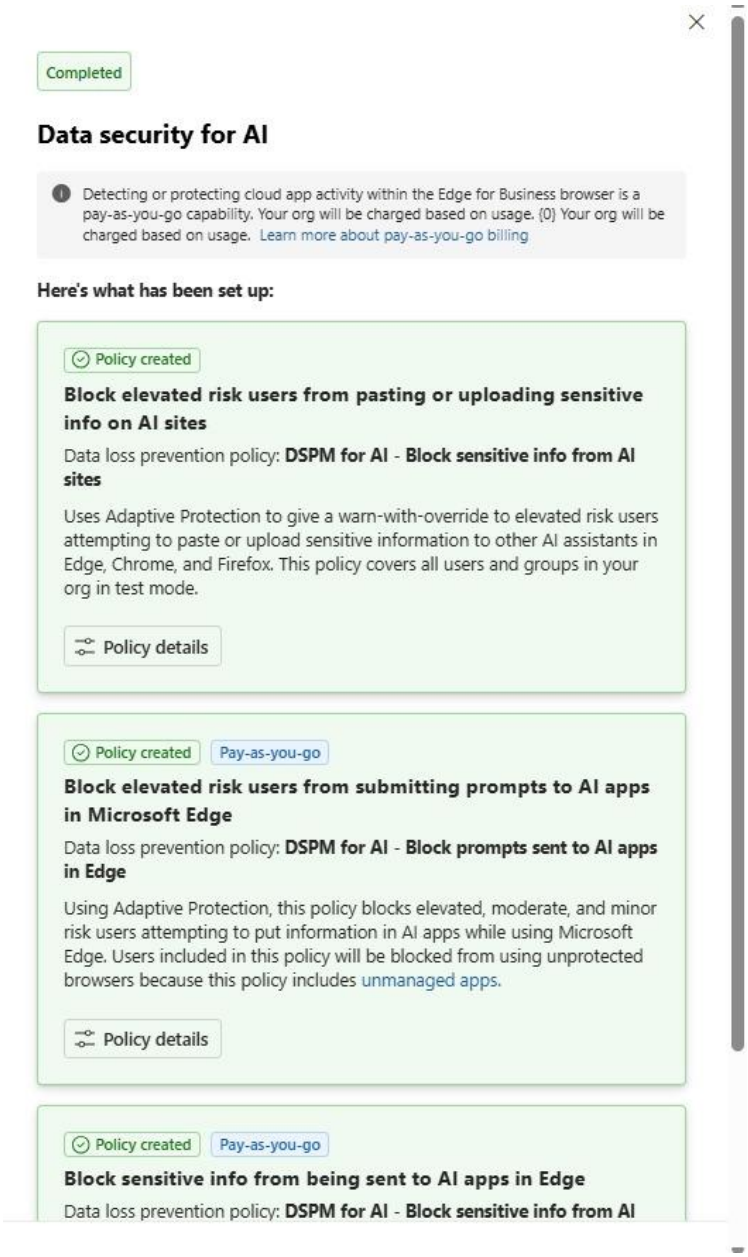
We review and enable the final set of policies to block risky AI behavior, such as:

- Blocking users from pasting sensitive info into AI sites.
- Detecting unethical behavior in AI apps.
- Protecting sensitive data referenced in Copilot responses.
- **[Insert Image: Remediation actions - Data security for AI]**



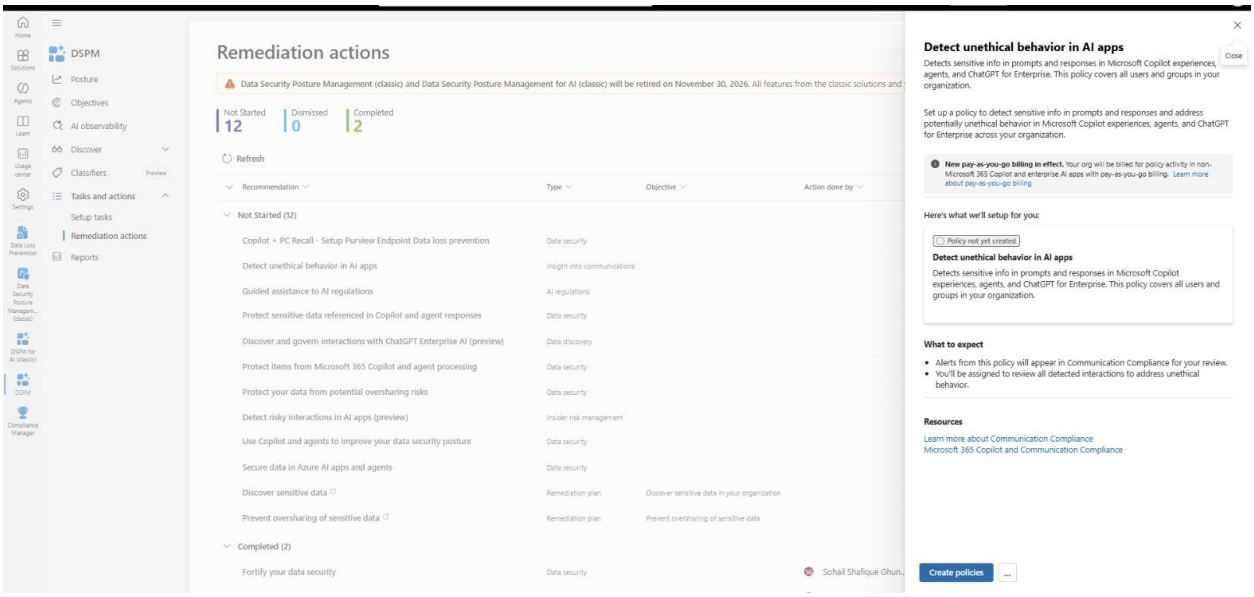
- *Figure 7.15: Reviewing the policies to block sensitive info from AI sites and block elevated risk users.*

- **[Insert Image: Data security for AI - Policies created]**



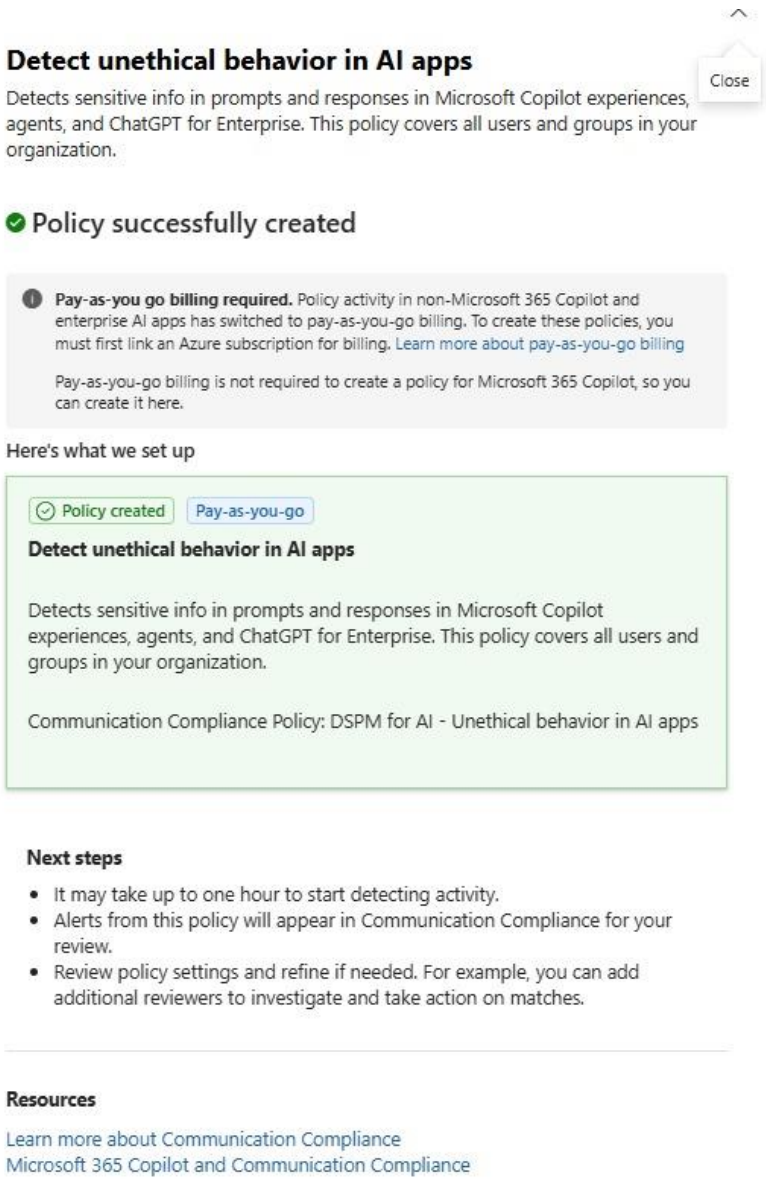
- *Figure 7.16: Confirmation that the policies to block sensitive info from AI sites are created.*

- **[Insert Image: Detect unethical behavior in AI apps]**



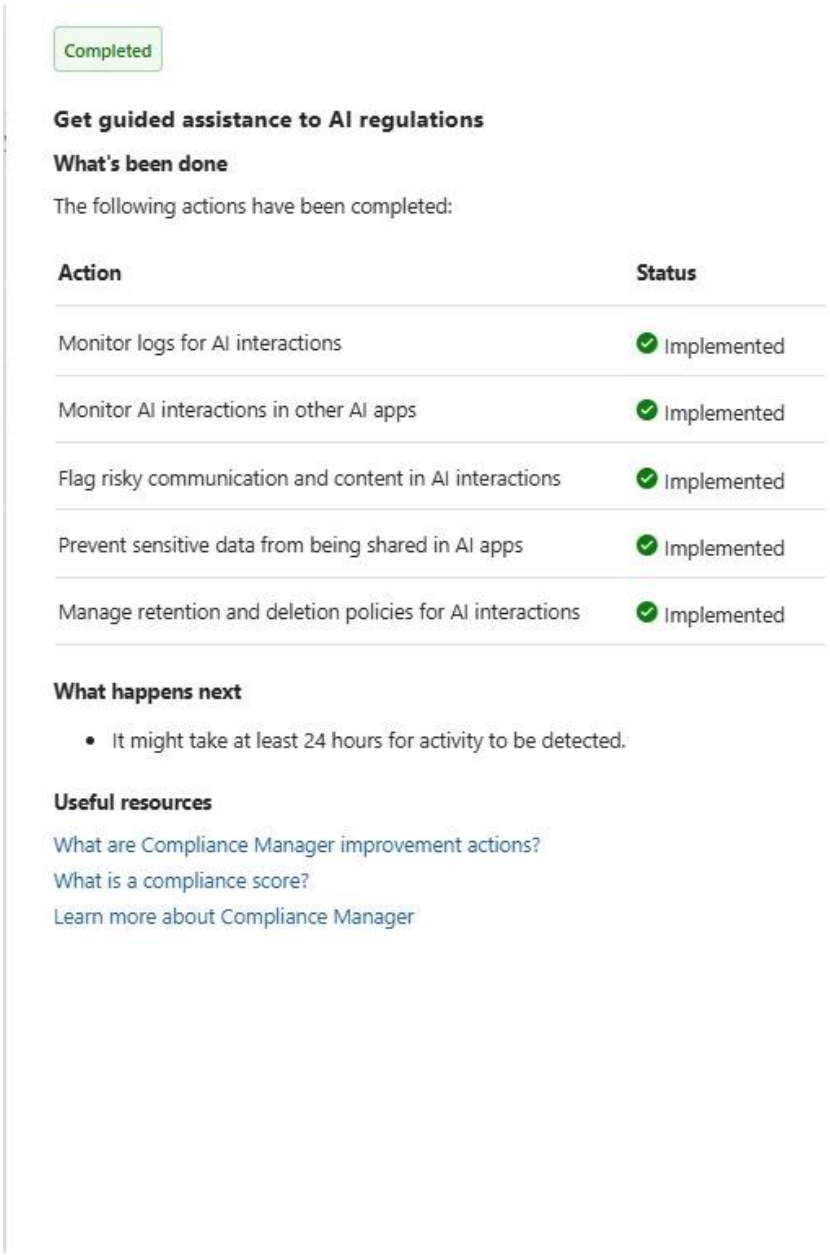
- *Figure 7.17: Creating a policy to detect unethical behavior in AI prompts.*

- **[Insert Image: Unethical behavior policy created]**



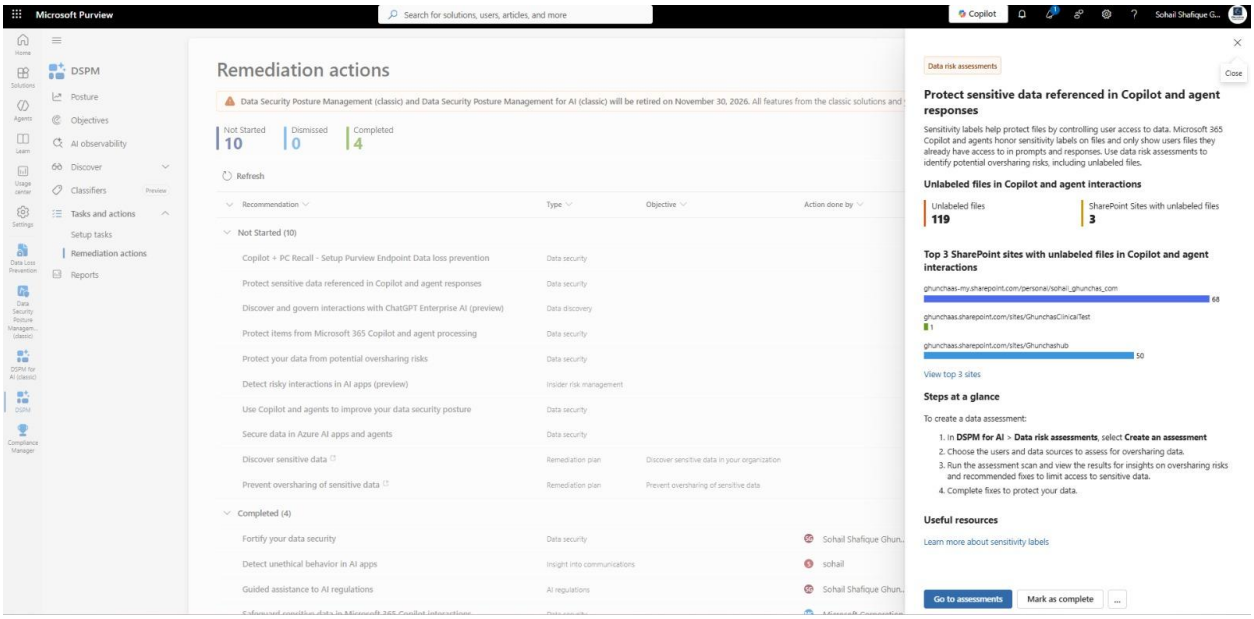
- *Figure 7.18: Confirmation that the unethical behavior detection policy is active.*

- **[Insert Image: Guided assistance to AI regulations]**



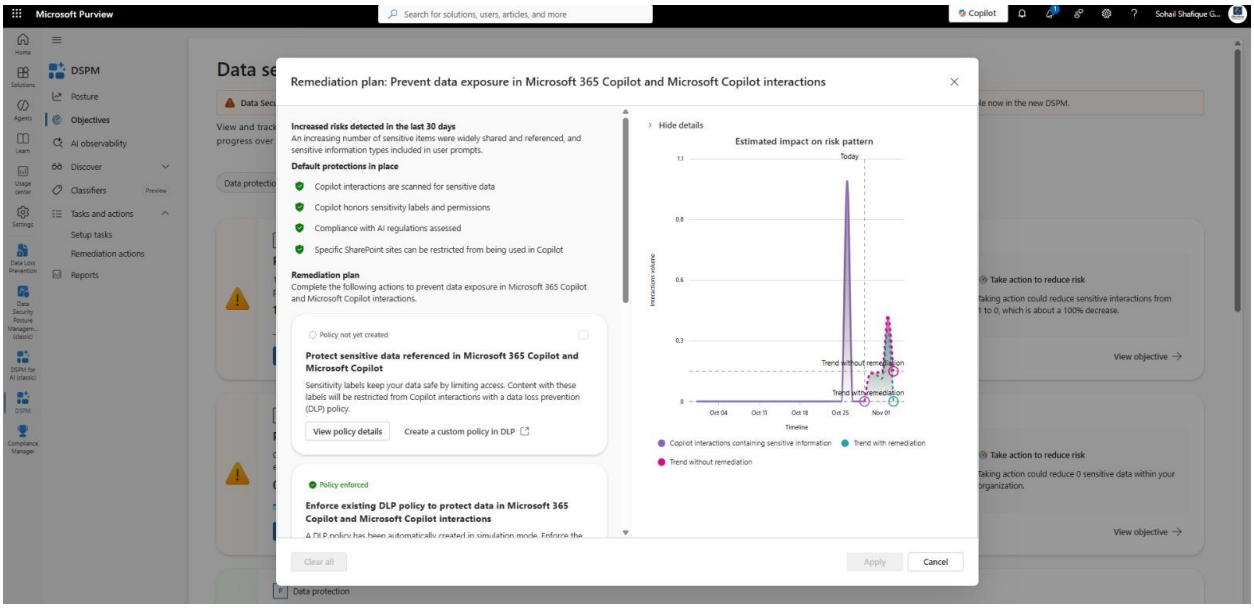
- *Figure 7.19: Completing the guided assistance task to ensure all AI regulatory controls are implemented.*

- **[Insert Image: Protect sensitive data referenced in Copilot responses]**



- *Figure 7.20: Reviewing the final remediation action to protect data in Copilot responses.*

- **[Insert Image: Remediation plan - Prevent data exposure in Copilot]**



- *Figure 7.21: The remediation plan showing the estimated impact on risk pattern if the policy is applied.*

PHASE 8: DATA LIFECYCLE & RECORDS MANAGEMENT

Objective: Establish a defensible data retention and deletion strategy. This ensures the organization keeps data for regulatory compliance (HIPAA/HITRUST) and deletes it securely when it is no longer needed to reduce risk and storage costs.

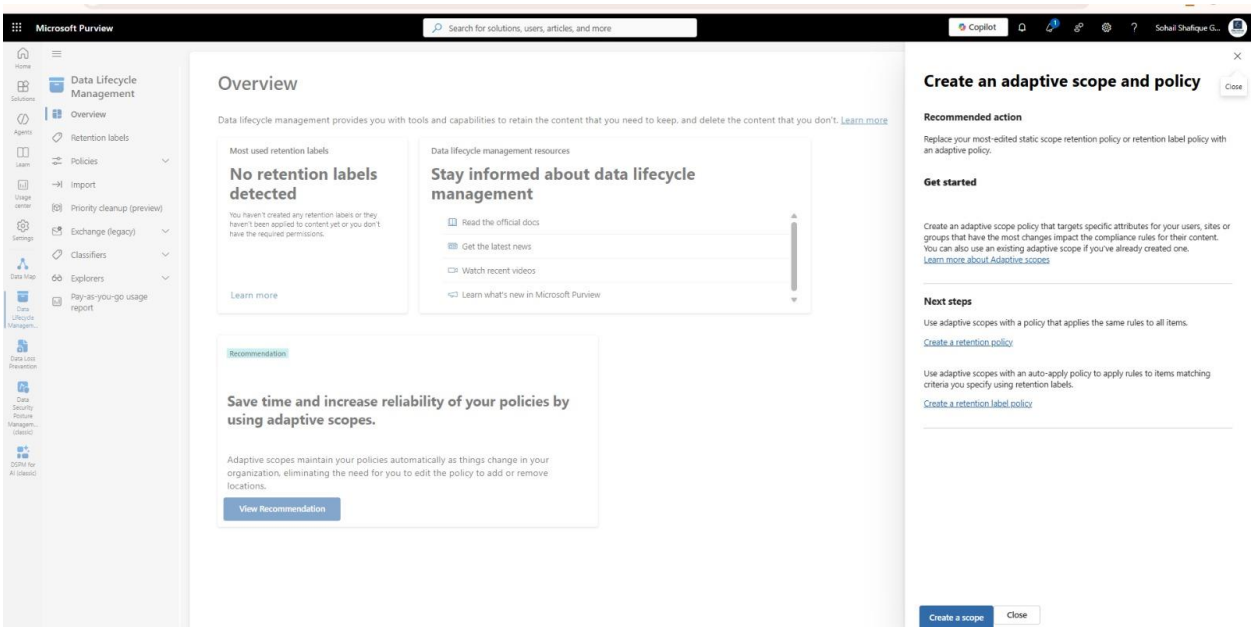
8.1 The Business Value (Why We Do This)

Healthcare organizations generate massive amounts of data. However, keeping patient records forever increases legal liability and storage costs, while deleting them too soon violates HIPAA retention laws. Ghunchas deploys static retention policies to set a strict baseline (e.g., keeping emails for 7 years) and uses Retention Labels for high-value records (e.g., an immutable 10-year record for patient data).

8.2 The Ghunchas Configuration Standard

Step 1: Reviewing Data Lifecycle Management Dashboard
We begin by reviewing the DLM dashboard. It shows if any labels or policies are active and provides recommendations for optimizing retention.

- **[Insert Image: Data Lifecycle Management - Overview]**

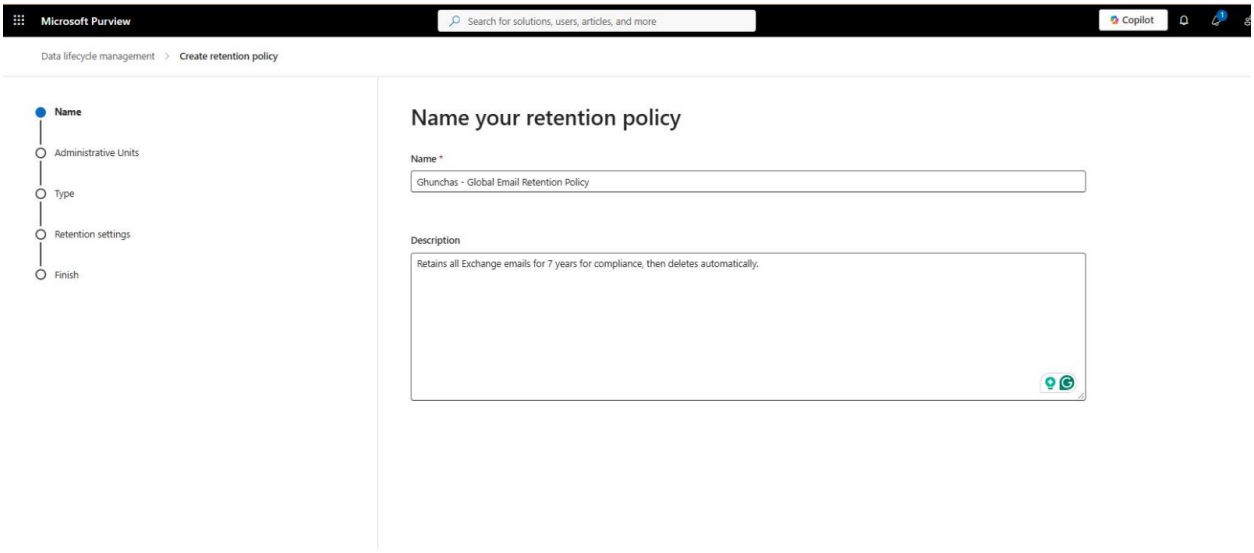


- *Figure 8.1: The DLM dashboard, showing the recommendation to use adaptive scopes.*

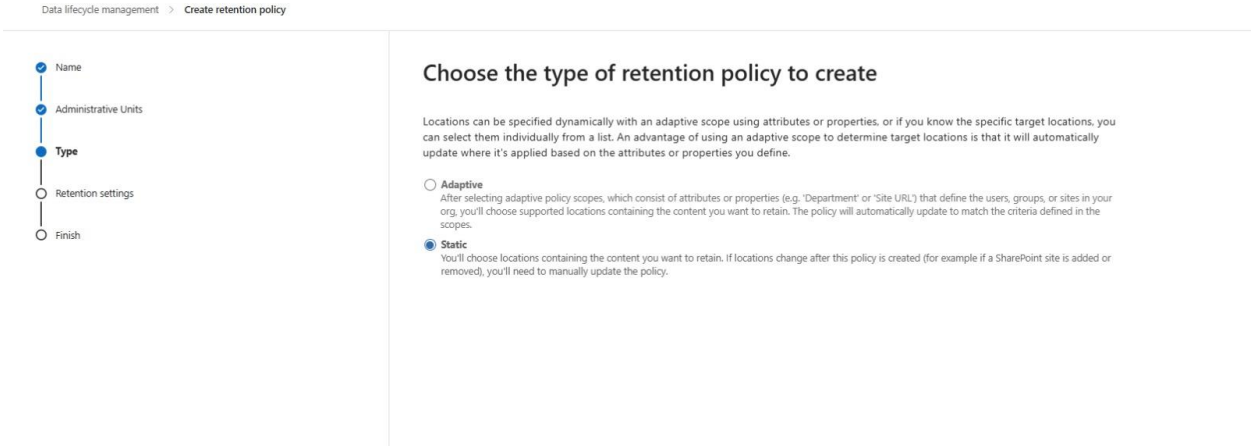
Step 2: Creating the Email Retention Policy (7-Year)

We create a baseline retention policy for Exchange to ensure all email communications are retained for 7 years to meet legal and regulatory requirements.

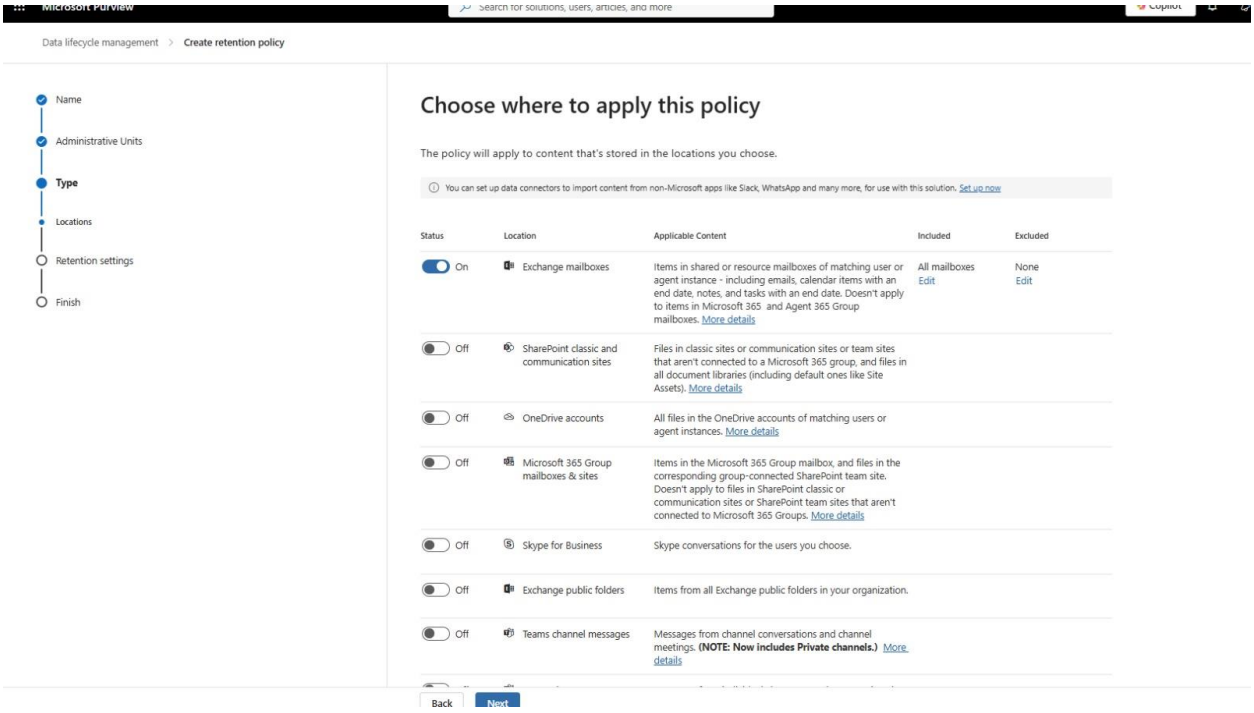
- **[Insert Image: Name your retention policy - Global Email]**



  - *Figure 8.2: Naming the policy "Ghunchas - Global Email Retention Policy".*
- **[Insert Image: Choose the type of retention policy - Static]**

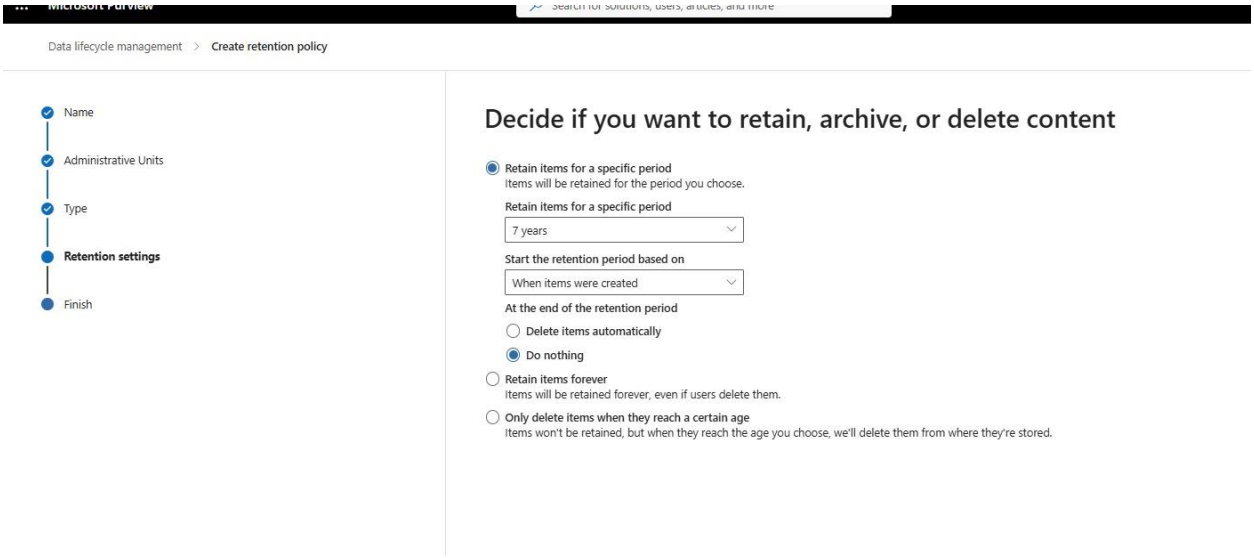


  - *Figure 8.3: Selecting the "Static" policy type to target all mailboxes.*
- **[Insert Image: Choose where to apply - Exchange mailboxes]**



- *Figure 8.4: Scoping the policy to Exchange mailboxes.*

- **[Insert Image: Decide if you want to retain - 7 years]**

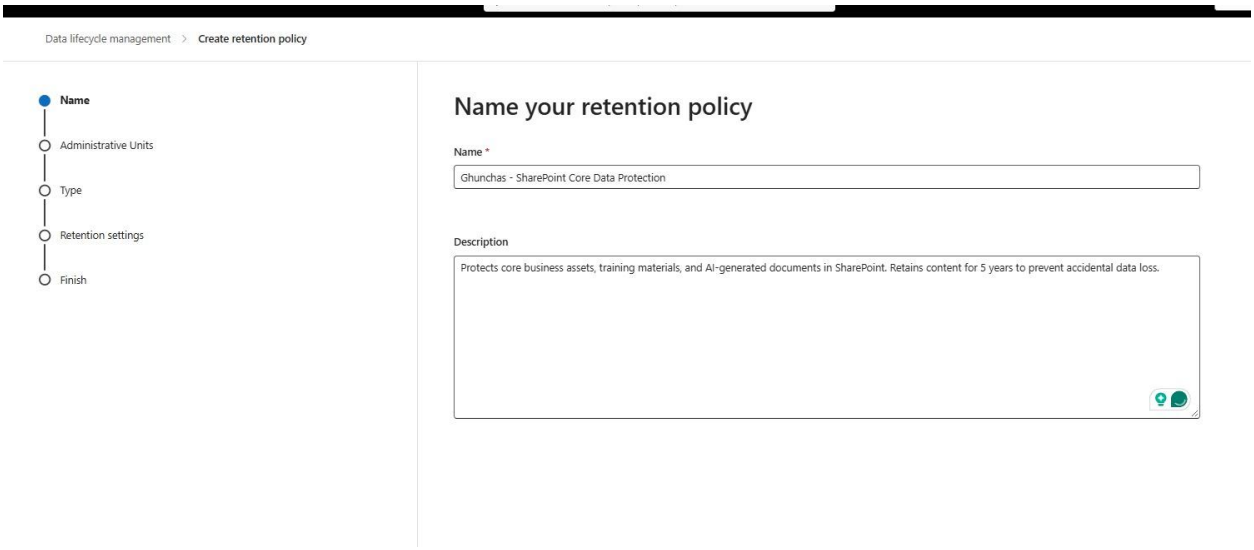


- *Figure 8.5: Setting the retention period to 7 years and selecting "Do nothing" at the end (or Delete, based on the final selection).*

Step 3: Creating the SharePoint Retention Policy (5-Year)

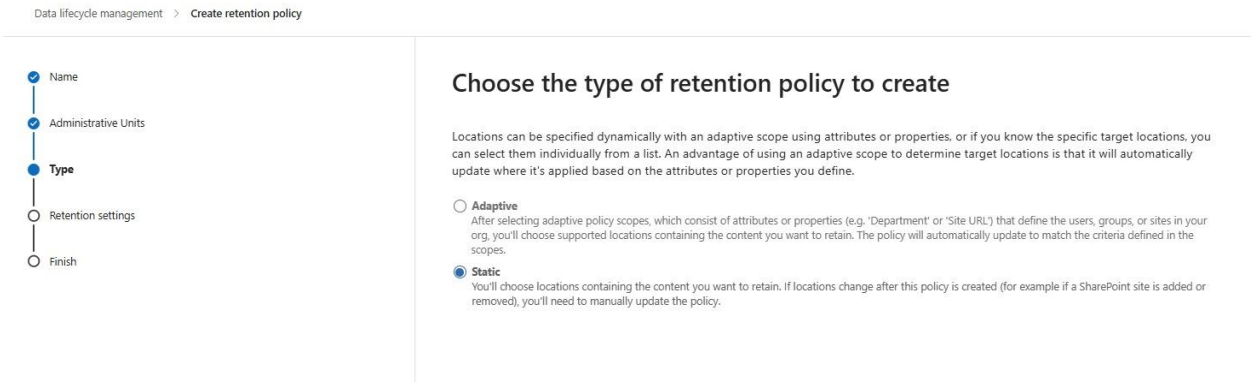
We create a policy to protect core business assets, training materials, and AI-generated documents in SharePoint. We retain this for 5 years and do nothing at the end (to prevent accidental deletion of critical content).

- **[Insert Image: Name your retention policy - SharePoint]**



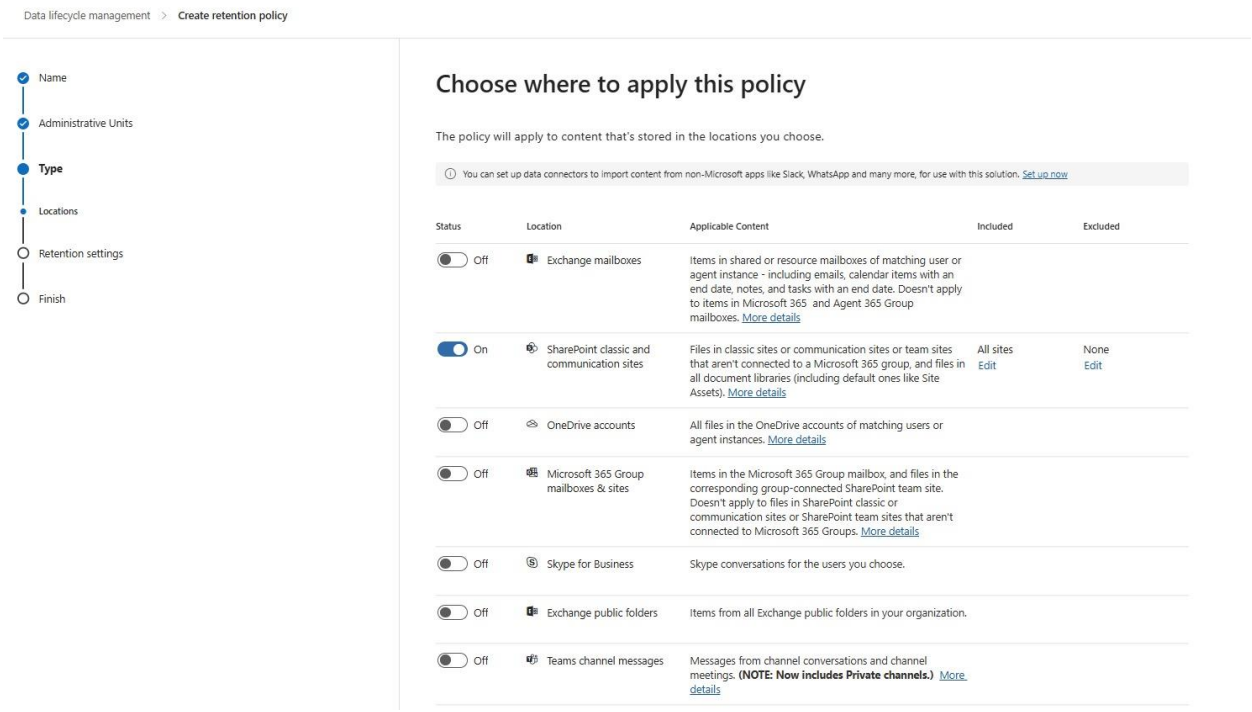
- *Figure 8.6: Naming the policy "Ghunchas - SharePoint Core Data Protection".*

- **[Insert Image: Choose the type of retention policy - Static (SharePoint)]**



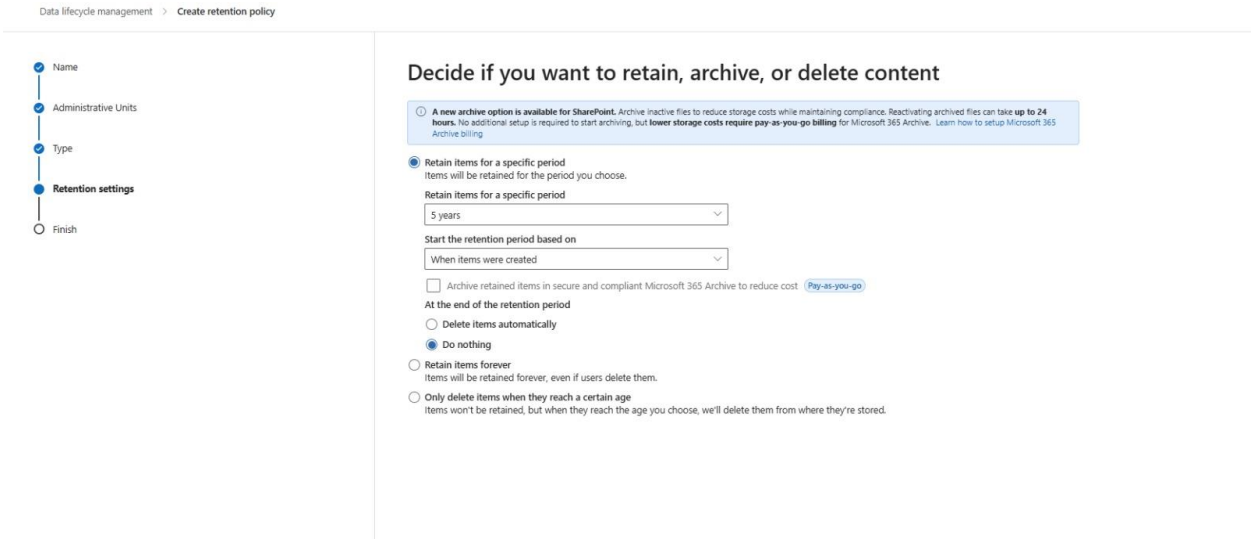
- *Figure 8.7: Selecting the "Static" policy type.*

- **[Insert Image: Choose where to apply - SharePoint sites]**



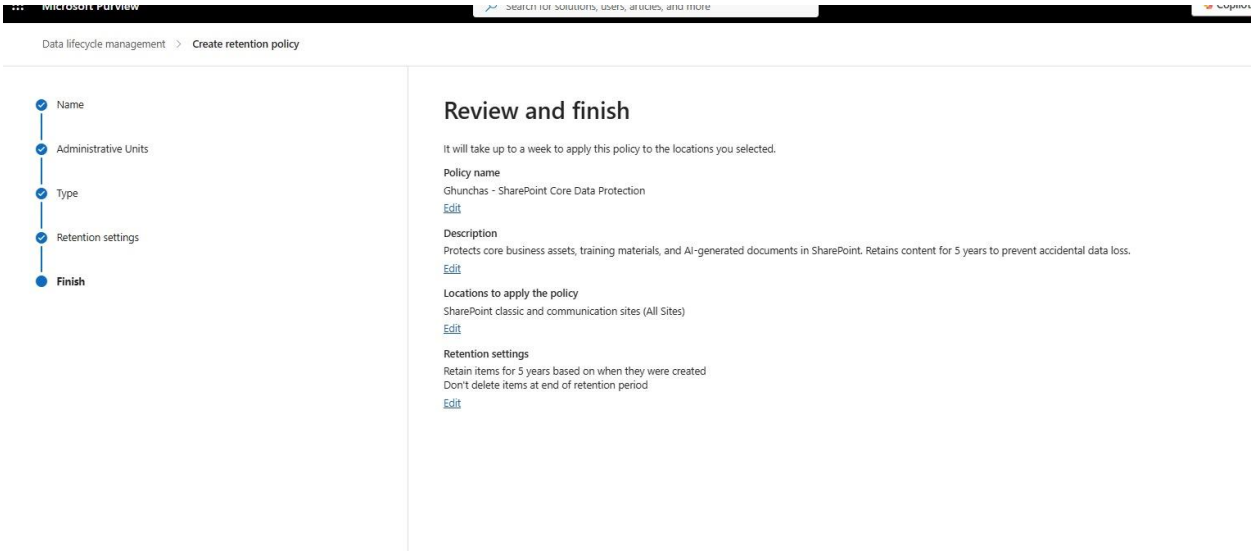
- *Figure 8.8: Scoping the policy to SharePoint classic and communication sites.*

- **[Insert Image: Decide if you want to retain - 5 years]**



- *Figure 8.9: Setting the retention period to 5 years.*

- **[Insert Image: Review and finish - SharePoint]**

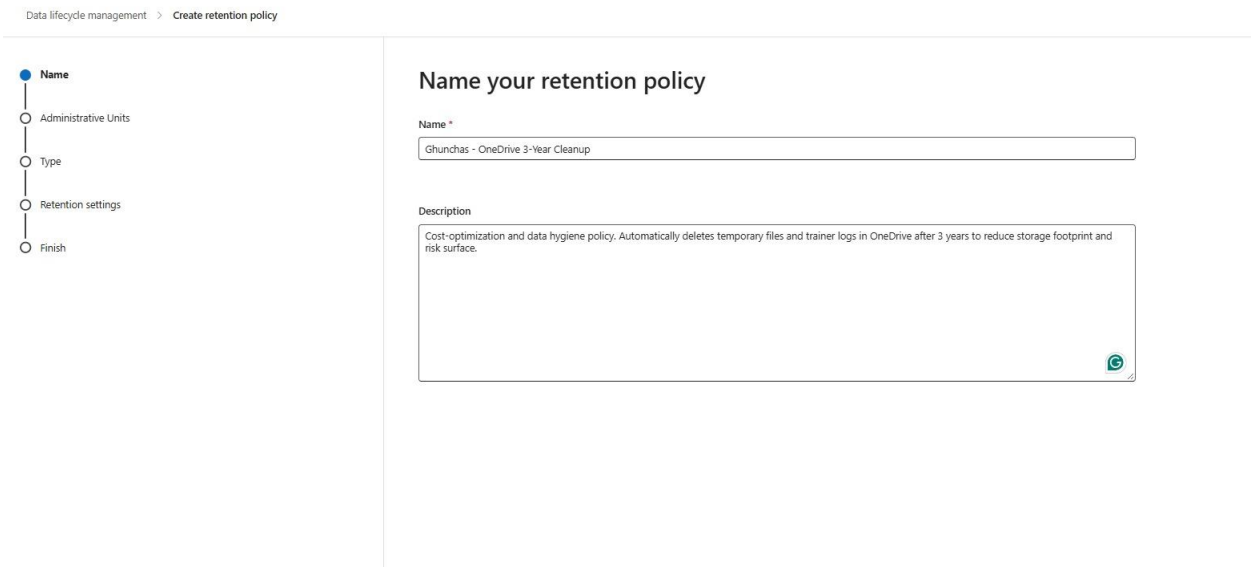


- *Figure 8.10: Reviewing the SharePoint retention policy configuration.*

Step 4: Creating the OneDrive Retention Policy (3-Year Cleanup)

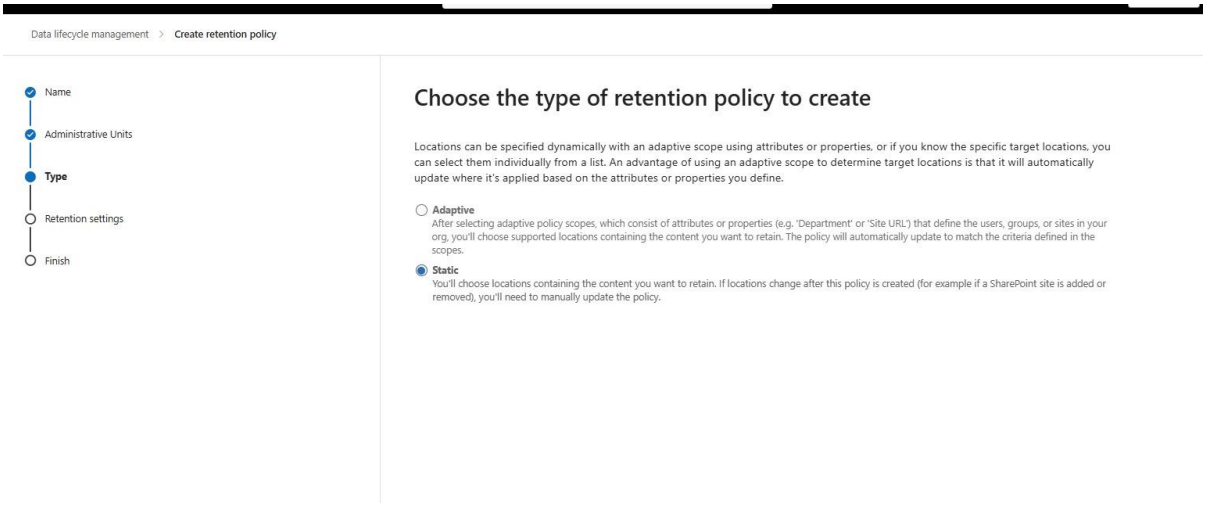
We create a policy to automatically delete temporary files and trainer logs in OneDrive after 3 years, reducing the storage footprint and risk surface.

- **[Insert Image: Name your retention policy - OneDrive]**

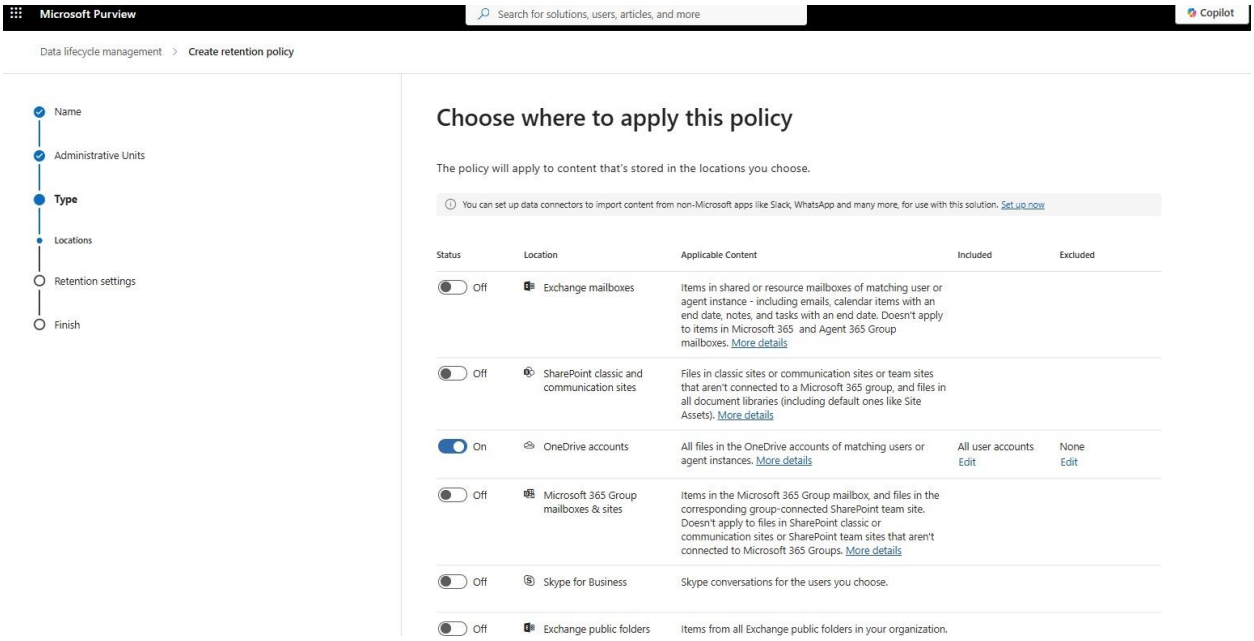


- *Figure 8.11: Naming the policy "Ghunchas - OneDrive 3-Year Cleanup".*

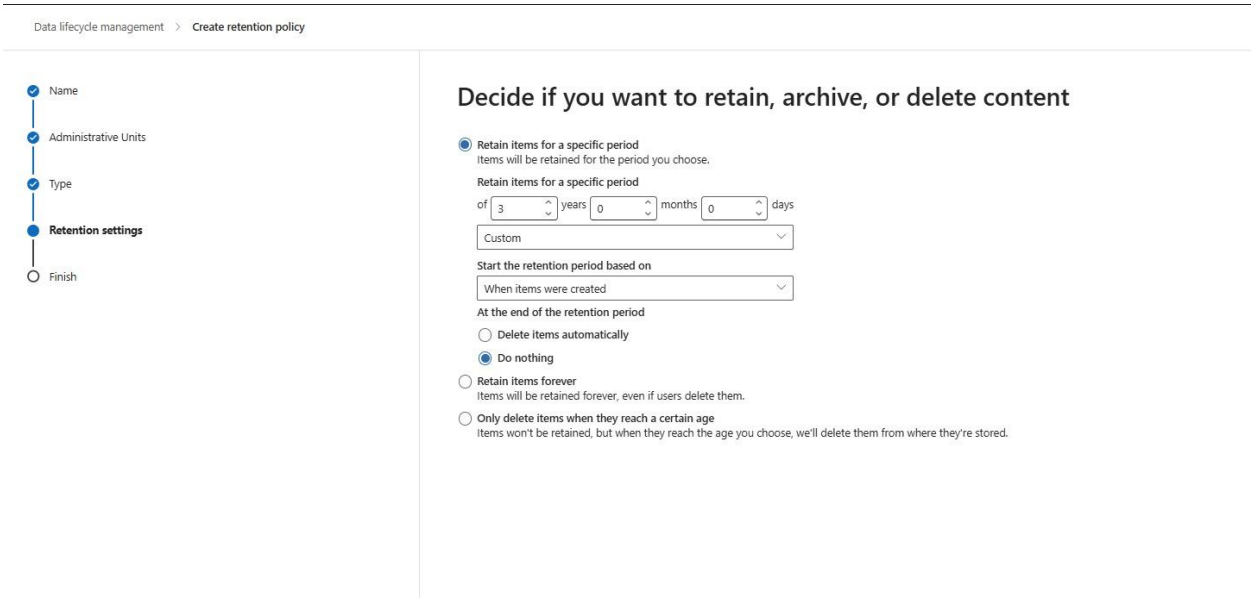
- **[Insert Image: Choose the type of retention policy - Static (OneDrive)]**



  - *Figure 8.12: Selecting the "Static" policy type.*
- **[Insert Image: Choose where to apply - OneDrive accounts]**



  - *Figure 8.13: Scoping the policy to OneDrive accounts.*
- **[Insert Image: Decide if you want to retain - 3 years]**

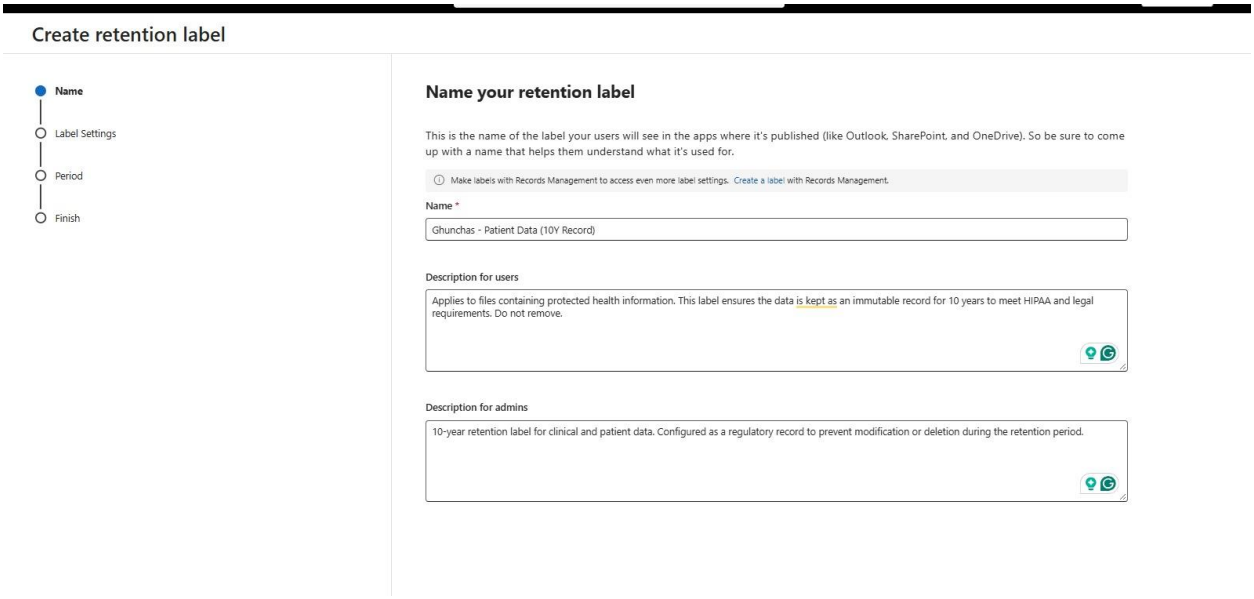


- *Figure 8.14: Setting the retention period to 3 years and selecting "Delete items automatically" at the end.*

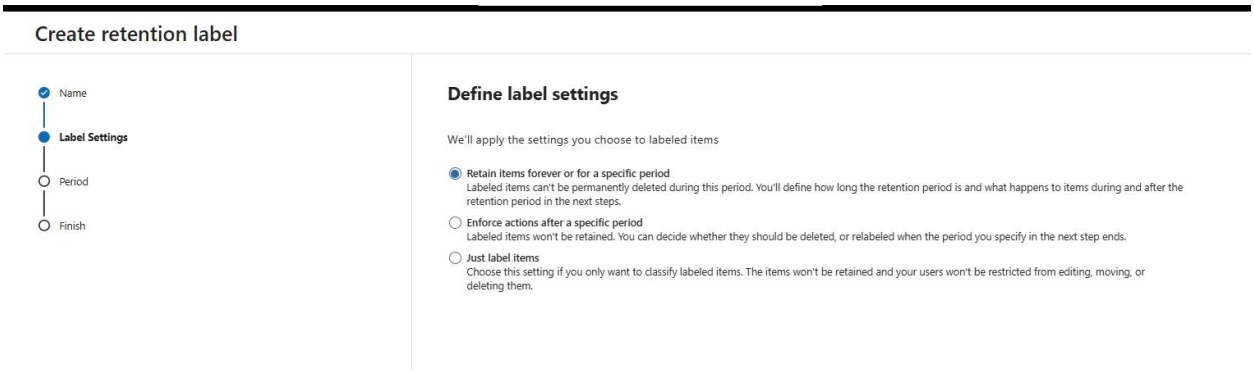
Step 5: Creating the 10-Year Patient Data Record Label

We create a specific Retention Label for patient data. We configure it as a "Record," meaning it cannot be modified or deleted for 10 years.

- **[Insert Image: Create retention label - Name]**

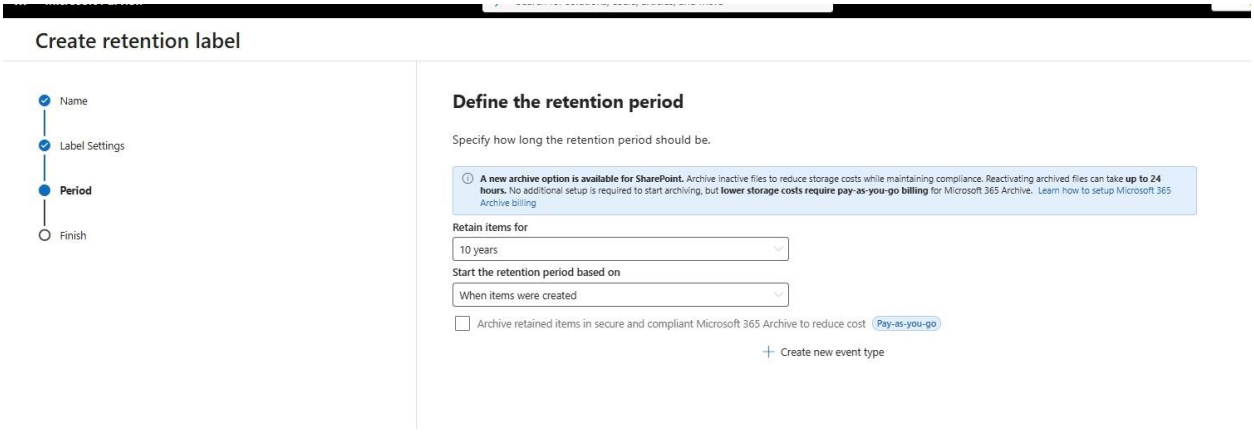


- *Figure 8.15: Naming the label "Ghunchas - Patient Data (10Y Record)".*
- **[Insert Image: Create retention label - Label settings]**



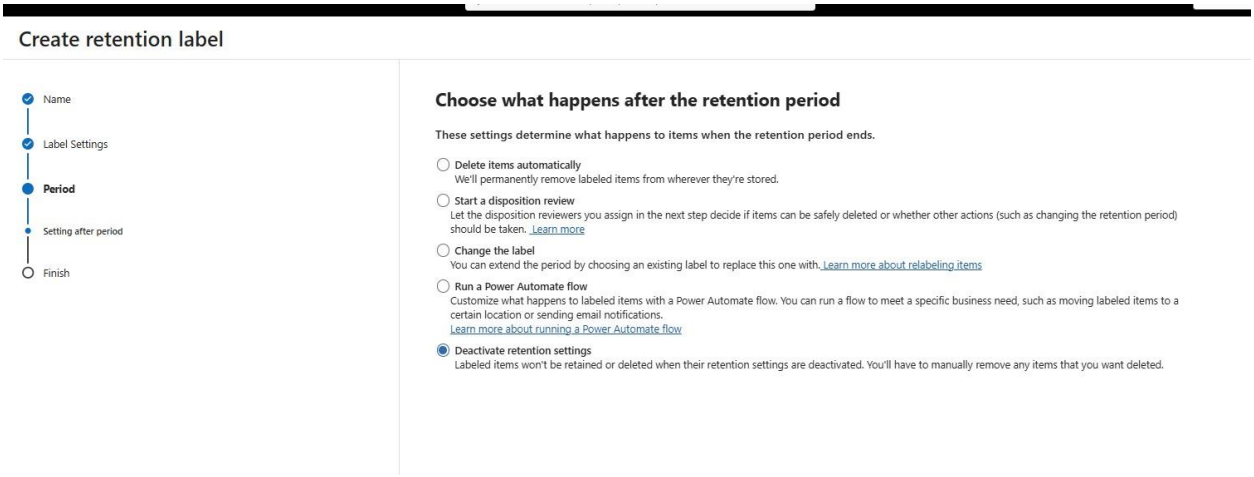
- *Figure 8.16: Selecting "Retain items forever or for a specific period".*

- **[Insert Image: Create retention label - Period (10 years)]**



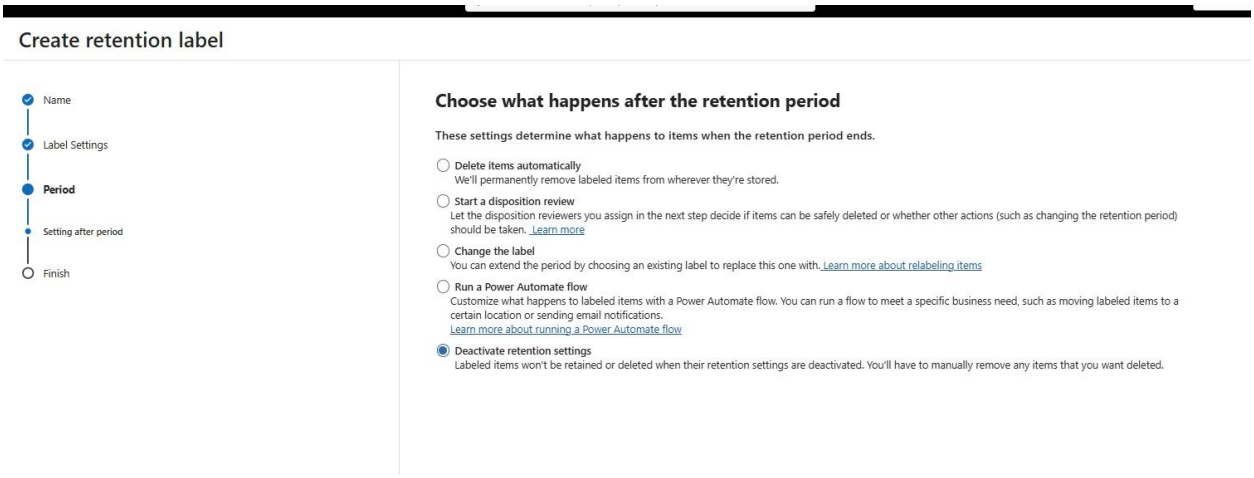
- *Figure 8.17: Setting the retention period to 10 years.*

- **[Insert Image: Create retention label - Choose what happens during retention]**



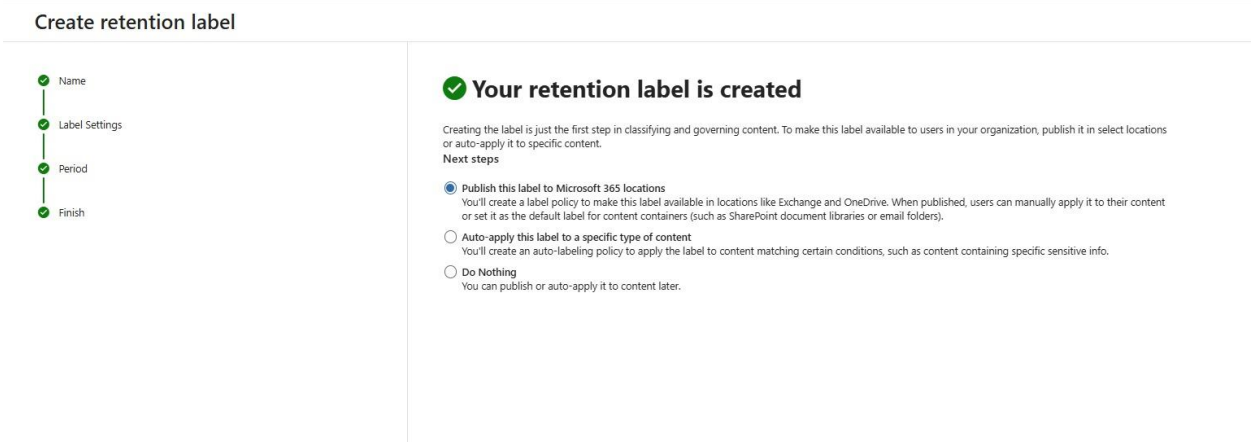
- *Figure 8.18: Selecting "Mark items as a record" to prevent editing.*

- **[Insert Image: Create retention label - Choose what happens after retention]**



- *Figure 8.19: Selecting "Deactivate retention settings" at the end.*

- **[Insert Image: Your retention label is created]**

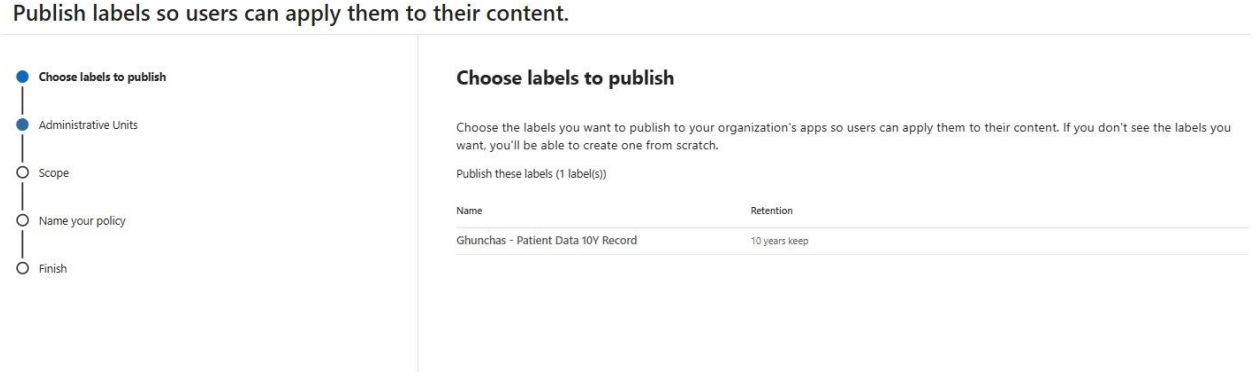


- *Figure 8.20: Confirmation that the label is created.*

Step 6: Publishing the Retention Label

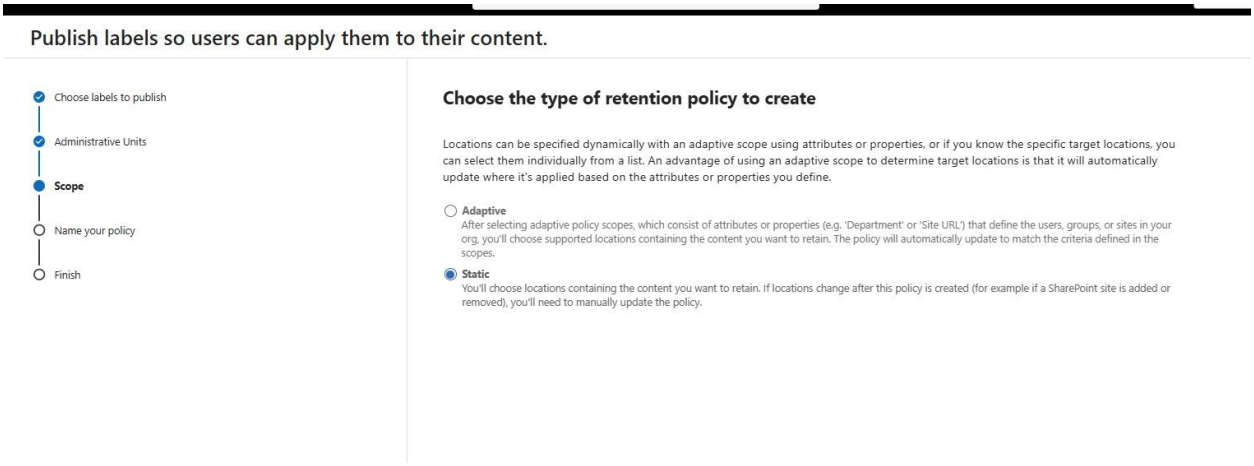
We publish the label so users can manually apply it to files, or so it can be applied automatically via policy.

- **[Insert Image: Publish labels - Choose labels to publish]**



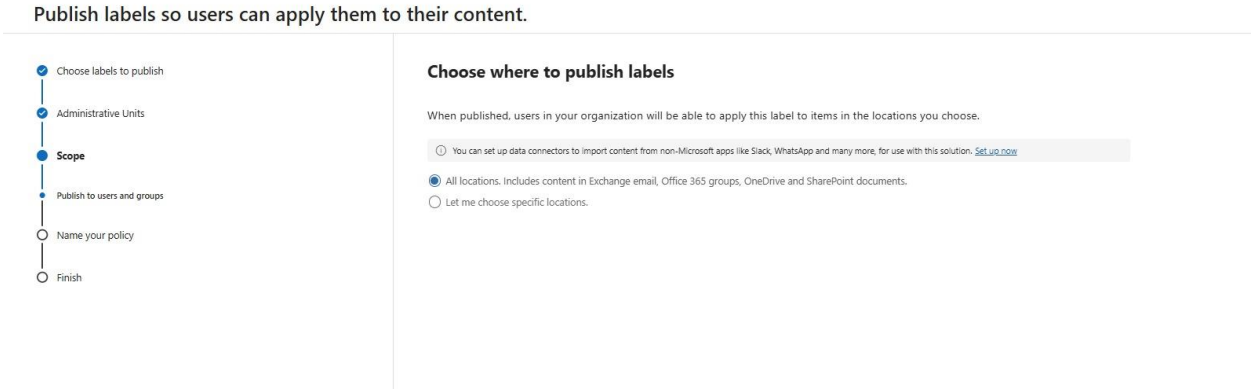
- *Figure 8.21: Selecting the Patient Data label for publishing.*

- **[Insert Image: Publish labels - Choose the type of retention policy - Static]**



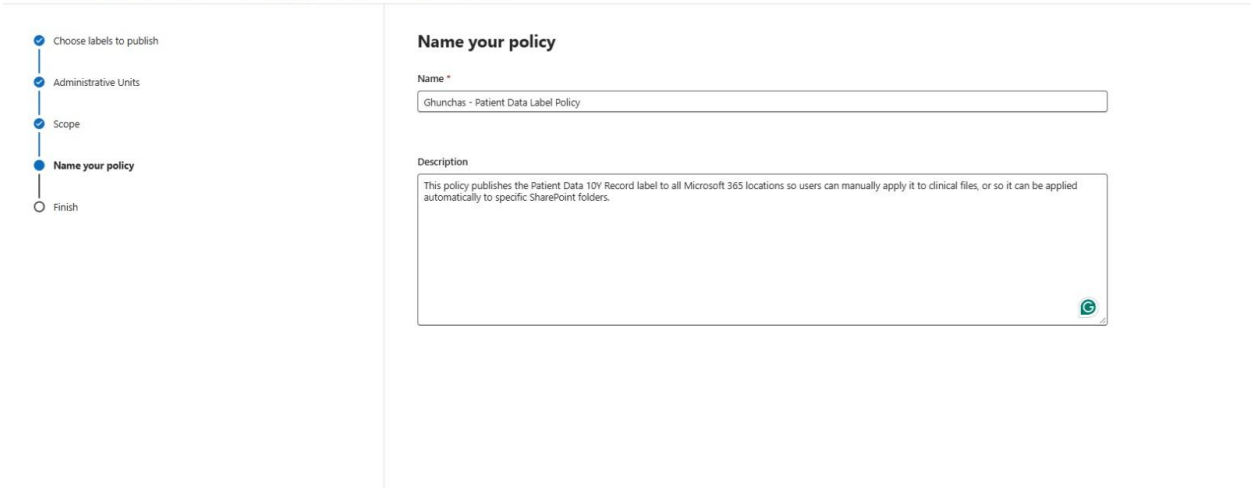
  - *Figure 8.22: Selecting the "Static" scope.*

- **[Insert Image: Publish labels - Choose where to publish]**



  - *Figure 8.23: Publishing to "All locations" (Exchange, SharePoint, OneDrive).*

- **[Insert Image: Publish labels - Name your policy]**

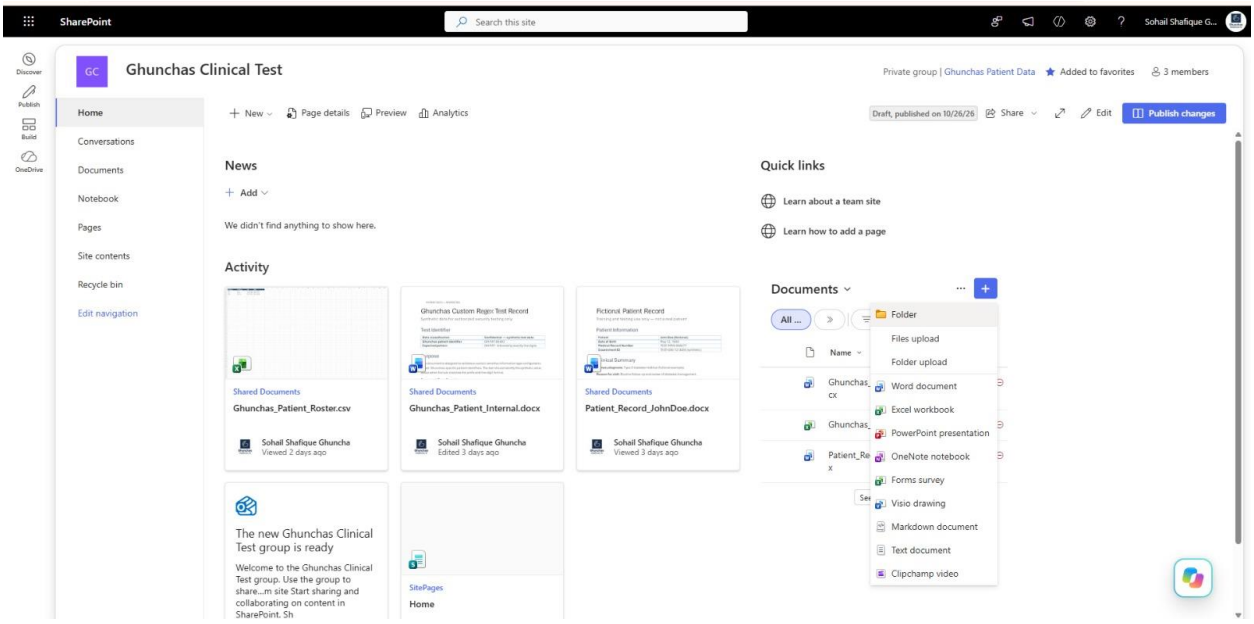


  - *Figure 8.24: Naming the policy "Ghunchas - Patient Data Label Policy".*

Step 7: Applying the Label to the SharePoint Container

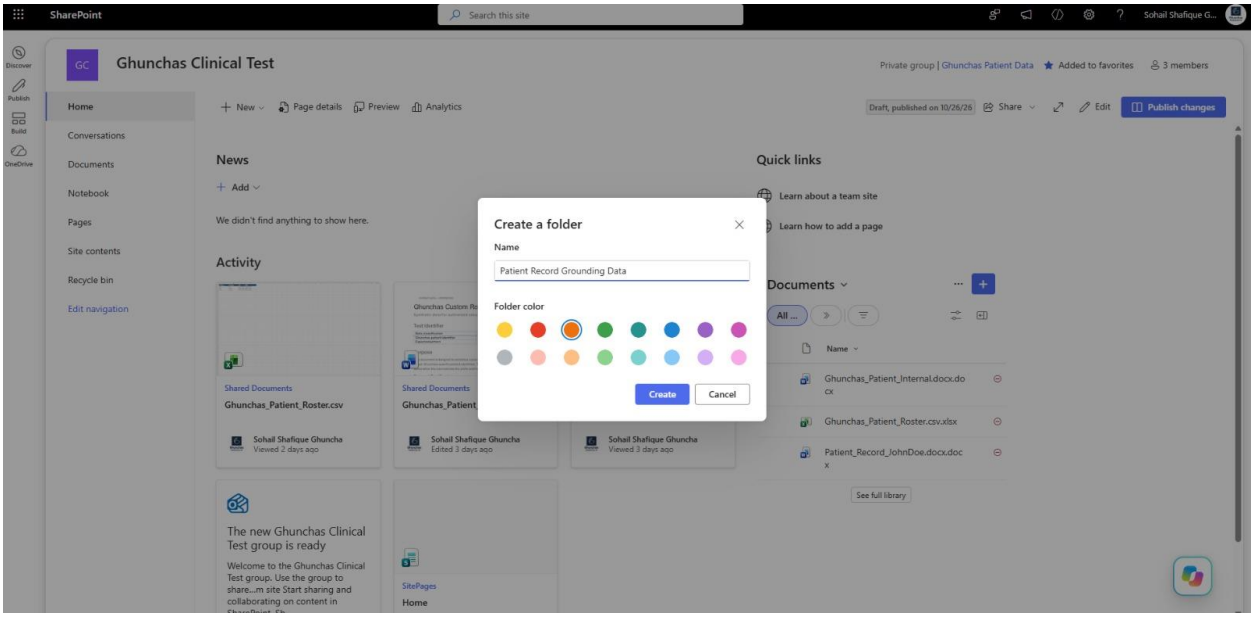
We navigate to the "Ghunchas Clinical Test" SharePoint site and apply the sensitivity/retention label to the folder level. This ensures all documents dropped into the folder inherit the label.

- **[Insert Image: SharePoint - Site Home]**



  - *Figure 8.25: The SharePoint site "Ghunchas Clinical Test".*

- **[Insert Image: SharePoint - Create folder]**

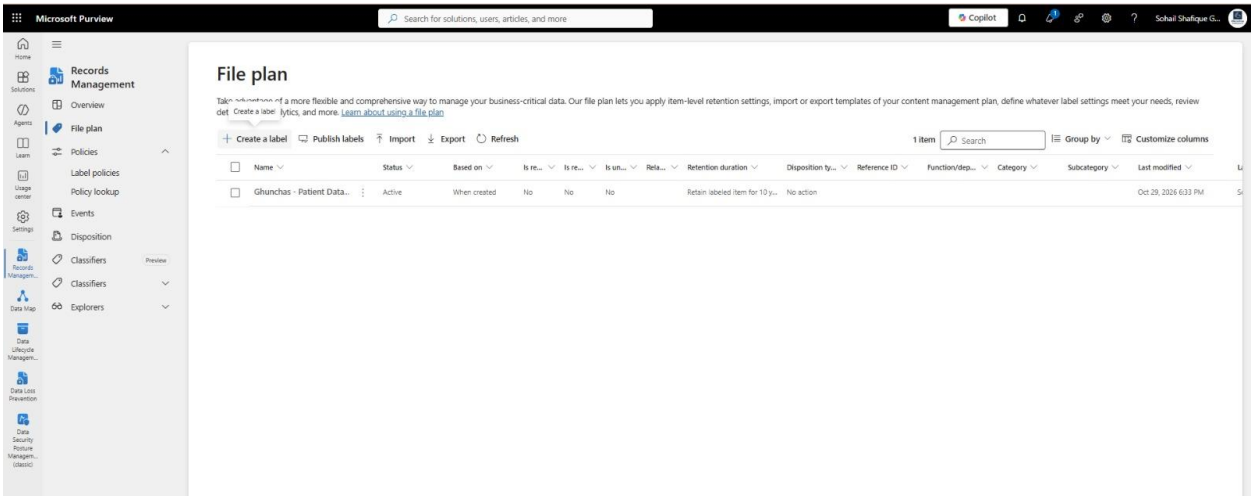


  - *Figure 8.26: Creating a folder named "Patient Record Grounding Data".*

Step 8: Creating the File Plan Descriptors

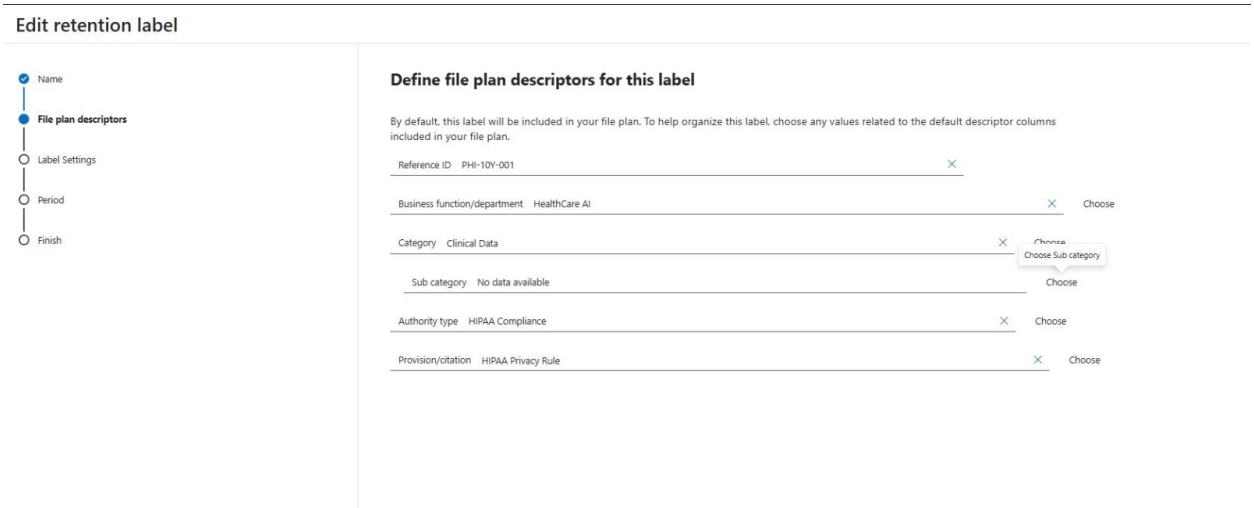
We use the File Plan to map the "Patient Data" retention label to the exact HIPAA regulatory citations. This proves to auditors why we are retaining the data.

- **[Insert Image: File plan - List]**



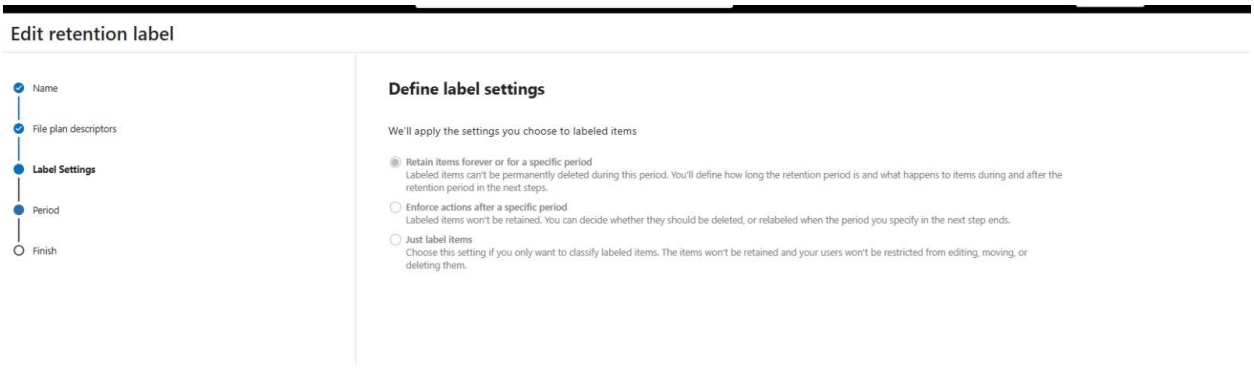
  - *Figure 8.27: The File Plan dashboard, showing the "Ghunchas - Patient Data" label.*

- **[Insert Image: Edit retention label - File plan descriptors]**



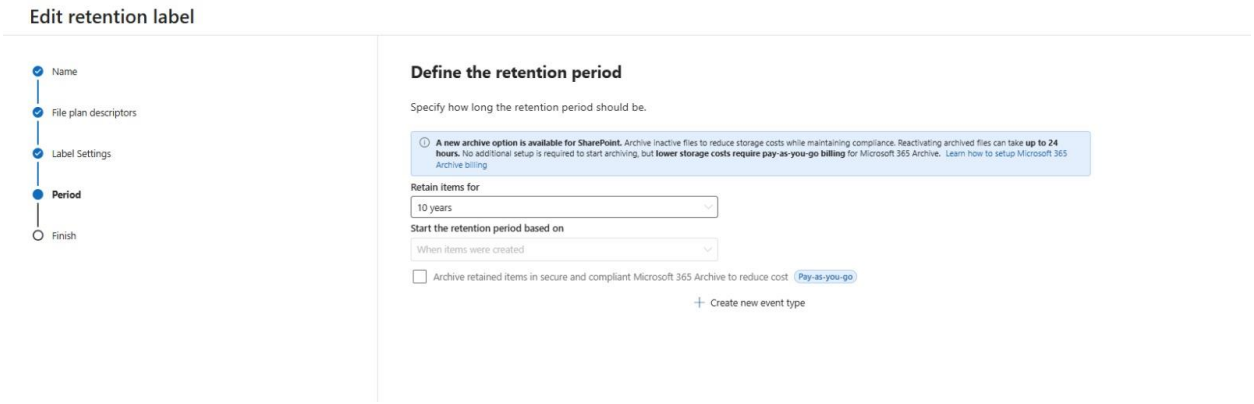
  - *Figure 8.28: Mapping the label to Business Function (Healthcare AI), Category (Clinical Data), and Authority Type (HIPAA Compliance).*

- **[Insert Image: Edit retention label - Label settings]**



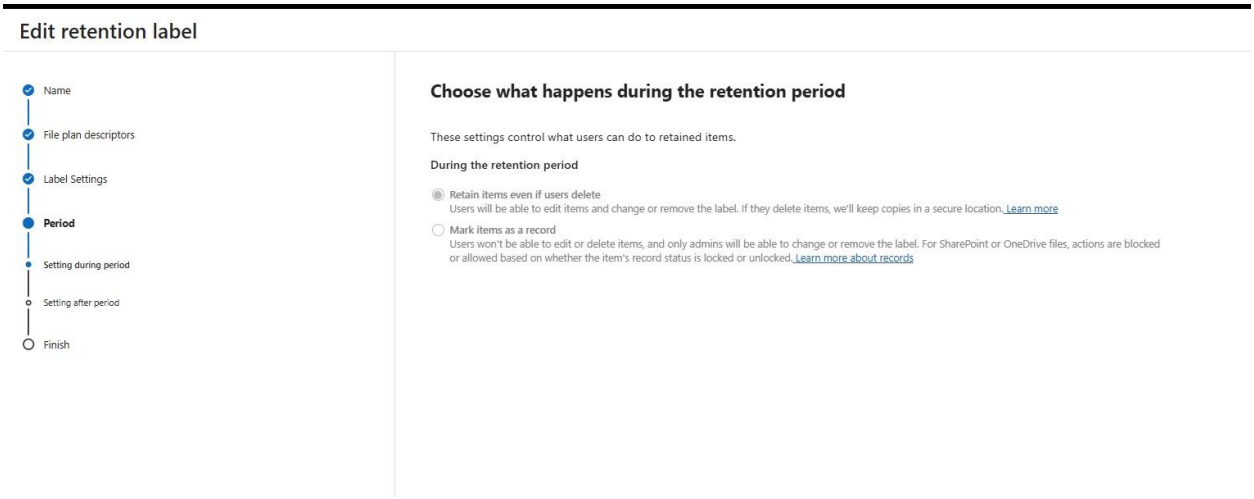
- *Figure 8.29: Confirming the label retains items for 10 years.*

- **[Insert Image: Edit retention label - Period (10 years)]**



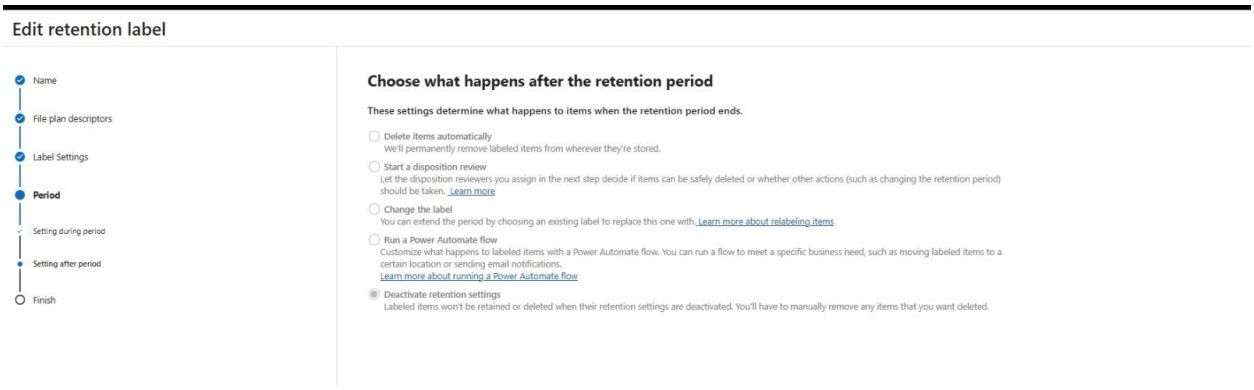
- *Figure 8.30: Confirming the 10-year retention period.*

- **[Insert Image: Edit retention label - During retention]**



- *Figure 8.31: Confirming items are marked as records.*

- **[Insert Image: Edit retention label - After retention]**

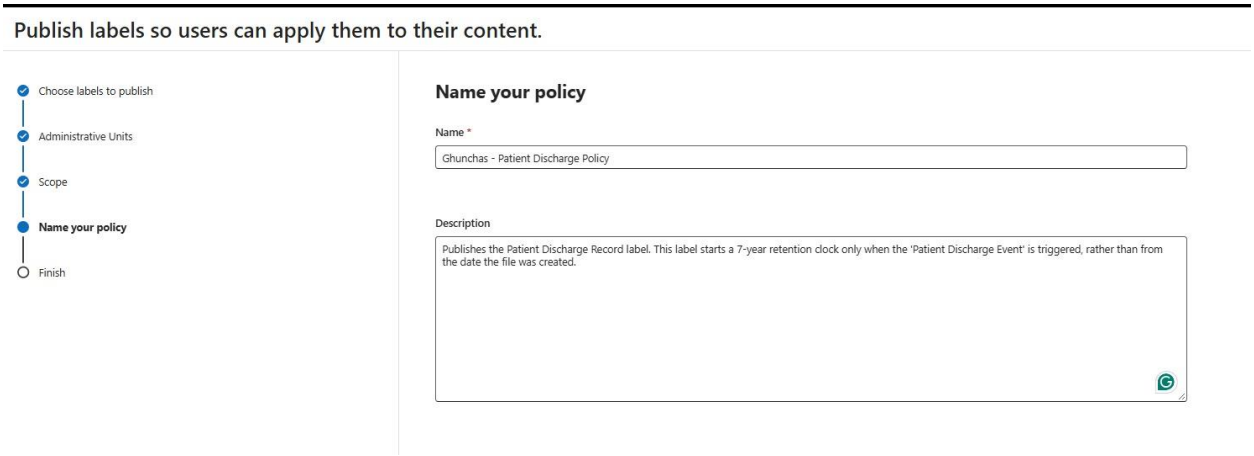


- *Figure 8.32: Confirming the label is set to "Deactivate retention settings".*

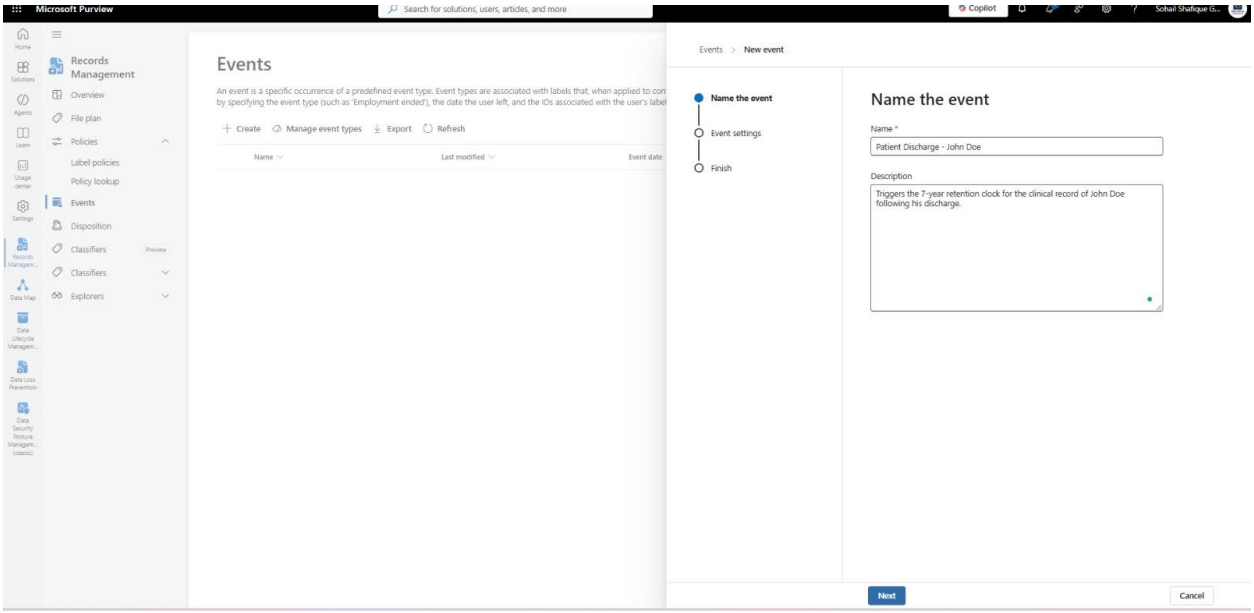
Step 9: Creating the Event-Based Retention Label

We create a label that starts its 7-year retention clock only when a specific event (e.g., Patient Discharge) occurs.

- **[Insert Image: Publish labels - Name your policy - Patient Discharge]**



- *Figure 8.33: Naming the policy "Ghunchas - Patient Discharge Policy".*
- **[Insert Image: Events - Name the event]**

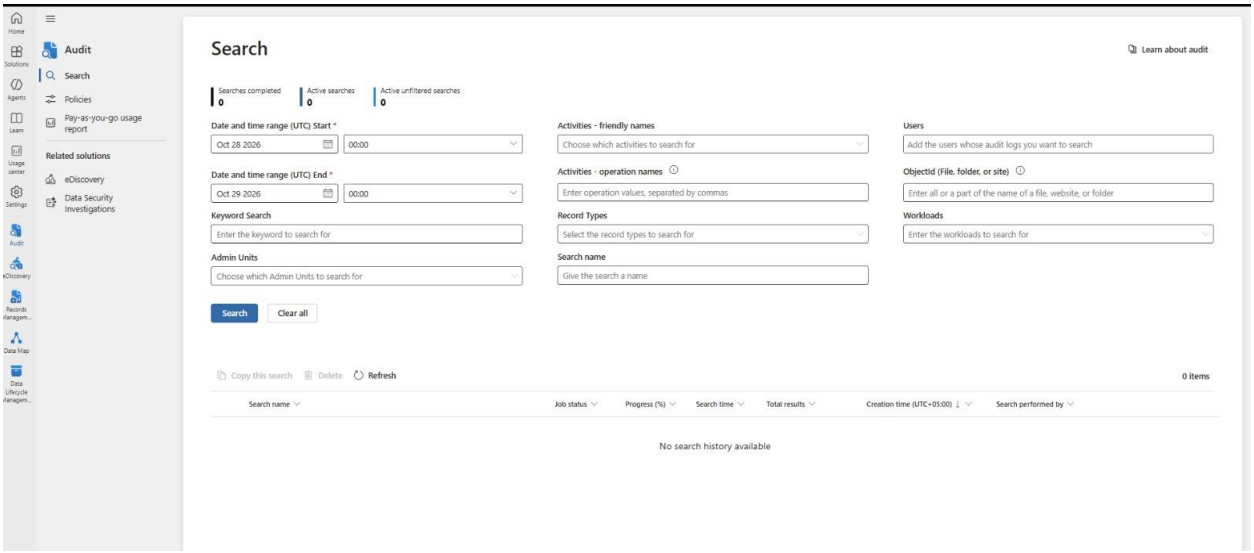


- *Figure 8.34: Creating the event "Patient Discharge - John Doe".*

Step 10: Configuring Audit Retention

Finally, we configure the Audit Retention Policy to ensure audit logs for clinical file access are kept for 1 year (or the maximum allowed by the license).

- **[Insert Image: Audit - Search]**



- *Figure 8.35: The Audit search dashboard.*

- **[Insert Image: Audit - Policies]**

- *Figure 8.36: The list of active Audit Retention Policies.*

- **[Insert Image: New audit retention policy - Details]**

New audit retention policy

Create a policy to retain audit logs for up to ten years based on the Microsoft 365 service where the activities occur, specific activities in the selected services, and the user who performs an activity. Learn more

Policy name *

Ghunchas - Clinical Audit Trail

Description

Retains audit logs for clinical file access and modifications.

Please choose Users and/or Record Types to apply this policy to.

If no value is selected, the policy will apply to all values within that field.

Users

BG Bakhtawar Ghuncha × Search

Record Type

SharePointFileOperation

Activities

If no activities are selected, then this policy will apply to all activities for the selected record types.

Accessed file, Changed retention label for a file, Deleted file marked as a reco...

Duration *

Choose how long to retain logs that match this policy's conditions before they're automatically deleted. Learn more about licensing

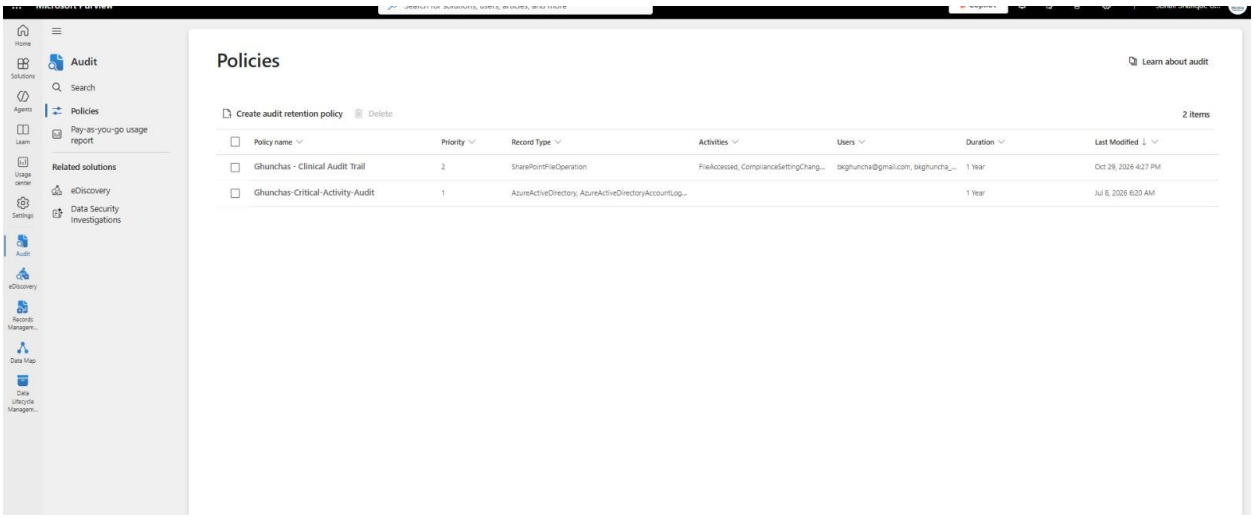
1 Year *

Priority * ⓘ

2 *

- *Figure 8.37: Creating the policy "Ghunchas - Clinical Audit Trail" for SharePointFileOperation activities, set to 1 Year.*

- **[Insert Image: Audit - Policies list (Final)]**



- *Figure 8.38: The final list of active audit retention policies.*

PHASE 9: eDISCOVERY & AUDIT INVESTIGATIONS

Objective: Execute the Electronic Discovery Reference Model (EDRM) to investigate a suspected PHI exfiltration. This involves creating an isolated case, placing a Legal Hold to prevent deletion, running targeted searches, and extracting evidence. We also configure Audit retention to ensure the investigation trail is preserved.

9.1 The Business Value (Why We Do This)

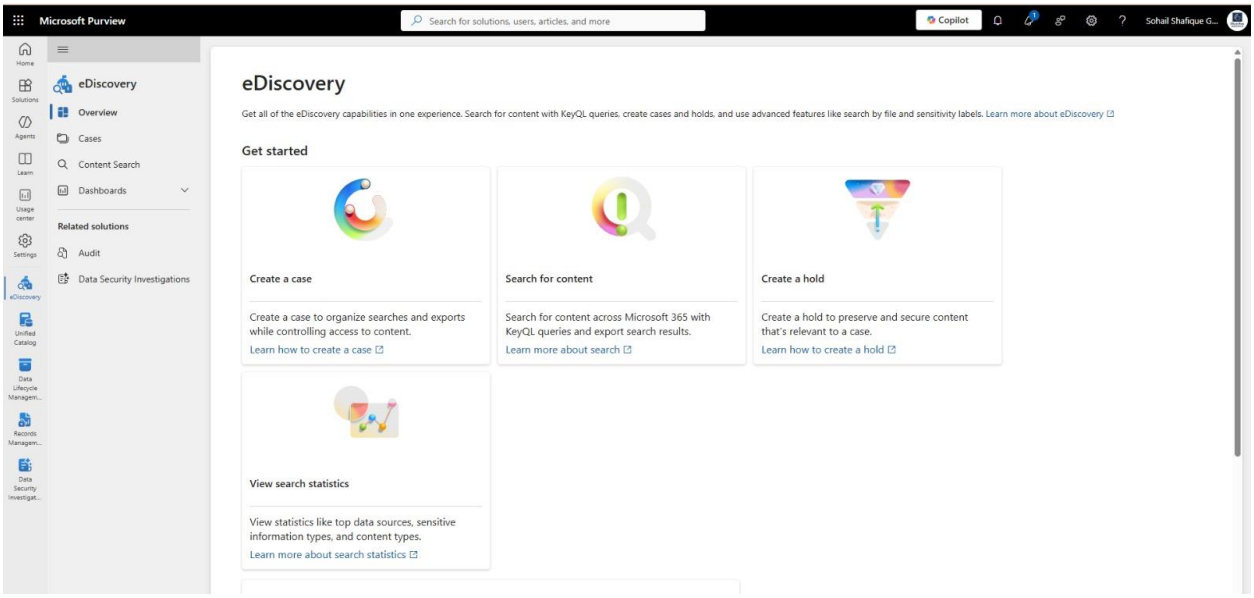
When a potential breach or insider threat is detected, speed and defensibility are everything. Healthcare organizations must be able to freeze data (Legal Hold) to prevent a user from deleting evidence, search for specific PHI, and export it securely (Chain of Custody). Furthermore, if a malicious admin tries to delete the audit logs to cover their tracks, our 1-Year Audit Retention policy ensures the evidence remains available for HITRUST auditors.

9.2 The Ghunchas Configuration Standard

Step 1: Accessing the eDiscovery Dashboard

We begin by navigating to the eDiscovery solution to initiate a new investigation.

- **[Insert Image: eDiscovery - Overview]**

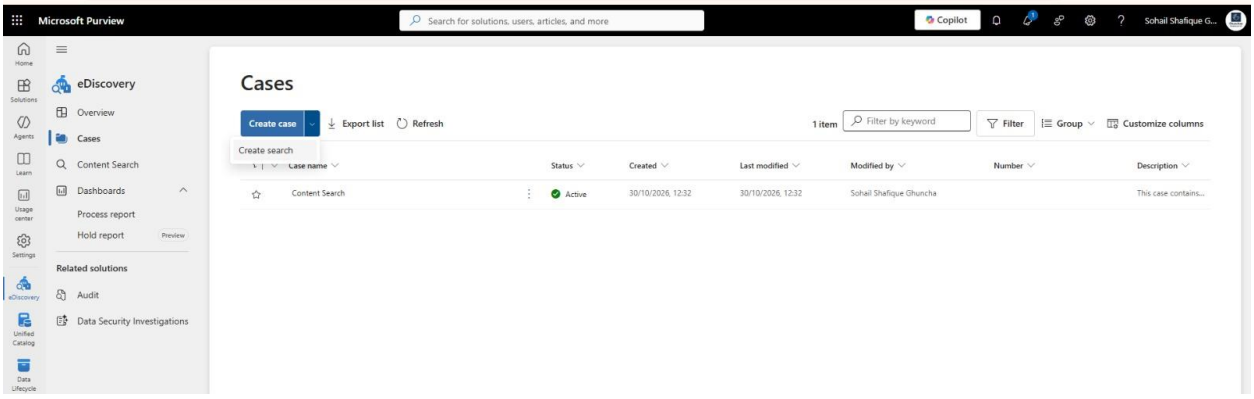


  - *Figure 9.1: The eDiscovery dashboard, showing options to Create a case, Search for content, and Create a hold.*

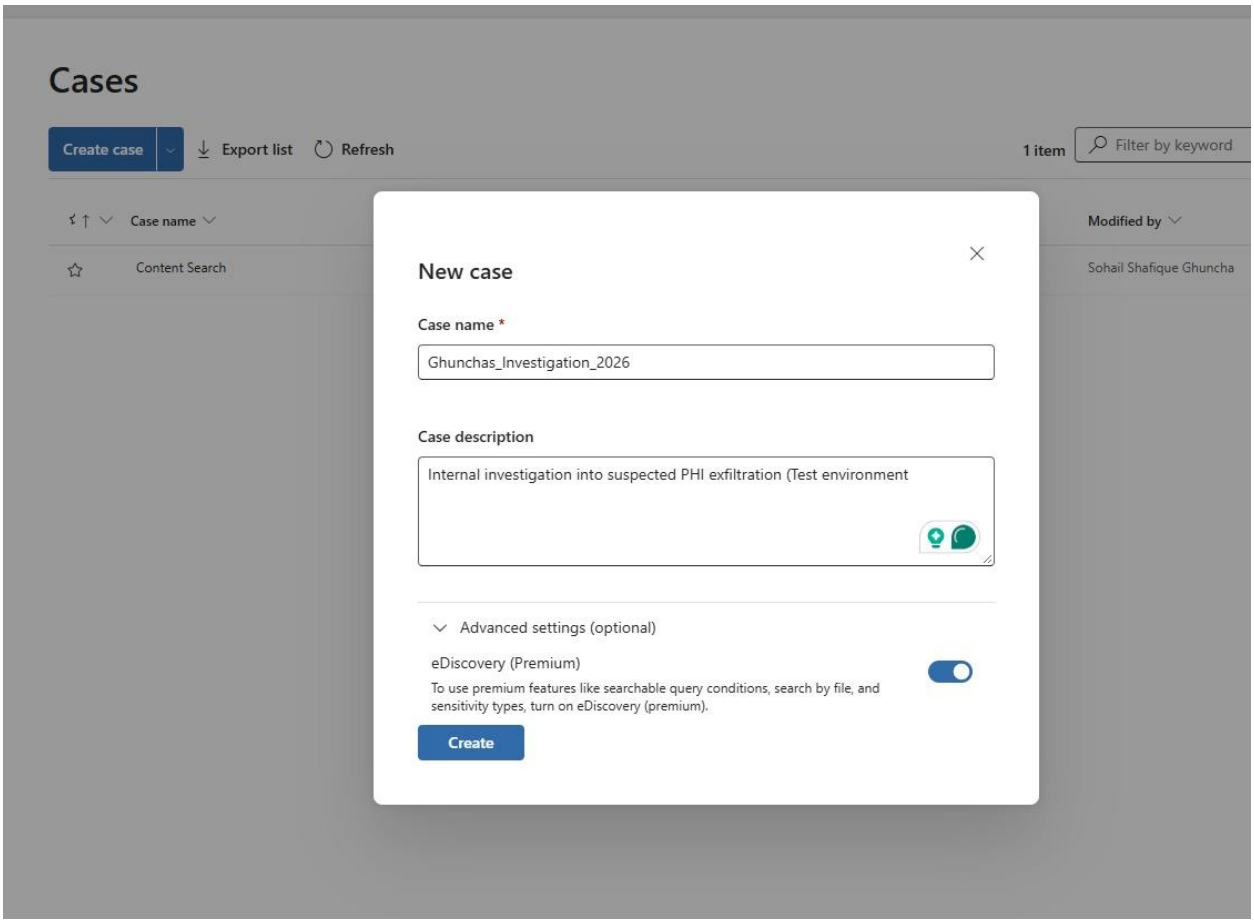
Step 2: Creating the Investigation Case

We create a dedicated case to isolate the investigation. This ensures only authorized investigators can access the data.

- **[Insert Image: Cases - List]**



  - *Figure 9.2: The Cases dashboard, initiating the creation of a new case.*
- **[Insert Image: New case - Case details]**

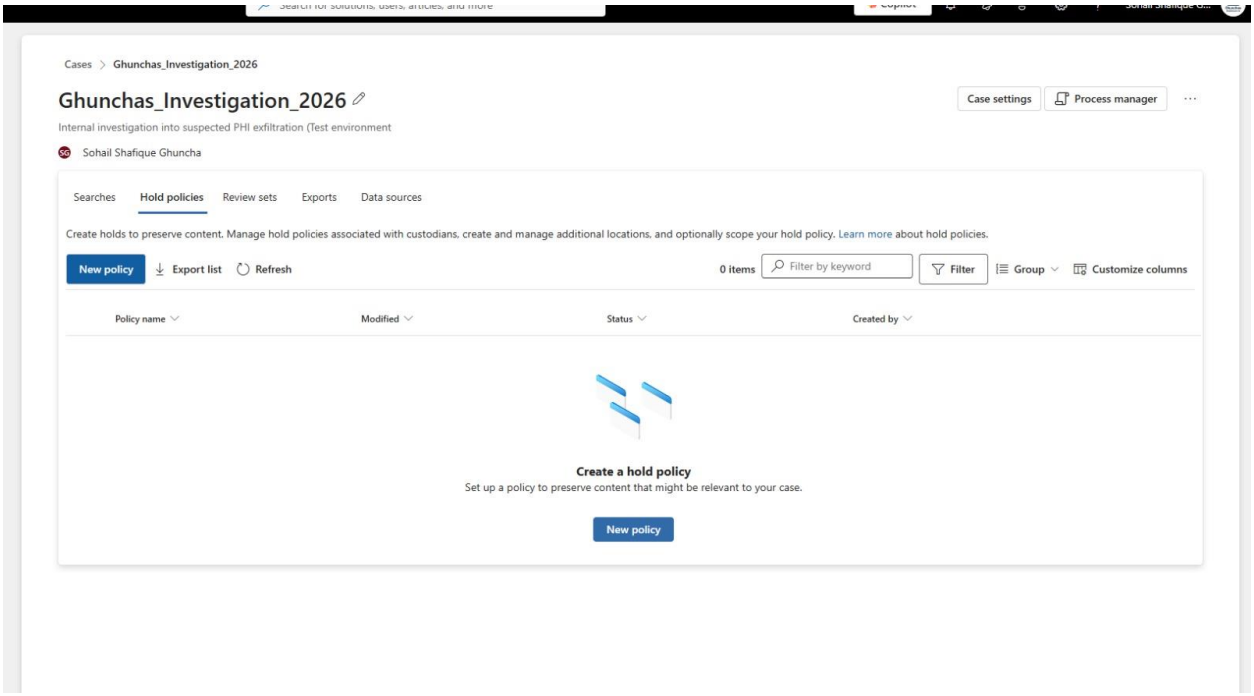


- *Figure 9.3: Naming the case "Ghunchas_Investigation_2026" and enabling eDiscovery (Premium) for advanced features.*

Step 3: Preserving Data (Legal Hold)

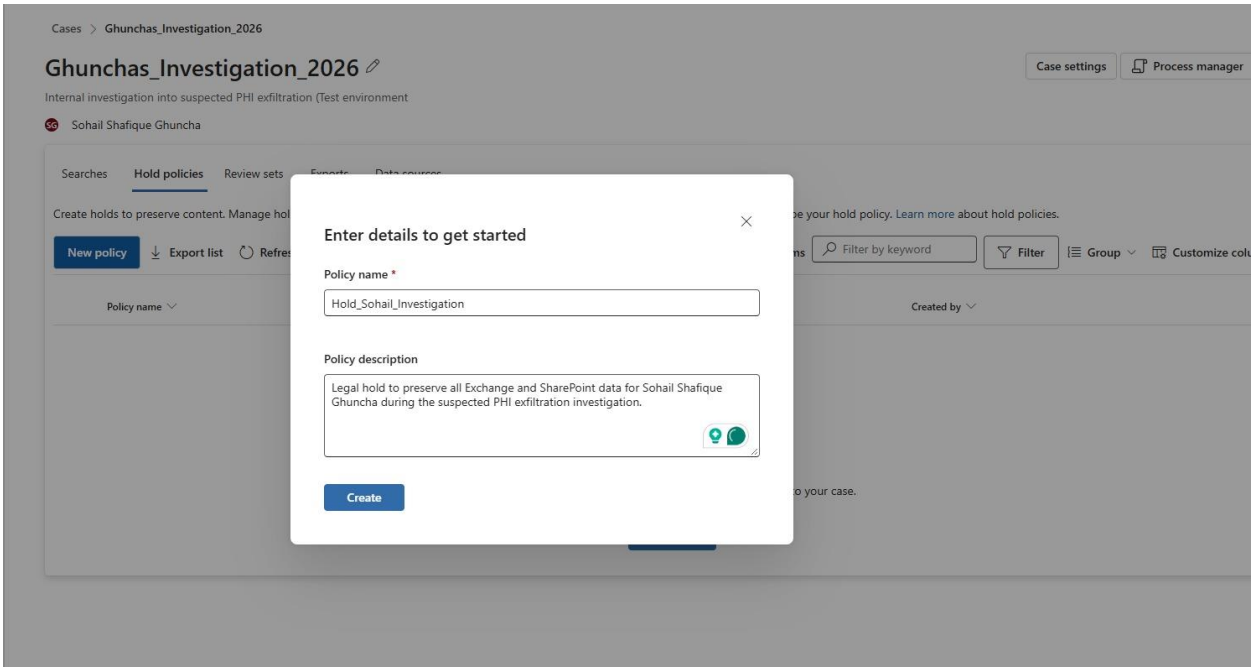
Before searching, we must freeze the data. We apply a Legal Hold to the target user's mailbox and SharePoint site so they cannot delete evidence while the investigation is ongoing.

- **[Insert Image: Hold policies - New policy]**



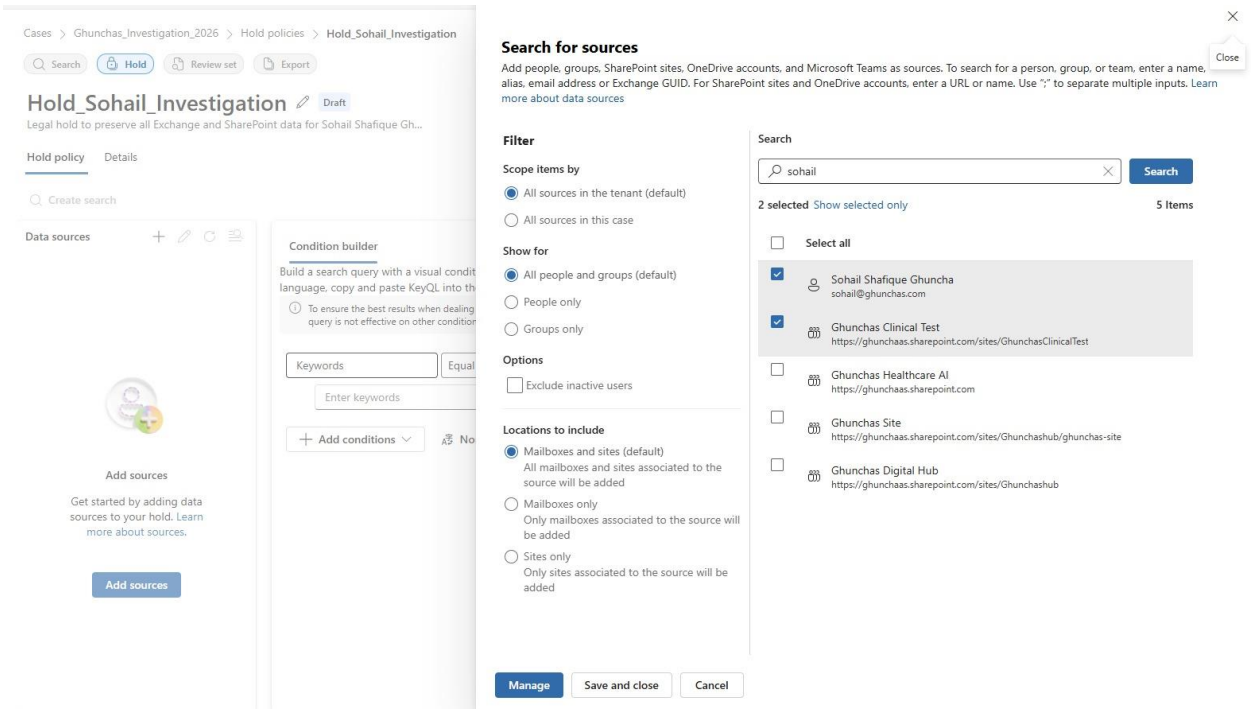
- *Figure 9.4: Creating a new Hold policy.*

- **[Insert Image: Enter details to get started - Policy name]**



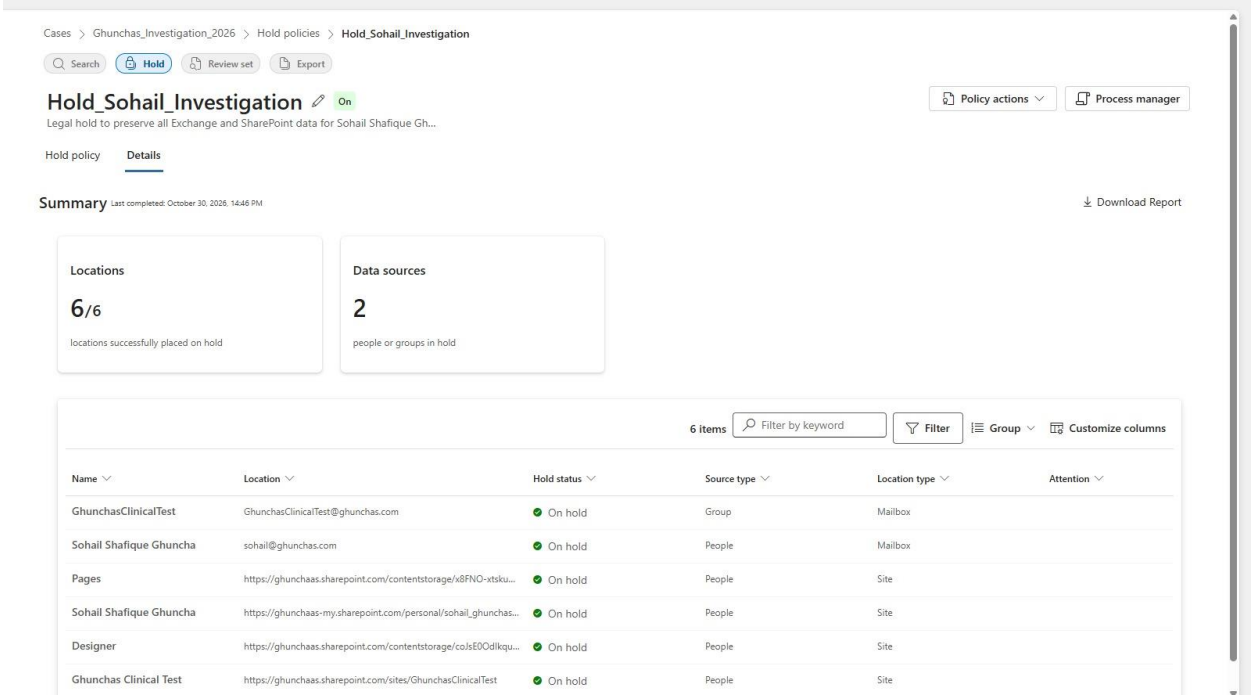
- *Figure 9.5: Naming the hold "Hold_Sohail_Investigation" and describing the legal preservation intent.*

- **[Insert Image: Search for sources - Sohail]**



- *Figure 9.6: Selecting the user (Sohail) and the SharePoint site to be placed on hold.*

- **[Insert Image: Hold policy - Details]**

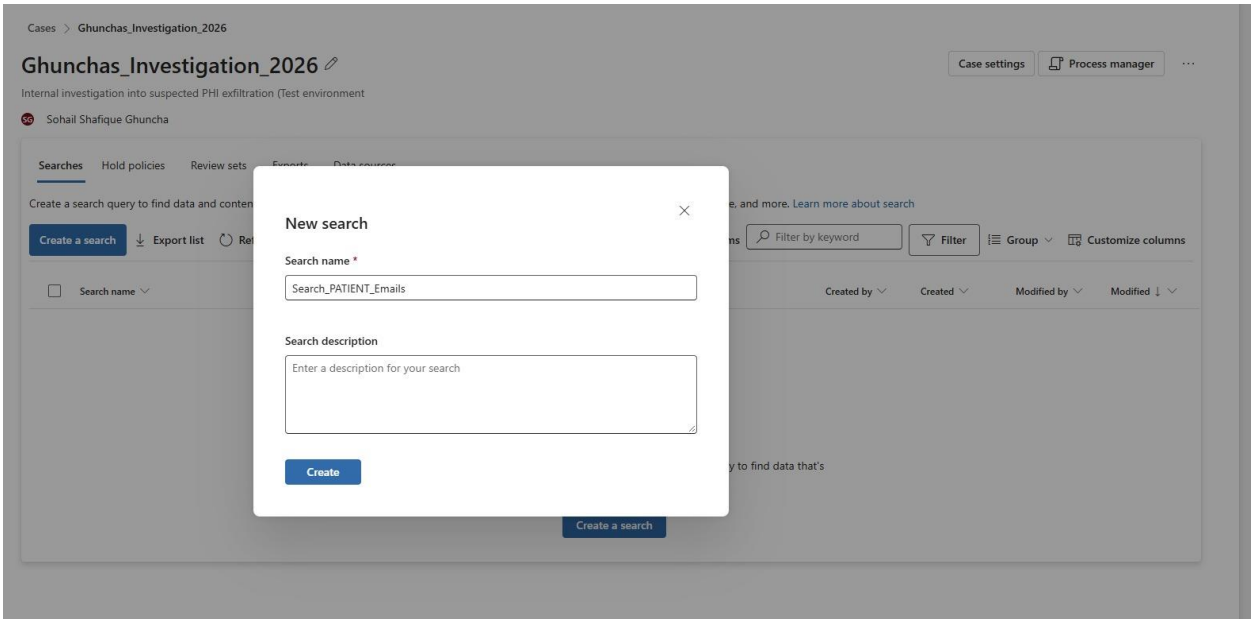


- *Figure 9.7: Confirming the hold is active (6/6 locations successfully placed on hold).*

Step 4: Running the Search Query

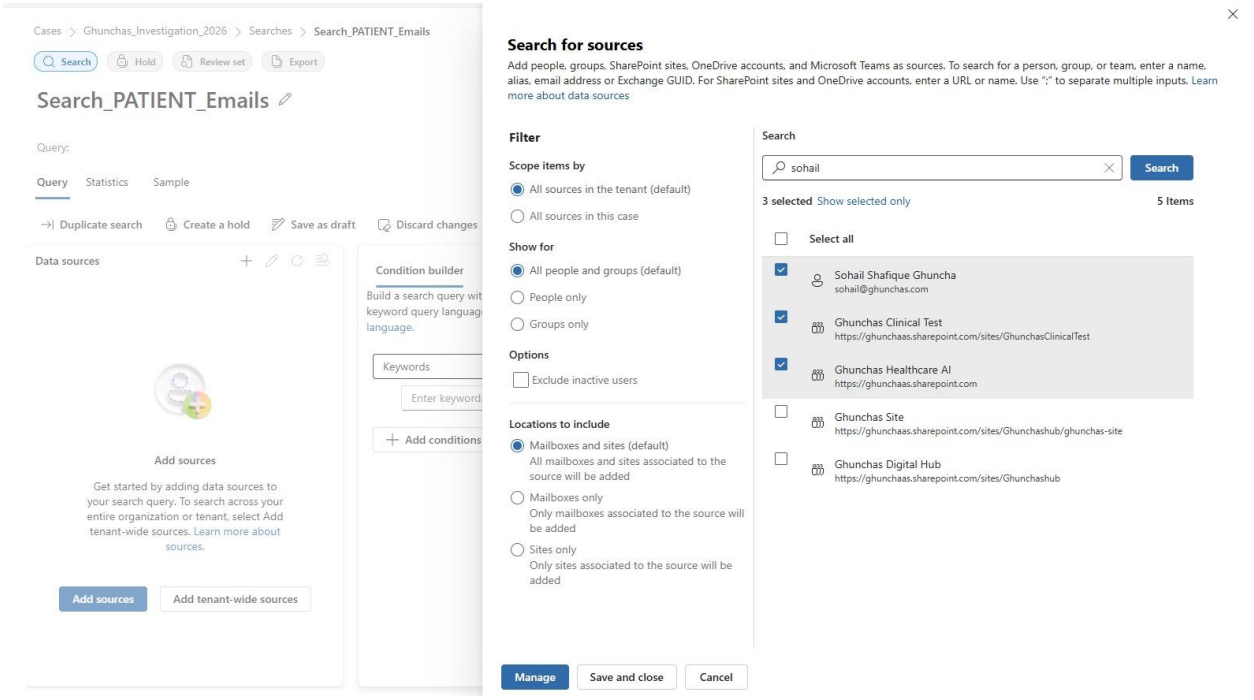
Now that the data is preserved, we run a targeted search using KQL (Keyword Query Language) to find the specific PHI.

- **[Insert Image: New search - Search name]**



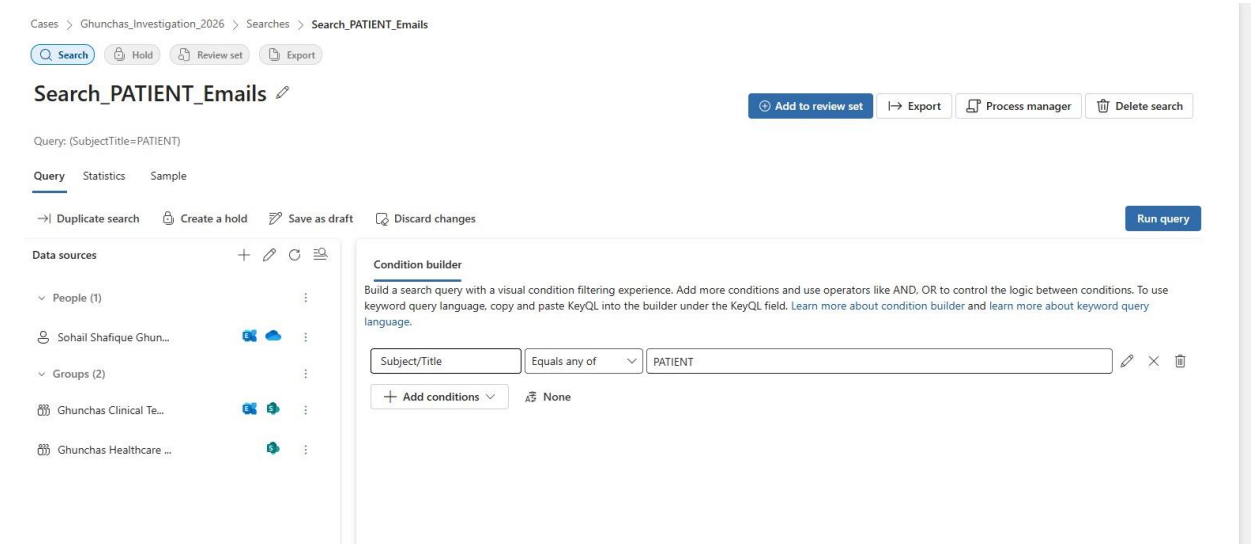
  - *Figure 9.8: Naming the search "Search_PATIENT_Emails".*

- **[Insert Image: Search for sources - 3 selected]**



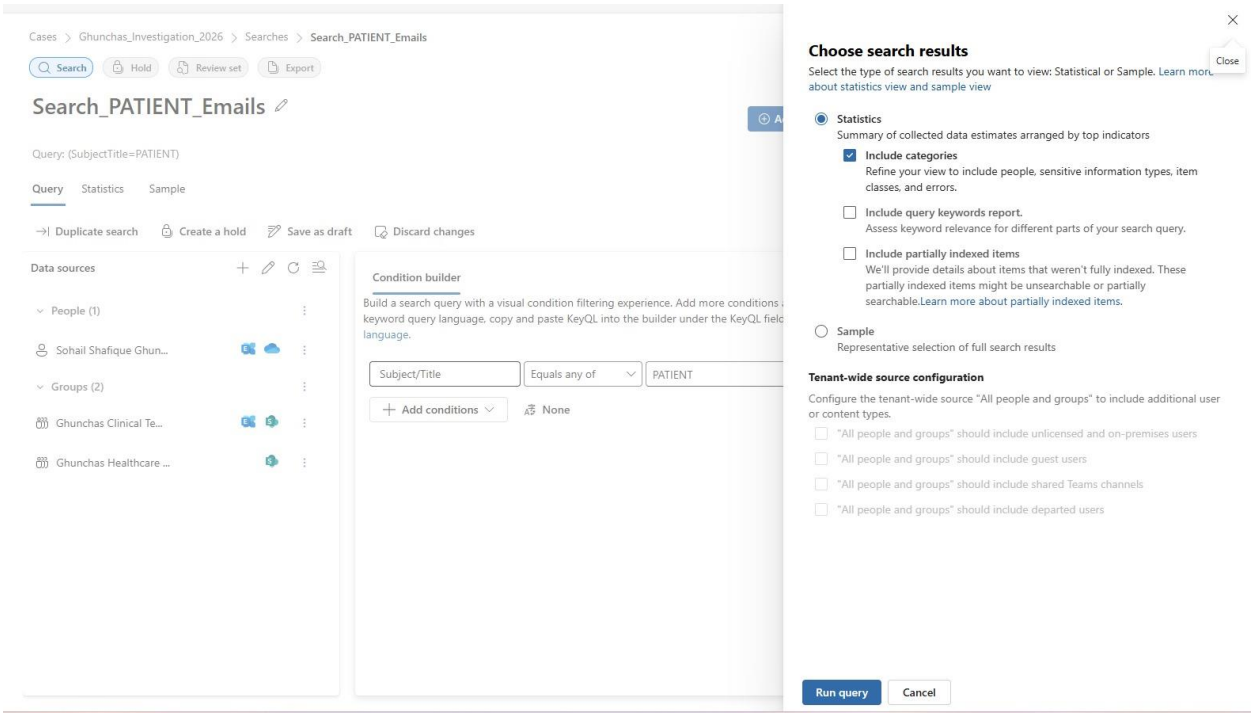
  - *Figure 9.9: Scoping the search to the user's mailbox and specific SharePoint sites.*

- **[Insert Image: Condition builder - Subject/Title contains PATIENT]**



  - *Figure 9.10: Configuring the KQL query to find emails where the subject contains "PATIENT".*

- **[Insert Image: Choose search results - Statistics]**

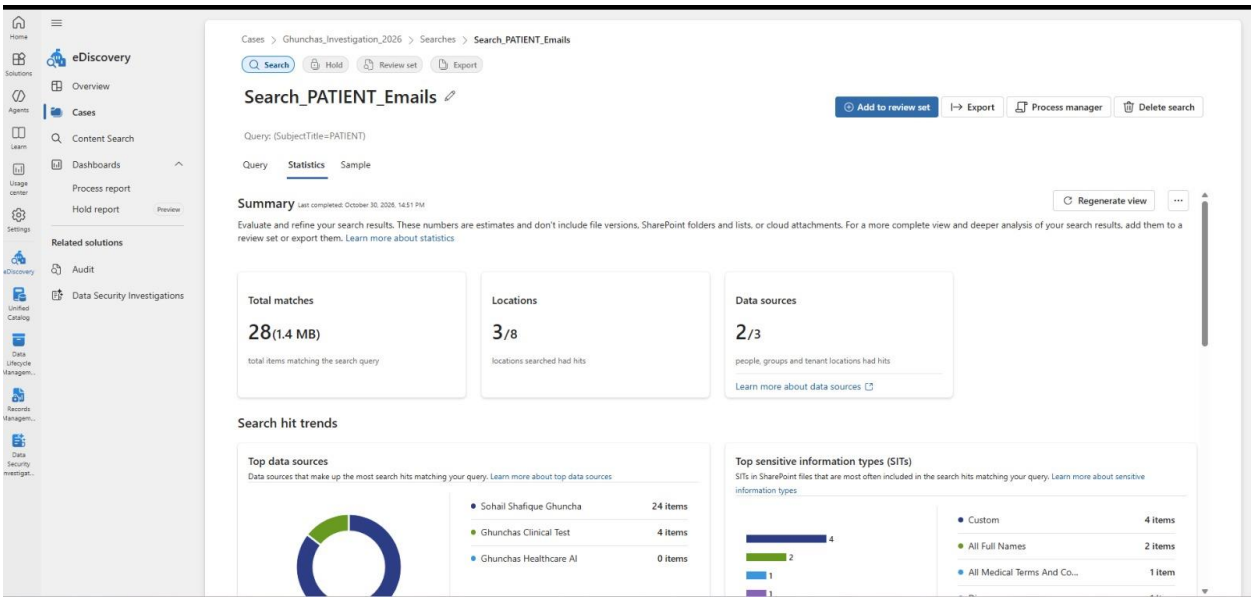


  - *Figure 9.11: Running the query and selecting "Include categories" to categorize the findings.*

Step 5: Reviewing the Search Statistics

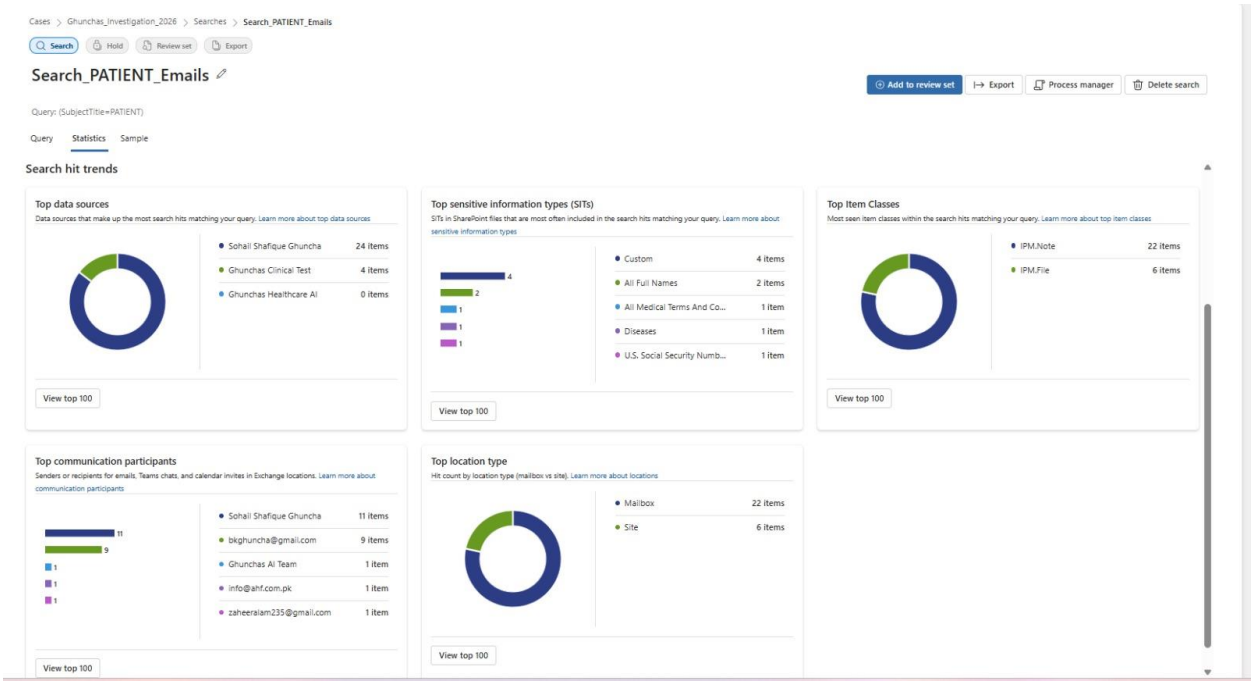
We review the search results to understand the scope of the data leak.

- **[Insert Image: Search Statistics - 28 matches found]**



- *Figure 9.12: The search statistics showing 28 matching items and the top sensitive information types found.*

- **[Insert Image: Search Statistics - Charts]**

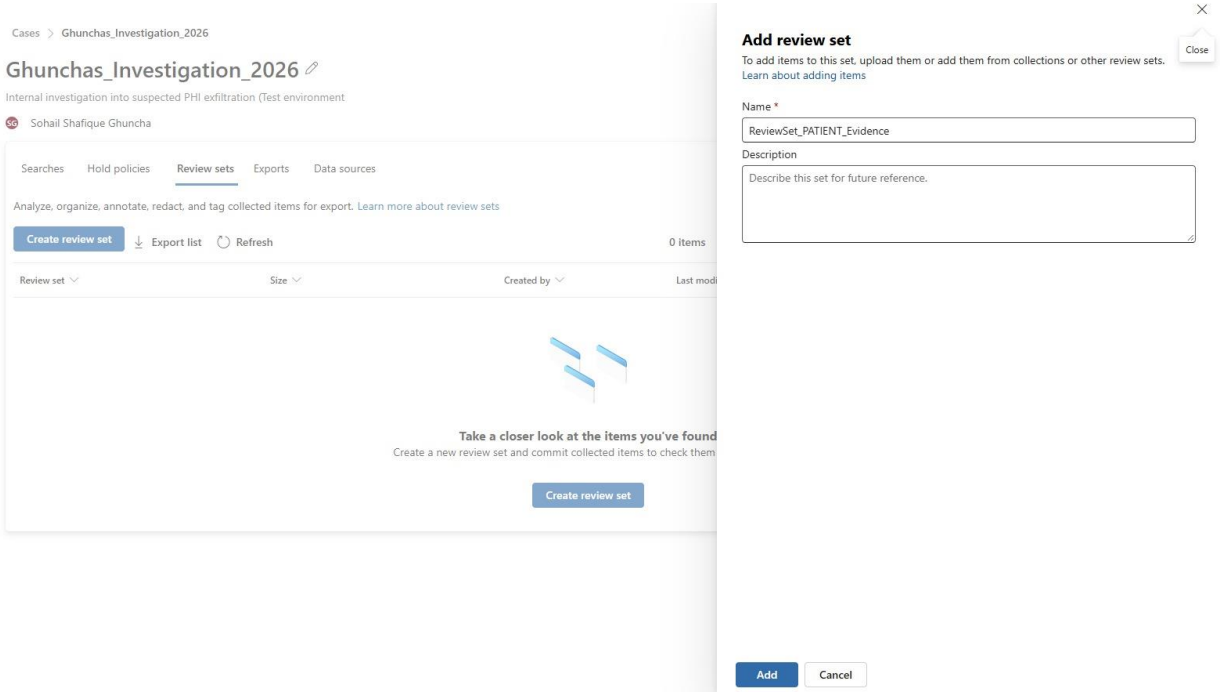


- *Figure 9.13: Detailed charts showing the top data sources, item classes, and communication participants (e.g., bkhuncha@gmail.com).*

Step 6: Adding to Review Set

We move the search results into an immutable Review Set. This is a secure container where the evidence cannot be altered.

- **[Insert Image: Add review set - Details]**

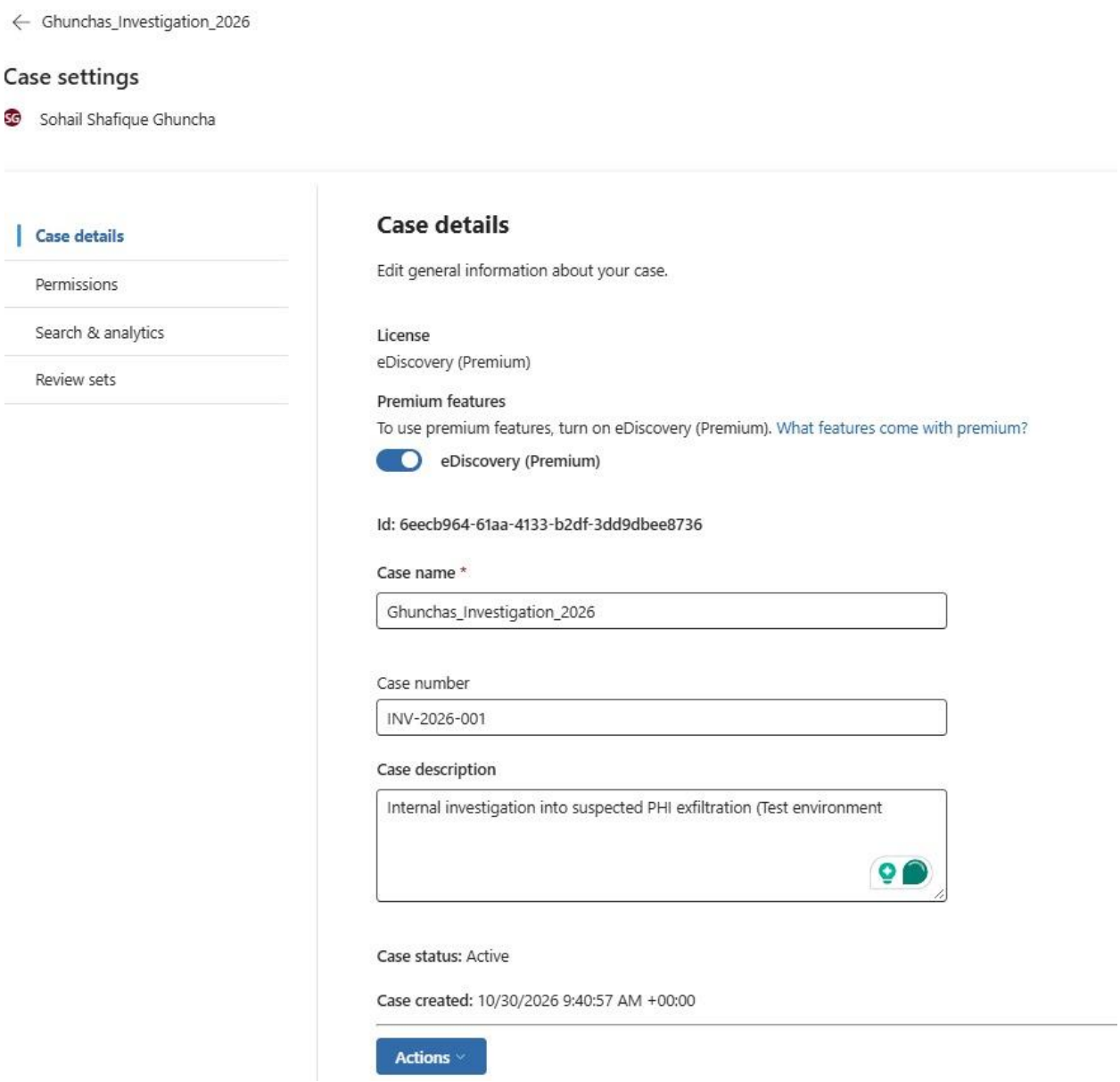


  - *Figure 9.14: Naming the Review Set "ReviewSet_PATIENT_Evidence" and preparing to add all results.*

Step 7: Exporting the Case (Chain of Custody)

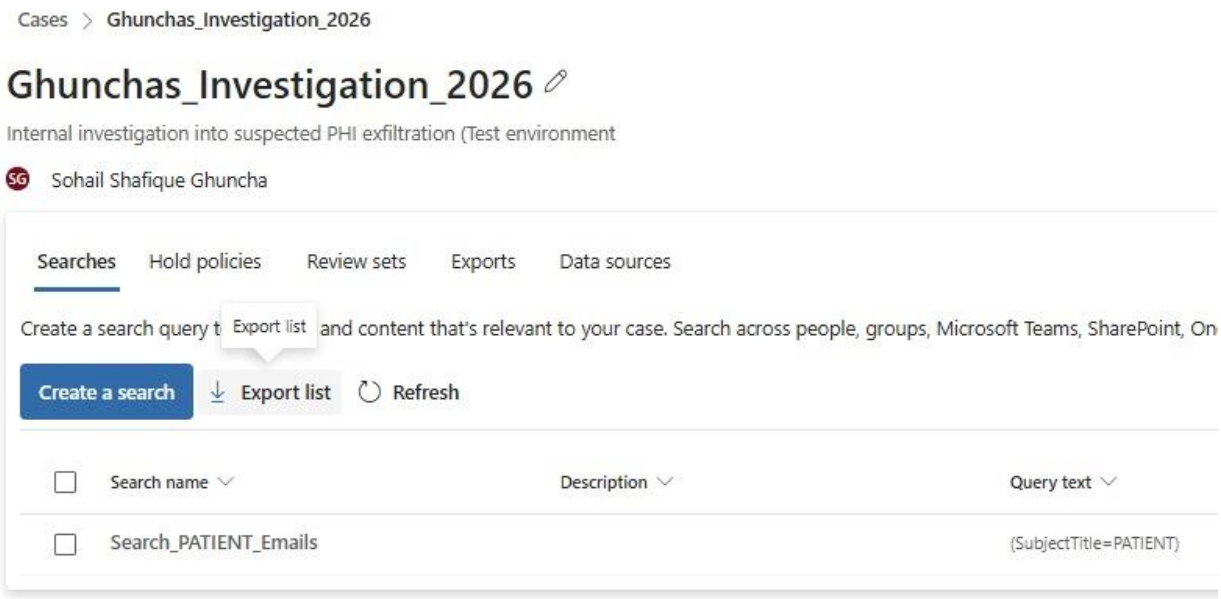
We export the search results for external review or legal proceedings. This generates an encrypted PST file and a unique export key, preserving the chain of custody.

- **[Insert Image: Case settings - Details]**



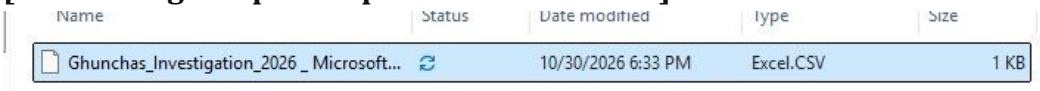
- *Figure 9.15: Adding a Case number (INV-2026-001) and description to the case.*

- **[Insert Image: Search_PATIENT_Emails - Export]**



- *Figure 9.16: Selecting the search and clicking "Export".*

- **[Insert Image: Export Report - CSV download]**

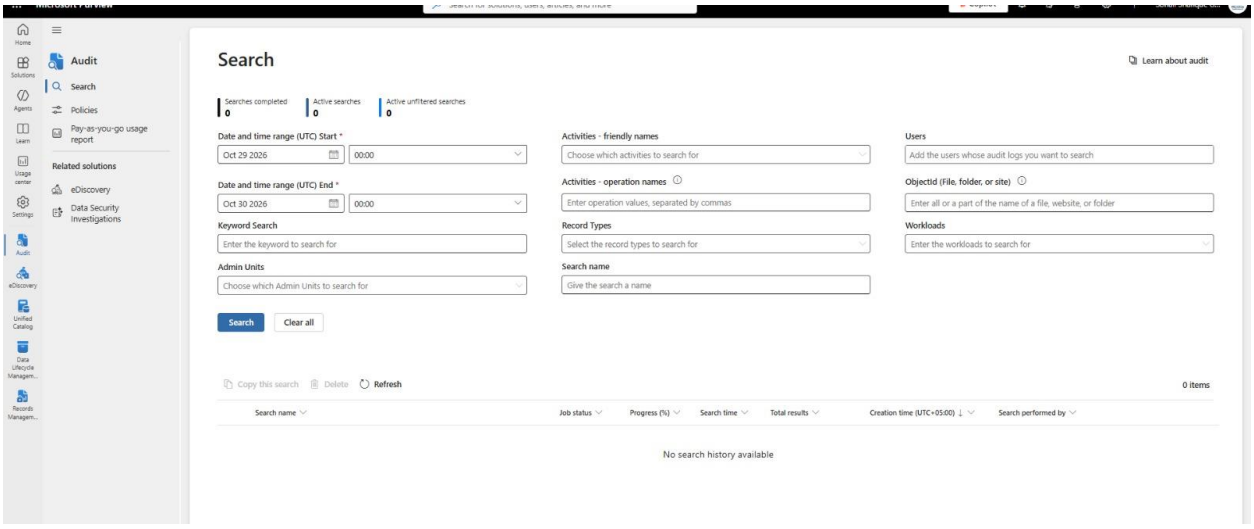


- *Figure 9.17: Downloading the export report (CSV) confirming the evidence extraction.*

Step 8: Configuring Audit Retention

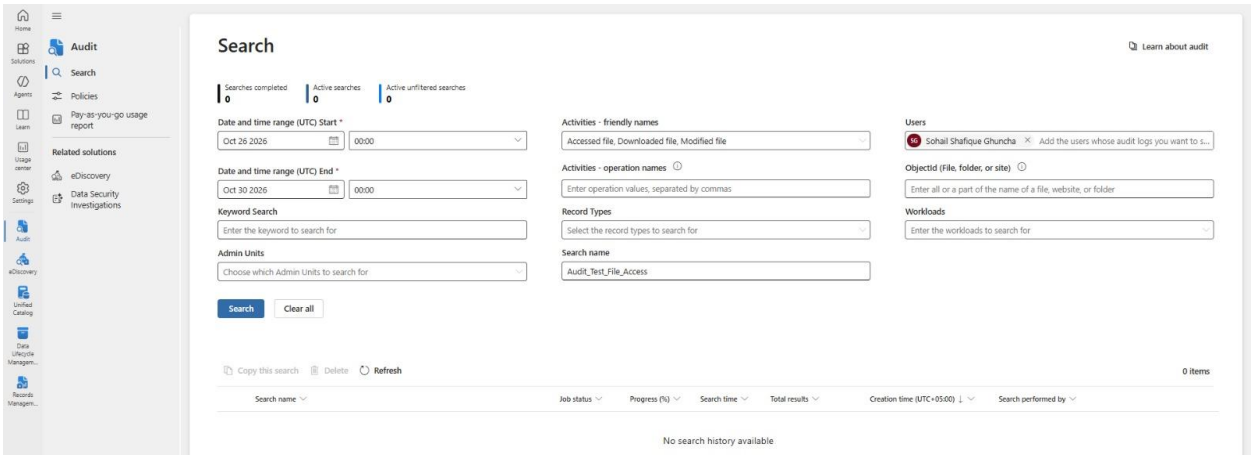
To ensure the evidence trail remains, we configure the Audit Retention Policy to keep logs for 1 year.

- **[Insert Image: Audit - Search dashboard]**



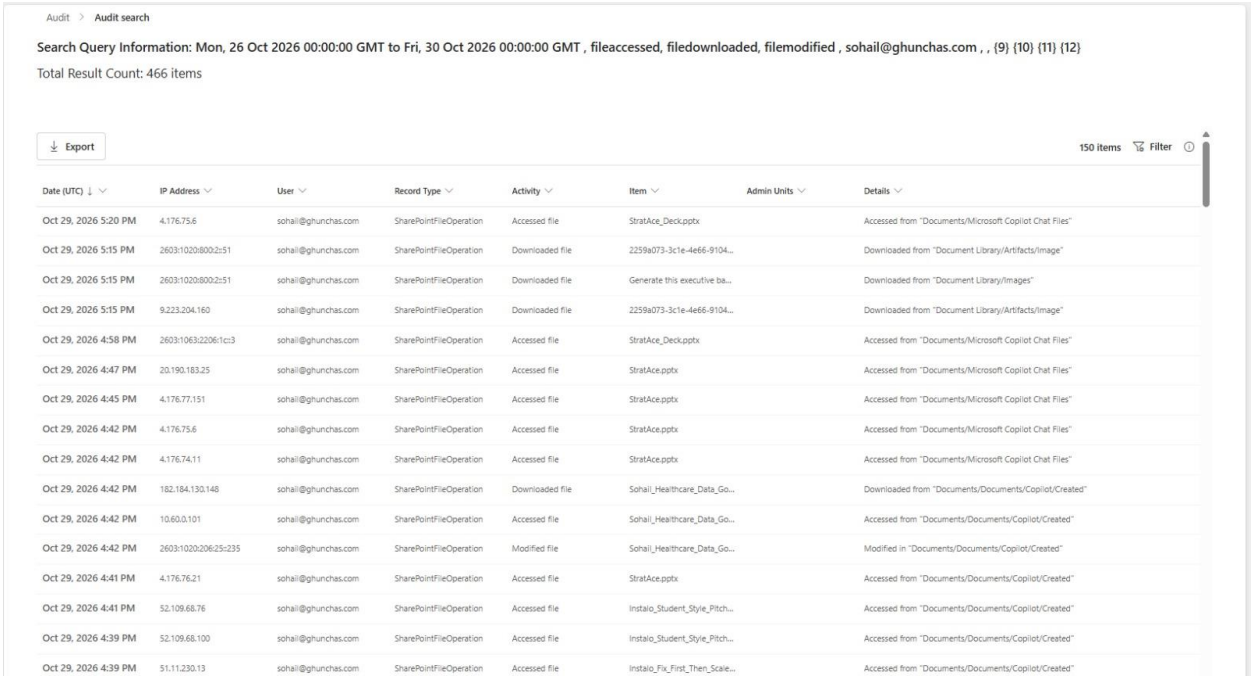
- *Figure 9.18: The Audit search dashboard, used to investigate user activity.*

- **[Insert Image: Audit - Search query - File access]**



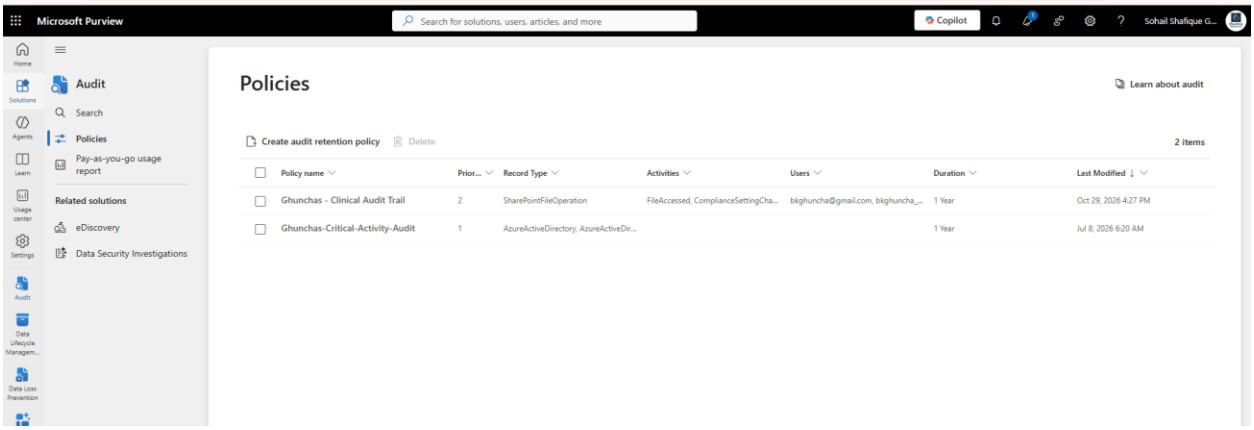
- *Figure 9.19: Running an audit search for "FileAccessed", "FileDownloaded", and "FileModified" by the user.*

- **[Insert Image: Audit Search Results - 466 items]**



- *Figure 9.20: The audit results showing 466 items, including exact timestamps, IP addresses, and file names.*

- **[Insert Image: Audit - Policies list]**



- *Figure 9.21: The Audit Retention Policies dashboard, showing the "Ghunchas - Clinical Audit Trail" policy.*